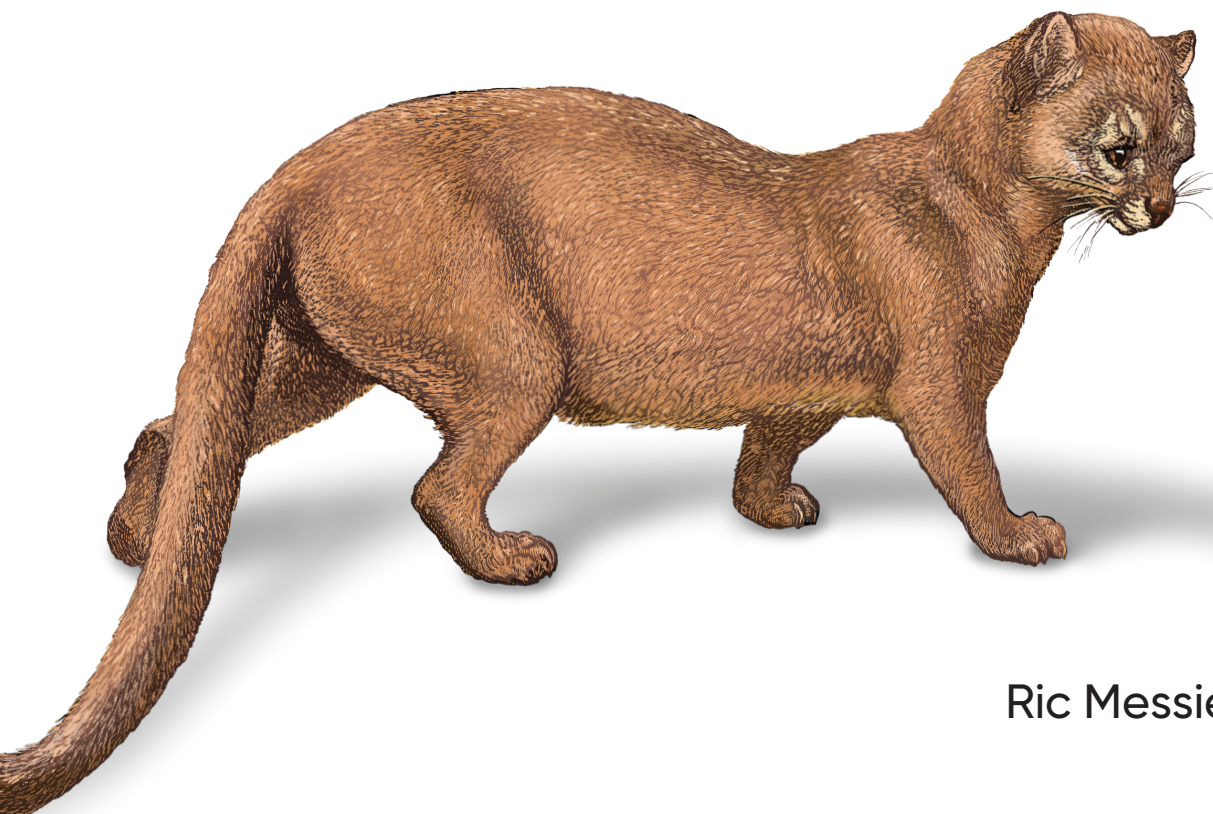


O'REILLY®

Learning Cloud Security

Cloud Computing and
Security Architecture Essentials



Ric Messier

"Cloud security is now a fundamental skill that every risk and security professional needs to have in their toolkit. This book is a great source of instruction and reference for cloud security for everyone from the journeyman to the advanced professional."

John Pironti
President of IP Architects

Learning Cloud Security

Are you an experienced cloud security professional looking to upskill or take your career to the next level? There's a growing demand for cloud security practitioners and the Certified Cloud Security Professional (CCSP) exam provides a vendor-agnostic framework for exploring the breadth of topics a cloud security professional should understand.

Industry expert Ric Messier uses the CCSP as a guide to lay out all the domains a certification candidate should learn to successfully prepare for the exam. Using clear and engaging explanations of essential concepts, this comprehensive and empowering book will help you to ably meet the challenges of certification—or simply boost your skills for the workplace.

- Uncover different approaches to cloud security architectures
- Understand risk management and compliance with cloud environments
- Learn essential security controls for cloud platforms and infrastructure
- Discover emerging trends including zero trust architecture

Ric Messier is an author, consultant, and educator who holds CSSP, GCP ACE, AWS CCP, GCIH, GSEC, CEH, and CISSP certifications and has published several books on information security and digital forensics. With decades of IT experience spanning programming, network engineering, and academia, he is currently working with Apple as a security engineer.

CLOUD SECURITY

US \$59.99 CAN \$74.99

ISBN: 978-1-098-17942-7



5 5 9 9 9

O'REILLY®

Praise for *Learning Cloud Security*

Cloud security has never been more important, and it's never been more accessible than it is here. In *Learning Cloud Security*, Ric Messier brings the fundamentals within reach of anyone who wants to understand them, whether you're new to the field or finally filling in the gaps.

This is a comprehensive overview written with rare clarity. Cloud security can be dry territory, and too many books lose their readers in the tedious stretches. Messier doesn't. His writing keeps you engaged from start to finish, carrying you through even the driest material with ease. The result is a book that gives you more than scattered facts. You'll walk away with the full picture and a genuine understanding of how it all fits together.

For everyone who needs to know cloud security, this is where to begin.

—Alexander Arlt, principal security
consultant at Mandiant/Google

Cloud security is now a fundamental skill that every risk and security professional needs to have in their toolkit. This book is a great source of instruction and reference for cloud security for everyone from the journeyman to the advanced professional.

—John Pironti, president of IP Architects

Learning Cloud Security

*Cloud Computing and Security
Architecture Essentials*

Ric Messier

O'REILLY®

Learning Cloud Security

by Ric Messier

Copyright © 2026 Ric Messier. All rights reserved.

Published by O'Reilly Media, Inc., 141 Stony Circle, Suite 195, Santa Rosa, CA 95401.

O'Reilly books may be purchased for educational, business, or sales promotional use. Online editions are also available for most titles (<http://oreilly.com>). For more information, contact our corporate/institutional sales department: 800-998-9938 or corporate@oreilly.com.

Acquisition Editor: Simina Calin

Development Editor: Shira Evans

Production Editor: Aleeya Rahman

Copyeditor: Sonia Saruba

Proofreader: Carol McGillivray

Indexer: Ellen Troutman-Zaig

Interior Designer: David Futato

Cover Designer: Karen Montgomery

Illustrator: Kate Dullea

June 2026: First Edition

Revision History for the First Edition

2026-06-03: First Release

See <http://oreilly.com/catalog/errata.csp?isbn=9781098179427> for release details.

The O'Reilly logo is a registered trademark of O'Reilly Media, Inc. *Learning Cloud Security*, the cover image, and related trade dress are trademarks of O'Reilly Media, Inc.

The views expressed in this work are those of the author and do not represent the publisher's views. While the publisher and the author have used good faith efforts to ensure that the information and instructions contained in this work are accurate, the publisher and the author disclaim all responsibility for errors or omissions, including without limitation responsibility for damages resulting from the use of or reliance on this work. Use of the information and instructions contained in this work is at your own risk. If any code samples or other technology this work contains or describes is subject to open source licenses or the intellectual property rights of others, it is your responsibility to ensure that your use thereof complies with such licenses and/or rights.

978-1-098-17942-7

[LSI]

Table of Contents

Preface.....	xi
1. About the Certified Cloud Security Practitioner.....	1
The Need for the CCSP	2
Historical Context	2
Business Context for the CCSP	3
About ISC2	4
About the CCSP and Topics	5
Domain 1: Cloud Concepts, Architecture, and Design	7
Domain 2: Cloud Data Security	7
Domain 3: Cloud Platform and Infrastructure Security	8
Domain 4: Cloud Application Security	8
Domain 5: Cloud Security Operations	9
Domain 6: Legal, Risk, and Compliance	10
About the Exam	10
Preparing for the Exam	11
Summary	12
Other Resources	12
2. Cloud Computing Fundamentals.....	15
What Is the Cloud?	16
On Demand, Self-Service	18
Broad Network Access	19
Resource Pooling	19
Rapid Elasticity	21
Measured Service	22
Building Block Technologies	22
Networking	23

Storage	29
Virtualization	33
Automation	36
Logging and Monitoring	37
Cloud Models	39
Infrastructure as a Service	40
Platform as a Service	41
Software as a Service	43
Storage as a Service	44
Shared Responsibility Model	47
Location, Location, Location	49
Roles and Responsibilities	53
Challenges and Benefits of Cloud Adoption	54
Summary	56
Other Resources	57
3. Cloud Architecture and Design Principles.	59
Security Concepts	60
Threats	61
Cryptography	65
Identity and Access Management	72
Network Security	76
Traffic Inspection	79
Data Protection	79
Hygiene Practices	80
Zero Trust	82
Design Principles	83
Business Impact Analysis	84
Business Continuity/Disaster Recovery	85
Functional Requirements	87
Design Patterns	88
DevOps Security	94
Evaluating Cloud Provider Security	97
Summary	100
Other Resources	101
4. Cloud Data Security.	103
Cloud Data Concepts	104
Cloud Data Lifecycle	104
Data Dispersion	112
Data Types	114
Data Location	118

Cloud Data Storage Architectures	120
Storage Types	120
Storage Threats	124
Design Considerations	129
Data Protection Technologies and Strategies	133
Encryption	133
Hashing	137
Handling Production Data	139
Data Loss Prevention	140
Information Rights Management	143
Visibility	145
Summary	146
Other Resources	147
5. Cloud Platform and Infrastructure Security.....	149
Infrastructure Security Architecture	150
Reference Architectures	151
Boundaries and Segmentation	152
Data Center Security	157
Physical Security Controls	157
Operational Security	161
Redundancy and Reliability	162
Disaster Recovery and Business Continuity	165
Identity and Access Management	167
Network Security in Cloud	170
Virtualization Security	172
Container Security	173
Summary	175
Other Resources	176
6. Cloud Application Security.....	177
Application Security Threats	178
Identity and Access Management	178
Misconfiguration	180
Poor Vulnerability Management	180
Insufficient Logging and Monitoring	181
Poor Segmentation	183
Infrastructure Misconfigurations	185
Cloud Security Control Mechanisms	185
Cloud Access Security Broker	186
Zero Trust Network Access	187
Security Service Edge	188

Secure Access Service Edge	190
Outsourcing Applications	192
Web Application Security	194
Using Application Programming Interfaces	196
Summary	197
Other Resources	198
7. Cloud Development.....	199
Security and the Software Development Lifecycle	200
Software Development Lifecycle Methodologies	200
DevOps and DevSecOps	205
Threat Modeling	207
Continuous Integration/Continuous Deployment	210
Infrastructure as Code	212
Site Reliability Engineering	214
Code Repositories	216
Introducing Security	217
Design Styles	220
Multitier Architecture	220
Application Programming Interface	222
Cloud Native Design	224
Summary	228
Other Resources	228
8. Cloud Security Operations.....	229
Types of Adversaries	230
Hacktivists	231
Organized Crime	231
Government-Sponsored Groups	232
Security Operations Frameworks	233
Cyber Kill Chain	233
Attack Lifecycle	235
NIST Cybersecurity Framework	237
Security Operations	242
Security Engineering	246
Logging	247
Monitoring	248
Security Information and Event Management	249
Summary	251
Other Resources	252

9. Cloud Security Governance and Risk Management.	253
Risk Management	254
NIST Risk Management	257
ISO Risk Management	259
FAIR	262
Compliance	264
NIST and ISO	265
Cloud Security Alliance Cloud Control Matrix	267
Financial Requirements	268
System and Organization Controls 2	268
Cloud Support for Compliance	269
Policies, Standards, and Procedures	271
Policies	272
Standards and Procedures	274
Business Continuity and Disaster Recovery	275
Summary	276
Other Resources	277
10. Legal and Regulatory Considerations.	279
Data Privacy Regulations	280
General Data Protection Regulation	281
California Consumer Privacy Act	283
Other Privacy Laws (New York, China, etc.)	284
Contracts and Service Level Agreements	286
Vendor Management	288
Legal Compliance Best Practices	290
Digital Investigations in the Cloud	292
Summary	294
Other Resources	295
11. Cloud Security Emerging Trends.	297
Cloud Native Security	298
Modern/Emerging Identity and Access Management	301
Zero Trust Architecture	305
AI/ML in Cloud Security	307
Summary	309
Other Resources	310
Index.	311

Preface

Because cloud resources are so convenient, powerful, and in most cases cost-effective, businesses and individuals alike are making use of them. New businesses can quickly turn up essential information technology resources to enable critical functions. It's almost like a whole information technology department in a box. Because of this, there are significant security considerations. After all, both companies and individuals want to ensure they are protecting sensitive information. Privacy is becoming more of a worry, especially considering the cloud resources are generally accessible to anyone on the public internet.

As more cloud services become available, the protections necessary evolve. It seems like a good idea to have a single book that consolidates many of the controls and considerations necessary to protect cloud implementations. It's always a good idea to start with a framework for subject matter like this, and certainly you can look at how each of the major public clouds thinks about security. Because the use of multiple cloud providers is common, having a framework that is vendor agnostic is a good approach. After all, foundational ideas underpin each implementation, so this book sticks with the basics and uses examples from the major cloud providers. The framework for this book is the Certified Cloud Security Professional (CCSP) certification, because it is managed by a highly respected organization, and because it is vendor agnostic.

While you can use this book as a study guide if you want to pursue your own certification attempt, the book does not teach to the test, focusing on concepts instead. This will help you understand the subject matter better than simply trying to memorize a bunch of facts to pass an exam, since that won't help you much if you try to apply the knowledge.

Additionally, this book can be used if you want to get some understanding about the application of information security principles to cloud computing platforms.

Conventions Used in This Book

The following typographical conventions are used in this book:

Italic

Indicates new terms, URLs, email addresses, filenames, and file extensions.

Constant width

Used for program listings, as well as within paragraphs to refer to program elements such as variable or function names, databases, data types, environment variables, statements, and keywords.

Constant width bold

Shows commands or other text that should be typed literally by the user.

Constant width italic

Shows text that should be replaced with user-supplied values or by values determined by context.



This element signifies a tip or suggestion.



This element signifies a general note.



This element indicates a warning or caution.

O'Reilly Online Learning

O'REILLY®

For more than 40 years, **O'Reilly Media** has provided technology and business training, knowledge, and insight to help companies succeed.

Our unique network of experts and innovators share their knowledge and expertise through books, articles, and our online learning platform. O'Reilly's online learning platform gives you on-demand access to live training courses, in-depth learning paths, interactive coding environments, and a vast collection of text and video from O'Reilly and 200+ other publishers. For more information, visit <https://oreilly.com>.

How to Contact Us

Please address comments and questions concerning this book to the publisher:

O'Reilly Media, Inc.
141 Stony Circle, Suite 195
Santa Rosa, CA 95401
800-889-8969 (in the United States or Canada)
707-827-7019 (international or local)
707-829-0104 (fax)
support@oreilly.com
<https://oreilly.com/about/contact.html>

We have a web page for this book, where we list errata and any additional information. You can access this page at https://oreil.ly/learning_cloud_security.

For news and information about our books and courses, visit <https://oreilly.com>.

Find us on LinkedIn: <https://linkedin.com/company/oreilly>.

Watch us on YouTube: <https://youtube.com/oreillymedia>.

Acknowledgments

With grateful acknowledgment to all the professionals who help guide the development of the objectives for the CCSP, since they try to keep up with all the changes in the industry. Thanks also to my agent Carole Jelen, as well as my editors, Shira Evans and Simina Calin. Also, thanks to both Jessica Rocchio and Karl Ots for their assistance and support.

About the Certified Cloud Security Practitioner

Topics covered in this chapter include:

- Why the CCSP is necessary
- About the ISC2
- CCSP domains
- About the exam

While news has become very personalized in many ways, and each person's news feeds and sources will be populated in ways that are relevant to what they have shown an interest in, it is true that in general, news about one sort of cyberattack or another shows up very regularly. This is because technology has made criminal activities not only significantly easier, but also potentially more lucrative. You can get more results with less because the computer, and your victims, are doing a lot of the work for you. This significantly increases the need for security-focused professionals to protect information resources. Presumably, this is a big part of why you have grabbed this book. You would like to be able to declare that you know what you are talking about with respect to cloud security, and the material covered in the Certified Cloud Security Practitioner (CCSP) exam is one way to do that.

This chapter includes a short history lesson to better put cloud computing into context of decades of changes and evolutions. This helps you understand the return to outsourcing information technology to large providers. It also covers the exam, including the organization responsible for maintaining the exam. You will get a better understanding of what the exam process is before you get the test scheduled and sit down to take it. Understanding specifics ahead of time may help you be calmer when

you sit for the exam. Limiting the amount of uncertainty can free up parts of your brain to focus on the content of the exam, rather than worrying about the structure or format.

The Need for the CCSP

There is now a long history of information processing, and as it becomes more ubiquitous, it is easy to lose track of where we have come from and miss that while the scale is different, much of what we are seeing is just another version of where we have already been. The economics interfaces and scale are different, but in the end, the move to cloud providers for data processing resources is another version of the pendulum that has been swinging for decades. Do you want to process your own data or do you want to pay someone else to do it for you?

It makes a lot of sense. In the last couple of decades or more, many companies have had to become information technology companies. To keep up with the modern world, it was necessary for data to become digital and for workers to have computing devices to access and manipulate that data. This meant a lot of technology resources for companies whose primary business had nothing at all to do with computers or technology. Obtaining and maintaining computing resources became a cost of doing business for everyone around the world.

Historical Context

Many decades ago, the chairman of International Business Machines (IBM) was said to have indicated a belief that there was a worldwide market for about five computers. While there is no direct evidence that Thomas J. Watson actually made that assertion, there was a time when computers were so expensive (there may not be enough adjectives to adequately convey how costly they were compared to their time), and were often built on an as-needed basis rather than mass-marketed, that the expectation was companies that needed data processing would go to another company to have it done for them. This was if they actually needed a computer to do the processing rather than just employing humans to do the work.

In the early 1980s I worked for a service bureau, which was a company you could hire to perform data processing on your behalf. Much of the work that company did was managing mailing lists of addresses that would then be printed onto labels to affix to catalogs. This was not all the work, but it was a substantial amount of what was done at that company. The first service bureau was established in 1932 by IBM, and for several decades, large computers were owned primarily by these service bureaus, handling information processing for smaller companies that didn't want to purchase their own multimillion-dollar machines.

Even after the advent of the personal computer, there were shifts in how computers were maintained and who owned them. Even today, companies are in the business of owning data centers where they either rent out space or rent out processing capabilities.

All of this is a long-winded way of saying that cloud computing is just the next evolution of the outsourcing that has been going on for decades. Essentially, there has been a swing between in-house and out-house processing for ages. Suggesting that cloud computing is a new animal misses decades of history.

This is not to say that cloud computing hasn't brought some changes in how we work, but nothing more than switching from using a mainframe to using a personal computer, and then switching to being able to have multiple programs running at the same time with visual representations of the data rather than being strictly text-based. We continue to evolve our data processing capabilities and how we manage access to them. Switching to an outsourced cloud provider is the next step, but don't expect it to be the last step that is taken in your or my lifetime.

One of the most significant changes that cloud computing brought was automation. This had been going on in various ways for a long time, since automated tasks have more predictability and consistency of results. When you marry automation with the use of web-based technologies to interact with the automation and systems, you get significant business advantages. While businesses have long been moving toward virtualization, cloud providers have accelerated that movement because they have made it easy and cost-effective. Imagine every business trying to re-create all the web interfaces and automation that the major cloud providers have created. This creates efficiencies and significant cost savings.

Business Context for the CCSP

Because it has become such an important part of the business landscape, however, with all the economic benefits and efficiencies that come with it, cloud computing deserves a lot of attention. And since data resources are valuable, they need to be protected. One of the challenges with using any outsourced vendor to manage critical business resources is figuring out who is responsible for what level of protection. And since cloud computing resources are often accessed over the open internet, this level of protection is a little more challenging than if you were in a locked data center at your own facilities.

Cloud computing has not only made it possible for larger companies to enhance their data processing capabilities in a more cost-effective way, it has also effectively democratized information processing. Small businesses can get started quickly with the same computing capabilities that larger companies have.

As a result, we need security professionals who know how to apply the fundamentals of information security to cloud computing platforms. It's important not to lose sight of the fact that the critical properties of information security—confidentiality, integrity, and availability—remain. We still need to ensure we have strong identity and access control in place, for instance. We still need to have strong protections in place to ensure attackers can't get access to critical business resources. This includes all the network and application protections you are used to, as well as the usual things like encryption, access control, data management lifecycles, and all the other elements of a strong information security program.

This is why a certification like the CCSP is important. Individual cloud providers will have their own certifications that are security related, but the current landscape of how businesses are using cloud providers suggests a multicloud approach where instead of using a single service provider, a company is using multiple providers to support its information processing needs.

About ISC2

The CCSP exam is managed by the International Information System Security Certification Consortium, more commonly known as ISC2, sometimes stylized as (ISC)². ISC2 is an organization that was created in 1989 out of a recognized need for vendor-neutral certifications. This led to a Common Body of Knowledge (CBK), detailing all the information a highly skilled and knowledgeable practitioner should have. This was completed in 1992, and the Certified Information Systems Security Practitioner (CISSP) certification, which ISC2 is primarily known for, became available in 1994. Since that time, ISC2 has developed other certifications.

In addition to managing the CCSP, CISSP, and other certifications, ISC2 offers trainings and conferences. As of mid-2024, ISC2 had nearly 675,000 members worldwide. ISC2 facilitates training and education, as well as networking for all of its members. The courses offered by ISC2 to members go beyond security-related subjects and include leadership training.

Ethics is an important element of information security. Security professionals often have access to sensitive information or perhaps they are given access to do testing, which can do significant damage to businesses and their resources if not handled appropriately. Because of this level of potential impact to businesses, security professionals are generally expected to act with a high degree of ethics. As a result, anyone who is certified through ISC2 has to agree to a code of ethics. Security professionals have to agree to **the following precepts**:

- Protect society, the common good, necessary public trust and confidence, and the infrastructure
- Act honorably, honestly, justly, responsibly, and legally

- Provide diligent and competent service to principals
- Advance and protect the profession

Essentially, credentialed security professionals through ISC2 agree to not only do no harm willingly but also actively work to ensure information assets are protected from harm. It is possible, though, for bad events to happen without being ethical violations. Vulnerabilities happen despite the best of intentions. You will be expected to act with the best of intentions and do so in a professional manner, serving those who are employing you in particular, but also taking care to look out for others should you encounter situations where damage may occur.

You will notice the last bullet says “Advance and protect the profession.” As with other professional certifications, you will be expected to continue to enhance your knowledge and understanding within the information security space. You do not obtain an ISC2 certification and then never do anything about it again. You will need to provide continuing education credits as long as you hold the certification to demonstrate that you are continuing to progress your knowledge or that you are passing your knowledge on to others. You can attend conferences, speak, write, take classes, or engage in many other activities to obtain credits. You will then have to provide proof to ISC2 that you engaged in these activities. This is required for their certification auditing.

Anyone who does not abide by the code of ethics may be reported to the ISC2. There is a professional conduct committee as well as a process for complaints against members, including an investigation of facts. The Ethics Committee will issue a recommendation to the board, which will rule on what happens to the member who has been accused of a violation of ethics. Forms are available from the ISC2 for issuing complaints, and the process of resolving the complaint is detailed at a high level there as well. Everything is available at the [ISC2 Code of Ethics](#).

The CCSP certification is one of several that have been approved under the United States Department of Defense Manual 8140.03, *Cyberspace Workforce Qualification and Management Program*. Essentially, it details requirements to demonstrate candidates are qualified within individual information technology and information security subjects. While generally certifications that have been approved under 8140.03 can be used to help qualify for government jobs, those certifications also may hold additional weight in industry, simply because of the requirements for maintaining the integrity and applicability of the certification and exam. Basically, the certification has its own certification from the US government saying it is rigorous and well-managed.

About the CCSP and Topics

The CCSP is a cloud-focused certification but it is vendor agnostic. You will not need to know specifics about individual cloud platforms and the endless array of products and services offered by those providers. Knowing all of that information from the

three major cloud platforms can be positively dizzying, so you may be relieved you don't need to keep all of that in your head. This means you will need to understand higher-level concepts that are important for anyone working in cloud security. As with the CISSP, the CCSP is broken into domains. There are six domains related to the CCSP:

- Domain 1: Cloud Concepts, Architecture, and Design
- Domain 2: Cloud Data Security
- Domain 3: Cloud Platform and Infrastructure Security
- Domain 4: Cloud Application Security
- Domain 5: Cloud Security Operations
- Domain 6: Legal, Risk, and Compliance

As mentioned earlier, all of these domains are relevant to on-premises operations. Probably the biggest area of difference is when it comes to architecture. Cloud-based offerings have accelerated adoption of certain design patterns that are less commonly seen on premises. Additionally, a significant change is who is responsible for what. This is a concept called the Shared Responsibility Model, which we will go into in [Chapter 2](#). As there are different types of cloud offerings, understanding who is responsible for what is essential. You want to make sure you understand the different service offerings to determine whether your organization members have the right skills to be responsible for their part.

Cloud offerings are delivered with internet-based technologies, but that does not mean services are necessarily exposed to the open internet. Services and data can be protected through appropriate design and architecture decisions and security controls.

Another significant advantage of using cloud service providers is having so many common security controls available under one umbrella rather than having to cobble together entire solutions on premises from multiple vendors. This does not mean you are going to be limited to the service provider you choose for network access control, data protection, and other security control solutions. Often, dominant vendors in those markets will have offerings through the cloud provider, usually through a marketplace. They will integrate into the designed solution.

When you put your technology resources in the hands of others, it does change how you manage those resources. This includes monitoring and alerting when something happens. It is important to understand where the boundaries are and who is going to do what, as well as how you can take control of cloud security operations for yourself, if that is what you choose to do.

Each of the domains listed above will come with some nuances to be aware of, but if you have a strong grasp of them in general, you will be in a better place. The next sections are a high-level overview of the topics covered in the exam. While there is a lot of material, the list of subjects is not comprehensive but instead is a summary of the exam outline.

Domain 1: Cloud Concepts, Architecture, and Design

This domain covers the essential fundamentals of cloud computing: definitions, as well as roles and responsibilities. This means roles like customers, providers, brokers, and other positions, plus the responsibilities for each role. You will also need to know the types of cloud services and the technologies used to deliver them.

You will also need to understand the cloud reference architecture, including activities, capabilities, categories, and deployment models, like public, private, hybrid, community, and multicloud. You will need to know the interaction with other related technologies.

This domain also includes basic security concepts and their implication for cloud computing, including cryptography, identity and access management, network security, common threats, virtualization security, and security hygiene. Additionally, it includes business impact analyses, business continuity practices, functional security requirements, and the responsibility of the vendors compared with the customers. Different cloud providers also have their own security frameworks, as do vendor-agnostic organizations. You will need to understand those frameworks. Finally, you will have to be able to evaluate different cloud providers against common criteria, including industry-standard criteria.

Domain 2: Cloud Data Security

An essential function of any information security professional or program within an organization is protecting data. You will need to understand basic data concepts like data lifecycles, data flow, and data dispersion. You will also need to design and implement data storage architectures, technologies, and strategies.

Part of a good data program is classifying data, so you will need to know how to perform data discovery, as well as how to create classifications based on business needs and definitions. Data discovery should include both structured and semi-structured types. You will also need to be able to design and implement information rights management (IRM).

As part of a data lifecycle, you will not only identify data and its classification, but also know retention requirements and how to ensure data is destroyed appropriately when it is no longer needed. This also includes archiving data that may not need to be

kept readily available but is still needed by the business. You will also need to know how to handle legal hold.

Movement of data should be trackable—have an audit trail. This means you will need to understand how to audit trackability of data. You will also need to understand logging, chain of custody, and nonrepudiation.

Domain 3: Cloud Platform and Infrastructure Security

In cloud platform and infrastructure security, you will have to know the different components of the cloud platform, including the physical environment, virtual environments, network and communications, compute, storage, and the management plane. You will need to design a data center, including logical, physical, and environmental design. You will also consider resilience in your design.

Vulnerability and risk management are essential aspects, so you will need to understand the elements of a vulnerability management program, as well as be able to identify business risks associated with the vulnerabilities, design, and implementation of the cloud solution.

You will need to be able to design a business continuity and disaster recovery plan. You will also need to be able to plan security controls, including physical and environmental protections; system, storage, and communications controls; identification, authentication, and authorization; and audit mechanisms to verify the security control implementation and effectiveness.

Domain 4: Cloud Application Security

Application security is a broad topic that covers the software development lifecycle (SDLC), taking its foundational ideas and the implementation into consideration. This includes knowledge of threat modeling, using frameworks like STRIDE, DREAD, and PASTA. It also includes secure development practices, especially as they apply to remediating vulnerabilities identified by the Open Worldwide Application Security Project (OWASP) common vulnerabilities list. You must also be able to justify the use of training and awareness for application security, including common vulnerabilities and concerns.

You will need to apply security validation and assurance, including common testing practices. You will also need to know how to make use of verified and validated tools and technologies to protect against vulnerabilities introduced upstream. This includes validating open source software. You will also need to understand common application design patterns and technologies, including web application firewalls, cryptography, sandboxing, the use of microservices and containers, firewalls, and API gateways.

While this is covered in other domains as well, because you will handle it in infrastructure, identity and access management are also essential to application security, since any developed applications should also support authentication and authorization. This includes federated identity, the use of identity providers, the use of single sign-on, multifactor authentication, cloud access security broker, and managing secrets. This is especially true when it comes to managing any secrets used to authenticate the different elements within the architecture.

Domain 5: Cloud Security Operations

Cloud security operations cover the implementation of all the elements used in design and development, so there is overlap. This is where you actually do the work. This means not only will you need to know how to design the physical and logical infrastructure, you will also need to know how to implement it, including the differences in types of hypervisors, as well as physical infrastructure. You will need to understand physical protections like the trusted platform module and hardware security modules.

You will need to know how to deploy any application that has been developed, using Infrastructure as Code, and implement security network configurations and the controls relevant to them. This includes the use of virtual local area networks (VLANs), the Dynamic Host Configuration Protocol (DHCP), Transport Layer Security (TLS), and virtual private networks (VPNs).

You will need to understand the practices for managing information technology implementations, including problem management, incident management, release management, change management, deployment management, configuration management, asset management, service-level management, and capacity management.

You will need to be able to support digital forensics for gathering information related to evidence collection and management. You will also need to be able to manage communication with vendors, customers, partners, regulators, and any other stakeholders.

Management of security operations will be on the exam, including the use of a security operations center. You must know how to implement technologies that can be used to collect information to support detection and response to incidents. This includes logging, as well as technologies for incident detection, both at the host and at the network. You will also need to know about using a security incident and event management solution to gather and manage information coming in from different security elements.

Domain 6: Legal, Risk, and Compliance

You will need to understand legal requirements and anything that may be unique to the cloud environment. This includes any conflicting requirements between jurisdictions, because data usage and data storage may be in different locations. You must understand legal frameworks and guidelines.

Privacy is an important consideration, so you will need to understand considerations related to privacy, including personally identifiable information and personal health information. You will have to understand how different jurisdictions define those categories. This includes understanding the different privacy laws that exist, including the General Data Protection Regulation (GDPR).

You will need to be able to support audits, including understanding audit requirements. This includes understanding policies and how to manage them, as well as how to audit the use and implementation of those policies within the cloud environment. It also includes how to use technologies to support verification and auditing within the cloud environment.

The cloud environments will need to be monitored for risk, so you will know how to identify and manage risk within the enterprise risk management function. This includes any regulatory considerations, as well as the difference between data owner/controller versus data custodian/processor. You will need to understand the different risk treatments and considerations for when and how to implement them. You will need to know about different risk frameworks, as well as metrics related to risk.

As you are outsourcing when using public cloud providers, you need to know about contractual considerations. This includes understanding business requirements, and the use of appropriate vendor management practices. When it comes to the use of vendors, you will need to understand right to audit and anything related to metrics, termination, assurance, and compliance. You will also need to be able to recognize the application of cyber risk insurance toward the cloud platforms.

About the Exam



Experience Required

To ensure the integrity of the certification so they are not just paper certifications, where someone has passed the exam but may not have any practical knowledge, ISC2 requires you to have five years of experience in information technology, with at least three years in information security and at least one year of experience in the domains associated with the certification. It is possible to be an Associate with ISC2, though, while you gain the experience necessary to get the full certification. You just need to pass the exam.

As you might expect, the exam is computer-based and taken at a testing center. There are 125 multiple-choice questions, and you will have 3 hours to complete the exam. You will need a passing score of 700 out of 1,000 to pass the exam. The exam is administered at Pearson VUE testing centers. You can register for the exam online at [the ISC2 website](#).

As of late 2024, ISC2 indicates the average weights to the exam categories shown in [Table 1-1](#). This is not a guarantee that you will see these weights in your specific exam, since each set of questions is different. On average, though, these will be the weights used for the exam.

Table 1-1. Average weights to the exam categories

Domain	Average weight
Cloud Concepts, Architecture, and Design	17%
Cloud Data Security	20%
Cloud Platform and Infrastructure Security	17%
Cloud Application Security	17%
Cloud Security Operations	16%
Legal, Risk, and Compliance	13%
Total	100%

Preparing for the Exam

When it comes to preparing for the exam, this book is a good start but it is also important to understand the practical considerations and applications. While there are several ways to implement cloud platforms, including technologies you can implement yourself, there are three primary vendors of cloud platforms: Amazon Web Services (AWS), Google Cloud Platform (GCP), and Azure. There are often ways to get free credits with these platforms so you can try to implement some of the technologies you are less familiar with. At a minimum, each platform has a free tier, which you can use at low or no cost. Make sure you have taken a look at implementing these technologies within the different platforms to understand the differences. While these will not be on the test, seeing different implementations will give you some different perspectives, which may help you understand the concepts better.

ISC2 also has some free resources that may help you study. You can get flash cards, as well as a practice exam. The practice exam provided will be of limited use, because it is only 10 questions.

Resist the urge to find other practice tests online, since they may include actual questions from the test. This would put you in violation of the code of ethics you will need to agree to. Using actual questions from the test—and there are providers that have a

test bank directly from the actual test rather than just similar questions—would be considered cheating.

There are study groups and communities available online, which may be of some use. You can discuss different study strategies, as well as the concepts on the exam.

Summary

The CCSP certification is a certification and associated exam that is managed by ISC2. This is a nonprofit organization that is responsible for managing and maintaining security certifications that are vendor independent.

The CCSP exam is 125 questions, and you will need to obtain a score of 700 out of 1,000 to pass. The exam covers a broad range of subject areas from the following six domains:

- Cloud Concepts, Architecture, and Design
- Cloud Data Security
- Cloud Platform and Infrastructure Security
- Cloud Application Security
- Cloud Security Operations
- Legal, Risk, and Compliance

While many, if not most, of the same topics are relevant to on-premises security implementations, there may be some topics that are either specific to the cloud or have different implementations in the cloud, simply because of the resources that have been put into automation and abstraction that are harder to do on premises.

There are several resources that are available to help you prepare for the exam in addition to the material from this book. These include resources available from ISC2 plus free resources from the cloud providers.

Other Resources

The following pages include additional information about the CCSP, as well as places to get free access to cloud services for learning:

- “CCSP Study Tools and Resources,” ISC2 (<https://oreil.ly/q9kkB>).
- “AWS Offers: Explore Different AWS Offer Programs and Gain Free, Hands-On Experience,” Amazon Web Services (<https://oreil.ly/a-Kpg>).
- “Build in the Cloud with Azure for Students for Free,” Microsoft (<https://oreil.ly/EK3rN>).

- “Free Google Cloud Features and Trial Offer,” Google Cloud (<https://oreil.ly/hkIKY>).
- “CCSP Study Group,” ISC2 (<https://oreil.ly/OSXYk>).
- r/CCSP [CCSP study group], Reddit (<https://oreil.ly/CprOi>).
- Ric Messier, *Build Your Own Cybersecurity Testing Lab: Low-Cost Solutions for Testing in Virtual and Cloud-based Environments* (O’Reilly, 2020).

Cloud Computing Fundamentals

Topics covered in this chapter include:

- Cloud definition
- Underlying technologies
- Cloud models
- Roles and responsibilities
- Pros and cons of cloud adoption

Everyone knows what the cloud is, right? After all, you are probably using it every day. You may not even know you are using it when you are using it. It's one of the great things about adopting cloud providers to support your information infrastructure. In most cases, it should be entirely transparent and just work the way your users are used to working. Of course, one of the reasons they are used to working with the cloud is because it's become so ubiquitous. Cloud providers and the ways they deliver services have enabled businesses to be fast and likely offer more and better services than they did before they moved to the cloud.

However, can you define what the cloud means? Do you know what the different technologies that go into cloud services are or the different delivery mechanisms? This chapter will provide a clear definition of cloud computing. This includes all the underlying technologies that make cloud delivery possible, helping to reduce costs and make consumption of resources easier. Once you understand the delivery mechanisms and features that define cloud computing, we can talk about the different styles of cloud computing. After all, there are different levels, depending on how much control you want to have, meaning how much work you want to take on. This includes understanding the Shared Responsibility Model. Not only is this important

from the perspective of the exam, but it's also essential so you know what you need to be doing if you are using cloud platforms.

While you may think cloud is all about using someone else's computing infrastructure, cloud is more about the technology and delivery. So you will need to consider location when you are making cloud decisions. You'll also need to know the different responsibilities related to vendors, consumers, and different technologies to control the flow among them.

What Is the Cloud?

The cloud just means you are using computing resources available on the internet, right? Actually, no. One of the reasons it's called the cloud is because when networks are diagrammed, the large amorphous mass that is all the interrelated networks we call the internet is generally represented as a cloud. This suggests there are organizations, devices, and activity that are difficult to fully represent or diagram, so it's easier to put a big fluffy mass in place, suggesting a certain level of obscurity in the situation. As an example, [Figure 2-1](#) is a generic network diagram for an on-premises network that connects to the internet through a pair of firewalls and a pair of routers.

So, what does cloud computing mean? If all it meant was computing resources available over a network, you'd miss a lot of essential nuance describing what makes modern cloud computing unique and essential. You may find some definitions like that online, but if they were correct, remotely accessing a server using Virtual Network Computing (VNC), Secure Shell (SSH), or Microsoft's Remote Desktop Protocol (RDP) would be cloud computing and we know that's not true. Cloud computing is also not limited to computing resources available on remote networks, accessible through the internet, since that misses some implementations as well.

It's also not simply outsourcing. We've been outsourcing computing resources since the 1960s once time-shared computing became a reality, allowing for multiple users and jobs to run simultaneously on a mainframe system. Virtualization also became a reality in the 1960s. The outsource model has been a go-to for a lot of companies for decades, so in that sense, handing off computing capabilities to other companies is nothing new.

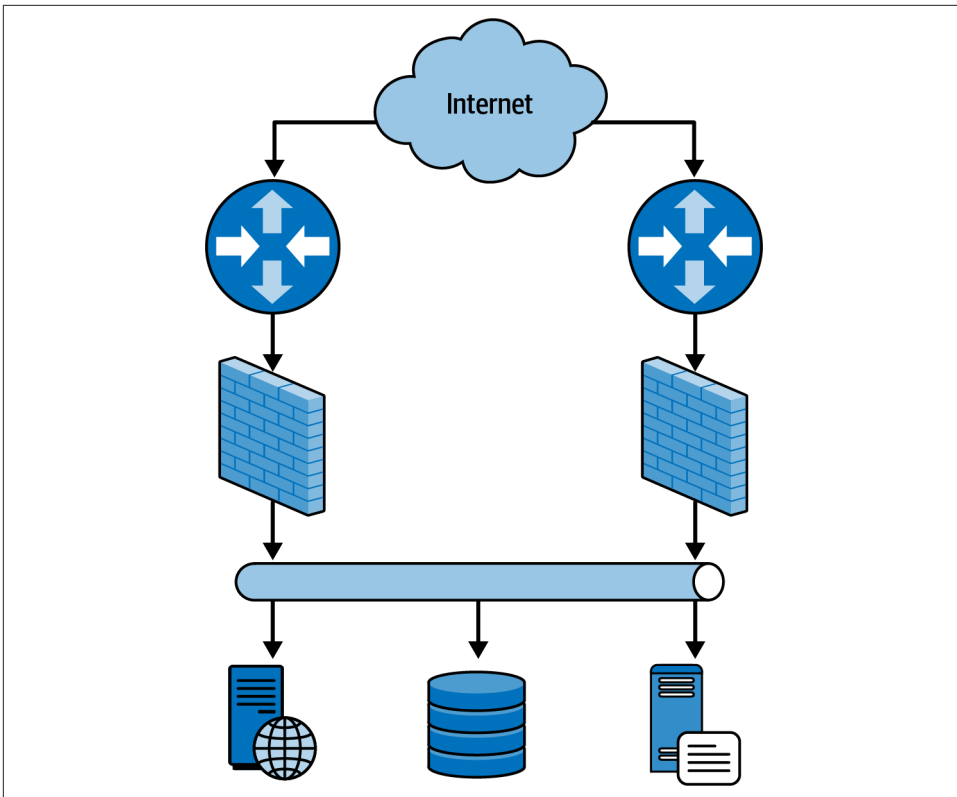


Figure 2-1. Network diagram

The US National Institute of Standards and Technology (NIST) defines five essential characteristics of cloud computing:

- On-demand self-service
- Broad network access
- Resource pooling
- Rapid elasticity
- Measured service

In addition, you will generally find that a common aspect of cloud computing is multitenancy, where many consumers of the cloud services are using them at the same time. This may be many different departments in the same company, but in the case of the public cloud, multitenancy means there are many consumers of the service across multiple companies. This puts the burden of separation and isolation on the cloud provider to ensure no access or information crosses from one customer (or tenant) to another.

On Demand, Self-Service

If you were just accessing a remote server, as would be the case with VNC or RDP, you may not have any ability to fully manage the system, meaning manage its power, as well as make decisions about the operating system and hardware. While you can do this with administrative access to a virtual machine system, that requires some additional items to be in place, including either a virtual image to clone, or a virtual disk to install from. None of this will be quick and easy, and most people won't have that administrative access, because more administrators opens the door to misconfigurations or other problems. This means most people would have to ask an administrator to create a virtual machine for them. This is not really on demand, nor is it self-service.

One aspect that NIST leaves out is that cloud computing makes use of common networking protocols, including and especially in this case, web-based protocols like the hypertext transfer protocol (HTTP). By using HTTP, a user already has everything they need to get access to cloud computing resources, not only to consume them but specifically to manage the instance. On demand means that any time a user wants to create a new instance of some cloud computing resource, they can do it without having to rely on anyone else. This is commonly done through a web interface. And as long as that user has the right permissions, they can be completely self-service. All of the activities that would normally require administrative access on the part of the user are done by services behind the scenes, making it easy and fully self-service.

This is not to say that everyone should have the ability to create instances of cloud resources. Because there are costs associated, these permissions should be granted only as needed. Self-service doesn't mean everyone. It just means that those who have the right permissions can manage the instances themselves without having to work with another human. Not that working with other humans is bad, necessarily, just that as soon as you get someone else involved, you are now at the mercy of their schedule and speed. On demand, self-service means when you want it, you got it.

It also enables access from people who are much less familiar with traditional computing administration requirements. This has enabled smaller businesses to have extensive access to computing resources without needing to hire someone whose responsibility is the care and feeding of equipment in a data center. You create a

simpler interface and make access a lot easier for many more people, so anyone who has set up a cloud environment for use by others has opened the door to many more people being able to use those resources.

Broad Network Access

Since we are using network technologies, where generally the resources are remote rather than sitting in front of you, you also must have access to networks. In most cases, cloud computing providers will have much faster, more resilient network access than most businesses. In part, this is because they are sharing the network across large numbers of resources and customers; they are also providing a service and as a result, the customers have expectations for the delivery of that service. If network access was slower when going with a cloud provider, most businesses would likely stay with on-premises resources.

Network access does not necessarily mean internet access, by the way. At least, it may not mean direct internet access. First, there are private clouds, which may be entirely within a business environment and may not be accessible from outside the business network. Additionally, while the administrative interface for public clouds should probably have internet access to make them the most broadly accessible, there are ways to restrict users from getting access to not only resource administration, but also restrict the resources from getting direct internet access, either incoming or outgoing.

As we are talking about delivery, at least of administration if not necessarily direct access to the resources once they are available, over web-based protocols like HTTP and the Transport Layer Security (TLS) protected HTTPS, we are talking about traditional Transport Control Protocol/Internet Protocol (TCP/IP) networks, which HTTP/HTTPS runs on top of.

All of these are factors that go into broad network access: you must have a TCP/IP network that is accessible to your customers, wherever they may be, and you must have adequate bandwidth to support the number of customers you have with the volume of resources and network needs required.

Resource Pooling

It's not a big surprise that cloud computing has taken off because it has the potential to be less expensive for businesses. One reason is because providers can pool resources to share across large numbers of customers. Computing, network, and storage resources can all be shared across all the customers. In an on-premises environment, let's say you had a 2-GHz processor that was capable of 16 floating point operations per clock cycle, per processor core. That means each processor core can handle 32 billion floating point operations per second (FLOPS). If you had 8 processor cores, that means your system can support 256 billion FLOPS.

If you were to look at the utilization on your computer at any given moment, and a desktop is far less likely to stress a processor than a server would, you would see a processor that is mostly idle. On my laptop, as I write this, **Figure 2-2** shows that even with multiple applications open, the processor is 93.61% idle. This varies a lot, depending on the applications, but modern processors are not especially stressed by what we are asking them to do.

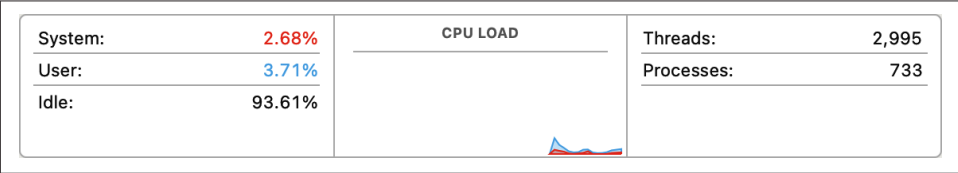


Figure 2-2. Processor utilization

Because of this, there is a lot of excess computing power in the world that could be used for other purposes. This very idea was the basis for projects like Distributed.net, a distributed computing project designed to break up complex computing tasks across a large number of systems with excess compute power. Also, SETI@Home is a project to support the search for extraterrestrial intelligence (SETI) using distributed computing resources, again based on the idea that you have a lot of compute power you aren't using. The same is true for Bitcoin mining, which can run on your computer to support cryptocurrency.

The same is generally true of network capacity, meaning you have a lot of excess capacity that isn't being used since it's unlikely you are maxing out your internet connection all the time. However, this is ameliorated because the sharing then happens at your provider's level. You are sharing with everyone else in your community who uses the same provider, and perhaps even with everyone in your state, region, or whatever geographic region the provider has spread its capacity across. Even though you are sharing with a large number of people, the sporadic nature of network requests and responses means there is still a lot of capacity available.

The same is true for storage, of course. Look at the excess capacity on your local drive to get a sense of what you have free, then multiply that by the billions of devices around the world.

All of this is to say that providers acquire large amounts of computing resources, then make the entire pool of resources available to share. This works and is economical because providers oversubscribe. Let's say, for instance, that your internet service provider (ISP) had sold 250M connections to 10 customers. Without oversubscription, it should mean the provider would need to have a 2.5 gigabit Ethernet connection to support all of those customers. Since they assume no one is utilizing all 250M all the time, they can get away with far less capacity than they have sold. You get a fast connection when you need it, but when you aren't using it, your neighbor can be using it.

This oversubscription is how the economics of cloud computing work. Businesses would typically need capacity or systems for all the applications and capabilities they need to support. They may still be using some version of resource sharing or pooling, just at a much smaller scale than a cloud computing provider. It is this pooling of resources that marks cloud computing, because it is essential to make the economics work.

Rapid Elasticity

There are some foundational elements that are not included in the list of properties or characteristics that define cloud computing. One of these is automation. Without automation, you don't get on demand. After all, without automation, you end up having to get someone involved. Additionally, without automation, you don't get rapid elasticity. Rapid elasticity is the property of being quickly responsive to demand. Nearly three decades ago, I was working at a large internet service provider that hosted systems for customers, generally for web applications. Each year, any customer who was going to engage in an activity that would increase demand, like running a Super Bowl ad, for instance, would have to tell the company about it. This meant additional systems would have to be provisioned and added to the load balancer so the additional requests could be processed when needed.

This is not rapid elasticity. Rapid elasticity is maintaining enough capacity within the resources available to the application to support the requests coming in, and adding additional resources as demand increases. This means quickly provisioning and deploying systems, containers, functions, or whatever other cloud resource is being consumed. This could mean doing some version of pre-provisioning, meaning they are warm and on standby for when they are needed. Some resources deploy considerably faster, so the resource could be provisioned in the moment it is needed and still be able to respond to user requests within a reasonable amount of time.

Elasticity is bidirectional. This means when the demand is no longer there, the resources are deprovisioned. The application should only have enough resources operational to respond to the requests that are coming in. Rapid elasticity means just-in-time provisioning, essentially.

Of course, this also implies close monitoring. The overall application needs to be monitored to identify when it is approaching the point where requests can't be supported any longer. At that point, automation will help to ensure the needed additional support is being provisioned. And, on the other side, once the requests have tailed off, the additional resources can be deprovisioned. You have to have effective performance monitoring in place to know when to scale up or scale down, based on need.

Measured Service

Measured service is the primary way cloud computing is cost-effective for businesses. In the earlier example where additional systems (actual hardware) were deployed well ahead of the demand, the customer paid for the additional systems, whether they were used or not. They needed to be deployed in case of additional demand, but there was no guarantee the Super Bowl ad, for instance, actually drove more people to the website, which justified the need for the additional resources that were being paid for. This was not cost-effective for the business, but it was the way things were done then.

Today, because cloud providers will scale their solutions based on need, and they have extensive monitoring in place, customers only pay for what they need. This is measured service. The usage is measured and the customer pays only for what they use. When the application scales up to support demand, the business pays more for the period of time the additional resources are deployed. When resources return back to a normal level, the billing returns to the reduced level based on usage.

Generally, everything is measured. Every aspect of your application will be monitored and paid for. Network usage will be billed, as will compute usage and storage. Keep in mind that these are not just system resources, meaning some version of a computer instance. You will also have virtual networks and any external IP addresses that are used, which will be billed. Any data that is stored will be billed, and if you are using a database, you will be charged for storage and transactions, since transactions encompass compute power and network.

There are often ways to reduce the overall cost, including using lower cost and lower priority resources, as well as making commitments and accepting reduced performance or availability. This means it's not quite as straightforward as everything you use is paid for, but generally, you are using what you pay for down to a very fine grain of measurement. Ultimately, this is likely still less expensive than the cost of maintaining hardware on premises, since then you have hardware costs, plus all the power required for the system, the network, and cooling.

Building Block Technologies

Cloud computing is built on top of some essential technologies, about which you will need to have a good understanding. These are foundational technologies that are necessary for all of the cloud computing offerings, including networking, storage, virtualization, and automation. Additionally, while it is less visible, logging and monitoring is another essential building block. While it's more likely to be used by the provider, since it is critical for measuring service usage and performance, it's still worth covering.

Networking

As one of the requirements for cloud computing is broad network access, it makes sense that networking is a foundational element. Communication with the cloud portals happens over a network using web-based protocols, messages to automation systems happen over the network, and then resources become available across the network. All of this is to say that networking is an important element of cloud computing.

Networks are a means of organizing devices that are related in some way. For most people, whether they are at home or working for a business, the organization has to do with belonging to the same group, whether it's a family or a company. There may also be a geographic component, such as a public wireless network where users are simply related by their proximity to one another. An internet is a collection of networks that are connected to one another. The purpose of networks is to allow communication from one device to another.

Open Systems Interconnection

In the 1970s, the International Organization for Standardization (ISO, from the French name for the organization) wanted a model for communications protocols, so a seven-layer model was developed. You will commonly hear layers referred to when discussing protocols, and generally the Open Systems Interconnection (OSI) model is used for numbering. The following are the layers in the OSI model:

Physical

This is where devices connect with hardware, whether it's cables, network interface cards, or just the means of transmission from one device to another in the physical world. At this layer, the protocol data unit (PDU) is a bit.

Data Link

Data is collected as frames and structured to be sent out through the physical interface. The media access control (MAC) address is used to identify one device from another. At this layer, the frame is the PDU. At this layer, everything is local. Data Link protocols cannot leave a local network, so communication here is switched, meaning it is sent from one location to another by way of the MAC address.

Network

Addressing at this layer relies on an understanding of networks, meaning routing decisions are possible here because the address for the device can be used to organize devices together, where the MAC address is completely independent of any other device. IP is a network protocol, so IP addresses are used to differentiate devices at this layer. The PDU is a packet here. This layer allows communication to move from one network to another through routing.

Transport

Protocols at the transport layer help to organize data so it can be delivered to applications later. This may include ensuring that data is segmented correctly and identified so it can be restructured on the receiving end correctly. Addressing is done by way of ports, so each port is attached to an application. This helps to allow multiple applications to talk using the same IP address at the same time. Transport layer protocols may ensure that transmission from one node to another happens with acknowledgments and other tracking information. The Transmission Control Protocol (TCP) and User Datagram Protocol (UDP) are common protocols at this layer, and the PDU is either a segment or a datagram, depending on the protocol being used.

Session

The session layer manages any information that is necessary to maintain a state from one system to another to ensure continuous communication from one endpoint to another remains possible. This includes establishing a connection and maintaining the dialog from one device to another throughout the session. Network Basic Input/Output System (NetBIOS) is an example of a protocol at this layer. There is no specific PDU at this layer. It is just called data.

Presentation

This layer is responsible for translation of data between the application and the network. This may include encryption, compression, or data encoding. As with the session layer, there is no PDU. It is still just data here from the perspective of the model.

Application

Protocols are used for applications to communicate with one another in structured ways. Often, this is a client communicating with a server, as in the case of the hypertext transfer protocol (HTTP) or the File Transfer Protocol (FTP). This allows for the client to send messages to the server to issue requests and get responses that the client will be able to understand. Again, information is just data at this layer rather than having a PDU.

The OSI model is conceptual, meaning it can be applied to many implementations. It does not describe the ideal means of organizing information but is instead a way of conceptualizing the flow of information between systems communicating with one another. It has generally worked well, and you will often hear people refer to a Layer 2 problem, for instance, to suggest something that happens on the local network.

TCP/IP

There is another way of conceptualizing network communications that is easier, but it lacks granularity, which may be fine for most cases. The Internet Protocol Suite is an architecture describing how the protocols used across networks, based on TCP/IP, are

organized. In [Figure 2-3](#), you see the OSI model alongside the Internet Protocol Suite layers. The link layer of the TCP/IP suite corresponds to the physical and data link layers of the OSI model. The network layer of the OSI model is the same as the internet layer of TCP/IP. Transport is the same in both designs, and application in TCP/IP encompasses session, presentation, and application in OSI.

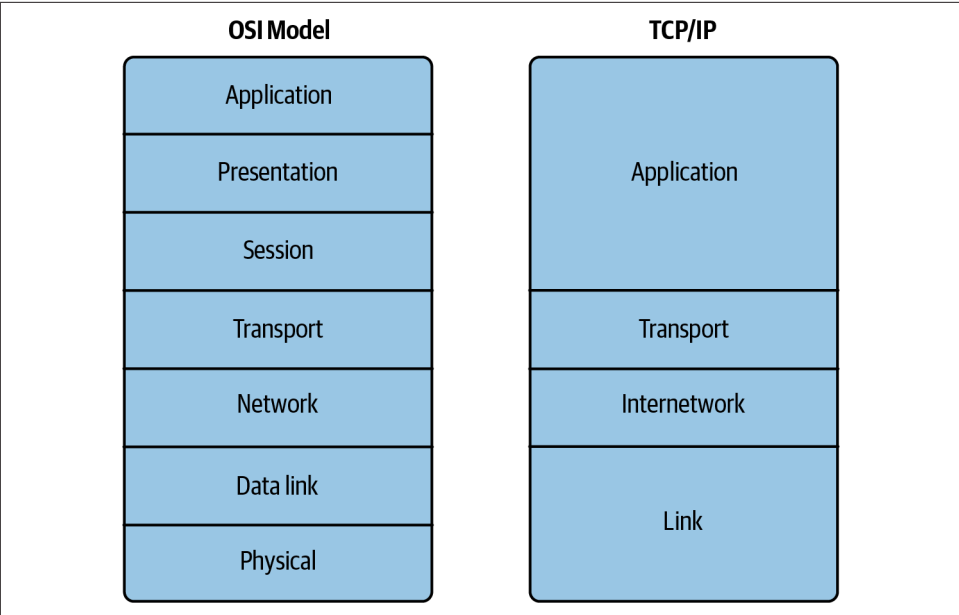


Figure 2-3. OSI model and Internet Protocol Suite

Data flows are constructed starting at the application layer, regardless of the model you are thinking about. As the information flows down the protocol stack, information is generally added. This is called encapsulation and will often take the form of a set of structured data called headers. An example of this is shown in [Example 2-1](#), where you can see the HTTP headers over the top of the hypertext markup language (HTML) that the server is sending. The headers provide status information and other essential context for the client's browser to look at without passing it on to the user who only sees the result of the HTML as rendered by the browser.

Example 2-1. HTTP headers

```
HTTP/1.1 200 OK
Server: nginx/1.24.0
Date: Mon, 23 Sep 2024 19:43:00 GMT
Content-Type: text/html
Content-Length: 10701
Last-Modified: Thu, 14 Sep 2023 17:19:02 GMT
Connection: keep-alive
```

ETag: "65034086-29cd"
Accept-Ranges: bytes

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Apache2 Debian Default Page: It works</title>
    <style type="text/css" media="screen">
      * {
        margin: 0px 0px 0px 0px;
        padding: 0px 0px 0px 0px;
```

Network segmentation

Now that you know the protocols, you should be aware that networks are segmented. In the real world, meaning the physical world, typically you can segment networks physically by connecting devices to one another through switches. Even with physical switches, you can still segment virtually. If you call a physical network a local area network (LAN), using a switch to isolate some devices from other devices so the segmentation is handled inside the switch is called a virtual LAN (VLAN). This relies on configuration in the switch to indicate which ports belong to individual VLANs. In general, a port has to belong to just one VLAN, though you can pass the VLAN tag in the header from one port to another if the port has been specified as a trunk. This typically means connections between switches where the VLANs carry across the different switches, so the VLAN tags need to be carried to distinguish where the frame is allowed to be delivered.

In general, you don't have to worry as much about the Layer 2 communications with cloud providers, since that gets handled within the infrastructure. You will generally need to be concerned with IP networks, though. While the cloud provider will take care of a lot of the addressing, it doesn't hurt to make sure you understand at least minimally how IP networks are addressed.

First, you need to understand the structure of an IP address. Since 1982, IP version 4 has been in place, commonly referred to as IPv4. It has four numbers that are stored in binary as eight bits, called an octet to distinguish it from a byte, which was not standardized at that time to the eight bits we usually think of today. The address is typically represented as the four numeric values separated by dots (.). So, you may have an address that looks like 19.15.56.42. In this address, there is a network portion and a host portion. The network portion is designated since your network stack on your local system will check to be certain whether a destination address is local to you, meaning it will be delivered using a Layer 2 address, or remote, meaning it will go to a router to be sent to the next network.

The network portion of the address is determined using a bitmask. A similar dotted quad (the four numbers separated by dots) is used, called a subnet mask or a network mask. A 1 in the subnet mask denotes the network. Everything that is a 0 is the host portion. This means you will have a continuous stream of 1s starting at the most significant octet, which is the one furthest to the left. When you convert the binary to decimal, you will get something that looks like 255.255.255.0. That means the first three octets are the network, while the last is reserved for the host. Out of the host address block, the lowest address is the network address, while the highest address is the broadcast address. This is the address that is used to send to all hosts within an IP network. Using the address from earlier along with this subnet mask, the network address would be 19.15.56.0 and the broadcast address would be 19.15.56.255.

The subnet mask can get to be unwieldy, and since all the bits have to be filled in from the left to get a contiguous block of addresses, it is easier to just indicate the number of bits to be used in the subnet mask. This is called Classless Interdomain Routing, or CIDR. To use the same subnet mask, you would designate the IP network we've been talking about as 19.15.56.0/24 because you have 3 octets where all the bits are used, so that is 8×3 , or 24. If we were to make the network larger to accommodate more hosts, we could use a bit from the subnet mask, making it a /23, and the subnet mask would be 255.255.254.0 because the last octet doesn't have the least significant bit filled with a 1.

This brings us to IPv6, because subnet masks are not used to indicate networks in that version. The addresses are considerably longer as well, so numbers are not usually represented in decimal. Instead, IPv6 addresses are generally represented in hexadecimal where each octet gets two hexadecimal characters. That's because 2 hexadecimal characters can represent 256 values, so 0-255 in decimal becomes 00-ff in hexadecimal. The IPv6 address is 64 bits, which translates to 8 octets, or 16 hexadecimal digits. It is commonly represented with a colon (:) between each hexadecimal value. So, for example, you would see something like fe2c:2356:5fcd:7540:1886:880e:7d3c:c6fb for an IPv6 address. You would also generally see the CIDR designation to indicate which part of it is for the network and which part is for the host.

While a lot of the networking capabilities may be handled automatically for certain resources with cloud providers, you may still have the ability and desire to manage your own networks. Generally, you will be using private addresses and letting your cloud provider handle any needed translation between the private address and a public address, if needed. Private addresses are specified in Request for Comments (RFC) 1918 and fall into the ranges 10.0.0.0/8, 172.16.0.0/12, and 192.168.0.0/16. In [Figure 2-4](#), you can see the creation of a virtual private cloud (VPC) in Amazon Web Services (AWS), which indicates the address blocks that will be used for all resources within that VPC. Out of the network allocations, you would create all of your subnets.

VPC settings

Resources to create [Info](#)
Create only the VPC resource or the VPC and other networking resources.

☒ VPC only

☐ VPC and more

Name tag - optional
Creates a tag with a key of 'Name' and a value that you specify.

MyNetwork

IPv4 CIDR block [Info](#)

☒ IPv4 CIDR manual input

☐ IPAM-allocated IPv4 CIDR block

IPv4 CIDR

172.30.42.0/24

CIDR block size must be between /16 and /28.

IPv6 CIDR block [Info](#)

☐ No IPv6 CIDR block

☐ IPAM-allocated IPv6 CIDR block

☒ Amazon-provided IPv6 CIDR block

☐ IPv6 CIDR owned by me

Network border group
A network border group is a unique group of Zones from where IPv4 and IPv6 IP addresses are advertised. All Availability Zones in this VPC will use this network border group.

us-east-1

Tenancy [Info](#)

Default

Figure 2-4. Provisioning networks in AWS

You may notice that the selection under IPv6 is to use Amazon-provided addresses. The default option is to not use IPv6 at all. While it is widely adopted, it is not necessarily common to use it within a network but is more likely to be used between larger networks. You can easily get by using an IPv4 address, but if you have any devices that would prefer to communicate using IPv6, you can specify your own address range or use an Amazon-provided range.

All networking configuration with cloud providers is going to be software-defined networking (SDN). Everything is based on configuration settings within the software because the control plane and the data plane are decoupled, allowing for configurations to be defined in the control plane by the user, while the underlying infrastructure that handles the movement of data is completely abstracted. All changes done to any hardware are taken care of automatically, though there may not be any traditional networking hardware used to pass data from one place to another within the SDN infrastructure.

Storage

Typically, you will want to store information so you can use it within applications, or even store it so other people can get access to it. This is a common use of cloud computing, actually, as we will discuss later in this chapter in [“Cloud Models” on page 39](#). You may be familiar with storing files and data on your local computer or on your mobile device. Storing in the cloud may be different, depending on the type of storage you are using.

Hardware

Somewhere is a storage medium, no matter what kind of device you have. A long time ago, disks were enormous platters that were stacked with heads in between the platters that moved in and out as they spun. The storage capacity was small by today’s standards. When you have a bare platter, you need a way to address data that you want to store on it. Keep in mind you have a circular surface, with two sides, and a number of those stacked on top of each other. When you have a disk constructed in this way, a way to address it is to create sectors based on creating concentric circles with lines from edge to edge. Where you have a space bound by two lines and two concentric circles, you have a sector. You can see an example of what this would look like in [Figure 2-5](#).

You can address the locations on the disk using a technique called cylinder-head-sector (CHS). You determine the side of each platter by specifying the head. The cylinder is which concentric circle and the sector is the space between two of the lines. This gives you the location on the disk you are going to read data from. This used to be a way to address disks until it became harder to address larger disks like this. Also, you can’t use CHS for disks that weren’t constructed in this way. As a result, logical block addressing (LBA) is currently used to address locations on disks. This type of addressing abstracts the locations on the hardware from the locations the operating system is responsible for knowing about. The firmware in the hardware is expected to do any translation from LBA to the location on the device.

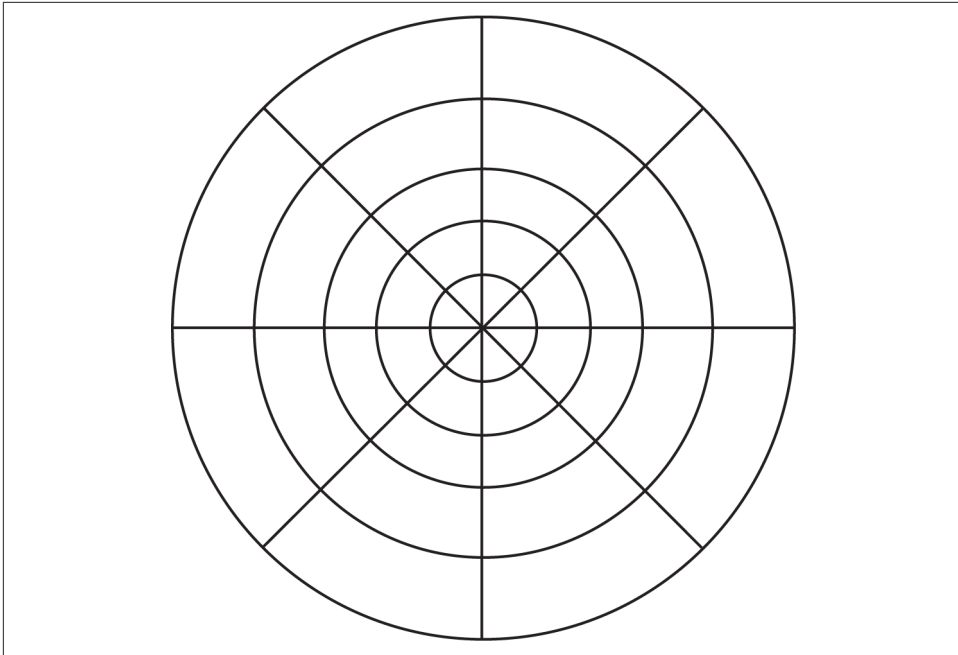


Figure 2-5. Cylinder head sectors

Disks are addressed in this way because it is more manageable. You don't want to address individual bits or bytes because that doesn't scale well. Instead, you get blocks. Currently, you will run across different types of disks. The first is the older style hard disk, where you have spinning platters and heads. The faster the platter spins, the more throughput you get from the disk. Higher platter speed means more data that you can read or write in a given period of time. You may see 5,400 revolutions per minute (RPM), for example. A disk that spins at 7,200 RPM will have better performance.

For many years now, though, we have had solid state drives (SSDs). SSDs use integrated circuits to store data, rather than relying on magnetic storage, as used with traditional hard disk drives. This is similar to primary memory used in your computer system, but where that is volatile memory, meaning what is stored is gone the moment power is removed, the SSDs use nonvolatile memory. Typically, this type of storage will use NAND (NOT AND) flash. NAND flash uses a series of transistors that are put together in a way that the action resembles the NOT-AND logic function. NOT AND is the inverse of an AND function. AND requires that both input values be 1, using Boolean logic, before the output is also 1. With a NOT AND, the result of 1 AND 1 is 0, while all the other combinations result in a 1.

The advantage of using SSDs is because they are entirely electronic and significantly faster. The only time you get a slowdown is when the data has to move from inside an

integrated circuit across wiring to another location. When you have something like a Serial AT Attachment (SATA) device, data gets transmitted across fast buses on the motherboard to a cable connection to a drive where the integrated circuits are packed together.

Today, the fastest long-term storage for PC-style systems is using a Non-Volatile Memory Express (NVMe) device. This generally uses the PCI Express (PCIe) bus, which is much faster than using a SATA interface because the PCIe bus was intended to connect cards with a speed as though they were directly on the motherboard. There are no cables involved. The PCIe device effectively plugs directly into the motherboard using the fast bus lines that are on the board. There is no passing through another interface, through a cable, then into a controller on a device.

Filesystems

Once you have a disk, you need to be able to get data to it in an organized way. This is not something you would normally be aware of, but files are organized by filesystems, which are data structures on the disk. Your disk is organized into blocks. There are the 512-byte blocks that are used to address the disk, but there are also contiguous blocks on the disk used to allocate to storage because it isn't efficient to allocate 512-byte blocks. These contiguous chunks of blocks are sometimes called clusters.

The filesystem has to keep track of the allocation of these clusters to files, as well as how the files are organized into directories. The filesystem also has to keep track of who owns the file or directory, as well as other permission settings. On a Linux filesystem, for example, each file (and everything on a Linux filesystem is considered a file, including directories and devices, for simplicity of interaction) has read, write, and execute as possible permissions. The owner, owning group, and then everyone else each has a set of read, write, and execute permissions. On Windows filesystems, there are even more permissions, and they can be assigned to a much broader set of users.

The filesystem is also responsible for keeping track of and allocating free space for files. In a filesystem as simple as the file allocation table (FAT) system, a table includes all of the free clusters on the disk; files will just fill in the table with information about the file to indicate the cluster was taken. An example of the table in a FAT32 filesystem can be seen in [Figure 2-6](#). This uses four bytes for each entry to support larger disks with a large number of clusters. Where a cluster is in use, there will be a value. Typically, the value in the table indicates the next location of the file. When no more entries are associated with the file, the last entry in the table will have a value between 0x0FFFFFF8 and 0x0FFFFFFF, depending on the application, operating system, or utility writing the entry. Locating all the data blocks associated with a file requires locating the first entry in the allocation table and following the chain until the final block.

Offset	+0	+1	+2	+3	+4	+5	+6	+7	+8	+9	+A	+B	+C	+D	+E	+F
+0000	F0	FF	FF	0F	FF	FF	FF	0F	FF	FF	FF	0F	04	00	00	00
+0010	05	00	00	00	06	00	00	00	07	00	00	00	08	00	00	00
+0020	FF	FF	FF	0F	0A	00	00	00	14	00	00	00	0C	00	00	00
+0030	0D	00	00	00	0E	00	00	00	0F	00	00	00	10	00	00	00
+0040	11	00	00	00	FF	FF	FF	0F	00	00	00	00	FF	FF	FF	0F
+0050	15	00	00	00	16	00	00	00	19	00	00	00	F7	FF	FF	0F
+0060	F7	FF	FF	0F	1A	00	00	00	FF	FF	FF	0F	00	00	00	00
+0070	00	00	00	00	F7	FF	FF	0F	00	00	00	00	00	00	00	00

Figure 2-6. File allocation table

Other filesystems will just include the cluster information in the metadata about the file. Where the FAT has directory entries providing information like the filename, a filesystem like the New Technology File System (NTFS), first used for Windows New Technology (NT), has a master file table (MFT). The MFT carries all the data about the files and directories, including metadata about the filesystem itself. In some cases, file data may be stored inside the MFT entry, if the file is small enough.

Filesystems allocate space in clusters of blocks. The default cluster size for NTFS is 4,096 bytes, which is eight 512-byte blocks on the disk. However, the cluster size in NTFS is configurable, and some systems may perform better with much larger allocations so the application and operating system don't have to keep requesting allocations of clusters. You may find allocations like 65,536 bytes (64K). You can end up with a lot of unused space on the drive in that case. If you had a file that was 5,112 bytes, for instance, you would need to have 2 clusters allocated. Only 16 bytes of the second cluster would be used, however. As more data is added to the file, additional allocations are not necessary until the file exceeds 8,192 bytes, at which point another cluster would be allocated. In the meantime, however, 3,080 bytes would be unused from the existing allocation. This is where you need to trade off between unused space and performance. Having to use fewer allocations is faster, and that is especially true if the allocations end up being scattered around the drive rather than being contiguous. However, if you have 65,536 bytes allocated to a cluster and you are only using, say, 100 bytes, there is a lot of unused space on the disk. If you have a large number of files that are only using small percentages of the allocated space, you end up with very inefficient use of storage space.

With really large, very fast disks, none of this tuning may make a lot of difference because there aren't performance penalties, especially if there is a lot of time waiting for user interaction or other events to happen, which will cost more from a time perspective than waiting a few microseconds for space to be allocated and data to be written.

Memory

Primary storage is considered to be random access memory (RAM). This is volatile storage that is generally installed on the motherboard with a very fast bus between the processor and the memory to allow interactions with data, instructions, and the processor to have as little lag as possible. Memory has addresses associated with it, and the address space is based on the width of the bus between the processor and the memory. Modern processors and systems use 64-bit bus widths, so memory addresses are 64 bits long. This is called a bit boundary, so when you see memory represented in a diagram, it will be broken up into 64-bit blocks. You can see a representation of memory in [Figure 2-7](#), with 64 bits for each memory location. Because of the size of the memory, addresses are typically represented in hexadecimal, which you can see on the lefthand side.

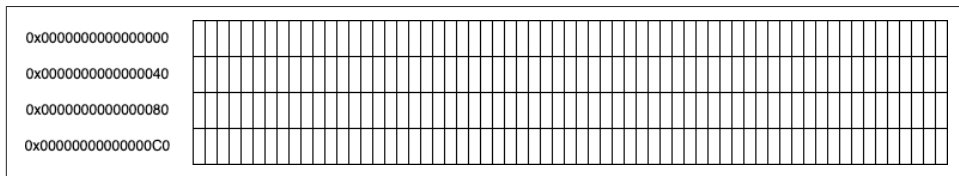


Figure 2-7. Memory allocation

The operating system is responsible for handling memory allocation. When an application is executed, the operating system will load the application and allocate the memory required to store it in memory. Any additional allocations while the process is running will be made to the operating system.

Virtualization

It's always fun to know a little history to maintain some perspective. Virtualization as an idea has been around since the late 1950s. In the early 1960s, computer manufacturers had figured out how to support the implementation of multiple operating systems running at the same time. The reason this is a big deal is because the operating system is in sole control of the hardware for the system. Having multiple applications running at the same time is a much easier problem, since it just means managing the primary memory and processor time. Virtualization is a very different problem, though.

There are a couple of problems with virtualization. The first has to do with memory, and it is true even if you aren't using virtualization. Anytime you have programs that are relocatable in memory, meaning they can be loaded, unloaded, and swapped out to disk before being put back into memory, there needs to be an abstraction in memory addresses. This is because the application won't be able to readdress itself every time it moves around in memory. It's easier to let the operating system take care of figuring out the real address based on the virtual address the application knows

about. In many cases, with compiled programs, the addresses are hardcoded into the executable, which is easier than trying to calculate offsets on the fly while the application is running.

There is hardware support, generally, for memory virtualization. The operating system has to be able to look up the real address from the virtual address anytime an application reaches out to memory locations, which is very common. Having to do a software lookup, meaning executing additional code that runs through the processor, would be very slow. Instead, there is something called a translation lookaside buffer (TLB) that does a direct lookup of the real address from the virtual address.

TLBs may be implemented as content-addressable memory (CAM). This is a specific type of memory, along the lines of a dictionary in Python or key, value pairs. You would use the virtual memory address as the key to look up the value of the real, physical address. Because there is no programmatic searching and everything is done in hardware, it's very fast. There is some additional overhead associated with populating the table and handling any misses where the address might not be in the TLB, but it's much less overhead than other solutions.

As it turns out, virtualizing memory is helpful for system virtualization because abstracting an entire piece of hardware relies, in part, on abstracting memory. Beyond that, though, the rest of hardware needs to be abstracted. Interrupts are used to message between the processor and other hardware, including disks and input/output devices. Support for operating systems running inside other operating systems requires a piece of software to catch the interrupts and either translate them into software actions or pass through directly to hardware.

The software used to catch these interrupts and manage the overall virtual solution is called a hypervisor. There are two different types of hypervisors. You can see a diagrammatic representation of the two types in [Figure 2-8](#). The first is a Type 1 hypervisor, also called a native or bare-metal hypervisor. The hypervisor runs directly on the hardware, called the bare metal. The first hypervisor, developed by IBM in the early 1960s, was a bare-metal hypervisor. You ran the hypervisor, then loaded the operating system that was going to interact with users or jobs over the top of the hypervisor. The same is still true today. You can get a hypervisor like Hyper-V or VMware's ESXi server, which runs directly on the hardware. You then load other operating systems like Windows 11, Linux, Windows Server, or NetBSD. Each of these behaves as though it is installed directly on native hardware, with its own memory, disk, display, network, and other devices you'd expect a hardware computer to have.

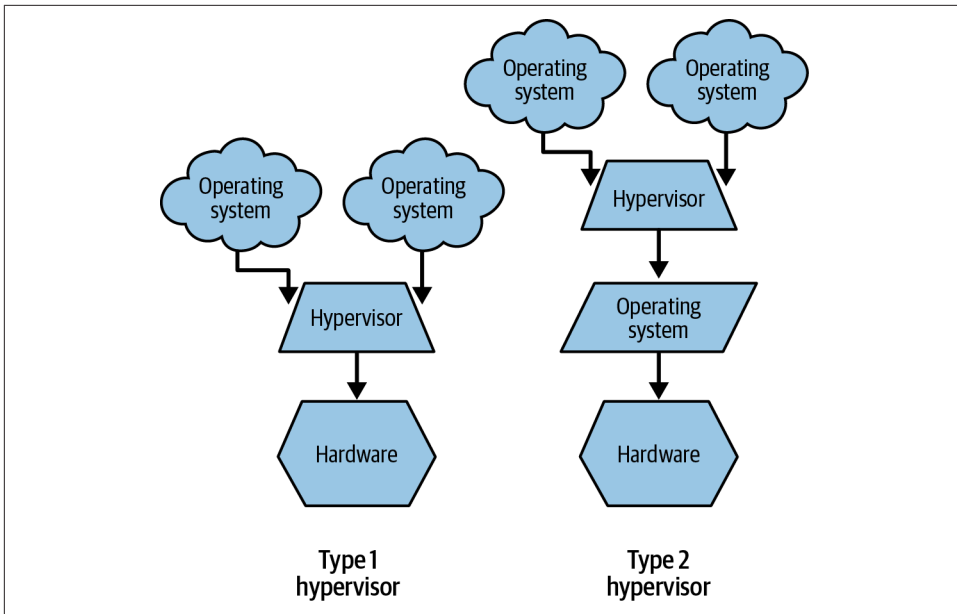


Figure 2-8. Types of hypervisors

Type 2 hypervisors are installed on top of an existing operating system: something like VMware Workstation, Parallels Desktop, or Oracle VirtualBox. The hypervisor still manages the guest operating system like a Type 1 hypervisor, but rather than interacting directly with the hardware, the Type 2 hypervisor has to interact with another operating system. Barring serious vulnerabilities in the software, a Type 1 hypervisor will do a better job of protecting the virtual machines from one another since there isn't an intermediate operating system between the hypervisor and the hardware to mediate requests.

In both cases, a monitor watches for hardware interrupts from the guest operating system. The interrupts are then translated into either software actions if the hypervisor is emulating the hardware, as may be the case with storage or network devices, or they may be passed directly to the hardware as needed. This may be the case if you pass through devices like USB storage to the guest operating system.

It is also possible to virtualize applications, which is what is happening in containers. With a virtual application, there is additional isolation that happens over and above the abstraction of the virtual address the application knows about from the real, physical address. As usual, there is no direct access to hardware, since all of that goes through calls to the operating system, but containers use additional memory protections. The memory of a virtualized application may be tagged with a namespace. There is software, usually in the form of the kernel or a kernel module, that ensures

any requests to memory locations do not fall outside of the namespace. This keeps the application effectively isolated from anything else that is executing on the system.

Automation

Automation is a significant part of cloud computing. It helps to enable not only the speed but also the scalability of the cloud solutions. Without automation, you rely on the work of people. This is prone to delays with a lot of typing and mouse-clicking required for a person to do provisioning and configuration tasks. Additionally, there is the potential for errors. Misconfigurations can happen due to oversights in process—errors in reading or moving information from one system to another.

In addition to automation, the use of virtualized systems makes copying one system to another significantly easier. It also ensures consistency. You can create a template with all the specific configurations, applications, and settings you need. You can ensure the system is hardened following a standard and documented approach, using something like the Center for Internet Security guidance, for instance, then always have the exact same setup each time you create a new instance based on that template. The same is true when it comes to application virtualization. The application, settings, and all prerequisites will be the same every time an instance of that application is initialized.

Beyond the use of templates, which would just be copying a base instance to a new location, you can also automate the creation of the build from scratch. There are several software packages you can use to build systems or install software as needed. This is commonly called Infrastructure as Code (IaC). Tools like Ansible, Puppet, and Chef use configuration files that are read and applied to endpoints under their control. The configuration files may contain information about applications to be installed or settings to be applied to the endpoint. A tool like Terraform does similar things but looks more like what you might expect application code to look like. Essentially, Terraform also is a set of configurations to be applied. These types of tools perform Declarative IaC, where you specify what you want, and the tool takes care of doing it. This is a functional style of IaC.

You can also use Imperative IaC where instead of specifying what, you specify how. This means statements are written to perform specific tasks in specific orders, much like a traditional programming language. You can use a language like PowerShell, for instance, along with APIs to perform installation and configuration tasks. While this approach gives you a lot more control over the outcome, which may be useful if order and timing are essential, it does take programming skill and knowledge of how to use the APIs to interact with the targets. Each major cloud provider has its own API for interacting with them. That means you would need to rewrite the code for each cloud provider. Using a declarative tool, you could use a single configuration file regardless of the target.

Of course, these are not the only IaC tools available. IaC has quickly become a common approach to not only building systems, but in some cases actually managing application installation and updates for enterprises. In some cases, like Puppet, for instance, you have an agent that runs on the endpoint and periodically checks in with a server for new states to apply. This is an excellent way to manage a large enterprise deployment, since you can ensure that new configuration settings and application updates are applied as long as the agent can get to the server.

Logging and Monitoring

This may not be an area that gets covered a lot when it comes to underlying essential technologies, but cloud providers cannot keep their operations running without extensive logging and monitoring. For a start, they need to understand when the resources are operational, as well as how much utilization there is. Without this level of monitoring, they would not be able to bill customers. Without billing, there is no revenue.

Each cloud provider typically offers its own logging and monitoring solution for customers to keep track of what is happening within their own resources. These solutions are the primary means to take a look at data collected from the resources in use. One problem with logs is consistent formatting for tools to parse the data from them. For many years, Unix systems have commonly used syslog to take care of formatting, transmitting, and storing log information. Linux followed suit, and on Linux distributions you will commonly see an implementation of syslog running. On Windows systems, the Windows Event Viewer and associated event logs are how log information is stored.

Syslog originated as a log management system for the Sendmail mail program. Syslog is actually a log format, a set of specifications related to how the logs are categorized and prioritized, as well as a protocol for transmission over the network. And, of course, it is the implementation of all of that in server applications. A syslog message contains a facility, which is the type of system the message came from. The list of documented facilities is shown in [Table 2-1](#), including the code for the facility, as well as the keyword that would be used in configuration files to indicate the disposition of the log message.

Table 2-1. Syslog facilities

Facility code	Keyword	Description
0	kern	Kernel messages
1	user	User-level messages
2	mail	Mail system
3	daemon	System daemons
4	auth	Security/authorization messages

Facility code	Keyword	Description
5	syslog	Messages from the syslog daemon
6	lpr	Line printer daemon
7	news	Network news subsystem
8	uucp	Unix-to-Unix copy subsystem
9	cron	Scheduling daemon subsystem
10	authpriv	Security/authentication messages
11	ftp	File Transfer Protocol daemon
12	ntp	Network Time Protocol subsystem
13	security	Log audit
14	console	Log alert
15	solaris-cron	Scheduling daemon
16–23	local0-local7	Locally used facilities

In addition to the facility, there is a severity. This is also used to determine how a log message is handled. You may not want to do anything with some severities, while others you may want sent somewhere to be looked at immediately. [Table 2-2](#) shows the different severities documented as part of the syslog standard.

Table 2-2. Severities

Value	Severity	Keyword	Condition
0	Emergency	emerg	A panic condition where the system is unusable
1	Alert	alert	A condition that should be addressed immediately
2	Critical	crit	Hard device errors
3	Error	error	Error conditions
4	Warning	warning	Warning conditions; the warn keyword is deprecated
5	Notice	notice	Conditions that are not error conditions but are significant
6	Informational	info	Normal messages; the system may be indicating it is working as expected
7	Debug	debug	Messages used for debugging that wouldn't be used in normal operation

While you can get syslog for Windows, Windows has its own event log format and storage, typically viewed using the Windows Event Viewer or sometimes queried using command-line utilities since the logs are not stored in ASCII format as syslog messages are. Since Windows Server 2003 R2, Microsoft has used the Common Log File System (CLFS) as a subsystem for both user as well as system logs. Each application that registers with the subsystem gets its own entry in the Event Viewer for organizational purposes. There is more metadata associated with Windows messages. This includes Event IDs, which can be used to identify specific messages so all the same events can be searched or extracted. Also included, as you can see in [Figure 2-9](#),

are the hostname of the entry; the level, which is the same as the severity for syslog; the user; and the source.

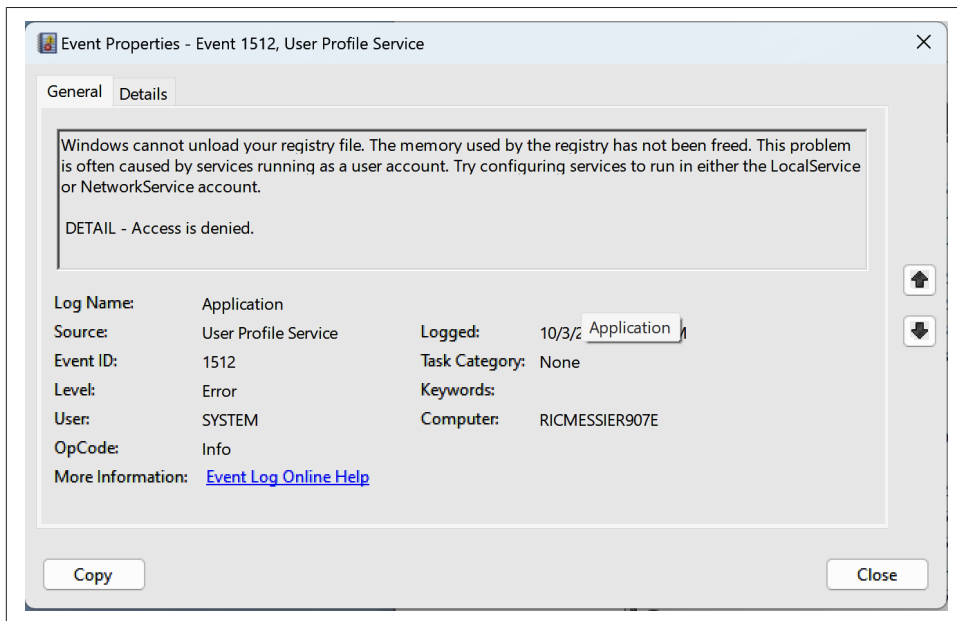


Figure 2-9. Windows Event Viewer entry

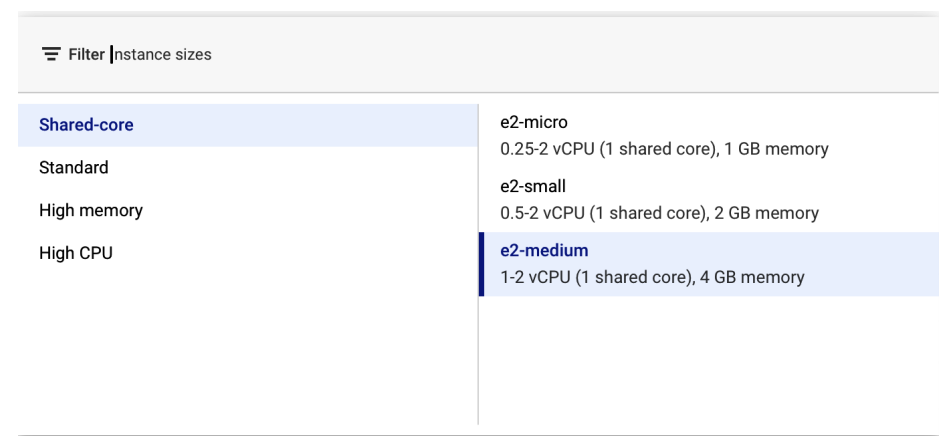
While the information is very detailed, you will need additional services to collect all the Windows logs to a central location for analysis and correlation. Where syslog software typically lets a configuration setting send log entries within defined parameters to another system, this is not a default part of the Windows Event Viewer. It's also useful to keep in mind that Windows systems generally generate a lot of log data, especially at the informational level, which means you want a tool that can also filter to send specific levels or types of log entries to a centralized log management system.

Cloud Models

We say cloud often as though it means one thing. In fact, there are different services you can get from cloud providers. Not all models or services are available from all cloud providers. Cloud models include infrastructure as a service (IaaS), platform as a service (PaaS), software as a service (SaaS), and storage as a service. While these are generally self-explanatory, we're going to dissect them a little more. There are descending levels of responsibility on the part of the consumer as we go through these services, so we will talk about the Shared Responsibility Model that is common across all cloud providers to make clear who is responsible for which tasks between the provider and the consumer.

Infrastructure as a Service

IaaS offers the most control to the consumer, but conversely, requires the most responsibility. Effectively, you are using someone else's infrastructure to create systems that you manage. You get virtual servers with storage, network, memory and an operating system. You get to specify how much capacity you want from the perspective of the system configuration. As cloud services are generally pay-as-you-go, which is part of their appeal, you pay more for higher performance, meaning more processing power and memory. **Figure 2-10** shows machine type selections available in Google Compute Engine (GCE), which is the IaaS component of the Google Cloud Platform (GCP). Rather than going through the process of selecting individual settings for memory and processor, machine types are pre-configured for different sizes and capabilities. This includes not only the processor type, but also processor speed and memory configuration.



The screenshot shows the Google Cloud Platform console's 'Filter instance sizes' interface. On the left, there is a sidebar with four filter categories: 'Shared-core', 'Standard', 'High memory', and 'High CPU'. The 'Shared-core' category is currently selected. To the right of this sidebar, a list of machine types is displayed. The list includes 'e2-micro' (0.25-2 vCPU, 1 GB memory), 'e2-small' (0.5-2 vCPU, 2 GB memory), and 'e2-medium' (1-2 vCPU, 4 GB memory). The 'e2-medium' option is highlighted with a blue background, indicating it is the selected machine type.

Filter	Instance sizes
Shared-core	e2-micro 0.25-2 vCPU (1 shared core), 1 GB memory
Standard	e2-small 0.5-2 vCPU (1 shared core), 2 GB memory
High memory	e2-medium 1-2 vCPU (1 shared core), 4 GB memory
High CPU	

Figure 2-10. IaaS configuration

What you get is a virtual machine that is like a hardware device with an operating system installed on it and at least one user to allow you to access it. You also get remote access to the system. This may be through a web interface, meaning you will get to the console of the operating system through your web browser. Aside from interacting with it through a browser, you will have the same interface as if you were sitting in front of the device. Depending on how you have configured your network and how you are getting to the cloud provider, you may be able to remotely access the system using other protocols like RDP and SSH. This would require exposing the protocol to other networks.

Speaking of which, you will need to manage all users, data, security, and updates. This is exactly like having your own system, so aside from not needing to take care of the hardware, you will have to do all the same things from an administrative perspective

that you'd do if you had the hardware. There are a few restrictions, just as there would be if you had the hardware in your own data center. You can't do anything illegal and probably shouldn't do anything unethical. The cloud provider does, after all, monitor its own network and infrastructure. However, when it comes to installing software on the virtual machines, that's up to you.

Since the virtual machine must be connected to a network, otherwise you won't have any access to the system, you need to pay attention to the network configuration, including all the security considerations, such as what ports and protocols you want to allow in to your system. By default, typically nothing is allowed in, so you have to add exclusions for anything you want. If you want to run a web server or database server, for instance, and have complete control over the software you use and its configuration, you will need to open the ports and protocols.

If you have a piece of software you would like to run that may not be offered by the cloud provider and managed by them, you should consider IaaS. You could also develop your own application on top of an unsupported platform. There are a lot of reasons why you may want to fully control your systems.

Platform as a Service

PaaS is the next step up the ladder of control. The purpose of PaaS is to provide platforms on which customers can build applications. Applications are built on top of application servers, which are frameworks that are language-specific and abstract all the network and protocol interactions so just the business logic is the responsibility of the development team. With PaaS, you select the application platform on which you want to develop on top of, and mostly let the cloud provider take care of everything else. **Figure 2-11** shows a list of different runtimes you can build on in Microsoft Azure. Azure supports .NET, Java, Python, PHP, and Node. In addition to selecting the runtime and language you want to build your application on, you can select the operating system you want to run.

Just because you can select the operating system, though, doesn't mean you will be responsible for maintaining it. That is up to the cloud provider. With some providers, you may not even be able to select the underlying operating system. When configuring a PaaS deployment on AWS, for instance, you may only get one option for the operating system, depending on the platform you are developing your application on. You will be responsible for all the security from the perspective of the application, though. This includes anything to do with the network to the extent it impacts your application, like making sure you have allowed the right ports to be open if you were doing something different from the standard ports. You also need to be responsible for all users, from provisioning to access control to continued management.

Instance Details

Name

CCSPApp

-fma2gvesayeqbuf5.canadacentral-01.azurewebsites.net

☒ Unique default hostname (preview) on. [More about this update](#)

Publish *

☒ Code
☐ Container
☐ Static Web App

Runtime stack *

Select a runtime stack

Operating System

Region *

Pricing plans

App Service plan pricing tier determines the [Learn more](#)

Linux Plan (Canada Central) * ⓘ

Pricing plan

.NET

.NET 9 (STS) (Preview)

.NET 8 (LTS)

.NET 6 (LTS)

ASP.NET V4.8

ASP.NET V3.5

Java

Java 21

Java 17

Java 11

Figure 2-11. Runtime selection in Azure

As you don't have responsibility for the operating system, you probably won't have any access to it. All interfaces with the environment will be done through the web interface. With AWS, for instance, you upload and deploy your code once you have configured the environment and it is up and running.

PaaS is about more than just providing a runtime environment on which to develop code. It provides all the underlying components and middleware, meaning the intermediate components required to hold the entire application together, necessary for a complete application to be developed. As a result, you will get a limited set of configuration options since deployment of the underlying systems, storage, and networking components are the responsibility of the provider. You are responsible for all identity management and access control, as well as managing development and deployment of the code that runs the application. The complete stack includes any database that your application uses, so database services are considered part of a PaaS.

While the service provider is responsible for most of the networking configuration and implementation, you still have some responsibility for configuration to ensure all aspects of your application are accessible. If there are any additional controls, like restricting access to specific networks, which may be the case if you want to ensure

only your on-premises networks can access the application for your staff, you would need to have network configurations to support those restrictions. The provider will provide some basic configuration, but anything beyond that is your responsibility.

Software as a Service

SaaS is perhaps the easiest model to understand and is also the most far-ranging. It is likely that even if you have never touched IaaS or PaaS, you have used a SaaS solution somewhere along the way. If you have used either Microsoft Office or Google Docs/Sheets/etc. online, you have used a SaaS solution. SaaS is taking an application that you may normally run natively on your local computer and running it on infrastructure at a cloud provider using a web interface.

There are many advantages to both deploying and using SaaS solutions. From the perspective of the application developers, as well as the users, a SaaS solution means the provider has complete control over the version being used. Companies and developers no longer need to support and maintain multiple versions of an application. Instead, they are in complete control of the code being used without needing to rely on end users getting updates to reduce the exposure to vulnerabilities. In the same way, users are protected from vulnerabilities because they will always be running the latest version of the software without exposure to known vulnerabilities. On top of that, any vulnerabilities are somewhat abstracted from the user because most of the code is running on systems that are not sitting on the users' desks and laps. There is still some exposure from what happens in the browser, but some of the exposure is taken up by much of the code running on systems at the cloud provider.

Users also need far less power if they are using software that runs on other systems. All they need is a system capable of running a modern browser that supports the latest standards for HTTP, HTML, JavaScript, and other essential technologies to deliver high-quality, interactive web pages. Having a single interface for most, if not all, applications being used by users makes life significantly easier for them.

There are probably as many applications now being delivered through SaaS as there were through native applications running locally on systems. In some cases, there may be even more as SaaS has lowered the bar of entry for a lot of developers with easier distribution. With the introduction of machine learning capabilities as services from cloud providers, you end up with SaaS solutions like Napkin.ai, as seen in [Figure 2-12](#). Napkin.ai is a SaaS solution that will generate visuals from text. It is a service that uses machine learning and generative artificial intelligence to make the creation of presentations and graphics significantly easier. What you see in [Figure 2-12](#) are text and graphics generated from a simple prompt regarding the reading habits of technical staff.

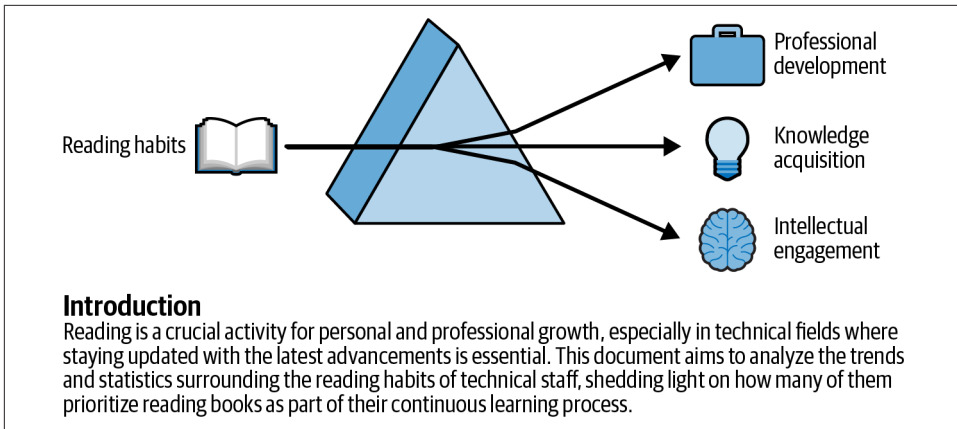


Figure 2-12. Text and graphics generated by Napkin.ai

Another significant advantage of SaaS solutions is that generally the data is stored with the provider. This makes life easier for users because it doesn't matter where they are or what device they are working on. They will be able to get access to their files and data. This is a downside for the provider, though. With so much data being stored with them, they become targets for attackers who want the data. With so much data being aggregated because their customers likely come from a significant number of businesses, targeting the provider means a trove of data that may allow them to launch other attacks on the businesses themselves. Or they might just make use of the data against the provider. The more data you are storing about people, the more of a target you are going to be.

In some cases, SaaS solutions are free to use, particularly if your information may be used for other purposes, as may be the case for using the Google productivity software, for instance, where Google may use information from documents you create to build out a more robust profile of you and what you may be looking for. Many SaaS solutions are subscription-based, which is different from the pay-as-you-go model used by IaaS and PaaS. You may find there are multiple tiers of offerings.

Storage as a Service

Underpinning a lot of SaaS solutions is storage, but that's different from just offering storage in the cloud. The same is true for storage in the cloud for SaaS solutions, however, in that you will be able to get access to your information from multiple devices. No matter where you are located or what sort of device you are on, you should be able to get access to your files. Storage as a service may be offered for free for a limited amount of storage. Additional storage space costs more money, and you may get significantly more storage space if you are subscribing to another service, such as Office 365, Microsoft 365, or Google Workspace.

While the common interface will be through a web browser, as with other cloud-based services, and as you can see in [Figure 2-13](#), you are often not limited to accessing data from the cloud. This would be limiting. After all, some people still use native applications for office productivity, for instance. The advantage to storage in the cloud is being able to work on these documents from multiple locations without having to move the file from one place to another using portable storage or email. Instead, you store the document in the cloud and grab it when you need it.

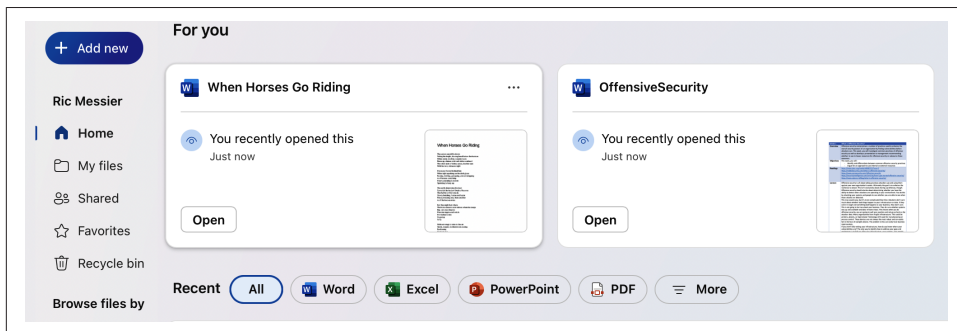


Figure 2-13. OneDrive home

Of course, having to download and re-upload would be onerous. Most of the storage in the cloud providers has an agent that allows you to synchronize files locally. This agent runs on your local computer and keeps track of changes that are performed locally so it can upload the changed files to the cloud storage. To save local storage space, which may not be as large as the space you have with the cloud provider, only files you want to use locally are download to the local disk. If you do happen to have a file on your local disk that has been changed elsewhere and uploaded to your cloud provider, the agent will download the changed file. Any other files that are changed in the cloud won't be downloaded until you need them locally. [Figure 2-14](#) shows the status of an agent that has been synchronizing files to my MacBook.

In cases where you are using something like Word and using OneDrive for storage, Word will be aware of where you are storing and will automatically upload changes as they happen. This behavior is just like making the changes using Word in a web browser. This is unlike other storage in the cloud options since there is a native application. Google Docs was designed to always run in a web browser, by way of comparison, so there is never a case of opening a file locally in Google Docs. This is not to say that Google and Microsoft have the only cloud storage services. If you have an iPhone, you may be familiar with iCloud, which is Apple's cloud storage service.

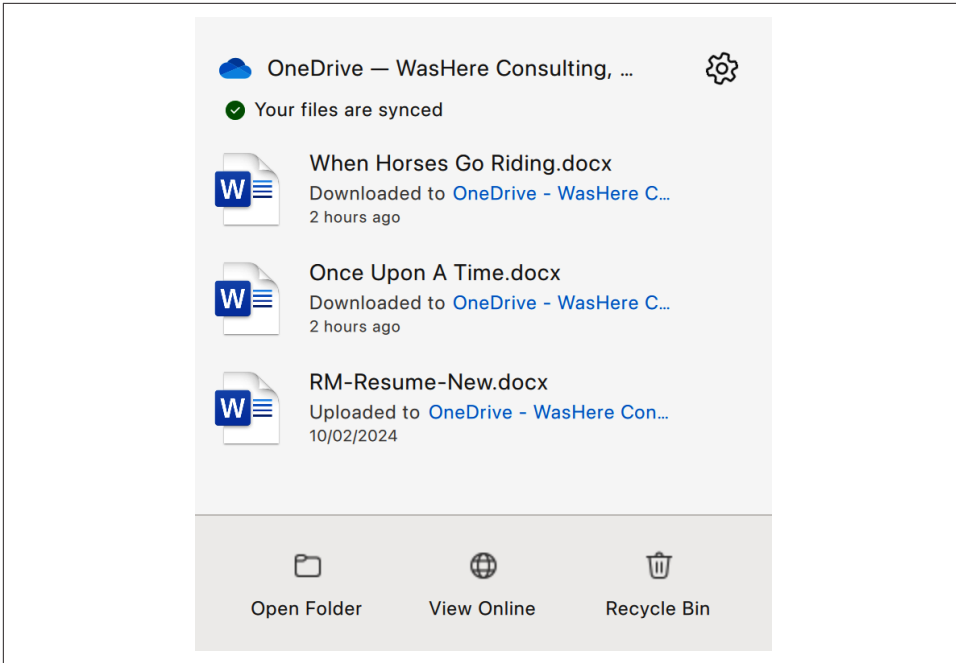


Figure 2-14. OneDrive Agent

There are several other storage providers, like Box and DropBox, that either only provide or primarily provide cloud storage. They also have web interfaces and offer agents for your local devices. In those cases, you will need external applications to manipulate files.

Storage as a service puts all the onus of managing the platform on the provider. The user is responsible for managing their data. While this generally means they need to maintain files and changes within their storage, you may get version control from your storage provider, as in the case of OneDrive where you can see the history of a Word document stored there, as shown in [Figure 2-15](#).

Another advantage of using cloud storage, in addition to being able to get access to the files yourself from any device you want, is to be able to easily share them with other people. On top of that, the cloud storage provider is responsible for identity and access management, meaning that only the person you share the file with will have direct access from your own storage location, assuming their account has not been compromised. You can also control the level of access they have, which may be limited to only reading the file, or you can offer them complete collaborative access so they can edit. You will be able to see all the changes that are made in the file, which provides great accounting to know who did what when something changes.

Version history

✕

Version	Modified	Size	Modified By
5.0	7/29/2024 8:27 PM	14.6 KB	 Ric Messier
4.0	7/29/2024 8:24 PM	14.5 KB	 Ric Messier
3.0	7/29/2024 6:34 PM	14.4 KB	 Ric Messier
2.0	7/29/2024 6:28 PM	14.3 KB	 Ric Messier
1.0	7/29/2024 6:22 PM	13.3 KB	 Ric Messier

Figure 2-15. OneDrive version history

Shared Responsibility Model

Along the way, you probably noticed that for each cloud model, there were notes about responsibilities for the provider as well as the user or business consuming the services. For each service, the responsibilities are different. This is the Shared Responsibility Model, which is recognized by cloud providers if for no other reason than it makes sense. When a customer gets a virtual machine, they would expect complete control over it, just as if they had spun a system up within their own data center. The provider would need to provide complete control to the customer because there is no way of knowing why the customer needs the system or what the requirements are. Simply deploying updates without the customer's involvement may end up breaking something, so the user should be the one to ensure updates are tested against their needs.

Similarly, the reason for getting a platform with just the language runtime and database alone with all the middleware may be because the focus is on the application and not the system administration. That shifts the burden of responsibility, outsourcing system care and maintenance to the provider, just as a development shop would outsource system care and maintenance to the information technology team.

While each provider you use may show you a different table to demonstrate the Shared Responsibility Model, the table in [Figure 2-16](#) makes it very clear who is responsible for what, depending on the different cloud model being used. You can see from this table that there are some aspects that will always be the responsibility of the customer. Anything that is specific to data and access will always be for the customer/user to manage. Similarly, anything with respect to the physical elements of the

service, from the data center to physical hosts and networks that all the virtual systems use, will always be the responsibility of the provider.

It is worth keeping in mind that there are some aspects of maintaining systems that are not covered in the Shared Responsibility Model. What is covered in the model relates to management of the service, but there are other tasks that teams will generally undertake as they are using infrastructure. This includes performing security testing, which may be specifically required in the case of application development. Even when the development team uses systems specifically for development or staging, they are still very likely in the cloud environment. This means testing has to be done against systems that are under the care of the cloud provider. This requires coordination with the cloud provider since it is their systems and networks that will be under test, as that is where the developed application is running.

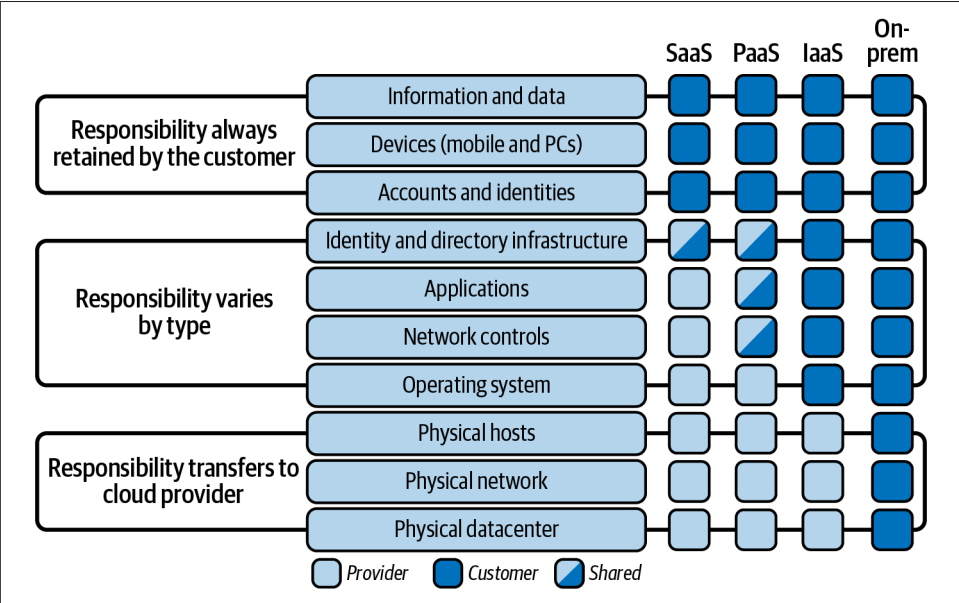


Figure 2-16. Shared Responsibility Model

As you select your service, it is always worth understanding where the lines of demarcation are between responsibilities. In some cases, as you can see in [Figure 2-16](#), the responsibility is literally shared because the lines of demarcation are not completely clear. In the case of SaaS and PaaS, for instance, the provider is generally responsible for maintaining the identity infrastructure, but the customer is responsible for maintaining the users, including determining levels of access. Similarly, with PaaS, there are aspects of the applications, like the database server for instance, that may need specific configurations to support the needs of the software being developed. While the provider is responsible for maintaining the overall application, including updates,

the customer is responsible for making configuration changes as needed and as available to support their development needs. Of course, networking is going to be shared because the provider maintains the physical networks as well as the software-defined networks, but the customer is responsible for configurations to support their needs.

Location, Location, Location

As the saying goes, it's all about location. While one way to look at this is the wide geographic distribution that public cloud providers generally have, which can be both beneficial as well as a burden. From the standpoint of the customer, the broad geographic spread of data center locations means they can put services close to their end users or clients, which may be much more difficult and certainly expensive if they needed to do it themselves. Using cloud providers offers far more geographic reach to customers than they would otherwise have access to. [Figure 2-17](#) shows a list from Microsoft Azure of where you can place resources. This is a very small subset of the regions offered from Microsoft. The complete list is far longer than can be easily shown here.

While this is great for customers, it also opens the door for legal challenges because data may be stored in a jurisdiction that has a different set of privacy and compliance requirements than where the customer is located. It may also be different from where end users and consumers are. Because of this, it may be worth talking to your legal team to identify what may be needed if the service is located in, for example, another country. Each region may have different pricing structures, which may be a factor in deciding whether to use that region. Availability may be different too. A lot of factors go into selecting the geographic location for services.

While this is a significant aspect of using cloud providers, the geographic location is not really what this is about. There are actually three types of cloud deployment, over and above the services that are offered. The first is primarily what we have been talking about so far: the public cloud. Providers like Google, Amazon, and Microsoft are all public cloud providers. Anyone with network access can make use of their services, which are generally available to anyone who is connected to the internet. Customers can choose to expose systems and services to anyone else connected to the internet.

In addition to the public cloud, there are private clouds. Network access and web-based protocols are commonly used to define clouds, but that doesn't mean that clouds can't be implemented within corporate infrastructure, limiting access to employees using that infrastructure. The important part of cloud services from that perspective is self-service and rapid deployment. While you may not be able to compete with all that the public clouds offer, considering the number of years they have put into refining their products and adding capabilities, you should be able to get

something to provide at least some minimal functionality for quick and easy virtual deployments for your staff.

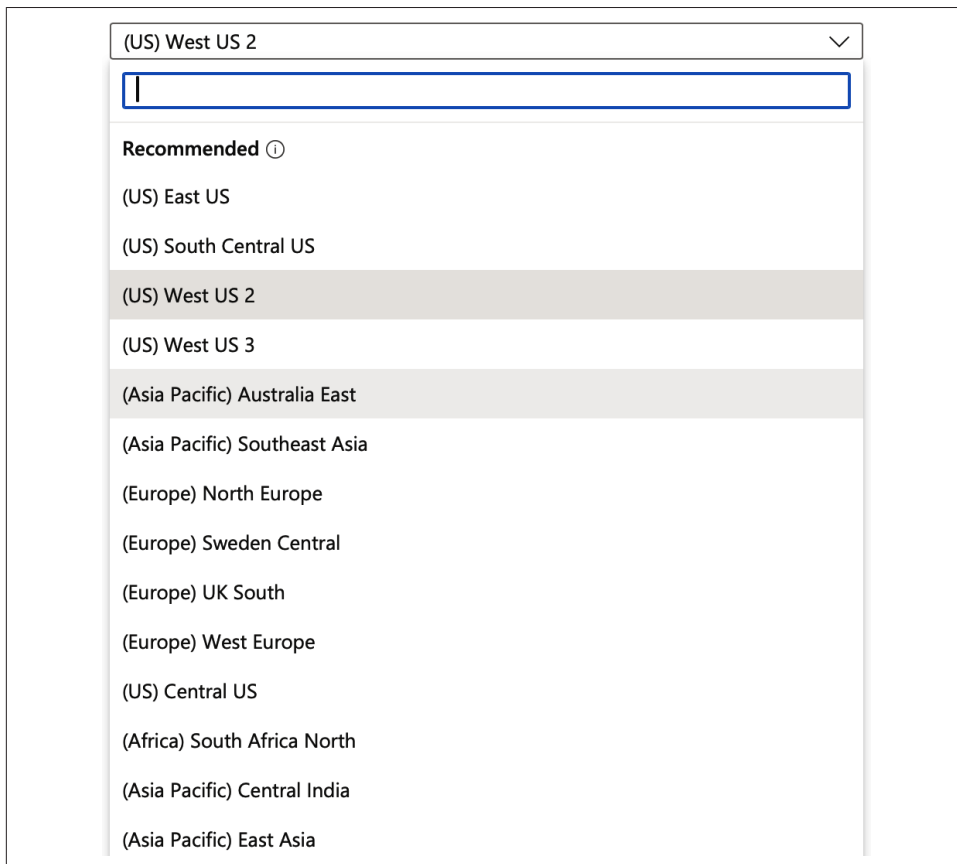


Figure 2-17. Geographic regions for Azure

There are different options when it comes to private clouds. You won't be able to just install the same software that GCP, AWS, or Azure uses, even if some of what they are using is open source. Their implementations are heavily customized. AWS and GCP may use KVM, a Linux-based hypervisor, for instance, but it is heavily modified and hardened, rather than being a stock build. When it comes to private clouds, you have options to support scale. You can do a single system deployment, which may be adequate if you don't have a lot of staff or needs and your system is stocked with disk, memory, and processor. You can also have multiple nodes, which your cloud software should be able to manage for you.

One approach is to use Apache CloudStack. This is open source software that is free to download and use. It runs on top of Linux systems and it can handle management of storage, networking, and images. These are some critical functions. You will need to have images available for rapid deployment, otherwise you are just hosting infrastructure to create virtual machines. One problem with CloudStack is the documentation does not hint at any automated installations. Instead, everything is done manually, and building out cloud infrastructure is complex because of the need for so much virtualization. You will need a hypervisor. You will need virtual networking, meaning you will need bridging software to support virtual interfaces that make use of your hardware interfaces. You will also need to have a server capable of managing your images and allocating processor and storage. Doing each of these manually is time-consuming.

Instead, a common approach for people who want to manage their own cloud infrastructure is OpenStack. This is a common piece of software and you are not limited to implementing it yourself on-premises. You could go to a hosting provider that offers OpenStack and let them create the infrastructure for you that you would then manage for your users, without necessarily letting anyone else in. OpenStack has multiple components that can be implemented on different systems, depending on the scale of your deployment. You'll get all the standard foundational cloud services you would expect to get. This includes the ability to host virtual machines and deploy application virtualization through containers.

OpenStack supports multiple operating systems. Deployment on them will vary in terms of difficulty of installation and configuration. Ubuntu is a Linux distribution that has an automated installation process using Snap, which is a packaging and deployment system for Linux. Once everything is installed, management of OpenStack can be performed using the web interface or through the command line on the host where it was installed. There is also a remote client that can be installed through the `pip` command available with Python. Once you have added the configuration for the remote system, this will allow you to manage OpenStack from systems other than the host where it was installed. It does require access to the URL for the management web interface.

The web interface, part of which can be seen in [Figure 2-18](#), is much simpler than interfaces from a public cloud and is straightforward. You can look at the networks and create any network segments you need, then add or configure storage, images, or create instances from those images. You'll also see key pairs, where you create cryptographic keys for authentication and encryption.

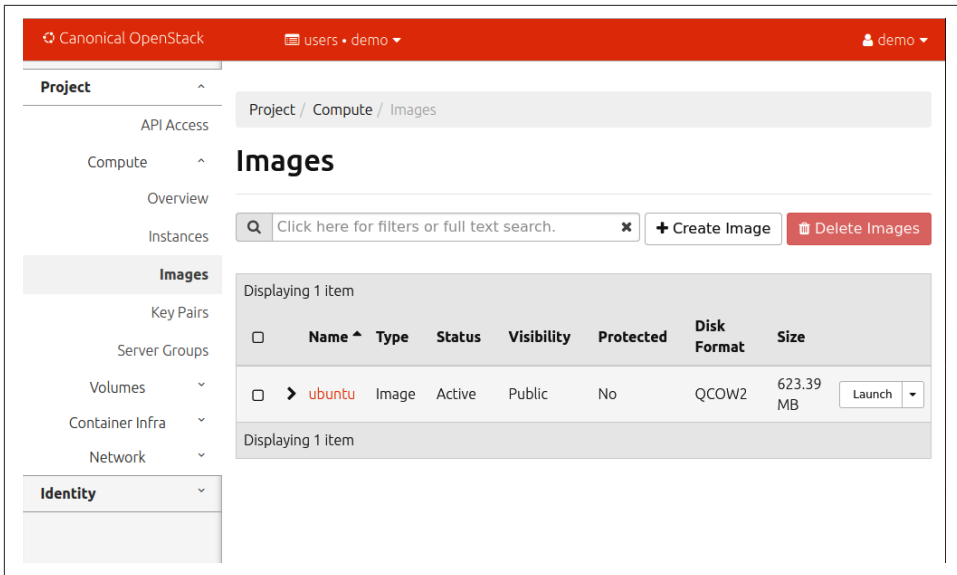


Figure 2-18. OpenStack interface

Private clouds don't have to be limited to individual organizations. You can also club together, if you will, as a community with several organizations that have shared goals. This may be a way to get the benefits of a private cloud while sharing the overhead and costs associated with hosting a private cloud.

Many organizations may use a combination of approaches. They may use multiple cloud vendors, for example. This reduces their exposure should one cloud have significant outages. Additionally, while the offerings will be the same at a high level, meaning cloud providers may have IaaS and PaaS offerings, there will be differences between the individual products and approaches across the different vendors. This means the organizations have adopted a hybrid approach by not following a single vendor and the way they operate.

More commonly, though, a hybrid cloud implementation is where an organization uses a mix of public and private clouds. These different instances may be connected using direct interconnects or through a virtual private network (VPN), which would provide the same functionality as if a direct connection. This would mean the organization would have to manage resources and applications across multiple locations, using different approaches. This also highlights the importance of automation. If you have automated deployment, taking into consideration the targets for deployments, you don't have to be concerned about individuals keeping track of where they are doing their work.

Roles and Responsibilities

Many groups are involved with cloud computing. Each has different sets of responsibilities and levels of interaction. You may have picked up on a lot of these, but let's talk specifically about the different roles and what they are responsible for:

Cloud provider

The cloud provider is responsible for maintaining all the facilities and hardware. This includes power and cooling, as well as all the computer systems, racks, cabling, and physical aspects of a data center. The provider is also responsible for security, which includes separation of the different customers and their implementations. Also, the provider is responsible for physical security, ensuring only approved staff and vendors get access to the location for the infrastructure to keep it protected. The provider is responsible for resilience and reliability, keeping systems, utilities, locations, and access running within the bounds defined in contracts with their customers. A provider may also be responsible for providing support to customers, and ensuring they comply with any regulations related to offering computing services to customers.

Customer

The cloud customer is ultimately responsible for protecting their resources, specifically all of their data and the data they are storing on behalf of their customers. They are also responsible for protecting any intellectual property. Also with regard to data protection, they are responsible for all compliance with privacy concerns, including health information privacy, payment card privacy, and the privacy of personal information to the extent that any of these are regulated. While it may be tempting to believe the cloud provider is going to always protect their information, the customer is responsible for ensuring all their data and resources are backed up in case something catastrophic happens. They are also responsible for applications, including resilience and reliability. While the cloud provider is responsible for its own resilience and reliability, this is within its infrastructure and doesn't necessarily protect the customers' application.

Cloud partner

Customers may look to a cloud partner to help with application development and management, as well as any migrations of resources from on premises to cloud or from one cloud provider to another. The cloud partner is responsible for application development, customer service, integration, and professional services, and ultimately, they are responsible for helping the customer protect data and resources. If a customer is using a cloud partner, they would expect the partner to help them protect critical resources.

Cloud service broker

A cloud service broker may be used to help companies determine their approach to using cloud services, including identifying requirements, selecting cloud providers, negotiating contracts, and perhaps aggregating the cloud resources to be consumed by the customer. The cloud service broker is responsible for procurement, including vendor selection and contract negotiation.

Regulatory bodies

Regulatory bodies would be responsible for working with the cloud providers and cloud customers to ensure the required laws and regulations were being followed. They should perform regular audits of implementations to ensure compliance with laws and other guidance specific to the industry the customer belongs to.

As you can see, using cloud providers may involve more external organizations and people than you would use in an on-premises deployment, but ultimately, the same functions would have to be in place, no matter where your computing resources were located. Knowing who is responsible for what, though, will help smooth out adoption and operations.

Challenges and Benefits of Cloud Adoption

There are many benefits to adopting cloud computing as a way of delivering information technology resources. You've probably seen several of these as you have been reading. The following are some of the primary benefits of going with a cloud provider:

Scalability

With the ease and speed of deployment, it is simple to keep up with the needs of infrastructure, especially if you are selecting products that will keep up with demand, based on utilization.

Cost-effective

Because you are often paying for what you use and paying as you go, it is cost-effective to go with a cloud provider. Certainly, you are not making large, up-front investments in facilities and hardware. The cost of entry is much lower with cloud providers.

Speed and agility

Because everything is prepared up front and so much is automated, you get speed of deployment and the ability to quickly adapt to changing circumstances.

Reliability

It is up to the cloud provider to ensure facilities remain up and available, which takes a significant burden off businesses that may struggle to get the same level of availability as a cloud provider.

Availability

Cloud providers will keep their facilities and services operational so they are available. You generally have the ability to deploy services in many geographic regions around the world, potentially letting you have services closer to where you have customers, regardless of where you are located.

Technical innovation

Because cloud providers are focused on improving services and generating operational efficiencies since it's their business, you can take advantage of technical innovations they are generating, making service development and delivery easier.

Core business focus

You are able to stay focused on your core business rather than spending a lot of time, energy, and resources on building and maintaining information technology infrastructure. The business can put its money into enhancing products rather than information technology.

Security

Because you have put your resources in the hands of someone you are paying to protect them, you are likely getting better security and protection. There are many other reasons you can improve your overall security posture, depending on application development and deployment. At a minimum, all the automation will reduce the number of mistakes and misconfigurations that can lead to vulnerabilities.

This is not to say that it is all strawberries and cream (or chocolate and cinnamon graham crackers) when you migrate to a cloud provider. There are many challenges you need to be aware of ahead of time. Being aware of the challenges lets you plan for them, so you can mitigate potential issues. The following are some of the challenges associated with migrating your information resources to the cloud:

Migration

Migrating your data and resources to the cloud takes a lot of planning and care. If you have a large amount of data, you will need to plan well ahead to ensure you have time to get all of your information to the cloud provider and then keep it up-to-date, since it is likely changing as you are copying it. You may also need to rethink how your infrastructure is architected to be certain you are taking advantage of the cloud provider and not just moving what you have to a new location.

Security considerations

You are migrating data and information assets to a public environment, so you need to ensure you have appropriate controls in place to not only protect the information, but also quickly detect potential unauthorized or unexpected access.

Vendor lock-in

While it can be enticing to think about using a single vendor for all your needs, staying with a single vendor may lock you in, making it more difficult to move to another provider in case of pricing changes or other changes that are disadvantageous to you.

Complexity

While the foundational concepts will be the same, in terms of hardening, networks, firewalls, and other common technology, the implementation will be different. It can be enticing to try to take advantage of a lot of cloud capabilities without fully considering the impact. Basically, trying to run before you can walk. This may introduce a lot of unnecessary complexity, which will be detrimental to both performance and security.

Cost management

With quick and easy infrastructure deployments and rapid application development, you must make sure you keep control over who gets to create resources with the cloud. Otherwise, it will be very easy to rack up a lot of additional, unexpected costs. Maintaining control over all costs in the cloud will be an important discipline, especially since you are billed for usage, which is harder to budget for.

Compliance

Your compliance program may have to change to adapt to a cloud model.

Every business should be aware of the benefits as well as the challenges associated with migrating to cloud environments.

Summary

Adoption of cloud providers offers a lot of possibilities for businesses. There are both benefits and challenges with migration. Businesses should be aware that cloud is a collection of attributes, including multitenancy, ease of access, commonly using web-based technologies, measured service, rapid elasticity, and resource pooling. Your cloud does not have to be “in the cloud,” meaning over the public internet. Instead, you can have a private cloud that implements all the common properties of cloud computing. If you are using both the public and private cloud, you have a hybrid model.

There are also different models for cloud computing. One is where you are hiring virtual hardware, called infrastructure as a service. You may also be using a collection of

resources that give you the ability to quickly build, deploy, and manage an application of your own without having to worry about the underlying hardware or operating system. This is called platform as a service. You may also use software as a service, where you are probably not getting what you are buying from a cloud provider directly, but instead, from a software vendor that is likely using a public cloud provider too. You may be very familiar with this, since so much software is delivered through a web interface, rather than through a native application that runs on your local computer. Finally, there is storage as a service, where you are using disk space at a provider, which is accessible from multiple locations.

Underneath cloud services are a lot of capabilities that you are probably already used to, including storage, virtualization, automation, and logging. You are still using standard computing resources, just interacting with them in different ways than sitting in front of them making use of a traditional desktop interface.

Other Resources

The following pages provide additional information about cloud computing and what it means:

- Peter Mell and Tim Grance, “The NIST Definition of Cloud Computing,” NIST Special Publication 800-145, National Institute of Standards and Technology, September 2011 (<https://oreil.ly/4vXeg>).
- “Types of Cloud Computing,” Amazon Web Services (<https://oreil.ly/8apsV>).
- “What Is the Cloud?” Microsoft (https://oreil.ly/dq_3e).

Cloud Architecture and Design Principles

Topics covered in this chapter include:

- Security concepts (such as cryptography, threat versus risk, identity and access management)
- Design principles and patterns
- Business continuity/disaster recovery

Building infrastructure and supporting applications in the cloud, as with on premises, relies on several foundational concepts. No matter where the resource is, protecting it on behalf of the business and its customers is the priority of security professionals. While there are several technical concepts that need to be factored in, many solutions are designed and architected to be business focused. Security is not only about protecting confidentiality, after all. Availability is a significant consideration, and while higher availability is easier using a cloud provider with all the resources and geographic zones it offers, you will ultimately need to keep in mind that the burden of protecting your data belongs to you, not the cloud provider.

Before designing any solution, it's important to understand the threats that could impact what you are doing. This way, you can ensure you have appropriate controls in place to protect against the manifestation of those threats. As with so much else with cloud computing, high-level threats are going to be very similar to threats to on-premises organizations.



This does not mean that on premise is the same as cloud. Although the concepts will be the same, the specific controls you implement with your cloud provider will be different from those you are using on premises.

When building business solutions, you will need to think about both business continuity and disaster recovery: how you handle disasters and how you recover from them. Along the way, you will also need to perform a business impact analysis. This chapter will cover all those aspects, since people who are responsible for technical implementations may be less familiar with the business aspects of design and architecture.

Of course, designing solutions also involves other factors, such as evaluating your cloud provider. We have discussed cloud providers as though they are all broadly the same, but you may find some essential features are different, especially for different regulatory or legal requirements. In addition to selecting your cloud provider, you'll need to be concerned about deployment. Often, companies will put development pipelines on cloud infrastructure, and this is especially true with so many technology companies moving to at least a hybrid, if not fully remote, working environment.

All of these factors will be covered in this chapter, as we continue to work through the first domain of the CCSP exam.

Security Concepts

Information security is all about protecting essential resources. In a business context, it's important to keep in mind that the goal is to focus on protecting the resources the business considers to be critical. Typically, the three primary security properties to be concerned with are confidentiality, integrity, and availability, also known as the triad, or CIA, completely separate and distinct from the three-letter agency.

You may have noticed this is a very broad remit. Security is not all about repelling attackers and doing the protection thing. There are a lot of factors that can go into those three properties, especially when you fold in the idea that a lot of security issues have nothing at all to do with malicious behavior. Our job as security professionals is to help ensure that essential resources are always available, so we need to work with other team members to design processes, solutions, and systems that will help keep data confidential, resources available, and everything operating with high integrity. This means unexpected changes should never happen, nor should any sort of corruption.

As we go through the threats that may impact a cloud implementation, and all the technical considerations for solutions, keep in mind where the triad plays in. You may find multiple properties are factored in for the different concepts covered in this section.

Threats

First, it's important to talk about what a threat is. According to the NIST, a threat is any circumstance or event that has the potential to adversely affect an organization or its resources. This is a broad definition and you may note that NIST doesn't specifically talk about information resources. There are also existential threats, meaning events or circumstances that could put a company out of business—extinction level events, if you will.

It also becomes a little more complicated because sometimes you will hear or read about threats when the reference may be to either threat vectors or threat actors. The threat is the event or circumstance that could be harmful. The threat vector is the avenue by which the threat manifests. By way of example, let's consider a human virus. With a virus such as the flu or COVID, the threat is the virus itself, and the adverse or harmful situation is the effect the virus will have on the human body. The threat vector is the pathway through which the threat manifests and causes the harmful circumstances. In our case of a flu virus, the threat vector is the droplets of moisture that pass from one person to another through respiration. The threat actor is the individual or group responsible for doing something that causes the threat to manifest, which could be your friends or loved ones.

You can see just from this example that threats do not have to be malicious in nature. People are not breathing and sneezing on you with the intent or hope you fall ill. It's simply a byproduct of existing. When it comes to cloud implementation, there are threats to be concerned with. They may vary from year to year and organization to organization, based on the type of business and business objectives, and you will also find different lists of threats from different security or cloud-oriented sources. However, here is a list of some common threats related to deployments of cloud computing:

Misconfiguration and human error

This significant threat is easy to overlook, which is one reason I listed it first. As mentioned earlier, threats may be sometimes thought of as malicious in nature. However, with misconfiguration and human error, this is not the case. There have been major outages over the years that resulted from mistakes, including the CrowdStrike issue that took down Windows systems around the world. Without testing, automation, and oversight, it is easy to introduce misconfigurations and other errors into production environments. This may result from typos, misunderstanding of requirements, lack of understanding of good practices, or just simple oversight from lack of attention to the task at hand. Misconfigurations and other similar errors can result in a loss of confidentiality, integrity, and availability.

Identity and access management failures

There are many threats to infrastructure and data that result from bad identity and access management practices, including bad password practices. In 2024, the NIST finally issued guidance that some of us in the security community had been talking about for years. Because of the onerous practice of creating long, complex passwords that had to be regularly rotated and not reused, people wanted to find ways around those policies, including writing passwords down, storing them in unprotected locations, or making the password complex while still easy to remember. Attackers know all of these tricks. In addition to passwords that could be guessed, people often reused passwords, which could lead to credential stuffing or password spraying attacks.

The lack of using multifactor authentication is another problem that falls under this category. This additional control can help protect against other password failures, but even this is not perfect.

Sensitive data exposure

While you could argue that sensitive data exposure falls under either misconfiguration or identity and access management, it is a big enough problem on its own that it should be discussed on its own merits. If you work in the industry, you may often hear about public S3 buckets (an offering from AWS), where there is the potential for sensitive data exposure. I have worked for companies that inadvertently had their cloud storage exposed to anyone who had the URL. If sensitive data is put into one of these storage locations, that data is exposed to the outside world. While it is less common, the lack of appropriate encryption at rest and in transit can result in sensitive data being exposed unnecessarily.

Figure 3-1 shows the configuration settings for access on an AWS S3 bucket. I did not notice the S3 bucket was created, but by default, permissions are only granted initially to the owner.

Access control list (ACL)

Grant basic read/write permissions to AWS accounts. [Learn more](#)

Grantee	Objects	Object ACL
Object owner (your AWS account) Canonical ID: 71a03404d8a3d25dbcfb98b5fad5f6c22eef2005747a2651acc0ed0ede12644	☒ Read	☒ Read ☒ Write
Everyone (public access) Group: http://acs.amazonaws.com/groups/global/AllUsers	☒ Read	☒ Read ☐ Write
Authenticated users group (anyone with an AWS account) Group: http://acs.amazonaws.com/groups/global/AuthenticatedUsers	☐ Read	☐ Read ☐ Write

When you grant access to the Everyone or Authenticated users group grantees, anyone in the world can access this object.
[Learn more](#)
☐ I understand the effects of these changes on this object.
 You must select the check box to continue.

Access for other AWS accounts

No other AWS accounts associated with the resource.

Add grantee

Figure 3-1. Access control list for an S3 bucket

Malware

Although there are protections in place against malware, especially if the application and other infrastructure are designed appropriately, it is still a problem. Malware in the cloud is just as bad as it is on premises and has the potential to result in the same issues, including unauthorized access from attackers, exposure and exfiltration of data, or corruption of systems and data.

Denial of service

Since public clouds are public, denial of service is a threat. Although large cloud providers and the many services they offer can alleviate or abate these sorts of attacks, they still have the potential to cause outages and disruptions.

Remember that not all denial of service has to do with flooding attacks where network bandwidth is consumed. There are denial-of-service attacks that can consume other resources. Web servers, for instance, are sometimes vulnerable to slow attacks that may cause resources within the server application to be consumed as they wait for a complete request.

Poor application design

A weak design for an application, without adequate controls, can expose the application and its associated infrastructure to attacks. One common approach is making use of the API, which allows clients and other external entities to interact with the application and its components. APIs and the components that consume them may not have adequate protections. Developers may be used to other components that offer the protection and forget that data should never be trusted, which may lead to multiple types of common web attacks, including various injection attacks.

Vulnerable components

Ultimately there is software in the mix, whether it's developed entirely by the company deploying it or is a mix of common off-the-shelf (COTS) software and internal, proprietary components. Software has vulnerabilities. Unless all the software components in the design have been regularly evaluated for vulnerabilities, including being scanned by vulnerability scanners or thoroughly tested by experienced application testers, vulnerable components may lead attackers to gain unauthorized access to your application and its data.

Supply chain weaknesses

Sadly, a very common attack in recent years has been packages and components that have been compromised by attackers. Malicious code gets added to a common software repository for open source libraries, and any software that makes use of the newly malicious library is vulnerable to immediate compromise without much effort on the part of the attacker.

Infrastructure failures

This is probably as much of a misconfiguration as anything else, but it's also worth pointing out separately. There are several ways infrastructure can fail. A simple way is to leave subnets unprotected, allowing more connections to endpoints within your virtual private cloud than are necessary for the proper functioning of the application or infrastructure. There are others, which may include using more resources than are strictly necessary (for instance, using a virtual machine instance rather than something simpler and more restricted, like a container). There are many others that come down to a combination of misconfiguration or poor design decisions. Some are more subtle than others, including not building your solution to support the requests that come in from users.

Each of these are broad scenarios that encompass many potential vulnerabilities, which would depend on the implementation. They should serve as cautionary tales for areas to watch out for as you are looking at solutions using cloud providers, and especially if you are involved with implementations.

Cryptography

Encryption is a common practice for systems and applications, whether they are native, mobile, or web-based. Cryptography is the practice of encoding and decoding information to protect it so those who are not specifically authorized can't read it. It has become a common part of day-to-day life for anyone who does anything on the internet. Websites today are generally all encrypted, no matter what the contents of the pages on the site are. Specific language is used to talk about encryption, so you should understand what that language is, the different types of encryption, and how encryption is used within cloud infrastructure.

First, to explain some of the basic language, we can talk about a very simple encryption strategy. You may be familiar with it already since it is something you might have done as a child. A cipher is any method used to transform plain text, which is what you are reading right now, into cipher text, which should not be readable without a key (which is the information that is applied to the plain text to get the cipher text, and vice versa). The rotation cipher, also called the Caesar cipher, involves the alphabet and a number. The number tells you how many letters to rotate the alphabet by to determine the cipher text. Here is an example of the rotation cipher using a rotation value of 4:

```
abcdefghijklmnopqrstuvwxyz  
efghijklmnopqrstuvwxyzabcd
```

To convert plain text to cipher text, you start by taking a letter from the plain text word or phrase, then map it to the lower alphabet line to get to the cipher text. As an example, if you wanted to write *wubble* in cipher text using the rotation value shown

above, the result would be *ayffpi*. You don't have to use the lined up letters. You can just count over four, and remember to wrap back to the beginning of the alphabet when you run into the end. This may be harder to do than just lining up letters and looking down. When you decode, you just do the reverse. You start with the bottom set of letters, then pick the letter that is directly above it to get the plain text from the cipher text.

This, of course, is not how computer encryption works. It would be too easy to figure out what the key is. In our case, the key just means the number of letters you are rotating. In real life, you would be using a far more complicated key that is significantly longer. The key we have been using so far is what is called a symmetric key, meaning the same key is used to encode as decode. This is not always the case, though. You may sometimes use a different key for encryption than for decryption. The keys would be mathematically linked, but you would have two separate keys. This is called asymmetric encryption.

Asymmetric encryption

When you use asymmetric encryption, you have a public key and a private key. The public key can, and should, be, shared with anyone. Your public key would be used by someone who wants to communicate with you to encrypt a message that could then only be decrypted by you using your private key. The public key does not need to be protected. The private key, however, does. As soon as your private key gets out, any messages that are encrypted with your public key can be read. To protect yourself, you should always password protect your private key so even if your key gets out, no one can use it without the password.

There are inevitably trust problems when it comes to encryption and keys. Who creates the keys? How are keys delivered from one person to another so they can be used? One way of approaching this is to generate your own keys and hand them out to people you want to have them. This may not scale well. Another approach is to use a trusted third party. The trusted third party will verify identities, issue keys, and validate them. This approach uses public-key infrastructure, and the trusted third party is called a certificate authority (CA). This relies on the transitive property, where you and I may not trust one another, but we both trust the CA and they trust us because they have validated our identities.

The certificate authority is responsible for issuing certificates, which are digital documents declaring the identity of an entity, whether it be an individual or a system. The certificate includes the encryption keys as well as information that identifies the entity so you can check the details. You can see this when you visit a website that has encryption enabled, as shown in [Figure 3-2](#). You'll see the CA used to create and manage the certificate as well as additional details about the entity, including the fully qualified domain name used to register the certificate.

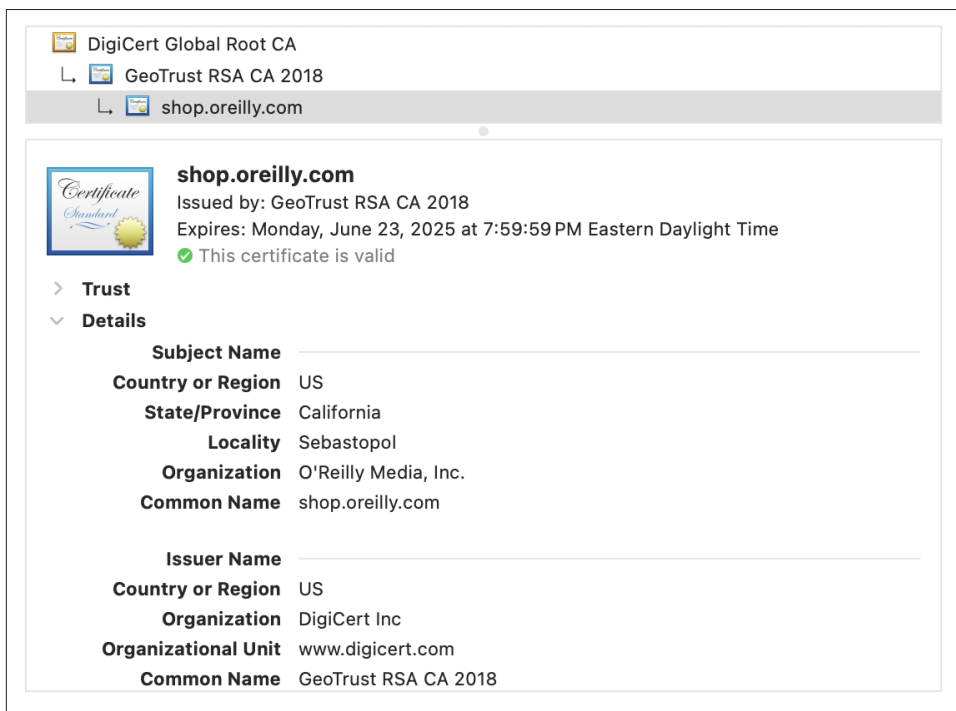


Figure 3-2. Encryption certificate

Asymmetric encryption using the public and private key can also be used to digitally sign messages. This is often done with email messages where you sign the message with your private key, and it can be validated with your public key to demonstrate you were the one who sent it. Because your key is protected with a password that only you know, no one else can send a message signed with your key. When you are unable to say that you didn't do something because the action is tied to something only you have access to, it is called nonrepudiation.

Some examples of asymmetric key encryption ciphers would be Rivest-Shamir-Adleman (RSA), Elliptic Curve Cryptography (ECC), and Digital Signature Algorithm (DSA).

Symmetric encryption

Asymmetric encryption is so-called because the same key is not being used in both directions. Using the same key for both encryption and decryption is called symmetric encryption. The most common symmetric key encryption cipher is the Advanced Encryption Standard (AES). Blowfish, Twofish, Rivest Cipher 4 (RC4), and ChaCha20 are all examples of symmetric key ciphers.

Key lengths vary a lot between different types of ciphers, especially when it comes to symmetric and asymmetric. A cipher like RSA will commonly have key lengths of 1024, 2048, or 4096. AES, on the other hand, uses key lengths like 128 and 256. While key lengths do matter when it comes to comparing within a cipher suite, since longer keys are harder to guess or derive because the key space is much larger, you can't say the same when comparing between cipher suites. AES-128 is not a weaker encryption cipher than RSA-2048, for example. Because of the differences in the mathematical algorithms, you can't compare one cipher to another directly just based on the key length.

Key lengths, by the way, are based on the number of bits used in the key. An encryption key with a length of 128 bits has 2^{128} possible values. This means you can have 340,282,366,920,938,463,463,374,607,431,768,211,456 possible values. If it's easier, you can think of it as 3.402×10^{38} . That is 39 decimal places, just to give you a sense of how large the key space is. Moving from 128 to 256 doesn't double the key space. Instead, you get a value that has 77 decimal places. These are enormous key lengths to try to guess, which is why any attempts to get the key are not generally based on trying to guess it.

Transport Layer Security

Transport Layer Security (TLS) is the means used to encrypt messages in transit from one system to another. While it is commonly used to encrypt messages being sent between a web server and a web browser, it is also used to encrypt virtual private network (VPN) traffic between sites, as it is generally easy to set up and manage, unlike the IP security extensions (IPsec), which can be harder to configure and manage. TLS was introduced in 1999 because the previous protocol was deemed to have too many design flaws.



Secure Sockets Layer

In the 1990s, Netscape, one of the first companies to develop web browsers, developed a way to encrypt messages in transit between a web server and a client browser. This was done to enable e-commerce so more companies would adopt the web as a way to do business. This method of encrypting messages was called the Secure Sockets Layer (SSL). SSL went through three versions that all had serious security issues, meaning it was possible for attackers to compromise the encryption of messages sent using SSL. Transport Layer Security was developed in 1999, and by 2015, SSL was officially deprecated, with most people using TLS instead.

One of the biggest challenges with using any type of cryptography is protecting the key. When it comes to asymmetric encryption, this is less of a problem because you can use my public key to encrypt messages to me, then I have my private key to decrypt. My private key never leaves my control. This is not true when it comes to symmetric key encryption. At some point, if we were to exchange messages using symmetric key encryption, we would need to agree on a key that we were both going to use. Then, we would need to ensure we both had the key. This could be done using a physical meeting, where one of us received a digital copy of the key. This is incredibly inefficient, however. Also, the longer you use a key, the more potential there is for an attacker to figure out the key value. So, you need to worry about re-keying, meaning getting a new key that both of us will use.

You may be wondering at this point why we don't just use asymmetric key encryption all the time. The asymmetric key encryption ciphers are generally not as efficient in terms of speed and processing power as symmetric key encryption ciphers. Also, as noted already, the longer you use a key, the more chances someone will be able to break it. Asymmetric keys, meaning the public/private pair, are intended to exist for long periods rather than being renewed on a regular basis.

TLS uses a hybrid approach to encryption. When the client initiates a request to the server, they use the public/private pair. The process can be seen in a ladder diagram in [Figure 3-3](#). The client initiates the request to the server with a ClientHello message. The client includes details about the ciphers it can support. The server responds with a ServerHello, where it selects the details that match what it can support that the client also supports. The server then sends along its certificate for the client to verify to ensure it is valid and matches the details about the server, including the fully qualified domain name. Once the server has been validated, the two are able to exchange keys that will be used for the session.

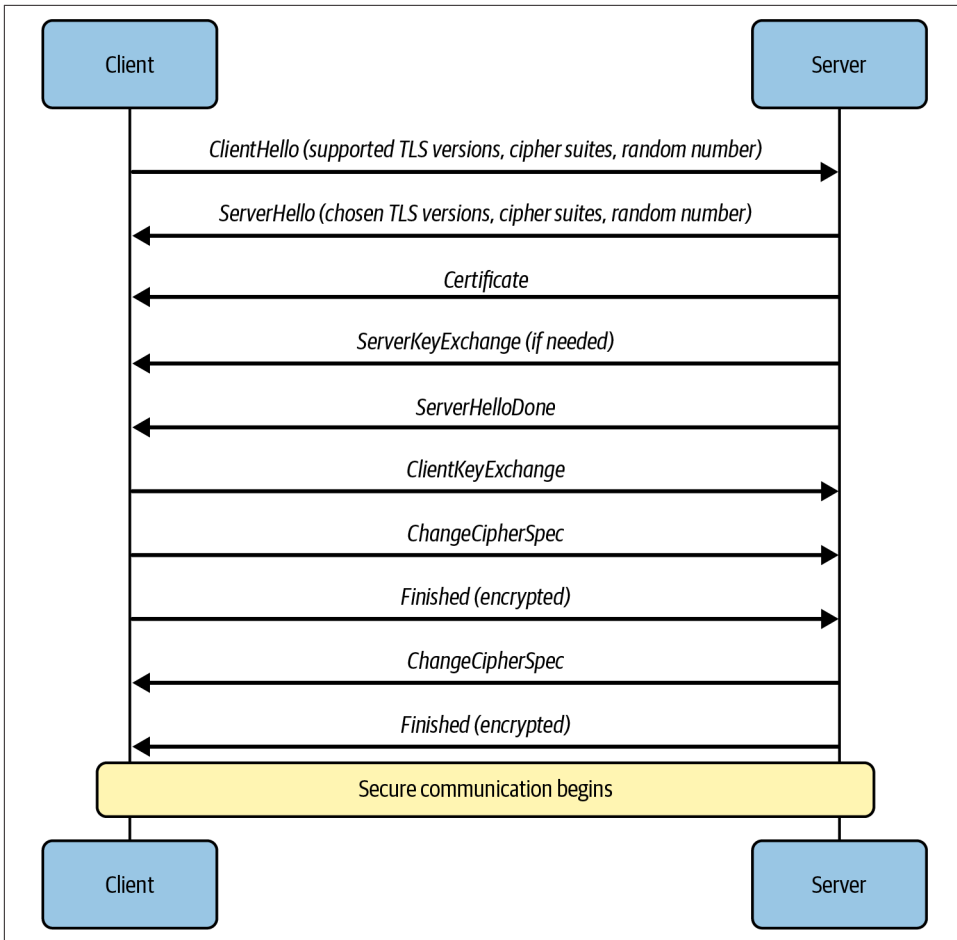


Figure 3-3. TLS handshake

The session key may be mutually derived, meaning both ends of the conversation share information that comes together to generate a key. Using this approach, named Diffie-Hellman after the two mathematicians who were among the first to identify the process, no information is shared over a public channel that could be used to generate the key. [Figure 3-4](#) shows a diagram of the Diffie-Hellman process.

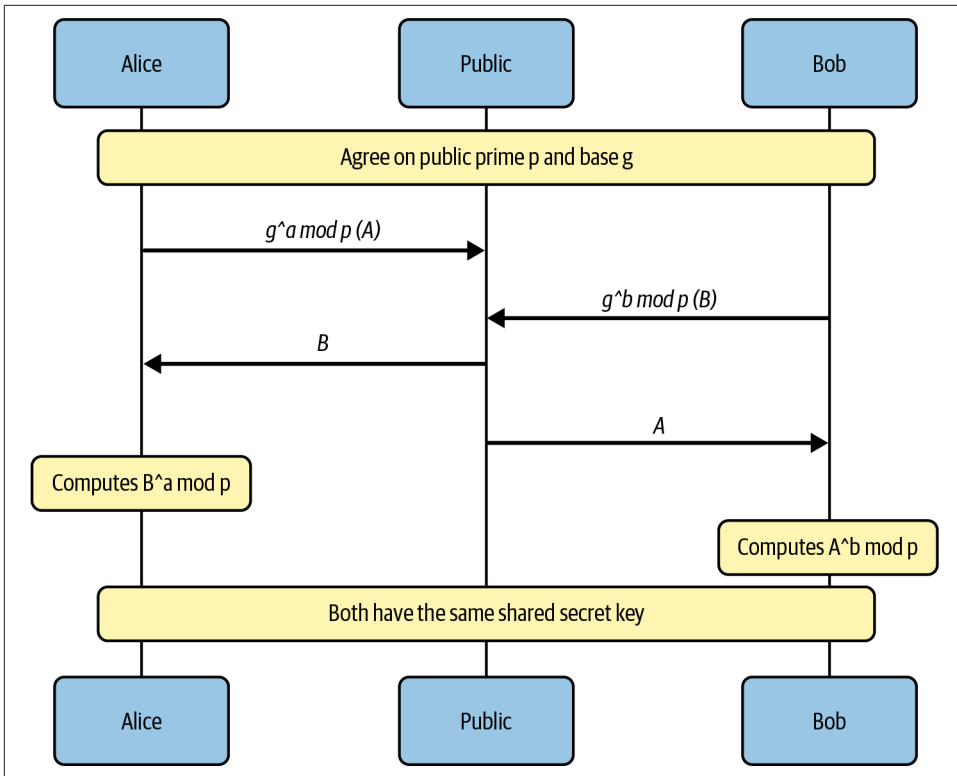


Figure 3-4. Diffie-Hellman

It may not be obvious from the diagram, but a key is never exchanged directly. Instead, both parties have secrets that they know, and the mutual key is derived from those pieces of the secret. It is common to explain Diffie-Hellman using two parties named Alice and Bob. We start off with the two parties agreeing to two pieces of information. This information can be shared over a public channel because there is still data required before a key can be generated. The information they agree on is a prime number and a base.

When the prime and the base are agreed to, Alice does a calculation involving a chosen number of her own, the prime and the base. Bob does the same thing using his own chosen number. Neither Bob nor Alice know each other's private value, but the results of the calculation are sent to the other party. Each then performs a separate calculation, again using the prime and the base along with the other's secret value. The result is the shared secret that is used for the key. Because of the way the calculations are performed and the order, they will result in the same values.

This is sometimes described using colors because you can see it more easily. Although colors get lost in a black-and-white print, you will still get what's going on from the explanation here. If Alice and Bob start with yellow as their shared color (the prime and the base), then Alice adds red (her own secret value) and Bob adds cyan (his own secret value), Alice will end up with orange and Bob will have green. They each send their resulting color (usually represented with paint because of the mixing) to the other one. They then add their private color. Each should then finish with a color that is a muted brown, which you can see in the Venn diagram in [Figure 3-5](#).

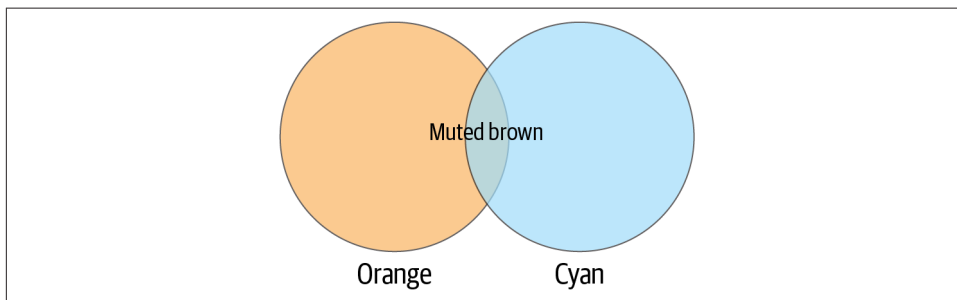


Figure 3-5. Color combination demonstrating key creation

Once each has their own copy of the shared key, they can use it for encryption. As it's symmetric key encryption, anything encrypted with the key can be decrypted with the same key. At some point during a long conversation, it may become necessary to re-key, meaning generate a new key to use. The same process can be used in this case.

Identity and Access Management

One of the most important aspects of any information security system is a solid Identity and Access Management (IAM) program. A good IAM program creates a complete lifecycle for the creation, management, and removal of user identities. This should include all the rights and permissions associated with each user.

An identity is a unique digital representation of an entity, which may include not only people, but also applications, devices (which may also have their own unique identities), and services. When an identity (account) is created, the entity needs to be validated. In human terms, some form of official identification should be used to confirm the individual is who they say they are, or who you expect them to be. This, in many cases, should include ensuring the individual is affiliated, as an employee, contractor, or someone else, with the organization. In the case of service, device, or application accounts, the owner of those, which should be another known identity, should confirm the necessity of the identity and the purpose for which it will be used.

All these identities should be stored in a single record that remains consistent across all uses in the organization. Most companies will use Active Directory since it has

long been the resource management facility provided by Microsoft for all its Windows systems. In cloud environments, companies may still use a version of Active Directory, but can also use whatever other built-in identity management system is offered by the cloud provider. This may include using something like federation, which means the identity provider of the cloud communicates with an on-premises identity provider like Active Directory, sharing all information about identities and any changes being made. **Figure 3-6** shows the creation of a user in Google Workspace, adding the user to the organization's directory as an identity resource.

User Information

First name * Last name *

Primary email * @ cloudroy.com

This will be the email the user signs in with

Secondary email Phone number

An email (like a personal email) where you can send the user initial sign-in instructions

[Manage user's password, organizational unit, and profile photo](#) ▾

 This user will be assigned a Google Workspace Business Starter license

CANCEL **ADD NEW USER**

Figure 3-6. Adding a user in Google Workspace

Once an identity has been created, they will need to be authenticated to use any organization-managed resources. Authentication is the process of proving that the entity knows information associated with the identity. This would typically include information like the username and password. It may also include something like a cryptographic key that is under the control of the entity. Authentication generally combines multiple factors, including something you know, something you have, and something you are. Something you know might be a password or passphrase. Something you have would be a token or key, and something you are refers to biometrics, like a voiceprint, fingerprint, or iris/retinal scan.

Identities need to be granted permissions to gain access to resources. Determining what resources an identity has access to is authorization. While this may be done in an ad hoc manner, assigning individual permissions and access to the user account, a better approach is to use role-based access control (RBAC). This approach assigns permissions to a group that is associated with a role within the organization. Individuals are then assigned to groups to take on the responsibilities and permissions of the role. This has the advantage of managing the role rather than individuals. Then you can add and remove groups from individual identities.

Another approach is to use attribute-based access control (ABAC). This approach assigns attributes to identities, like clearance level, title, department, and so on. You would then define policies that allow access to resources based on those attributes. This may provide a more granular level of control than RBAC, and is easier to manage because you aren't modifying group memberships for individuals. Instead, you are managing the identity the way you would normally do anyway. This approach would work well in organizations where things like clearance level and access to sensitive information is important.

You may also run across discretionary access control (DAC), which allows individual users to assign permissions to resources they have control over. This takes a lot of the control away from the organization itself, since resources with sensitive information could be shared with individuals who perhaps shouldn't have access to those resources. This approach is commonly seen on Windows systems, where you can share any directory on your system with others in your organization, unless it has been restricted by administrators. The opposite of this is mandatory access control (MAC). This is where policies are set at the organization level (or system level, by administrators), and only through modifying those policies can more access be granted to users. You may see this on Linux systems that use Security-Enhanced Linux (SELinux), a set of extensions developed by the National Security Agency (NSA) alongside Red Hat.

Privileged access, where any administrative work, including creating, managing, and terminating users and access, as well as making significant system modifications, is an important aspect of IAM. There are several approaches to privileged access management (PAM), and its related practice of privileged identity management (PIM). The first approach, that isn't limited to PAM or PIM, is that of least privilege. This is a practice that should be used across IAM. Any identity should only have access to the resources they actually need to perform their work. From a privileged account perspective, this might include requiring that individuals have two separate identities: one for only their administrative work, and the other for their other business activities like email, web browsing, and anything else they may do that is not specifically related to administrative activities that require elevated privileges.

PAM solutions may also offer things like password vaulting, where specific privileged accounts may have passwords stored and then checked out when they are needed. Session management may record and log all privileged access. There may also be just-in-time access, where privileged access is granted only when it is needed, and then only for a limited time. The goal of a PAM solution is to restrict access to privileged accounts and ensure they are only used when needed, with enough logging and monitoring in place to be able to track down anything that may have happened, either maliciously or accidentally, that caused a negative impact.

PIM, on the other hand, is about managing the identities of privileged accounts, across the entire lifecycle of account management, including provisioning, managing, and the termination or destruction of the account. PIM solutions may use automation to ensure accounts are created and managed in consistent ways to remove the potential for human error and variance. PIM solutions may also enforce the use of RBAC, as well as any other account management policies. PIM should also include regular review of accounts and permissions assigned to ensure the identity is still necessary, and the levels of assigned rights and permissions are appropriate.

There may also be an element of self-service when it comes to IAM. This may especially be true with cloud-based solutions because of the automated nature of cloud services. The most common place to have self-service is with password management. Organizations, and certainly cloud providers, may have web-based applications for password management, including resetting passwords and changing them on an as-needed basis.



Password Management

NIST has continued to evolve its guidance on password management. For years, NIST recommended regular rotation of passwords, in addition to long, complex passwords. The current guidance (as of 2024), which follows what several security professionals, including myself, have been saying for years, is that expecting long, complex passwords that are rotated regularly is effectively asking people to write their passwords down, or find other ways just to be able to keep track of all their passwords. Many of these bypasses create far more problems with passwords than the problems the guidance is intended to address.

Finally, in this very brief overview of IAM, there is behavior analytics. This involves knowing what users are doing, where they are doing it, and when. The purpose of this is to be able to identify any anomalies so they could be flagged as potential misuse. A common approach is to use geolocation, meaning the geographic area the access request is coming from. If a user commonly connects from New Jersey, seeing a request come from Manitoba would be an anomaly. This may require enhanced

authentication practices, including requiring a second authentication factor. There is also impossible login, meaning a user has connected from New Jersey while simultaneously connecting from Romania. While this may be an indication of account compromise, it may also be an indication that someone is traveling while also having left a device at home that is also trying to connect because applications left running on devices will continue to attempt to connect and authenticate.

Network Security

Traditional network security has been focused on perimeter protections, meaning the assumption has been that attackers are coming in from the outside. In that sense, networks are often created using a layered approach. Additionally, a good network design will segment specific resources from others. All of this is done using filtering technologies like access control lists (ACLs) and firewalls. A very simple, rudimentary firewall would be capable of granting or restricting access to networks or systems based on IP addresses and port numbers. Network administrators create rules in the firewalls based on the needs of the network or systems the firewall sits in front of. This is possible in the cloud as well, as you can see with the creation of a rule in AWS for inbound traffic to a subnet in [Figure 3-7](#).

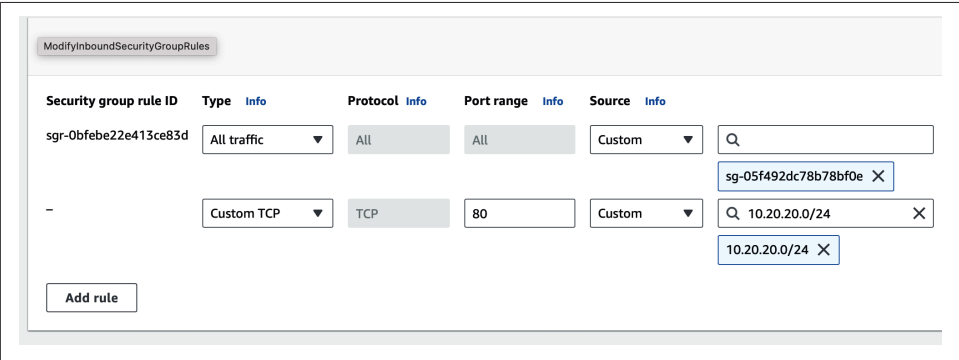


Figure 3-7. Inbound rule in AWS

Firewalls and network security groups

A more effective approach is to use something called a stateful firewall, since addresses can be spoofed, meaning someone may pretend to be using a legitimate address to get past the firewall. The stateful firewall keeps track of the direction of the communication and whether it has been seen before. This is helped by the use of the TCP three-way handshake to establish communications. TCP uses a SYN, SYN/ACK, ACK pattern to establish a connection between two parties. The SYN message is used to establish a sequence number from the client, while the SYN/ACK acknowledges the sequence number while also establishing the server's sequence number. Finally, the client responds, acknowledging the sequence number from the server. The

firewall will watch this handshake to know whether the two parties have effectively established that they are both legitimate and ready to communicate. UDP is harder, since it is connectionless, but the firewall will keep track of whether the messages are part of an expected flow.

Even stateful firewalls are old hat now. Modern firewalls not only pay attention to state, they may also look at higher-level protocols to ensure they follow appropriate patterns. They may also integrate other approaches to network security, including intrusion detection. An intrusion detection system (IDS) knows what anomalies in network traffic look like based on patterns that have been identified, and sends alerts to let someone know when something potentially bad has been identified. In contrast, an intrusion protection system (IPS) not only identifies the bad traffic but also blocks it. Either of these approaches may be integrated into the firewall. You may also get something like antivirus, since network messages that include the malicious software (malware) can be reconstructed by the firewall before being sent on and inspected to see whether any file or message matches known malware patterns.

When it comes to cloud implementations, a concept similar to firewalls is network security groups (NSGs). NSGs are collections of rules that can be applied at either the network interface or the subnet level. These rules filter traffic in similar ways to firewalls. You can create rules based on IP addresses, ports, and protocols. You can apply the rules to either ingress or egress traffic. They are typically stateful, so they know the state of the communications flow. You may also be able to assign priorities to the rules so you can ensure higher priority rules are applied first. This can be a problem with firewalls where you may have multiple rules that could potentially apply to any individual packet. You can alleviate that with priorities to the rules you apply within the NSG.

Virtual private networks

In cases where external individuals need access to resources behind perimeter protections like firewalls, virtual private networks (VPNs) are commonly used. A VPN establishes a tunnel that makes it appear as though the user is actually on the local network, even though they are remote. It does this by protecting messages with encryption, and by encapsulating the messages so the real endpoint of the user can't be seen by the remote system. The remote system should be communicating back to the VPN device on the local network rather than trying to communicate directly back to the user, since that communication would bypass the VPN and send the message unencrypted and unencapsulated back over the public network.

The VPN is managed using a piece of software on the user's system along with a hardware device or another piece of software within the network that the user needs access to. This is only required if the resources the user is trying to access are private to the local network. This would be common for on premises where resources like file

servers are not generally exposed to the outside world. In the cloud environment, it may still be necessary to protect management of sensitive devices that shouldn't be exposed to everyone. Specific subnets may only be accessible through other subnets within the virtual private cloud (VPC) at the cloud provider, which may include a subnet that has the VPN concentrator, responsible for taking in messages from the outside, decrypting them, and passing them along to resources on the inside network.

Typically, there are a couple of approaches to VPNs. One is to use the IP security (IPsec) extensions that were developed as part of IPv6 but backfitted to IPv4 to enable encryption from device to device. Another approach is to simply encrypt messages using a well-known protocol like TLS.

There are other approaches to VPNs like the Point-to-Point Tunneling Protocol (PPTP) or the Layer 2 Tunneling Protocol (L2TP) or even the Generic Routing Encapsulation (GRE) protocol, but the problem with all of these is they simply encapsulate the original message inside a lower layer protocol and don't offer any protection. They just get your message from you to the network you want to communicate with but don't do any encryption to keep it private. It's effectively virtual networking without any privacy.

Defense in depth and other strategies

When it comes to network security, a common phrase you will hear is defense in depth (DiD). DiD usually takes a layered approach to network security, meaning that multiple controls have been implemented to keep the network protected. This includes network segmentation, as mentioned earlier, where some resources are put on different networks from other resources. This allows for a consolidation of rules because access and security needs may be the same or similar for some groups of resources. You may also use firewalls and IDS/IPS devices to help protect the network.

The point is that attackers should have multiple layers to get through before they reach the target, which may be an endpoint. One reason for this is because attackers don't always start from the outside. They aren't always looking to attack external servers. Instead, they may be looking for other targets, like user endpoint devices. This means that in addition to perimeter protections, endpoints also need to be protected with host-based firewalls, which allow traditional network firewall rules to be implemented on the endpoint to keep it protected.

Firewalls do not guarantee protections, though. After all, network communication is essential, so some traffic has to get through. On endpoints, this includes web browsing, as well as email. These are avenues that attackers make use of using social engineering practices to introduce malware or steal credentials from users. You can protect against malware using anti-malware solutions. You can also use more comprehensive software like Endpoint Detection and Response (EDR), which may offer

enhanced anti-malware protection as well as the capability to detect other malicious activity and collect data if the endpoint becomes compromised.

You may argue that something like EDR is part of a defense in breadth (DiB) design. Where DiD takes a vertical approach to network security, providing layers of protections, especially to critical assets, DiB is meant to be broader, both in terms of coverage across the enterprise, but also in terms of the controls in place. DiB, for instance, may introduce threat intelligence to understand the types of attacks and who may be targeting the organization. This may help improve protections by knowing what vectors the attackers will be using. DiB may also implement vulnerability management across all assets within an organization.

Another way to think about network design and security controls that need to be implemented is to assume that attackers will get in. You should assume that at some point you will have malicious actors in your network. You want to be able to monitor and isolate them. You could consider a defensible network architecture. This means segmenting your network so you can isolate and disconnect where you need to. Additionally, you should think about collecting adequate logging to know what is happening and where it is happening. This should include the ability to enhance monitoring on assets and networks that may have been impacted by an attacker.

Traffic Inspection

One approach to consider is the ability to perform full packet captures within your network to gather essential network intelligence. When you have firewalls, selecting ones that can also capture packets at network entry points may be beneficial to collect essential forensic information. Within a cloud implementation, there may be multiple places where you can collect traffic to look at. You can use collection at the endpoints, or you could implement software-based firewalls within your cloud deployment that may be able to collect traffic. You may also use API gateways within your application and collect detailed information about the traffic.

One thing to keep in mind is that traffic inspection is not only about full packet capture. Sometimes the metadata associated with the traffic may be enough, and there can be multiple places where you can collect this information. Of course, one challenge with packet inspection is the fact that it's common for network communication to be encrypted. Web traffic, and most other encrypted network communication, use TLS. You may need to have firewalls or TLS gateways to handle decryption of the messages to collect the information, looking for potentially malicious data.

Data Protection

It can be easy to get wrapped up in technology and network design and easy to forget that the essential job is to protect business resources. That means data. Protecting a system for a system's sake is mostly meaningless. You should care about what data

that system may contain or what access that system may provide that could allow attackers or other malicious users to get to critical data. Remember, data is a vague term. It could mean intellectual property, personally identifiable information (PII), payment card information (PCI), personal health information (PHI), or other financial or legal data. This includes anything to do with users, with particular attention to usernames and passwords.

Data has a lifecycle with the following six phases:

1. Creation/ingestion
2. Storage
3. Processing/use
4. Sharing
5. Archiving
6. Deletion/destruction

At every stage of this lifecycle, the data needs to be protected. This includes all the way through deletion/destruction, which means you will need to ensure that data is actually destroyed when you think it will be. Data that has not been properly deleted or destroyed may come back later on and be used in unauthorized ways. Let's say, for instance, that you have a storage bucket that has a lot of data in it. You expect the data to be deleted. Perhaps that gets overlooked and the data destruction is not validated. Later on, someone stumbles across the bucket, which may not be managed properly anymore because it's expected to not exist. The bucket contains sensitive information, which may include PII. That PII can then be misused, all because the data wasn't managed all the way through the lifecycle. You are protecting the data as a means of protecting the organization and its users. Protecting data is not exclusively about making sure it doesn't get stolen or misused.

Hygiene Practices

Information security hygiene is a critical set of practices, whether you are an individual needing to protect your passwords, or a business with a complex set of tasks, either on premises or in the cloud. When it comes to cloud deployments, you will need to ensure you have solid practices for IAM, as previously discussed. This includes protecting accounts and ensuring multifactor authentication is in place. Account compromise is a common attacker technique, so having as many protections in place as possible will help prevent those takeovers.

In cases where you have responsibility for applications or operating systems, vulnerability management is an essential hygiene requirement. Vulnerability management entails identifying vulnerabilities in deployed software, including the operating system software. Once vulnerabilities have been identified and priorities determined, the

vulnerabilities need to be remediated. Often, vulnerabilities are identified through scanning with tools that have databases of signatures the scanner can compare against what it finds deployed on systems. Scanners are not the only ways to identify vulnerabilities, though they may be the best way to identify whether the deployed software is vulnerable.

Software vendors generally release notifications when they have identified a vulnerability in their products and have fixed the issues. Paying attention to these notifications and knowing what versions of any software are running should provide guidance on where vulnerabilities are. Of course, this relies on accurate asset management, including tracking of all versions. While this is a good practice that should be followed, a lot of organizations may not keep track of all assets, including the software versions. This is part of why vulnerability scanning is an important practice. It validates, to the best extent possible, whether vulnerabilities exist. Scanners do not exploit vulnerabilities. Instead, they look at characteristics of the vulnerability, including versions of the applications.

Patching or updating is the most important part of vulnerability management. Knowing where your vulnerabilities are doesn't help unless you are doing something to remediate them. Updating the software is not the only fix, since some vulnerabilities come from misconfigurations, but staying up-to-date with fixes is critical. While it may be possible to have software and operating systems update themselves automatically, it may not always be the best approach. After all, operating system or software restarts should be planned to ensure there are no outages at inopportune times. Also, some updates need to be tested to ensure there is no breakage in the internally developed application.

Updating systems and software relies on process and infrastructure. This should include a process to validate the updates, making sure they don't cause problems. Consider the CrowdStrike issue on Windows systems from 2024 as a good lesson on why testing should happen to ensure there are no issues before issuing updates. Once updates have been tested as needed, there needs to be a way to get updated software onto the target systems. There are several patching servers, including Microsoft Intune, which has generally replaced Microsoft System Center Configuration Manager (SCCM) for getting updates and other configurations to Microsoft endpoints. There are other third-party applications that will do similar things, including automation platforms like Puppet and Chef, which are often used in IaC deployments.

Using a baseline for operating system deployments that is regularly updated is another good security hygiene practice, ensuring there is consistency across deployments. When it comes to cloud deployments, there are different ways to implement baselines, including using standard machine images from the vendor. You could also develop your own templates with your own configuration on top of an operating system. This may include additional software you need for your organization. These

templates can then be quickly deployed as needed. Templates, just as any “gold image,” can be updated as new configurations are developed or new fixes are implemented.

Even though you are using cloud providers, don’t assume you are going to be immune from malware attacks. Just as with any other system, if you are running computing infrastructure, make sure you have some form of anti-malware software on your systems. This may also include endpoint protection beyond anti-malware, so using an Endpoint Detection and Response (EDR) solution may be a good idea as well.

Zero Trust

Traditional security designs with a perimeter are not always relevant today, which is especially true when it comes to cloud environments. With cloud environments, there are no traditional perimeters where there is an outside edge and everything is behind that edge. Cloud environments may have a conceptual edge, but in reality, cloud resources are distributed and accessible from anywhere, unlike on-premises environments, which are intended to be accessed from your desk, across a local network. Even in cases where the organization is global, the different sites are usually connected in such a way that everything behaves as though it is on the same network.

If a company has fully moved to a cloud model, it has email, chat, collaboration, file sharing, and other software services hosted by its cloud provider. Every one of these services is in different locations, so there is no perimeter. Because there is no perimeter to keep all services protected, even notionally, another approach is necessary to protect resources. With the Shared Responsibility Model, the business is not exclusively responsible for protections. The move away from a traditional on-premises model for information technology deployment and access has been going on for the last couple of decades or more.

While there is no consistent approach to zero trust or a definition of it, the objective is generally to enhance the protection of assets without relying on more traditional implementations of infrastructure, relying on data centers, and everything being connected through the same physical infrastructure. One reason why it is called zero trust is because in some cases, there was a reliance on that physical connection. Some organizations and technology professionals mistakenly assumed that anyone connected to their network was trustworthy, so there was limited authentication in some cases once you were connected.

Zero trust implementations often include microsegmentation, where devices are more isolated from one another using network firewalls as well as host-based firewalls. This helps add additional layers of protection rather than just exposing systems completely to the network they are connected to. Additionally, zero trust is focused strongly on authentication and a single source of identity information. Beyond the

typical user authentication, the expectation is to authenticate devices as well to protect against anyone bringing in systems and connecting them to the network. Devices may be provisioned cryptographic certificates by the organization, which are used to validate their legitimacy to be connected to the network.

This approach works well for a cloud-based infrastructure since there is no network to connect to that is managed by the organization. Since nearly everything is connected to over a public network, strong authentication practices are necessary. This is the only way to ensure a legitimate user is connecting to the infrastructure. Having the single authentication source means that everything is managed centrally, rather than having many authentication databases for every service. Where the services themselves are distributed, the authentication and authorization may generally be centrally managed.

Having a central authentication source allows for policies to be applied in one place. This can include some very fine-grained controls using conditional access policies, based on details like where someone is authenticating from, how recently they authenticated, and various other pieces of information to determine whether to allow the cached authentication or require a reauthentication, and whether additional factors may be necessary.

One element you may see referred to when looking deeper at zero trust is the assumption that a breach has happened. This means you can't assume that a request coming from a machine that has had a user authenticated against it is coming from the user. Systems can be compromised where attackers can get remote access to them under the context of the user who has been logged in. The request appears to come from an authenticated user, but the authentication may have happened on the local system. Applications should not assume that the user is the same, so the applications should also authenticate and enforce additional factors, like a passkey or a token or a one-time password.

Design Principles

When it comes to the design of a solution, a lot of technical factors come into play, but good design is more than just the technical aspects and getting all the application components into place. Good design always starts with customer requirements and business requirements. The business foots the bill for all the work being done, and ultimately the business needs to remain operational so ensuring that it and its resources are protected is essential. This includes understanding how any application or resource impacts the business. You also need to make sure your application or infrastructure continues to be able to support the business in case something really bad happens.

Once you understand the business needs, you can start to get into how the application or implementation is supposed to function from a customer or user perspective. Additionally, you can consider some best practices from the industry using frameworks that have been developed by vendor-agnostic organizations as well as the cloud vendors themselves. Finally, how applications are developed ends up being important, so taking a look at development practices and ensuring you have security covered from start to finish and a fully sustainable application in production are going to be important to everyone.

Business Impact Analysis

A good practice to get into from an information security perspective, as well as just good business management, is performing a business impact analysis (BIA). The purpose of a BIA is to identify potential areas of impact to a business from any disruption to a critical or important business process, function, or service. The impact may result from a disaster, accident, or emergency. The essential task is to help identify critical areas of the business and understand how any impacts might cause problems for the organization.

A BIA isn't a task you undertake once. It should be done for every critical or important aspect of the business to fully understand its importance. Each analysis should also be documented, reviewed, and updated on a regular basis. Businesses are not generally static entities. They change regularly with staff moves, process updates, technology changes, and shifting business priorities. This means any impact to the business may be changing.

To start, the business should have a catalog of all important or critical processes, functions, and services. This should of course include all essential applications and systems. Once they have all been identified, each should be evaluated to identify the impact from the following: financial loss, reputational damage, legal and regulatory consequences, and operational inefficiencies. Each of these should have some sort of monetary impact associated with them to help prioritize the most critical.

Once you have identified the impact to the business from outages or disruptions, you need to understand your recovery time objective (RTO). This is the maximum tolerable downtime. An RTO should look at how long the business can continue to remain effective without the use of this process, function, or service. The lower the amount of time the business can survive, the more critical the service is going to be to the organization. Additionally, identifying the recovery point objective (RPO), which is the acceptable amount of data loss in time, will be important. Once you have the RTO, RPO, and impact, you can identify priorities of each function, process, or service. These should be ranked to help identify resources that may need to be devoted to help protect and recover them faster.

Resources will need to be identified that support each area. This should include people, process, and technology resources. These resources should be documented. The resources should be identified in terms of current implementation, as well as what resources may be required to recover in the case of a significant incident.

All of this should be documented and kept for regular review. This not only includes review from the perspective of keeping it up-to-date, but to help inform business decisions.

Business Continuity/Disaster Recovery

The BIA should help inform business continuity/disaster recovery (BC/DR) planning. While these two are often put together, they are two separate things, even if they are closely related. Business continuity is the process of keeping the business operational in the face of a disaster, accident, or emergency. This may be natural, as in the case of a hurricane or earthquake, or it may be related to a cybersecurity incident, as in the case of something like ransomware, which can leave data unavailable and systems completely out of commission.

A business continuity (BC) plan can and probably should start with a BIA to fully understand the impact to the business. A BC plan should be focused on all means needed to maintain the operation of critical business functions. This may involve rethinking how those business operations are performed. Different scenarios that may impact the business should be developed, including natural disasters that may impact facilities, as well as any incident that could take information resources out. Also, consider scenarios involving the loss of large amounts of staff, as may be the case in an epidemic.

BC plans should include people, processes, and any technology that may be necessary to ensure all critical business functions are operational. This will probably include possible changes to the existing functions. It may be necessary, for example, to take computer-based processes offline, or at least have the contingency for other processing facilities to take over. Consider the possibilities for both short-term and long-term disruptions. You should not assume that any disruption will be negligible. Events like natural disasters, pandemics, and cybersecurity incidents, as a few examples, can take months or longer to resolve. The business should expect to be working with backup processes for extended periods.

An area where the BIA becomes important is identifying where you need to have BC plans. While all business processes should have BC plans, it may not be feasible for every function a business has to maintain, especially for larger organizations. That means a focus should be placed on those processes that are absolutely essential. This does not mean that businesses processes that are customer facing or impact revenue are the only ones that should be developed and implemented. Keep in mind that your

people are essential. This means you should also consider processes to keep them paid, allow them to retain their benefits, and hire and terminate them as needed.

Just developing the plans is not enough, though. All plans should be practiced on a regular basis to keep staff familiar with these unusual practices, so they retain an awareness of them. Additionally, practice identifies areas where an identified process change may not work, or may not work as expected. Any deficiency that is identified should be noted, with changes made to processes and any other contingencies. Practice should also be focused as much as possible on real-life scenarios and restrictions. Consider the case where computer systems are offline. Practice should take that into account, meaning all BC plans should be available in hard copy form. The result from these practice events should be regular plan updates, based on any learning taken away.

While business continuity is about weathering the storm and making sure all essential functions remain operational, disaster recovery is about getting off the contingency plans and back to normal operations. This is not to say returning exactly to business as usual. After all, in the case of a natural disaster, critical facilities might have been destroyed. It may be necessary to adapt to new circumstances. This was certainly the case when it came to COVID, whether businesses had considered a pandemic or not. They had to quickly pivot to business continuity without staff being in offices for months, if not years. Once the urgency subsided, the landscape had changed for many businesses and they had adapted beyond the need to return to how things were before the pandemic struck.

Disaster recovery planning is often about ensuring you have the capacities in place when you need them. This should include essential tasks like backups and alternate processing. In cases where the BC plan calls for manual processes, such as handling sales or other transactions on paper, the disaster recovery plan should ensure all the offline data is restored to the normal online processing capabilities. This may require merging of data, as well as understanding where data may have been lost, since backups are not generally real-time, so any destruction of systems or data may mean information loss.

If BC plans include failovers to alternate processing facilities, such as a backup data center or to another cloud provider, the disaster recovery plan should include clear guidance on how to switch back to the primary facilities.

As with the BC plan, the disaster recovery plan should be practiced on a regular basis. Backups and restorals should always be tested. This should include timing how long it takes to restore data. This may help decision making in some circumstances, and also help set expectations for how long it will take to get the business completely operational again.

Functional Requirements

Requirements drive any information technology project and describe what the expected outcomes from using the service or product should be. Nonfunctional requirements, including performance, security, usability, reliability, scalability, and business requirements, are important as well.

The focus on functional requirements needs to be on clearly identifying the problem. This means focusing on the what, rather than the how. Avoid specifying solutions, since that will obscure the situation and make it harder to determine whether you have achieved the overall goals. Ultimately, any requirement should be verifiable. You should be able to test to validate whether you have achieved the objectives.

Gathering functional requirements should focus on the user. This is a common practice with most modern development methodologies. However, users are not the only stakeholders. Identifying all stakeholders and their expectations will help with clearly documenting all functional requirements. In some cases, the users are not exclusively the end users. An application may be more complex than the interface that someone interacts with to view and deal with information. There are administrative requirements as well. This would certainly be the case with any centralized application that has multiple users. Getting the requirements from those who are responsible for maintaining and administering the application is also important. They are not the end user, but they are still users. This is why clearly identifying stakeholders and getting requirements from all the stakeholders is important.

There are different approaches to collecting requirements. An easy way is to interview stakeholders and just talk to them about what they expect to see. This may be an iterative approach, which is part of why rapid application development methodologies became popular. It is better to show off progress sooner rather than later and get feedback, rather than getting a year and a half into a project, delivering it, and discovering the understanding of the development team was very different from that of the stakeholders. Workshops can also be helpful, with groups of stakeholders, using a guided approach to talk through requirements and expectations.

Once requirements have been gathered, there will likely be some overlaps as well as conflicts. You talk to two partners about the colors they want in the house they are buying together, and you'll have one partner saying they want red carpets while the other partner wants beige. Those requirements are in conflict, so someone needs to resolve them. This may involve ranking the requirements in terms of priorities and even ranking the stakeholders from a prioritization perspective. Unfortunately, there is no guidance on how to figure out the right requirements and priorities. It will be entirely dependent on each organization.

There are, however, some standard approaches you may use to prioritize efforts:

MoSCoW method

Requirements can be put into Must Have, Should Have, Could Have, and Won't Have buckets.

Kano model

Requirements can be prioritized based on user satisfaction and necessity.

Weighted scoring

Use defined criteria then assign weights to them. Score each requirement based on the criteria that have been established.

Design Patterns

When it comes to putting the project together, there are some frameworks that can be used for guidance. The CCSP specifically calls out a few frameworks that can provide some guidance for developing solutions or applications. These include the AWS Well-Architected Framework, the SANS Critical Security Controls, which the CCSP exam outline refers to as the SANS security principles, and the Cloud Security Alliance (CSA) Enterprise Architecture. The SANS Critical Security Controls are now the CIS Critical Security Controls, even though the CCSP exam outline has not been updated to reflect the change in management. Each of these will have different perspectives so even if you are using one in particular, it may be useful to understand some of the others to broaden your perspective. As with so many frameworks, it is possible to take ideas from one and integrate them into the primary one you are using.

AWS Well-Architected Framework

As one of the predominant cloud providers is AWS, its Well-Architected Framework is a good starting point to talk about how to design applications using a structured, well-recognized approach. **Figure 3-8** shows the six pillars that have been identified as areas to consider when applications are being developed.

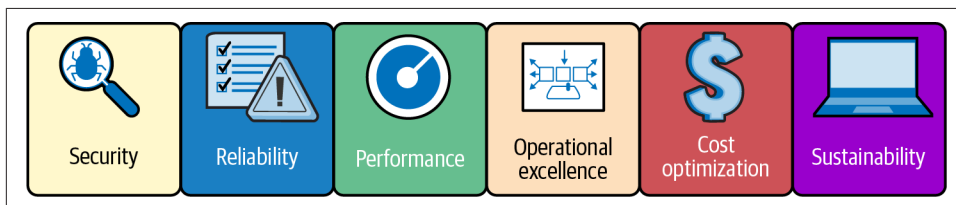


Figure 3-8. AWS Well-Architected Framework

These six pillars are the areas AWS considers essential to consider for robust application and service development:

Security

The focus here is on protecting information resources, including data, systems, and other assets. AWS recommends starting with a strong identity framework to protect account information. This should include using the principle of least privilege when assigning permissions. AWS also recommends applying security controls at all layers, not just at the network. The organization and application teams should also be prepared for incidents to be able to respond and recover quickly.

Reliability

This pillar is about ensuring that all the functions of a service or system can be delivered consistently and correctly. The service or application should be able to recover from a failure automatically, rather than needing manual intervention, which will just incur downtime. Availability is a strong focus here, so applications should scale horizontally to be able to retain functionality in the face of demand. Recovery procedures should be tested. Change should be automated wherever possible to reduce the possibility of human error. These automated change procedures should also be tested before deployment to ensure correctness.

Performance

Of course, this is always going to be a significant factor since customer/user satisfaction will rely on the overall performance of the system/application. Information technology and computing resources should be used efficiently, ensuring that the use of cloud resources is understood so services provided can be best utilized. Performance should be monitored, so metrics around actual performance factors should be developed. This will allow fact-based decisions to improve efficiency. Metrics should always be developed with a focus on what change you would expect to see as a result of those metrics.

Operational excellence

As with so much else, there is a focus on automation to achieve operational excellence. This includes automating changes, and using Infrastructure as Code (IaC) to automate deployments. Standards for daily operations should be developed and, where possible, daily tasks should be automated. The focus should be on small, frequent, reversible changes rather than larger, less frequent, and difficult to back out changes. Operations procedures should regularly be refined, which may mean developing a strong metrics program to fully understand how the system/application is functioning and the speed of deployments and changes. Failure should be anticipated and planned for, while any failure should be a learning event that can lead to improved operational procedures.

Cost optimization

One of the strongest inducements for a business to migrate to cloud providers is the reduced cost of deployment and operation. There should be a strong focus on implementing services and resources that get the lowest price point while still achieving business objectives. This may include moving to serverless architectures wherever possible and developing the agility to experiment with cloud services more easily. Measuring overall efficiency will help to understand cost factors for enhanced efficiencies. Analyzing usage on a regular basis will help to understand whether costs can be reduced. Using managed services and application-level services will help to reduce costs.

Sustainability

Sustainability takes into consideration all the impacts of the application and workloads on the environment. The pillar encourages the understanding of your impact through measuring and forecasting. It also recommends minimizing the amount of infrastructure being used by maximizing utilization of resources. Just as with the cost optimization pillar, the sustainability pillar recommends the use of managed services to help minimize the impact on the environment.

Critical security controls

SANS, an organization known for security leadership, trainings, and certifications, previously maintained a list of critical security controls. These have been migrated to the Center for Internet Security (CIS). CIS is known for controls for hardening operating systems and applications. The current version, 8.1 as of fall of 2024, contains 18 critical security controls, while the previous major version 7, contained 20 controls. These are the controls that CIS has indicated are critical:

Inventory and control of enterprise assets

Asset management is an essential security control and one of the foundational controls because so much else is based on it. It is more difficult in a cloud environment if resources are coming and going based on demand, but having a complete inventory helps provide a better understanding of what resources are in place, and ideally who owns them and how they are managed.

Inventory and control of software assets

Software inventory is also essential. This provides some insight into inventory costs due to licensing and acquisition expenses. Additionally, an inventory of software assets, if complete, will help to offer insight into whether there is vulnerable software and to what extent the organization is exposed.

Data protection

In a cloud environment, data protection is about ensuring there are appropriate access controls in place, as well as encryption where necessary, both in transit, as well as at rest. Finally, data loss protection should be in place.

Secure configuration of enterprise assets and software

Misconfigurations are a problem because they can expose installations to misuse, data theft, and more. This control is about ensuring configurations have been appropriately hardened and managed in an ongoing way.

Account management

This involves using the appropriate IAM implementation from the cloud provider to protect all resources.

Access control management

In addition to using appropriate IAM practices, you should be implementing the principle of least privilege and role-based access control, as well as managing privileged account access.

Continuous vulnerability management

Even in cases where the cloud provider may have responsibility for the implementation, you should be scanning regularly for vulnerabilities to have a better understanding of your exposure. This should also include management of the vulnerability all the way through remediation and validation.

Audit log management

Just as with on-premises environments, logging and monitoring are essential. This may involve the use of cloud-based logging and monitoring platforms, but at least ensuring that logs from cloud resources are captured and analyzed somewhere.

Email and web browser protections

This should include email protections that cloud providers offer if you are using a cloud provider for your email service, like threat prevention, attachment scanning, and sandbox detonation (opening email in a strictly contained environment to identify malicious behaviors). It should also ensure that cloud platforms are not being used to read email on unless they are specifically used for a virtual desktop infrastructure (VDI). The same should also be true for web browsing. Any virtual environment should not be used for web browsing unless it has been specifically built for that purpose and for remote desktops.

Malware defenses

Cloud platforms should also have anti-malware solutions in place, just as your on-premises environments have. While not all organizations are using anti-malware on servers, this should be a common practice, both on-premises and in the cloud.

Data recovery

Backups should be used in cloud environments, alongside complete disaster recovery plans.

Network infrastructure management

This should include appropriate controls and management over virtual networks, security groups, and other network services.

Network monitoring and defense

Cloud native logging and monitoring should be used for the network to include intrusion detection services.

Security awareness and skills training

Anyone using or operating cloud environments should be aware of threats to those platforms and have appropriate training to operate them so resources and assets are protected. While this may be generally happening in most businesses, there may be some awareness related to cloud deployments that should be specifically defined in addition to the usual security awareness training.

Service provider management

Appropriate management of cloud providers is the focus here, including contracting, escalations, and support. Staff required for this role should understand how to manage vendors.

Application software security

Security should be introduced at all phases of the software development lifecycle, with a specific focus on cloud native approaches, including common practices like continuous integration/continuous deployment (CI/CD) and the impact security can have on those practices.

Incident response planning

Incident response plans should be developed for the organization that will encompass responding to incidents in the cloud. This should include planning for access outside of the cloud operations team, and ensuring that logs and other essential information can be made available to the team responsible for responding to the incident and investigating it.

Penetration testing

The organization should be conducting regular penetration tests to all deployments in the cloud. This should be used to augment vulnerability management to identify areas that are harder to find with traditional vulnerability scanning and identification.

While the previous CIS version had 20 controls and the current has 18, that is not an indication that some controls are no longer critical. Instead, it comes from the consolidation of controls that made more sense to be put together. For example, control of admin privileges and control access based on need to know were consolidated into access control management. Nothing was specifically lost between the versions. The

controls have been brought up a layer in some cases, describing the general case and losing the specific cases.

Cloud Security Alliance Enterprise Architecture

The Cloud Security Alliance (CSA) has developed a comprehensive architecture designed to help organizations implement appropriate security controls within cloud deployments. Where the CIS Critical Security Controls are a list of controls or control areas, the CSA Enterprise Architecture is a complex architecture consisting of several layers, as seen in [Figure 3-9](#). Each layer brings along different needs and requirements. Essentially, each layer captures another stakeholder or set of stakeholders, every one with their own needs.

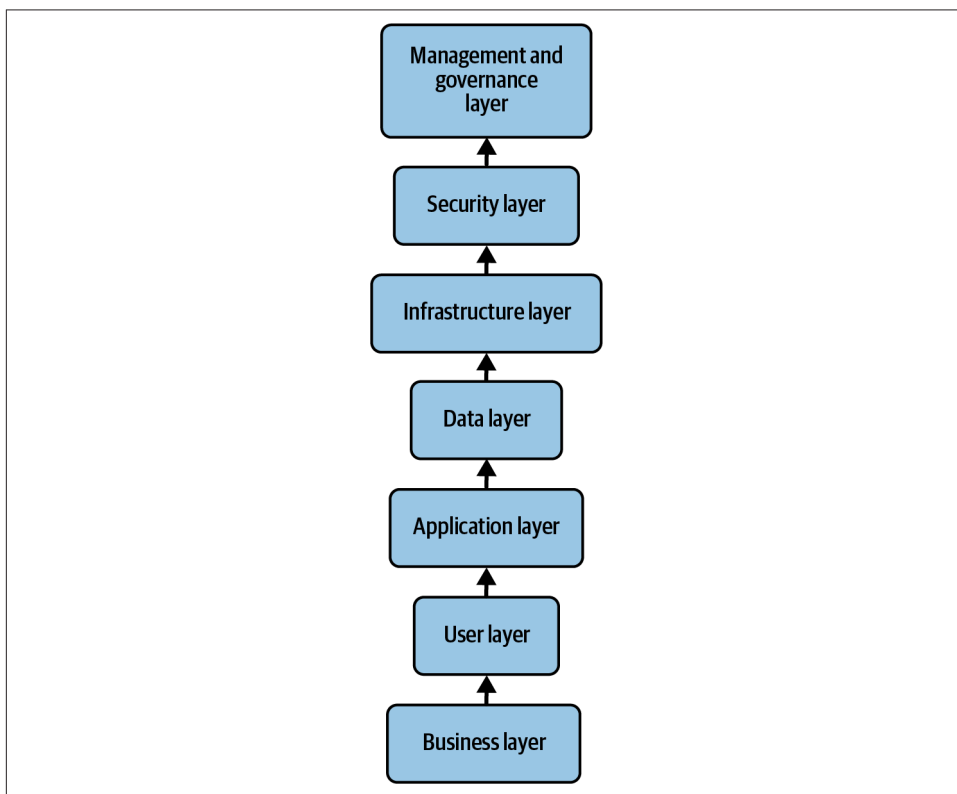


Figure 3-9. CSA Enterprise Architecture layers

From a security perspective, the architecture is concerned with the following 14 domains:

- Cloud computing concepts and architectures
- Governance and enterprise risk management

- Legal issues, contracts, and electronic discovery
- Compliance and audit management
- Information governance
- Management plane and business continuity
- Infrastructure security
- Virtualization and containers
- Incident response
- Application security
- Data security and encryption
- Identity, entitlement, and access management
- Security as a service
- Related technologies

The CSA also provides guidance on how to implement the architecture. It recommends assessing the current enterprise architecture, then identifying gaps in security and compliance. The CSA also recommends developing a road map for migration to the cloud environment. As the road map is developed and rolled out, security controls should be implemented across all the layers previously indicated. Once the deployment is in place, organizations should be implementing continuous monitoring and improvement. While many, if not most, organizations are already doing some level of monitoring, the continuous improvement is harder to achieve, since it requires well-understood processes, along with monitoring the performance and effectiveness of the processes and controls. This monitoring should be used to find inefficiencies.

The CSA does provide reference architectures and a Cloud Control Matrix that can be used to ensure the appropriate security controls are in place across all layers of the architecture. The architecture has also been developed to integrate well with other frameworks and standards, including NIST and ISO 27001.

DevOps Security

DevOps has become a common practice. This is especially true now that native applications are not as predominant. Cloud deployments are not focused on native applications but on web applications. With web applications, the same company that develops the application also has to maintain it, so making sure the development team understands what the challenges to operating the solution will be helps reduce costs on the operations side. It also helps to reduce friction in the workspace, where engineering teams may not be looked upon kindly by operations teams if engineering makes things too onerous to manage. This is an area I experienced in the late '90s and

early 2000s working at a large internet service provider that offered managed security solutions. When engineering did not factor in the needs of the operations team, operations regularly complained about engineering. This is not a good working environment, since everyone should be working for the good of the customer and the organization.

One of the most important objectives of DevOps practices, where the development and operations team meet, if not merge, is to reduce the amount of time it takes to develop and deploy a solution. Another equally important element of DevOps practices is to increase quality, which may be enabled through faster development and deployment cycles, since vulnerable code does not need to sit in production for long periods of time. Some of the common elements of DevOps include:

Collaboration

There should be a focus on breaking down the walls and barriers between the different teams responsible for delivering and managing the solutions. One element of this should be increased communication.

Automation

A significant hallmark of DevOps practices is automation. This helps to ensure speedier development and delivery of products, and also increases quality by reducing human errors.

Continuous integration

Code should be regularly merged into a centralized code base, so the primary repository is always up-to-date with fixes and features.

Continuous deployment

Automation is essential for the ability to continuously deploy new code into either staging for testing or to production for users to pick up.

Infrastructure as Code

Rather than manually building and deploying infrastructure, programs, scripts, configurations, and templates can be utilized for consistent and repeatable deployments. The code can then be tested and managed for enhanced quality and reliability.

Monitoring and logging

Operations is responsible for monitoring and managing the deployment, so logging is essential to provide data and telemetry to know what is happening in production.

Microservices

Applications should be developed in small, separable components rather than into a monolithic architecture. This helps with manageability, as well as with

deployments and testing. It reduces the potential interaction from one service to another.

There are areas within DevOps where security is naturally enhanced just because of the practices employed. One example here is the use of microservices, since the attack surface can be reduced substantially by not having a single, enormous application running that might be exposed to the outside world. Instead, small pieces can be exposed to the outside world, as needed, while other pieces can be protected behind layers of networks and other security controls. The practice of actually introducing security into the DevOps practices is called DevSecOps. This means that the security team members become active members of the overall development team, with a seat at the table to express concerns or articulate requirements. It also allows the security team to work more effectively with development and operations, rather than potentially being seen as a roadblock or hindrance to the work of getting applications deployed into production.

Beyond the natural enhancements to security that DevOps practices can offer, there are areas where security can easily be implemented. First, the focus on collaboration means that security team members can be part of the conversation to help ensure resources are protected effectively. When it comes to code development, a common practice is to review any code that has been checked into the central repository before merging it into the code base. While other developers commonly review the code for potential new bugs, code conflicts, or stylistic issues, security team members can review the code to ensure no areas of potential vulnerability are introduced.

The use of code pipelines to streamline merging, building, testing, and deployment facilitates security functions. This includes adding static code analysis tools into the pipeline. Where humans will offer a perspective by performing code reviews, static code analysis tools can provide another layer of insight into potential problems with the code. If serious enough, these problems could be kicked back to the developer for resolution before going further into the build and deployment stages. Other issues can be flagged for subsequent code changes and builds, as needed.

With a focus on automation, including automated testing, security can be introduced into the testing phase using dynamic security testing tools. Many tools can be fully automated to do some testing without any human intervention. While these tests may not be as deep as those performed manually by a human, using creativity, curiosity, and analysis, the fact that you can perform them in an automated fashion with every pass through the code pipeline provides some security testing ahead of builds. It's often the case that security testing is done after deployment because of the time-consuming nature of manual testing. Doing at least an initial pass of scanning and checking for basic vulnerabilities can help catch issues before deployment.

With so much automation, there is a lot of code around. This not only includes the application code but also code used to build environments. This should be protected

with strong access control practices. The same is also true when it comes to container images that are used. As there is a potential for inheriting problems from open repositories, it's best to house your own images for your applications. This way you are sure all the components have not been tampered with and you are getting something that is as clean as possible.

There is much that can be done with security from the perspective of DevOps. This is especially true if the security team is fully brought into the realm of the overall development team, where they can make significant contributions.

Evaluating Cloud Provider Security

You are not entirely on your own when it comes to the security of your project hosted with a cloud provider. Especially if you have to be in line with laws and regulations, you may need to be particularly aware of how a cloud provider manages its business and the computing resources you are using. If you are putting significant informational assets with them, you should be keenly aware of their overall practices. Usually, it's helpful to have a framework to review these practices. Fortunately, there are some that can be beneficial so you can ensure what you are doing will meet with common industry expectations.

One of these is from the Payment Card Industry (PCI): the Data Security Standard (DSS). The PCI DSS provides guidance on how to handle any data associated with processing and storage of payment card information. The PCI DSS is broken up into six groups of requirements that payment card processors are expected to adhere to:

- Build and maintain a security network and systems.
- Protect cardholder data.
- Maintain a vulnerability management program.
- Implement strong access control measures.
- Regularly monitor and test measures.
- Maintain an information security policy.

None of these sound especially onerous, but these break down further into 12 essential requirements that have not changed in all the years that PCI DSS has been in existence.

These are the 12 requirements anyone handling payment cards is expected to have implemented:

- Install and maintain a firewall system to protect cardholder data.
- Avoid vendor-supplied defaults for system passwords and other security parameters.

- Protect stored cardholder data.
- Encrypt transmission of cardholder data on open, public networks.
- Protect all systems against malware, and update antivirus software or programs.
- Develop and maintain secure systems and applications.
- Restrict access to cardholder data by business need to know.
- Identify and authenticate access to system components.
- Restrict physical access to cardholder data.
- Track and monitor access to network resources and cardholder data.
- Regularly test security systems and processes.
- Maintain an information security policy that addresses information security for all personnel.

Even these requirements, on the face of it, don't seem like they are too bad. However, these 12 requirements break down further into 220 subrequirements. You may notice if you look closely at the 12 requirements that they are very vague. There are no implementation details. The PCI DSS is more than just guidance, as well. Yearly, organizations are expected to certify their compliance. Depending on the volume of transactions they process, the certification can be as simple as a self-assessment, or an external security assessor might need to be brought in to evaluate compliance with the standards.

If you are looking at handling payment cards at all in your cloud deployment, you should be looking at whether the capabilities of your chosen cloud provider will live up to the expectations of the PCI DSS. Because this will be infrastructure that you are responsible for, at least to some degree, and because you are processing or handling payment cards through this infrastructure, it will be subject to assessment just as if it were being done on premises in your own data center.

The PCI DSS may be a standard you have to comply with, but it is focused specifically on cardholder data, which is good for that information but doesn't cover other practices or elements of the infrastructure. There are other ways to assess the practices of your cloud provider. The International Organization for Standardization (ISO) has two standards you should consider. The primary one is ISO 27017, which is about security controls for cloud providers. However, it is based on top of ISO 27002, which includes guidelines and best practices for the implementation and management of an information security management system.

ISO 27002 includes organizational, people, technological, and physical controls. Across all those areas, there is guidance for policies, roles and responsibilities, access control, cryptography, communications security, and supplier relationships, among much else. ISO 27017 lays over the top of that foundation, adding controls that are

specific to cloud providers. The areas that cloud providers can and should be assessed under are as follows:

Shared roles and responsibilities

This is the Shared Responsibility Model, making sure there are clear lines of demarcation as to who is responsible for what between the provider and the customer.

Removal of cloud service customer assets

This should be reviewed with any cloud service provider, ensuring that when a customer leaves, all assets are returned to the customer or destroyed, as required. There should be no data left behind after a customer leaves, even on backups.

Segregation in virtual computing environments

Customers should know that their assets are fully segregated from other customers and, to the extent possible, how that segregation is being accomplished to ensure there is no possibility of another customer getting access to customer resources.

Virtual machine hardening

All infrastructure maintained by the cloud provider, including virtual machines provided to the customer but managed by the provider, should have hardening standards applied to them. Those hardening standards should be documented, at least from a methodological perspective.

Administrator's operational security

Administrator access should be documented and controlled.

Monitoring of cloud services

Cloud services should be monitored and managed accordingly. Information related to a customer should be conveyed to them by the cloud provider as needed.

Cloud service customer data alignment

There should be an alignment on handling data between the cloud provider and the customer. This should include ensuring that data deletion and retention policies are in sync. Otherwise, the cloud provider may retain information longer than the customer has specified, which could put them out of compliance with laws or regulations.

Beyond overall guidance for information security programs, like those discussed here, there may be specific areas that also have requirements. This could include the Federal Information Processing Standard (FIPS) 140. FIPS 140 provides requirements for encryption of nonclassified information. If you are handling particular types of data, you and your providers may be required to adhere to the FIPS 140 standard. This means your cloud provider will have to adhere as well. Similarly, you and your

providers may fall under the Common Criteria for Information Technology Security Evaluation. You can see a hierarchy of the areas the Common Criteria covers in [Figure 3-10](#).

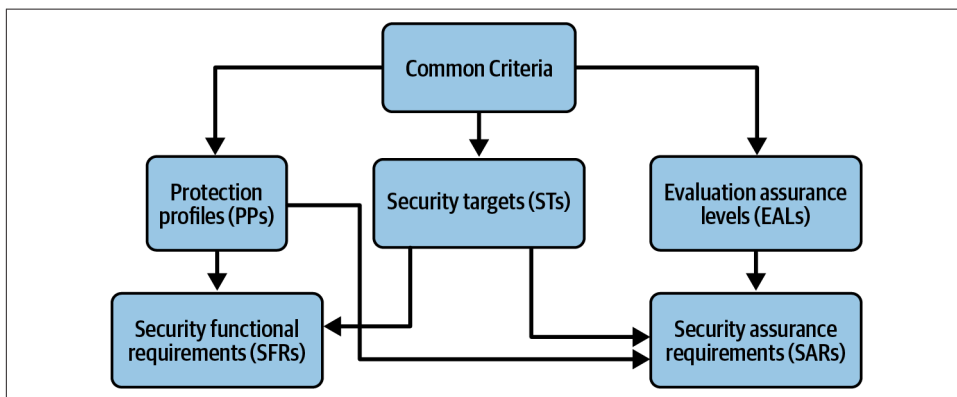


Figure 3-10. Common Criteria for Information Technology Security Evaluation

The Common Criteria provides a framework for a rigorous evaluation of information security products and technologies. You should be aware if you should be following the Common Criteria, which is an international standard. As with many comprehensive standards, the Common Criteria can be a very time-consuming and expensive process. While it provides standardization and rigor to the evaluation process, it may be more than you want to take on to evaluate a cloud service provider.

Summary

There are a lot of elements to information security, and most of the ones you should already be familiar with come over to the cloud environment just as they do in an on-premises world. There are some differences because of the Shared Responsibility Model where the cloud provider has some responsibilities, while in your own data center you would be responsible for everything. When you are working with cloud providers, you will still need to be aware of threats. Most of the threats that already exist for you and your business also exist in the cloud, but there are some nuances to be aware of. Similarly, when you are implementing controls in the cloud, you will need strong identity and access management practices, since users and their account information are always going to be targets for attackers.

You will also need to be responsible for network security for your own infrastructure if you have virtual machines or containers. If you are using software as a service solutions, you may not need to be responsible for that. You will, though, always be responsible for data protection, and you may also need to take care of cryptography to be certain that data is always transmitted using encryption. Where possible,

encrypting data at rest is a good idea, though it's always valuable to keep in mind that if an attacker compromises an account that has access to that data, the encryption will not help keep them away from it. This is why identity and access management is so important.

Strong hygiene practices, like patching and vulnerability management, will also help protect your assets. Policies and standards, and ensuring everyone is complying with them, can be beneficial, especially ensuring that privileged user access is tightly controlled and monitored.

When it comes to designing solutions in the cloud, starting with a business impact analysis can be really important to fully understand how processes, functions, and services can affect the company, as well as dependencies. Following this, there should be effective business continuity and disaster recovery processes in place that are regularly evaluated, tested, and updated. Even though you are using a cloud provider, it is not infallible, so business continuity and disaster recovery remains your responsibility.

Collecting requirements from all stakeholders, including functional requirements and nonfunctional requirements, especially those from a security perspective, is essential for any development activity. This should also include operational requirements since, with cloud deployments, the operations team and the development team are generally with the same company and everyone should be working toward the success of the company and its customers. This falls under DevOps, which has the potential to increase customer satisfaction while also increasing the overall security of solutions if the DevOps practices are followed and especially if security is involved from the beginning.

When you are looking at a cloud provider, you should consider using a framework for evaluating its security practices. In some cases, this may be a requirement, as would be the case for the PCI DSS. Ensure you understand the requirements provided by the PCI DSS. For a broader perspective, while providing more specific details on how to evaluate a cloud provider, consider ISO 27017 and ISO 27002, which it relies on. You may also look at other specific requirements that may apply to you, including the Common Criteria.

Other Resources

The following pages provide more details or other viewpoints regarding cloud security and cloud architecture:

- “What Is Cloud Security?” Google Cloud (<https://oreil.ly/FGLPg>).
- “What Is Cloud Security?” Check Point (<https://oreil.ly/BBnIf>).
- “What Is Cloud Architecture?” Google Cloud (https://oreil.ly/V01F_).

Cloud Data Security

Topics covered in this chapter include:

- Cloud data concepts: types, location, lifecycle, and dispersion
- Cloud data storage architectures
- Data protection technologies and strategies
- Information rights management

While information security itself can be an exciting and fascinating topic, the reason we engage in the practice, at least with respect to working with organizations, is to protect resources. Without that protection, businesses and other organizations can be put into dire circumstances, which could result in existential events, meaning they could be put out of business. This is a worst case scenario, of course, but it's entirely possible, especially with catastrophic incidents if the organization doesn't have the right contingencies in place. So, why bring this up? Because data is an important resource to any organization. In most cases, it is foundational to running the business, agency, or nonprofit.

Since data is such a significant and important asset, protecting it should be an important part of the job of an information security professional. Unfortunately, understanding the complete data lifecycle is not always very common, and many organizations may not do a good job fully protecting data, especially as data has moved outside of the traditional perimeter where there is more control over it. We will also discuss how to protect data using cloud services, including encryption, as well as asset tagging and monitoring data as it moves and is used.

Fortunately, cloud providers, as with so much else they do, have opened up capabilities that were previously harder for organizations to take advantage of. These include making it easier to use and manage different data types, as well as opening more ways

of storing that data. In this chapter we will discuss the essentials of using cloud to store and manipulate data, including an overview of the lifecycle and understanding how data is used, as well as where it goes. This includes data classification to better understand the impact of data loss or corruption on the business.

An advantage of talking about the data lifecycle is to discuss the entire process of data usage, since there is often a lot of focus on storing and transmitting data but less on the data end of life. This includes understanding data retention needs, as well as the needs when it comes to data destruction. There is a time when it is better for data to not be retained, and it may not be a good idea to keep some data indefinitely. As much as you may want to keep all your emails around forever to help remember conversations or information that was sent to you, it may be detrimental to the business and expose the organization to the possibility of threats.

Cloud Data Concepts

Data is something we all work with every day, and yet most people probably don't think about it at all. Even this text is just data. It is being written as I type, sent off to storage in the cloud somewhere, where it becomes data at rest, unless I bring it back up to do some editing if I decide I don't like what I wrote or one of the many editors on the project end up objecting to something. While data is all around us in the information technology space, because we are constantly working with it, we likely don't even consider it as a separate entity. Because of that, we are unlikely to have thought about the processes by which data is created, stored, transmitted, managed, and protected. This section is all about the data lifecycle and how data is used within organizations, including how it disseminates and flows from users to applications. Additionally, you'll get an understanding of the different types of data you will run across, which will be especially of use in cloud security contexts because of the different ways data is often stored and managed there.

Cloud Data Lifecycle

Data passes through multiple stages and phases throughout its life. Just like humans, data does and should have a complete lifecycle rather than expecting it will live on in perpetuity, which is generally not advisable, nor is it entirely realistic. Museums can keep historical documents, but businesses may find keeping a lot of old information around not only costly but also potentially a liability. The stages of the data lifecycle are:

1. Data creation/ingestion
2. Storage
3. Processing/organization

4. Usage/analytics
5. Archive/retention
6. Deletion/destruction

Figure 4-1 shows the flow of data through the entire lifecycle, showing not only the stages, but also some of the steps that may be taken to get from one stage to another. While you may not have thought much about each of these stages, they are all a normal part of the life of data and information processing. You can liken it to the life-cycle of any organism, actually, since all organisms are created, go about their life, and at some point die. The same is true for data.

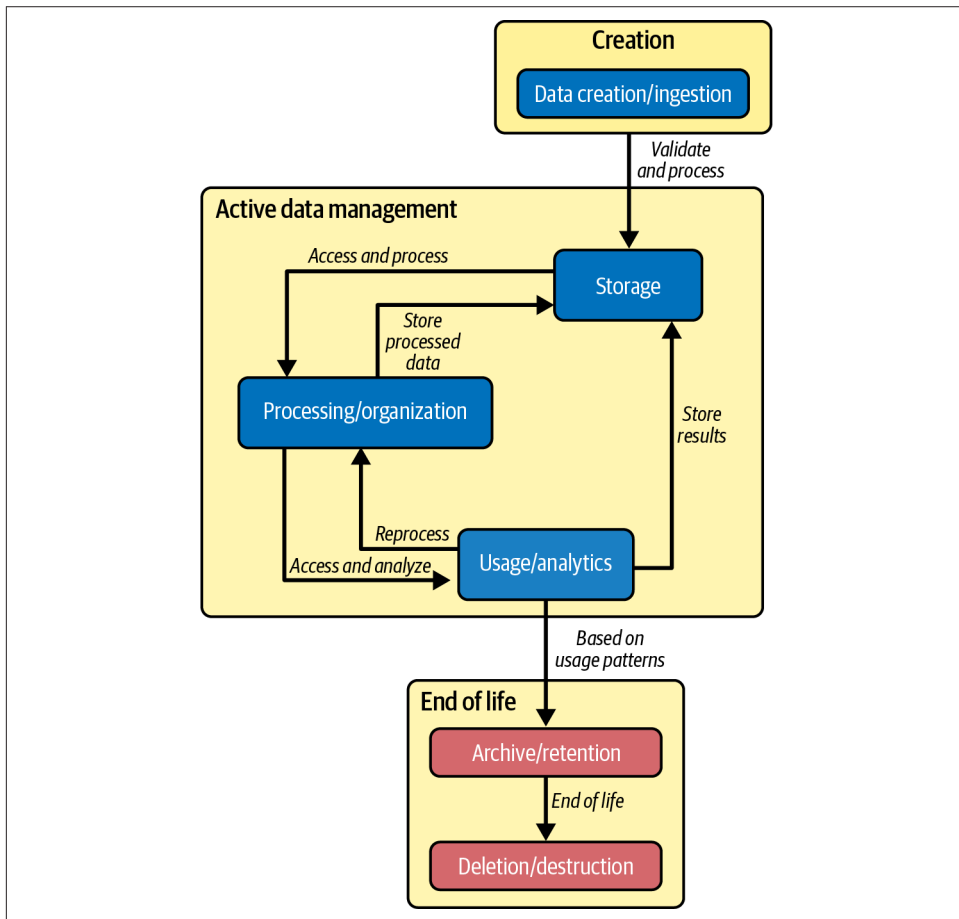


Figure 4-1. Data lifecycle process flow

Data creation/ingestion

In the beginning, there was nothing. Then, suddenly, there was data. Businesses, organizations, and people all create data. Even if you do nothing at all with word processing documents, spreadsheets, slides, photos, music, or any other common data artifacts, you probably have email. Or even text messages. These are all examples of data. In fact, your mobile device or laptop has data, regardless of whether you generate it or not. The simple fact of running an operating system generates data. Configuration files, log files, or other indications that there are processes running on a computing device are all data. The programs themselves are data, in that they are bits of information that can be utilized.

The first stage, as you may have guessed, is data creation. Writing an email is data creation. Putting information into a spreadsheet is data creation. Even running a program is data creation, since log information is likely created, especially on Windows systems where such information is tracked closely. On Linux systems, changes to running processes alter the pseudofilesystem that keeps track of anything executing in memory. It is considered a pseudofilesystem because it only exists while the system is operational and not when it is powered off. The simplest of things create data. It is not always an active process.

You don't have to actually be the one who generates data, though. It can be created somewhere else and ingested into your systems. The ingested data may come from sensors or security systems. Not everything has to come from being entered or generated by humans. Programmatic devices are as likely to be sources of data ingestion as anything a person may create.

Storage

The next step is storage. Initially, data is likely stored in memory, sometimes called primary storage. Secondary storage is something like a disk or other type of drive. Whether this is locally connected or somehow network connected, the medium is effectively the same. At some point there is an electromagnetic device of some sort that is maintaining information long-term. As indicated, this does not have to be local, however. Even in the case of cloud computing, the storage device may not be directly connected in a traditional sense to the primary computing platform.

When it comes to storage as a service, the data will always be stored remotely. Access is going to be across the network. Not that any of this much matters, since your access may end up being much the same, but it's still essential to know that at some point, data is going to be stored somewhere and how you access it is going to be a consideration. Storage should also consider not only real-time access, meaning online, but also offline or backup storage. You will want to protect data by ensuring it is backed up in case the online storage is compromised in some way.

Processing/organization

Processing and organization are about how you use and manage the data once you have it. This includes whether you are working with files and where those files are stored, or whether you have a database, either relational or nonrelational. That is the organizational piece, and you might think the processing part speaks for itself. However, processing is distinct from usage. Processing, in this context, means taking data and manipulating it to put it into a format where it can be used. This may simply mean taking raw data and storing it in files or databases, using the organization structures that have been decided on.

You may also think about processing in the context of creative endeavors. I have a setup where I have a MIDI keyboard, an input device to take guitar and bass into a computer, and an electronic drum. If I record myself playing the keyboard, it is a software instrument that I am playing, so the sound comes through the computer. The input comes in from the keyboard using digital signals. That's the creation process, but then it needs to be processed by Logic Pro, which is the digital audio workstation I use. This is done for two reasons. First, the computer needs to take MIDI signals from the keyboard and send them to Logic Pro, which needs to process them to understand what they mean in the context of the piece of music I am playing. Once Logic Pro has taken the input, it needs to organize it so it can make sense going forward.

This example shows how the data lifecycle crosses from one phase to another. We just walked from creation to storage to processing and organization, and there is a little crossover because primary storage, where the data is originally when it comes in from the MIDI keyboard, is ephemeral. At some point, if you want to use it going forward, the data needs to be written out in an organized way with other data to secondary storage, meaning disk.

Usage/analytics

Once data has been processed, it is ready for usage. Usage is any time data is taken from its at rest or stored state and brought into memory to be worked on by an application. This is not necessarily where a user does something with the data directly, as might be the case when spreadsheets or word processing documents are being edited, for example. This could also be background processes that have no user involvement. If data is being read and analyzed, that is usage. Data may not even need to be changed, necessarily. It just needs to be taken out of hibernation, if you will, and used.

In a cloud environment in particular, everything is about analytics. Data is constantly being collected. When you access your own data, there will be logging records to indicate the access. You may think about this as metadata because it is data about data. That will also follow the same lifecycle. It may or may not be your data, in the sense of having access to it, but your data and your access will be analyzed because it's

important to understand what is happening. Remember, data is probably the most critical resource being managed within your cloud environments. It's not about systems, it's about what the systems are doing and what they are storing and processing.

Without analytics, it is difficult to manage your environment. Analytics provides essential insights into not only how your systems are operating but also how your data is moving and who is accessing it. Analytics will help to drive the identification of potential misuse of data and systems. All of this does, though, generally require additional systems and the movement of more data. Log collection systems, security information and event management systems, investigation stations, and other systems are now in the mix where data is passed.

Archive/retention

It's possible that data may be used for years and years. However, it's just as possible that there may be long gaps between usage. Consider photos you have taken and stored digitally. Are you looking at them regularly? Perhaps the more recent photos, but older photos might be stored but not accessed very often, maybe for special occasions or when someone is feeling especially nostalgic. It's possible you are keeping them on your hard drive for just that moment when you have a flicker of a memory and want to relive a moment, but it is just as likely that you have offloaded the storage of these images to another device. This may be an external drive, for instance, where you are keeping data longer term. The same is true of businesses and other organizations. They have data they are storing, but at some point they may want to free up space for more recent information, so they archive some files.

When files or other data are archived, it may be done in a nearline fashion so they may be moved from a local device to a network fileshare for example, where additional effort is needed to access the remote system to look at the files. It may also be that these files are stored completely offline. You can have online, nearline, and offline storage. Online means the files are readily available. Nearline means they are still generally available but you would need to do something to get to them by accessing a remote system, for example. Offline means you have to do something physical to get access to the files. In the case of the external storage device, you would need to go get the disk, assuming you remember where it is, and plug the device into your computer. The disk would then need to be mounted so the files and data could be accessed.

Archiving is an important step, especially since access to the information still needs to be restricted. Maybe you have some really personal information, like intimate photos, for example, and you've offloaded them onto your external storage device. Unlike your computer, where someone would have to log in, external storage devices may be as simple as plug and look. You can solve this by locking up the storage device or encrypting it so it can't be read without a password or key.

Archiving doesn't just happen, of course. Businesses will often have retention policies. One reason for that is compliance with regulations or industry guidance. Keeping data around indefinitely is generally a bad idea, which is why some regulations and lists of controls suggest removing data after specific periods of time. One reason against keeping data around for a long time is that the organization may become a target for attackers who want access to the data. In some cases, attackers will make use of any data they can get because it can be used against the organization. Removing old data when it is no longer explicitly needed reduces the potential exposure.

In addition to security considerations, there are financial considerations. Data consumes storage space. Storage space costs money. Certainly, storage costs keep coming down, but a lot of data will take up space, and that will eventually cost money. There are other drivers for retention requirements, but it's generally considered important for organizations to identify the amount of time data is allowed to remain stored. This is usually based on the classification of the data. Data with a higher level of sensitivity may have different retention requirements than data with lower levels.

Deletion/destruction

You start with a filesystem, which includes all the data you have stored as well as all the metadata about those files. You create a file, then at some point you delete the file. In reality, though, you haven't really deleted it. In most modern operating environments, you don't directly delete files, you move them to some version of a trash can. This is a two-step delete process where you move the file to the trash can, then you empty the trash can. Of course, even then your files aren't actually deleted. Instead, depending on the filesystem in use, they may just be marked as deleted. You can see an example of this in [Figure 4-2](#), where a disk image shown in the forensics tool Autopsy shows some deleted files. The data is still in the disk and can be extracted easily enough.

<- Oct 2024 Summary Dec 2024 ->						
		Nov	2024	OK		
12288	m..b	d/drwx-----	1000	0	11	/1/lost+found
12288	.ac.	d/drwx-----	1000	0	11	/1/lost+found
2638	macb	r/rw-rw-r--	1000	1000	13	/1/emails.txt
0	.a.b	-/rw-r--r--	1000	1000	14	/1/\$OrphanFiles/OrphanFile-14 (deleted)
690	macb	r/rwxrwxr-x	1000	1000	15	/1/api_requests.py
5003	macb	r/rwxrwxr-x	1000	1000	16	/1/getDoc.py
1485	macb	r/rw-rw-r--	1000	1000	17	/1/.keystore
0	.a.b	-/rw-rw-r--	1000	1000	18	/1/\$OrphanFiles/OrphanFile-18 (deleted)
5230	macb	r/rw-rw-r--	1000	1000	19	/1/paros.message.txt
0	m.c.	-/rw-rw-r--	1000	1000	18	/1/\$OrphanFiles/OrphanFile-18 (deleted)
0	m.c.	-/rw-r--r--	1000	1000	14	/1/\$OrphanFiles/OrphanFile-14 (deleted)

Figure 4-2. Deleted files in Autopsy

Consider the case where the deleted files are removed from the filesystem metadata because the blocks they are stored in have been repurposed. However, larger files consume multiple blocks. It's possible that only a smaller number of blocks are used by a new file, which can still leave significant portions of data on the disk to be recovered. All of this is to say that deletion might not be destruction. The data can still exist on devices.

There are two ways to think about destruction at this point: logical and physical. Logical destruction means removing all traces of the data on the disk. With magnetic disks, it is possible for multiple layers of the bits to be stored on the disk. This means you could extract many generations worth of data with the right equipment. The same is not true for solid-state storage devices, in part because addresses on the drive do not remain constant due to wear leveling. The same cell on a solid-state disk may have a different address from one use to another because cells are swapped in and out of use to ensure some cells aren't overused. When it comes to magnetic disks, the best approach is to overwrite the storage locations on a disk. While it was considered best practice to overwrite several times, NIST special publication 800-88 says a single overwrite should be sufficient to remove the data from the disk. For solid-state drives, generally the drive takes care of wiping the elements because of the TRIM command that makes and erases unused blocks on the disk.

Ultimately, the objective of destruction is to make the data irretrievable. You can logically destroy data using cryptographic means as well. This may be as effective and take about the same amount of time as overwriting data. You take disks, use strong encryption with as large a key as you can generate, then lose the key. This effectively results in random data on the disk.

The other means of destruction is physical. In an on-premises environment, as may be the case in private clouds, you will have disks. Those disks should be destroyed appropriately. While you can overwrite the disks, overwriting large disks can be time-consuming. Some organizations like to physically shred the disks. There are companies that offer the shredding service. They take metal hard disks and run them through a device much like a wood chipper. The disks are no longer usable or readable. This may be the best approach for physical disks to avoid any data that may remain on the media that could be retrieved.

Destruction should also take backups into account. If there is a requirement for data to be destroyed, you should ensure that the backups of that data no longer exist. Some companies may perform long-term storage of backups. If there is critical data that should be destroyed, the backups become a liability. This is, of course, one of the problems with data. It has the potential to spread, much like unchecked ivy. You need to protect the data so you create multiple copies of it. This means you have a lot of copies of this data in various places. You may have multiple backups to ensure the data doesn't get lost. All of these should be factored into the destruction of data. In part, this can be a data retention problem, ensuring there aren't really long backups that are stored.

Cloud data deletion and destruction is a different situation. As the media belongs to the cloud service provider in the case of a public cloud, it is up to the provider to ensure all traces of the data have been destroyed so there is no way to retrieve it. This should be a part of any contractual agreement with the provider. The contract should also include a right to audit, to help ensure there is evidence that the data was destroyed. Just as in an on-premises environment, backups are a consideration. A data inventory should also help you understand where data is stored to know what needs to be destroyed to cover the cases of multiple copies of the same data.

There is an advantage with the Shared Responsibility Model here as well. Data should be encrypted as a general practice. The provider takes care of the storage media and may actually perform some level of backups for their own purposes. The customer takes care of encryption and is the only one who holds the keys. Even if the provider has some of the data, whether it's on physical storage media somewhere or on some sort of backup, the encrypted information is not accessible without the key. Retrieving the data would require an attack on the key or algorithm used to encrypt it.

Crypto shredding may be necessary for data that is encrypted. Crypto shredding is the practice of destroying keys that can decrypt data. If the keys no longer exist, theoretically, the data becomes inaccessible. It is still good practice to overwrite any media, to the extent you can, with random data to prevent any possibility that the keys have multiplied over time with backups or automation.

Data Dispersion

Data grows legs. Or, if you prefer, spreads like ivy. Or maybe spreads to new grazing spaces under the watchful eye of a herding dog. Whatever analogy you prefer, there are several reasons why data may move around. People just move it because it's more convenient for them. Applications need it in different places. There is a need for replication of data for resilience or recovery purposes. Backups will create multiple copies of the data. Data may be stored in different forms. There is raw data that may be in a storage bucket, while formatted data may be in an application store. There are a lot of other reasons for data spread.

The point is that there are lots of reasons data goes walking, to be colloquial about it. There are a lot of impacts to the data lifecycle from dispersed data, though. It's possible there are many entry points to the environment for data. You can also have a lot of different storage locations for data. Processing and usage potentially become problematic once data is dispersed because you can end up with version problems. One person or application may consider one location the primary source of information, while another may think a different location is primary. Two or more people or applications are now working on the same data from different locations.

This is one reason why mapping data is important. Data mapping is the process of documenting where all the data kept by an organization is located. This is a good practice no matter whether your information is on premises or stored with a cloud provider. A complete data map should include key elements like data sources, data types, storage locations, processing points, access controls, retention periods, and data transformations.

A good way to document your data maps is with data flows. This should be a common practice for all application or even information technology teams. Those who are in the best position to know how the data moves around through the environment should be responsible for creating the maps and the data flows.

Data flow diagrams

A data flow is a diagram and associated documentation showing how data flows through an application or set of systems. **Figure 4-3** shows a sample data flow diagram (DFD) of a web application that has a mobile interface as well as a traditional web interface. The data that flows from the client through the application into the backend includes credentials, as well as information related to orders. This may include details about orders, including what is being ordered and payment information.

The data flow shows the customer, payment processor, authentication provider, order database, inventory database, and other services and systems. You can see the types of data that pass from one system to another. Just including the systems in the diagram

does not provide the complete picture. It's important to include the types of data that are being sent back and forth. Ideally, a data flow diagram should also include the protections that may be in place. This should include any encryption of the data from one system to another. In addition, ports and protocols should be documented.

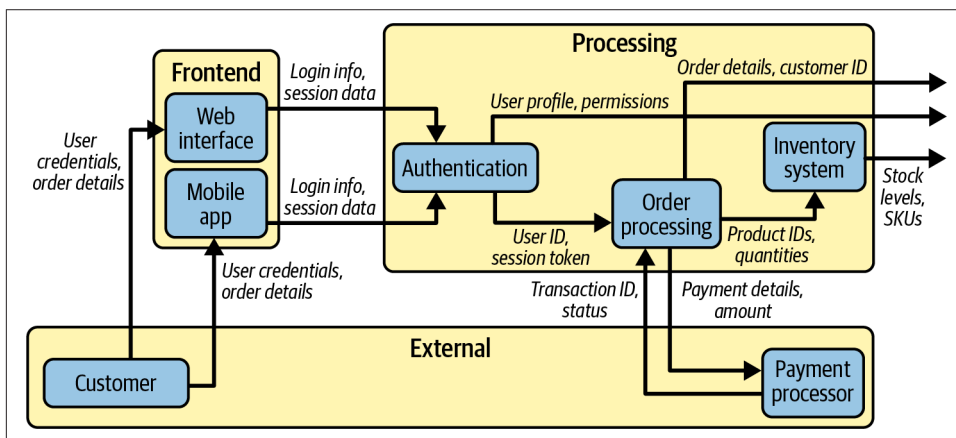


Figure 4-3. Data flow diagram

The diagram is helpful, but supporting documentation is also necessary to provide a full explanation of what is happening. Describe the protocols being used between systems and the protections being used to explain what is happening. Ideally, there should be justifications for the decisions with regard to protocols and any protective controls that may have been put in place, including encryption. A data flow diagram is generally more abstract than something like a network diagram or even an architecture diagram, which may include more details about the systems that have been deployed, including virtual machines or containers. While part of the architecture, and possibly included in a network or architecture diagram, these details are not necessary in a data flow diagram where the level of detail will be different. Similarly, a network or architecture diagram may not include the types of data that are moving around.

One important element when it comes to DFDs is documenting where the trust boundaries are. Trust boundaries are logical lines of demarcation between elements with different levels of trust or protection. Systems and the data that is handled on them will have different levels of sensitivity. Not all data is going to pass through all systems, after all. Even if the data is passed through multiple systems, some of them may not be able to see it. Encryption requires keys, and not all systems will have them.

Data transformations are important to document as well any time the information is changed in any way. Not everything is straightforward. Email addresses, physical addresses, and phone numbers may never get transformed in any way, other than

possibly being decrypted. That decryption is a transformation which should be documented, because now there is data that is in plain text. Some of it may be sensitive, because if any action is being taken on it, it wouldn't normally be done in an encrypted state.

These DFDs should not only be generated and kept, they should also be maintained over time. Applications change. Data requirements change. These updates require process to make sure changes in the applications are documented. Out-of-date DFDs can result in information leakage to locations where it may not be known or tracked. This can result in data dispersion and instances that may not be appropriately handled or disposed of.

Data Types

If you come from a programming background, you hear about data types and you may think integer, character, string, or something similar. That's not what we are talking about in this case, however. This is about how the data is organized. You have probably dealt with structured data, even if you didn't know it, since structured data just means the data has a known format that something knows how to deal with. Structured data has a predefined model, as well as consistent organization. Structured data also has clear relationships between elements.

SQL databases are structured data. There is a schema to a SQL database, meaning the fields in the database have definitions. This includes both the names of the different fields, known as columns, as well as the format of each field. It may be an integer, a text string, a blob, or some other known type of data. People don't typically interact directly with databases, but applications do. Also, if you are using a web interface for many applications, there is probably some sort of SQL database behind the scenes. This would typically be true of any ecommerce site, for instance.

Even Excel spreadsheets would be considered structured data. If you are using a spreadsheet, it is usually to organize information so each column has rows with related information. Maybe one column is a date, another column is an account number, and another is a monetary value. Each row won't have those values in different orders because it's harder to manipulate and correlate the information. You wouldn't be able to create charts and graphs from the data without a meaningful column structure. Because it is such a common piece of an office productivity suite, spreadsheets are usually the de facto "database" that people use. It is just a good tool for storing structured data, and for providing good input mechanisms like pull-down menus. **Figure 4-4** shows a section of a customer satisfaction survey spreadsheet available on Microsoft's website.

3. Indicate how many times per day you use the following communications services:

Outlook for Email	1 or Fewer	Over 1	Over 5
Outlook for Calendar	1 or Fewer	Over 1	Over 5
Outlook for managing Contacts	1 or Fewer	Over 1	Over 5
Outlook Web App for email, calendar, and contacts	1 or Fewer	Over 1	Over 5
Office 365 web portal for access to Outlook Web App	1 or Fewer	Over 1	Over 5
Office 365 web portal for access to Sites	1 or Fewer	Over 1	Over 5
Store and share your documents on OneDrive for Business	1 or Fewer	Over 1	Over 5
Store and modify team documents on SharePoint	1 or Fewer	Over 1	Over 5
Desk Phone	1 or Fewer	Over 1	Over 5
Skype for Business phone	1 or Fewer	Over 1	Over 5
Presence Status and Availability	1 or Fewer	Over 1	Over 5
Instant Messaging	1 or Fewer	Over 1	Over 5
Audio conferencing	1 or Fewer	Over 1	Over 5
Video conferencing	1 or Fewer	Over 1	Over 5
Content/Desktop sharing	1 or Fewer	Over 1	Over 5
Online or Web conferencing	1 or Fewer	Over 1	Over 5

Figure 4-4. Spreadsheet sample

Databases and spreadsheets are just a couple of examples of structured data. Anything that has a rigid, unchanging, defined structure would be considered structured data. Not all databases are considered structured data, though. NoSQL databases, where there isn't a rigid structure, would be semi-structured. These types of databases may use JSON and XML, which are also types of semi-structured data. Unlike other document types, which are entirely variable, there is defined structure to JSON and XML, but it is not a rigid and unchanging structure. JSON and XML are generally self-documenting in that the keys typically have descriptive names, while the values are data that relate to the keys. You can see sample JSON data in [Example 4-1](#).

Using that example, which is just a sample from a larger JSON document, you can see that the data is tagged with a name. There is a collection of data that is named "gifts," and within that collection is each day, named with the gift and containing the total number of that gift given over the 12 days. Even though this looks structured, there is nothing that can't be changed. You can see, for instance, that in the first day, there is a "trees" entry that isn't in the other days. In structured data, all the fields would remain the same over all the days, even if there wasn't any data in the field instance for a particular day. This may not be the kind of data that you'd bother storing in a database,

but it works well for JSON where you want some structure and definition without spending a lot of time creating a place to store all the data.

Example 4-1. Sample JSON

```
{
  "gifts": {
    "partridge_in_pear_tree": {
      "daily_counts": [1, 1, 1, 1, 1, 1, 1, 1, 1, 1, 1, 1],
      "total": 12,
      "trees": 12
    },
    "turtle_doves": {
      "daily_counts": [0, 2, 2, 2, 2, 2, 2, 2, 2, 2, 2, 2],
      "total": 22
    },
    "french_hens": {
      "daily_counts": [0, 0, 3, 3, 3, 3, 3, 3, 3, 3, 3, 3],
      "total": 30
    }
  },
}
```

JSON and XML are not really great examples from a user's perspective, since people aren't usually going to create this manually. We're also generally talking about technology so far, but there is a type of semi-structured data that has nothing to do with technology, since you may well have it stored outside of a computing device. My mother had data on 3×5 cards, for instance. Cooking recipes can be stored on cards, paper, in books, or digitally. The reason they are semi-structured is because there is a common, well-known structure to recipes, while the data can change. [Figure 4-5](#) shows a recipe for Welsh rarebit, sometimes known as Welsh rabbit. You can see the title, the timing information, the ingredients, and the directions.

A reason why this is semi-structured is that while the contents of the recipe are generally well-defined, it is possible to drop some fields. Some recipes may not include the timing elements, for example. Additionally, the contents of each field can be entirely free-form. Other examples of semi-structured data include email messages, where the headers that you don't commonly see have a known structure, but may change from message to message. Additionally, the headers you do see typically (To, From, Date, Subject) are there but may not have very well-defined requirements for what goes into them. None of those fields have any defined structure, because they are part of the data of the message. You can see an example of this in [Figure 4-6](#).

Classic Welsh Rarebit

Prep Time: 10 minutes

Cook Time: 5 minutes

Total Time: 15 minutes

Ingredients:

- 1 cup sharp cheddar cheese, grated
- 1/4 cup beer or ale
- 1 tablespoon butter
- 1 teaspoon Worcestershire sauce
- 1/2 teaspoon mustard powder
- Salt and pepper to taste
- 4 slices thick bread, toasted

Instructions:

1. Melt butter in a saucepan over medium heat
2. Add cheese and beer, stir until melted and smooth
3. Mix in Worcestershire sauce, mustard powder, salt, and pepper
4. Pour hot mixture over toasted bread
5. Place under broiler for 2-3 minutes until bubbly and browned

Serve immediately while hot.

Figure 4-5. Welsh rarebit recipe

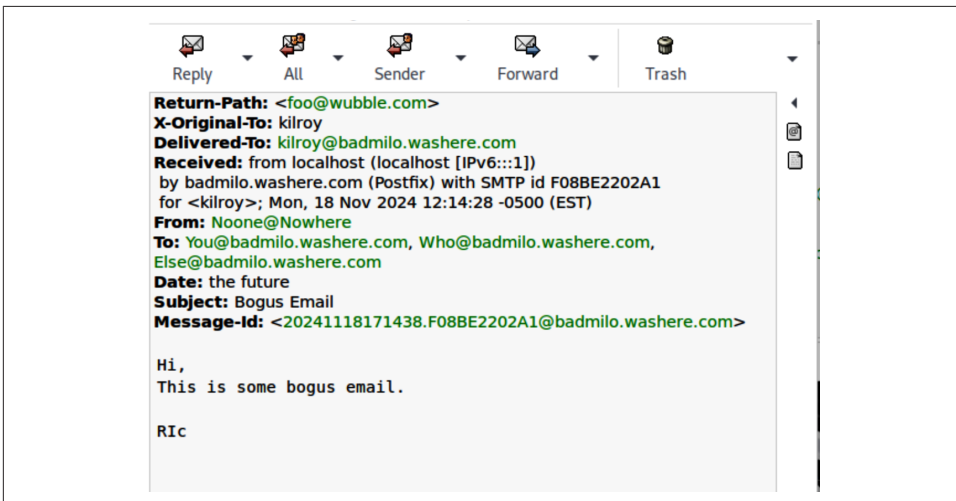


Figure 4-6. Email with bogus data

The To, From, Date, and Subject lines are just text. The actual headers that matter to applications that deal with email are all the other lines. The To line comes from using “You Who Else” in the To line when the email was sent manually, and the receiving server filled in the domain name it knew about.

Log data is similarly considered to be semi-structured, because while there is a generally agreed-on structure to log data, each log entry can be wildly variable. There are generally some essential fields in something like a syslog message, but they may not be required and the contents will change a lot, depending on what is doing the logging.

Based on this, you can see that you will have different types of storage and applications, depending on the type of data you are working with. This is important with cloud services, because it’s not like a traditional system where you have files, and each type of data is crammed into that one way of thinking about the world. In the end, using cloud services abstracts you from the way the information is stored, and all you have to worry about is the data itself and how it is managed and protected.

Data Location

The cloud is everywhere. While this has a lot of advantages, including the ability to keep services closer to customers, it can also cause complications. One complication is regulations or laws related to privacy. While California and New York, to name a couple of states, have strong privacy regulations, there is no particular burden on the business because the privacy regulations are based on where the business is located, or where the subject of the data is located. This is different from the General Data Protection Regulation (GDPR), which is Europe’s data protection law. The purpose of the GDPR is to protect individuals and their privacy rights. Unlike the US-based regulations, GDPR focuses on where the data is stored. This means you need to be aware of where your data is.

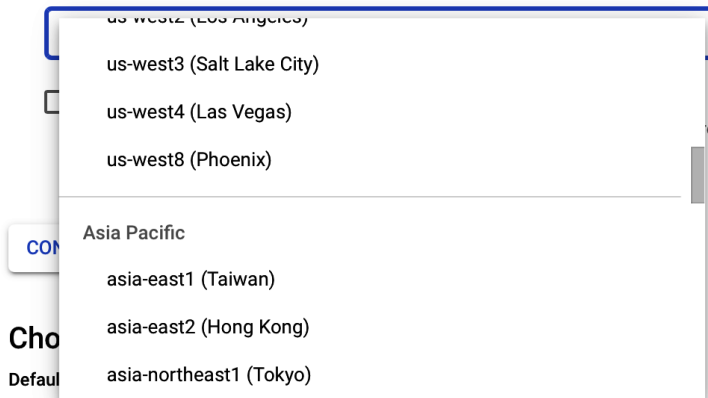
The larger public cloud providers generally have regions around the world where you can get computing resources, including storage. **Figure 4-7** shows a small sample of the different regions available with Google Cloud. There are locations in Asia, Africa, Australia, Europe, North America, and South America. Depending on need, there are multiple, if not dozens, of locations within each continent. As you can see in **Figure 4-7**, when you create a storage bucket, you can select multiple regions, which means you can store your data across several continents to ensure that customers who live in those regions have fast access to information.

Choose where to store your data

This choice defines the geographic placement of your data and affects cost, performance, and availability. Cannot be changed later. [Learn more](#)

Location type

- ☐ Multi-region
Highest availability across largest area
- ☐ Dual-region
High availability and low latency across 2 regions
- ☒ Region
Lowest latency within a single region



The screenshot shows a dropdown menu for selecting a storage region. The menu is open, displaying a list of regions. The first four regions are under the 'us-west' group: 'us-west2 (Los Angeles)', 'us-west3 (Salt Lake City)', 'us-west4 (Las Vegas)', and 'us-west8 (Phoenix)'. Below these, there is a section for 'Asia Pacific' with three regions: 'asia-east1 (Taiwan)', 'asia-east2 (Hong Kong)', and 'asia-northeast1 (Tokyo)'. A 'COM' button is visible to the left of the dropdown, and a 'Default' label is at the bottom left of the form area.

Region	
us-west2 (Los Angeles)	
us-west3 (Salt Lake City)	
us-west4 (Las Vegas)	
us-west8 (Phoenix)	
Asia Pacific	
asia-east1 (Taiwan)	
asia-east2 (Hong Kong)	
asia-northeast1 (Tokyo)	

Figure 4-7. Storage regions in Google Cloud

No matter where you or your customers are in the world, if data is stored in Europe, it will be subject to GDPR. China also has strong privacy regulation that would apply to customers or data located in that country. If you are thinking about storage in the cloud, you need to be aware of where your customers are, as well as protections and other controls that may be required based on privacy laws or other regulations that may be applicable to your data. This information should go into any decision making about the overall architecture of your solution. As privacy is a topic that has been gaining traction over many years, especially as more third parties are storing information, often out of the hands of both the data principals and data controller, this is a subject worth keeping a close eye on. Regulations continue to change, and new jurisdictions pass regulations from time to time.

Cloud Data Storage Architectures

With so many options for data storage, designing a complete solution can be a complex undertaking. There are different types of storage, depending on the application or usage. This includes the length of storage and its persistence, as well as the types of underlying technology used for storing the data. Anytime you are designing a solution, you need to be concerned about threats to the information resources. Based on those threats and the overall goals of the implementation, meaning business and user requirements, there will be other design considerations.

Storage Types

With so many different types of compute resources using cloud providers, there are likely to be multiple types of storage to go along with them. Some of this is dependent on the design and architecture of the solution being provided. Perhaps the easiest place to start is with traditional compute resources, meaning a virtual machine with attached storage. This is called instance storage, and is considered to be ephemeral. The reason for this is when the instance is terminated, all compute resources are returned to the overall pool to be used by other customers. This includes the disk space that had been allocated. The primary disk associated with the operating system (e.g., the C: drive under Windows) is instance storage. Anything that is stored on that volume will be gone if you terminate the compute instance. That doesn't mean pausing or suspending the instance. Termination is deletion.

You can avoid this by using long-term storage. This would be something like the Simple Storage Service (S3) offered by Amazon. Azure has Cool Storage, and Google Cloud offers a similar solution. This storage is common for any data that needs to be separate and distinct from the compute instance. If you have important information, it should be stored in long-term storage. No matter what happens to the compute resource, the storage is separate and won't be affected. If you have a traditional compute instance, the storage will be mounted as a regular disk. On a Windows system, it will show up as a D: drive or some other letter. On a Linux instance, it will be mounted as a mountpoint within the overall filesystem.

S3 and other blob storage may commonly be used for online, real-time access. However, there are other levels of storage, even within a service like S3. S3 Infrequent Access (IA) can be used for warm, rather than hot storage. It has similar availability to normal S3, but costs are different and access may take longer than the instant access available from the regular storage products. The expectation of S3 IA is that you will maintain your data for a minimum of 30 days. Storage costs are lower, but access costs are higher. This type of storage is not designed for running applications, but can be used for backups or disaster recovery needs. Essentially, it is for any data that you need to keep around but aren't going to be reading/writing on a regular basis.

Finally, there is archival storage. This is what you would use if you don't need quick access to the data. Amazon S3 Glacier and Google Cold Storage are products available for this archival storage. **Figure 4-8** shows the selection of the availability for Azure storage accounts. It can take hours to retrieve information from cold storage products. You would use this for anything where you had to retain it but didn't need regular access. This could be used for compliance purposes, for instance, or for long-term backup storage.

In addition to the types of storage products discussed so far where the storage and access are completely managed by the provider, block and object storage products are available. This essentially exposes the underlying storage to the compute products. Something like Amazon Elastic Block Store (EBS) or the Azure classic disk storage product provide block storage, which would work just like a normal disk connected to a physical machine. As these look like any normal disk from the perspective of your virtual machine, you can do whatever you like with them, including partitioning and formatting them. You are in control of the device. If you are familiar with computing devices where you have some measure of control over your hardware, such as with Windows or macOS, these devices will look and behave just like you are used to a disk behaving.

Hierarchical Namespace

Hierarchical namespace, complemented by Data Lake Storage Gen2 endpoint, enables file and directory semantics, accelerates big data analytics workloads, and enables access control lists (ACLs) [Learn more](#)

Enable hierarchical namespace

☒

Access protocols

Blob and Data Lake Gen2 endpoints are provisioned by default [Learn more](#)

Enable SFTP

☐

Enable network file system v3

☐

The current combination of storage account kind, performance, replication, and location does not support the NFS v3 feature. [Learn more about NFS v3](#)

Blob storage

Allow cross-tenant replication

☐

Cross-tenant replication and hierarchical namespace cannot be enabled simultaneously.

Access tier

☐ Hot: Optimized for frequently accessed data and everyday usage scenarios

☐ Cool: Optimized for infrequently accessed data and backup scenarios

☒ Cold: Optimized for rarely accessed data and backup scenarios

Azure Files

Enable large file shares

☒

Figure 4-8. Selection of cold storage in Azure

Any application that you would use a traditional disk storage device for would work with a block storage device. This includes creating a separate device to store files on,

or a device you want to store databases on to keep the storage separate from the disk with the operating system. One advantage here is the disk will be kept, no matter what happens to the virtual machine. This means you can carry the data from one virtual machine instance to another. The only consideration would be whether the operating system you are using could read the filesystem on the storage device.

If you have worked with cloud storage products, you may be more familiar with object storage. Amazon S3 buckets, for instance, are object storage. With object storage, you don't have the same sort of access as with block storage. While you could locally mount an S3 bucket or other object storage product as though it were a local disk, these types of storage products are not meant to be interacted with as though they were attached storage. There are performance penalties to using them in that way, and there is no native way to mount them to a local operating system without additional software that would provide a driver to allow that local attachment to happen.

When it comes to object storage, you don't see the underlying filesystem or similar level of insight into what is happening under the hood. This is by design. The idea is that you just take care of the information being stored there and the cloud provider takes care of everything else for you. Ultimately, there isn't a lot of difference among object or blob storage, and block or file storage. If you were to get a listing of the objects in an S3 bucket, which you could do, they would look like files because ultimately, there needs to be a way to organize the data. You don't just store bits blindly on these devices without a way to get to those bits in a coherent manner.

Just as with file storage, object storage stores the data as well as the metadata associated with the object. This is, of course, data about the data, which means type, size, and so forth. This is similar to the data stored in your filesystem, since the filesystem stores metadata about the files. One thing you will often get from object storage that you won't get from your local filesystem is versioning. The object storage may retain older versions of the data. Typically, each object would get a unique identifier. This may be a globally unique identifier (GUID), and it's used to identify the object or data without any regard to any filename or description of the contents of the blob, since you can get overlaps that way. While a lot of applications use GUIDs, there are 3.4×10^{38} potential GUIDs available, which will take a long time to get through even if all are truly unique.

One thing about cloud object storage is that it is typically accessed with a URL. This means you can access storage with web-based protocols, as should be expected with a cloud platform. This is unlike typical network-based file access protocols. You may not get a true URL in the form *file://location/file* with regular network-based file access. When you are talking about cloud object storage, the expectation is you will typically reference the object using the URL.

Finally, one last type of storage is filestore, as in Google Filestore, Azure Files, and Amazon EFS. This is a traditional hierarchical file storage service. It works just like if you had network file sharing on the corporate network. With these storage services, you would commonly access them using Server Message Block (SMB), which would be typical for Azure Files, or Network File System (NFS), which would be used for Amazon EFS or Google Filestore. You can see part of the configuration required to set up an NFS server in Google Cloud in [Figure 4-9](#).

VPC network
Choice is permanent. [Learn more](#)

Network *
default

Allocated IP range
Google will use this IP range to create subnets.

☒ Use an automatically allocated IP range (recommended)
☐ Use a custom IP range

Advanced network options ▼
A private service access option is available. [Learn more](#)

Protocol
Select the filesharing protocol, choice is permanent. For information on privacy, authentication and other considerations, see [Learn more](#)

☒ NFSv3
☐ NFSv4.1

AUTHENTICATION ▼

Configure your file share

File share name *
myFileShare

Choice is permanent. Use lowercase letters, numbers, and underscores. Start with a letter.

Access control

☒ Grant access to all clients on the VPC network
☐ Restrict access by IP address or range ?
Removes access from all clients and enable root squash by default.

Figure 4-9. Filestore configuration

You can mount these remote filesystems and access them as though they were local. You may experience latency, depending on how far away you are from the server and your own network bandwidth, since you are not accessing them on your local, corporate network. If you are working from home, you will of course be constrained by the bandwidth to your house.

Storage Threats

As with any cloud service, there will be threats. If you are familiar with threats to on-premises services or even think about how attackers operate, none of these will be a surprise to you. They are common threat vectors no matter what type of computing service is being used. It comes down to access control, data protection, network controls, operational threats, and compliance considerations.

Access threats

First, access threats are very common. Identity and access management issues are often a primary concern. Creating users and granting them access to resources exposes those resources to potential misuse. Users and how they interact with the resources are only part of the exposure to threats. Without meaning to be anti-people, the reality is that humans open a lot of doors to threats and resource misuse. Beyond the end users who are interacting with the data, it's not uncommon for those who are responsible for resource administration to misconfigure access controls. This is not always about misconfiguration or mistakes, however, to take at least some of the blame off those people. Often, it can be a case of misunderstanding what the right protections should be by the team responsible for requirements. It can be a case of miscommunication as well.

One very common problem is allowing too much access. This can be seen a lot with Amazon S3 buckets. These buckets are often used to store data that needs to be available to customers or other users. Sometimes when you sign up to download something, you will be given a link to an object that is stored with AWS. For example, as I am writing this book, I am using an automatic build system where digital formats of the book can be created when I click a button. If I then go to download the resulting file, I am sent to an object in an S3 bucket. The access to this file should only be for me and the editors and other production staff that need to grab it.

Sometimes, S3 buckets are configured to be public. In our particular case with this book, it wouldn't be ideal considering O'Reilly expects to sell the book and the access to it to recoup costs and help stay in business, employ people, and so forth. However, it's not like there is any sensitive information in the book. There may be S3 buckets created by businesses with truly sensitive information, like critical intellectual property, personally identifiable information, or other data that would be protected under privacy regulations. While sometimes this is truly misconfiguration, where the public

access is enabled when it should be restricted to specific users, configuring public access is a deliberate choice, since restricted access is the default, as can be seen in [Figure 4-10](#).

The screenshot displays the AWS S3 console configuration for a bucket. It is divided into two main sections. The top section, titled "Object Ownership" with an "info" icon, explains that object ownership determines who can specify access to objects. It contains two radio button options: "ACLs disabled (recommended)" which is selected, and "ACLs enabled". The bottom section, titled "Block Public Access settings for this bucket", explains that public access can be blocked through various settings. It features a "Block all public access" checkbox which is checked, followed by four sub-settings, all of which are also checked: "Block public access to buckets and objects granted through new access control lists (ACLs)", "Block public access to buckets and objects granted through any access control lists (ACLs)", "Block public access to buckets and objects granted through new public bucket or access point policies", and "Block public and cross-account access to buckets and objects through any public bucket or access point policies".

Object Ownership info
Control ownership of objects written to this bucket from other AWS accounts and the use of access control lists (ACLs). Object ownership determines who can specify access to objects.

☒ **ACLs disabled (recommended)**
All objects in this bucket are owned by this account. Access to this bucket and its objects is specified using only policies.

☐ **ACLs enabled**
Objects in this bucket can be owned by other AWS accounts. Access to this bucket and its objects can be specified using ACLs.

Object Ownership
Bucket owner enforced

Block Public Access settings for this bucket
Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, access point policies, or all. In order to ensure that public access to this bucket and its objects is blocked, turn on Block all public access. These settings apply only to this bucket and its access points. AWS recommends that you turn on Block all public access, but before applying any of these settings, ensure that your applications will work correctly without public access. If you require some level of public access to this bucket or objects within, you can customize the individual settings below to suit your specific storage use cases. [Learn more](#)

☒ **Block all public access**
Turning this setting on is the same as turning on all four settings below. Each of the following settings are independent of one another.

- ☒ **Block public access to buckets and objects granted through new access control lists (ACLs)**
S3 will block public access permissions applied to newly added buckets or objects, and prevent the creation of new public access ACLs for existing buckets and objects. This setting doesn't change any existing permissions that allow public access to S3 resources using ACLs.
- ☒ **Block public access to buckets and objects granted through any access control lists (ACLs)**
S3 will ignore all ACLs that grant public access to buckets and objects.
- ☒ **Block public access to buckets and objects granted through new public bucket or access point policies**
S3 will block new bucket and access point policies that grant public access to buckets and objects. This setting doesn't change any existing policies that allow public access to S3 resources.
- ☒ **Block public and cross-account access to buckets and objects through any public bucket or access point policies**
S3 will ignore public and cross-account access for buckets or access points with policies that grant public access to buckets and objects.

Figure 4-10. Access control in an S3 bucket

In addition to public access not being the default, it is possible to prevent accounts from ever enabling public access to buckets. Even if you create a public bucket because you don't care about protecting the information stored there and categorize it as public, it is possible for sensitive data to be stored there. Nothing in the configuration will prevent someone from dropping documents into the bucket that shouldn't be exposed to the public.

Beyond the misconfigurations and public access, there are also problems with account access. This can be the usual credential issues of easily guessable passwords, or passwords that have already been exposed. Leaked keys or credentials are typical. This is why multifactor authentication (MFA) is so essential. While it may not be perfect at keeping attackers out, it is significantly better than just usernames and passwords alone, or even unprotected access keys. Proper implementation where a simple push and accept is not allowed, or texting a code, is critical since those types of MFAs can allow attackers to bypass them. You may also have a problem where previously allowed users have not had their access revoked in a timely manner, which will give them access beyond the point where they were supposed to have it.

Data protection threats

A common way of protecting data stored with cloud services is to encrypt it. This should be done both in transit (especially in transit) and by encrypting data being stored. This returns us to the identity and access management concerns. If credentials

can be compromised, encryption won't be helpful. Anyone with the right credentials should also have the keys to decrypt the information. However, that's not to say that you shouldn't take appropriate measures to encrypt data. One of the problems with encrypting data is that you have keys that are needed to encrypt and decrypt that information. The keys ultimately need to be protected. There are different ways of protecting keys, which brings us back to access control since you want to be certain that only those who need access to the information get the keys.

You also want to be able to restore data that is lost or deleted. This takes the form of versioning, though versioning can be managed so sometimes you can lose versions of the data that you want to access. Versioning can help protect against attacks like ransomware, since you can roll back to earlier versions, assuming the versions still exist. Additionally, backups are essential. Backups can help protect against versions being deleted, whether intentionally or accidentally. Ransomware attackers may try to remove versions to help ensure they get paid. Backups can help to protect the organization, since data can be restored, assuming the backups are protected. You need to ensure that appropriate access control is in place and the backups are immutable, meaning once they are written, they can't be changed or deleted.

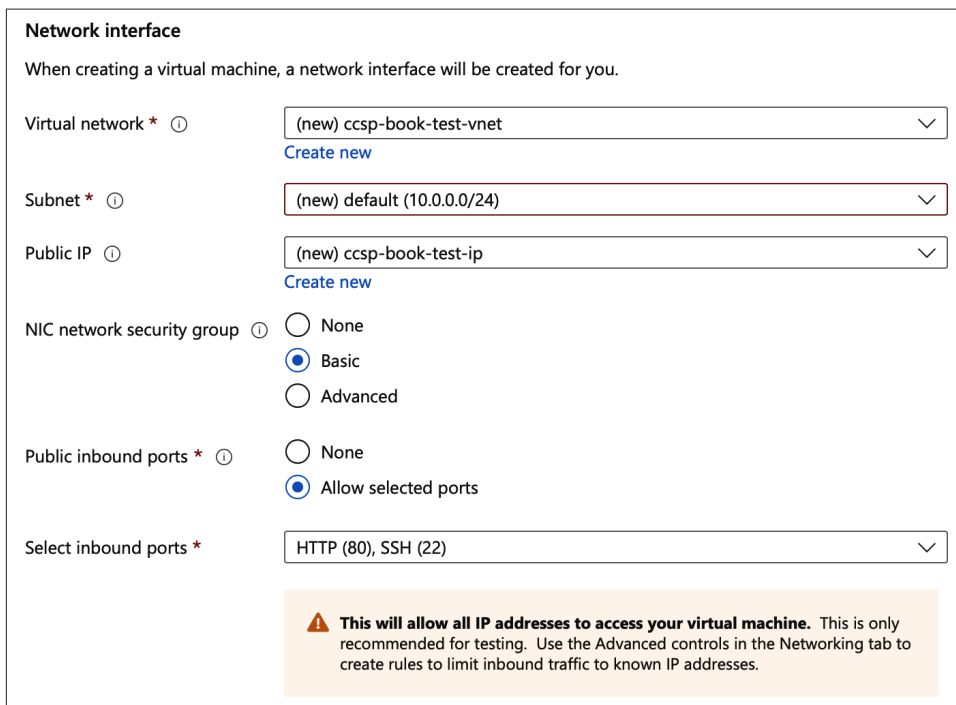
Network threats

Ultimately, misconfiguration is a common threat. Just as with configuring storage resources, you need to make sure you have appropriately configured networks. Resources reside on networks, even though they are software-defined networks rather than physical networks. Just as with any other network, you need to make sure you have appropriate controls in place. This includes access control lists (ACLs) to restrict access to resources only from specific locations. Since most implementations of infrastructure or applications include multiple components, network controls are necessary to constrain access from one component to another.

Generally, you will want to restrict access to services within the virtual private cloud (VPC), which is the isolated, private infrastructure being used by an organization within a public cloud provider. Sometimes there will be services that need to be accessible to the outside world, but you don't want the entire set of services and systems to be accessible. This means you need to have a set of policies and rules to restrict access to and from the correct set of systems.

Often, you will want to manage systems in ways that don't require you to log in to the portal for the cloud provider. You may want to use protocols like SSH or Remote Desktop Protocol (RDP) to gain direct access to the remote system for management. The problem is that the cloud provider is accessed through the public internet, unless your business has some sort of interconnection with the cloud provider, so the traffic is carried over a direct transit option rather than through public networks. This may be a virtual direct connection using a virtual private network (VPN), which creates a

tunnel using encryption to make it seem like you're directly connected, even though the underlying traffic is carried across open networks. **Figure 4-11** shows the configuration of network access restrictions on a virtual machine in Azure.



Network interface

When creating a virtual machine, a network interface will be created for you.

Virtual network * ⓘ (new) ccsp-book-test-vnet
[Create new](#)

Subnet * ⓘ (new) default (10.0.0.0/24)
[Create new](#)

Public IP ⓘ (new) ccsp-book-test-ip
[Create new](#)

NIC network security group ⓘ ☐ None
☒ Basic
☐ Advanced

Public inbound ports * ⓘ ☐ None
☒ Allow selected ports

Select inbound ports * HTTP (80), SSH (22)

⚠ This will allow all IP addresses to access your virtual machine. This is only recommended for testing. Use the Advanced controls in the Networking tab to create rules to limit inbound traffic to known IP addresses.

Figure 4-11. Network access controls

Specifically in Azure, you'll see that by default, any allow rules expose that port to everyone on the internet. You would need to use advanced options to further restrict so protocols like SSH are only allowed from specific IP addresses. You'll also see that the IP address allocated to the virtual machine is a private IP address. If you want to directly access the system from the internet, you need to obtain a public IP address from your cloud provider and assign it to the system. Otherwise, you need a way into your VPC so you can get to the private address from your external systems, either located at home for remote workers, or on premises at your business. Another approach is to use Network Address Translation (NAT), where the interface still gets the private address, but there is a network device between the system, and the internet translates the private address to a public address or vice versa.

Without these sorts of controls in place, or misconfiguration where you haven't fully restricted access to your systems, attackers can go after your services. Another network threat is a denial-of-service attack. While this may be a large-scale flooding attack using enormous volumes of traffic that may originate from multiple sources, it

can also be a problem with applications or services. This can result from slow attacks against some web servers where resources can be consumed by holding connections open.

Operational and compliance threats

Threats don't always originate from external attackers. They can also originate from a lack of actions from staff. Operational concerns can introduce threats to the organization. In this case, the concern might not be exposing services to attackers, which causes problems of course. Instead, one common problem is a lack of logging within the services. In some cases, as might be the case with software as a service where you may rely on the provider, logging may not be considered when implementing the service. Logging is essential to visibility within all services and applications, and without visibility you can't see what is happening. This could be seeing misuse, but it can also be visibility into service performance, which can lead to not only user experience problems but also potential outages.

You may also run into issues from a lack of appropriate encryption, both in storage and transmission. This could result in theft of sensitive data, which of course could negatively impact the organization. Keep in mind, though, that encryption does not guarantee that data can't be stolen. Certainly, encrypting network traffic makes it highly unlikely the data can be captured and decrypted, but encrypted storage protects against someone without authenticated, appropriate access to the information from getting it. If you can read the data using whatever means, such as an application that reads and displays the information, then anyone who can compromise your account can also read the data and make use of it.

One of the problems with data is that users interact with it. It's not uncommon for data to accidentally be deleted. Because this is what might happen while running an environment, it is an operational concern. Similarly, hardware failures can cause data issues. This brings up the issue of backups, since you would use backups to restore from hardware failures, once you corrected the issue. If you don't have backups, that's a problem. Backups are essential even if you are using a cloud provider. After all, the data is your responsibility, not the responsibility of your provider.

There are many situations that could lead to corruption or loss of data just by the mere fact of the data existing in a computing environment that users and administrators have access to. Again, this is not to blame the humans in any fashion. It's just the cost of doing business sometimes. People make mistakes or do things they have been told to do that have an impact. Also, hardware can fail and providers can have issues. In just the last year, there have been cases of customer data being accidentally destroyed by cloud providers. This doesn't even consider the case where the provider has been the victim of a significant attack that either compromised customer data or destroyed it.

Companies generally have regulations they have to live by. Because of this, there are threats that can come from those obligations. Just as with the operational issues, there are many ways you can run afoul of regulatory agencies and bodies. The first is simple noncompliance. This could be a result of data residency concerns where you may have a mismatch between the data location and the data subject, and unexpected laws may apply. You could hold on to data longer than you should, so you can have problems with data retention. There are privacy considerations and protection considerations if you are transferring data from one jurisdiction to another.

Regulations may also have audit and documentation requirements, and if you are not up-to-date on those, you may have issues with the agency or body administering the regulation. Lack of logging or audit trails will be a problem here. Also, if there isn't enough transparency in the security controls in place, that will also be an issue. Change management is such an important part of any good information technology practice, though it is sometimes overlooked. That makes it really hard to determine what happened within an information system, who did anything, and who approved anything that was done. Documentation is really important, but it's often the first thing overlooked.

Data classification may not exist. There may not be clear ownership of information, and there may also be a complete lack of understood or documented responsibilities. Even if data classification exists, the classifications may not be applied consistently across all data within the company. While data loss prevention (DLP) solutions can help with this, it can be really difficult to implement and maintain. Often it comes down to individuals ensuring the data has been classified and handled appropriately.

Privacy is a significant concern in some areas, like Europe in particular. Any problem with impacts to privacy will become a problem for the company. The company may also have inadequate Service Level Agreements to ensure data has been protected. This would be especially the case with cloud providers. Again, it's probably worth beating this dead horse a little more, but the cloud provider is not responsible for your data under any circumstances. It is up to you to ensure the data is protected, which may include being certain you have the right agreements in place with your provider for things like uptime and restoration in the case of a failure. Additionally, any support for investigations of incidents should be a consideration when reviewing these agreements.

Design Considerations

Let's say you've been asked to develop a coherent strategy for designing protections in the cloud for all data that is stored or processed there. There are three key areas you should think about, since any decision will have an impact on each of those areas. Managing (or perhaps more aptly, juggling) those three areas of consideration is complex, but unfortunately, it is also critical. The three key factors are data

protection, regulatory compliance, and business efficiency/continuity. You can see in [Figure 4-12](#) the different factors that should be considered during the design to ensure those key factors have been addressed.

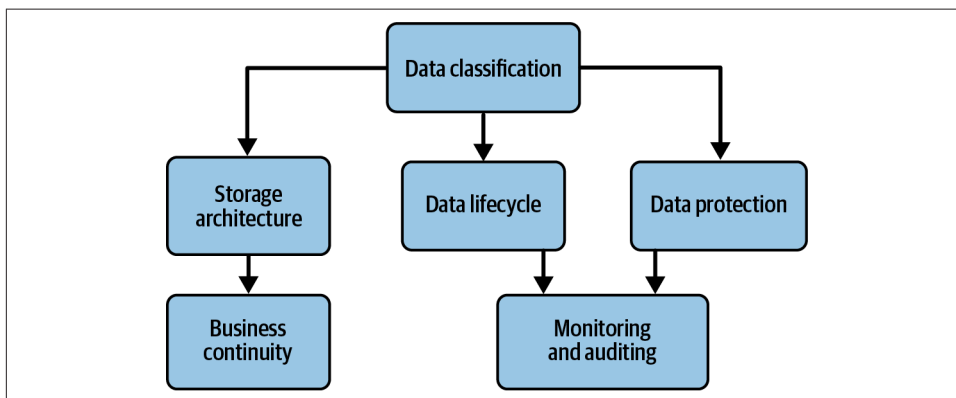


Figure 4-12. Design considerations

Each of those factors encompasses other ideas. When you are putting a solution together that includes data storage in the cloud, and after all at some point it's likely some data will be stored, even if it's not long-term, you should think about what the business objectives are. This will help define some of the essential ideas. First, the business objectives and the focus of the solution will tell you the types of data that will be stored. Ideally, your organization has already thought about data classification overall so you don't have to create that from scratch. You should just make use of the existing data classification policy and guidance. The classification will also help determine how data is handled.

Data handling comes down to protection. If all the data is public, you may not need to consider anything in the way of protecting the data since it doesn't matter if it gets out into the public. If there is anything sensitive, confidential, or private, you need to think about whether encryption is necessary. If it is, is it required when data is in transit, at rest, or in use? Each will lead to different solutions. "In transit" means not only passing back and forth between the client and the server, but also between different elements of the overall solution. If application programming interfaces are used with a microservices model, calls to those interfaces will need to support encryption. If you need to encrypt data at rest, your storage needs to be encrypted. This may mean encrypting the actual storage volume, or, if you are storing in a database, maybe it means encrypting the database. This may be even more of a consideration if you are using a cloud database solution rather than just implementing a database on your own inside a virtual machine.

You should also consider tokenizing data if it is especially sensitive. Tokenizing is replacing sensitive data like social security numbers, credit cards, patient identifiers, banking information, and other information that needs more rigorous protection. In place of the actual data, you store a token in your data records. The token refers to the actual data that is stored in a token vault. Along those lines, you need to ensure you are protecting information in testing or other nonproduction systems. Often, you want data that looks real without actually being real. Some organizations may start with production data rather than trying to create a lot of bogus entries, since it seems easier and faster. That means there is now additional, unnecessary exposure to those nonproduction systems, since they can be targeted to get the sensitive information. One way to address this is to use data masking, which obscures the real data without impacting the look of it to the application using it.

If you are using encryption anywhere, you need to be concerned about the encryption keys, since exposure of the keys is the same as never encrypting the data to begin with. You should be concerned about how you manage the encryption, the types of encryption you need, and how you protect the keys.

Protecting the keys should include appropriate access control, but that is a design consideration across the board. Strong identity and access management practices are essential in any application or information solution. This includes strong credentialing practices, such as strong passphrase usage, multifactor authentication, passcodes, or other modern authentication mechanisms. Once you have authentication in place, you need to think about authorization to ensure the right people get access to the application and the data that sits inside. Always follow the principle of least privilege and also factor in the need for administrators and managing how they interact with the environment. Will you use just-in-time credentials for them, separate administrator accounts, password vaults, extra monitoring of those accounts, or other practices to ensure privileged accounts are not misused?

Speaking of monitoring, you will need to ensure all the different components of your design are logging appropriately. Logging is certainly critical from a security perspective, though security is not the only reason for applications and systems to be logging. Performance and troubleshooting are also good reasons to ensure the right logging level is being used. Operations staff want to ensure the application is functioning correctly and users are getting a satisfying experience. Logging will also help with compliance reporting, which can be an important consideration for many businesses. Clearly documenting requirements for the different business drivers will help guide the implementation plan.

Keep in mind that data doesn't just come out of nowhere and reside in the environment. There is a lifecycle from creation through deletion and destruction. You will need to ensure you have all elements of the lifecycle covered. This includes understanding the provider's role in deletion and destruction. Are there any cases where

data may reside somewhere within the provider's infrastructure beyond the deletion stage? Many services like storage as a service will allow versioning of data. This means the provider keeps older versions of the documents. Even if you delete the document from your current view of the storage object, some part of the provider's infrastructure may be keeping older versions.

You also need to think beyond the current iterations of a document and the data that resides in it. Think about corner cases like when sensitive information is accidentally stored in a document that isn't sensitive normally. It may get stored before someone discovers what happened and removes it. Again, that previous version may reside in a versioning system. You aren't worried about the document itself, but that sensitive data is still available.

The nice thing about features like versioning is the impact they can have on recovering from circumstances where data is accidentally or even maliciously deleted. There are broader considerations you need to ensure you have strategies for, though. Business continuity and disaster recovery are important not only from an application perspective, but also from a data perspective. Don't assume that just because you are using cloud providers, they will have everything taken care of. You still need to think about situations where there are catastrophic failures at the cloud provider, or where attackers have gotten in and had an impact on your application and the data it is managing. Keep critical data backed up so you can recover from disasters and other business-impacting incidents.

Think about your recovery time objectives (RTOs) so you know you can get a service back up and functional within a period of time that the organization knows about and agrees to. This may involve using technologies like Infrastructure as Code (IaC) that will help you get all of your application elements back up quickly. You also need to think about your recovery point objective (RPO), which is the amount of time you can afford to lose data. You may have an RPO of four hours, for instance, which says you need to get the application back up within four hours of a business-impacting event. The business may only be OK with losing two hours worth of data. This means you need to think about how you are retaining information outside of the application using replication or backups, for instance.

When you are designing your application and all the components, you need to be thinking about what it takes to protect the business and the functionality of your solution. Everything you do is about making sure the business and its stakeholders, including customers, members, or other consumers, will be able to make use of the application when it's needed.

Data Protection Technologies and Strategies

Speaking of protecting the business, you want to make sure you are considering all elements of data protection. While we have skimmed over most of these, it's helpful to put them into the context of data protection. This means talking not only about data protection practices at a high level, but also about some of the technologies you should be looking at that will help you ensure you have good data protection strategies in place with the right technology to support them to keep your essential business data protected.

Encryption

Encryption is what most people start thinking about when we start talking about data protection. While this is reasonable, it shouldn't be the only consideration. Additionally, and more to the point for this section, there is more to it than just saying "Encrypt!" There are many considerations, including the types of encryption, algorithms, and key strength. Once you start talking about encryption, you need to think about keys and protecting them. What does that look like for your organization?

First, you may need to support multiple types of encryption. It is very common to use hybrid cryptosystems, which usually means both public and private cryptography. Once you start talking about public cryptography, you need to have certificates. While there are open solutions, including web-of-trust solutions that are decentralized, centralized solutions are more common, including using a Certificate Authority (CA). The CA is responsible for validating identities and issuing the certificate, which includes details about the CA itself.

Public key cryptography generally relies on a transitive trust relationship. Let's say that you know Zoey, and I also know Zoey, and we both trust her. If Zoey tells you that she knows me and trusts me, you can believe that I am who I claim to be. Similarly, if Zoey says she knows you and trusts you (as in trusts that you are who you claim to be), then I can similarly trust that you are who you say you are. In a web-of-trust situation, like Pretty Good Privacy (PGP), this process is decentralized and relies on a lot of people vouching for each other. This process is made easier, though not less expensive, by using a CA. The CA becomes a version of Zoey, who trusts people, so that if we trust her, then we trust those she vouches for.

Certificates have a well-known structure, regardless of whether you are using a centralized or decentralized approach. The standard is referred to X.509 and that standard is managed by the International Telecommunication Union (ITU). There are a whole series of standards related to directory services, and X.509 is one of them. X.509 specifies the structure and contents of a certificate. The table in [Table 4-1](#) shows all the X.509 elements.

Table 4-1. X.509 certificate fields

Component	Description
Version	Specifies the version of the X.509 standard being used.
Serial Number	A unique identifier for the certificate assigned by the issuing authority.
Signature Algorithm	The algorithm used to sign the certificate, ensuring its integrity.
Issuer	The entity that issued and signed the certificate.
Validity	Indicates the certificate's active period with "Not Before" and "Not After" dates.
Subject	The entity the certificate is issued to, typically containing identifying information.
Subject Public Key Info	Contains the public key and the associated algorithm for the subject.
Extensions	Optional fields providing additional functionality, such as key usage or SANs (Subject Alternative Names).
Signature	The digital signature verifying the authenticity of the certificate.

When a certificate is issued, it has a lifespan. Certificates eventually have to be renewed, which means going through the process of demonstrating who “you” are, whether the certificate is for an individual or a system. Sometimes, certificates can be misplaced or compromised in some way. This results in needing to revoke the certificate. Unfortunately, while the certificate process using a CA is centralized, using the certificate does not necessarily require contacting the CA. One way to manage this is to use certificate revocation lists (CRLs) which are just as they sound; they are lists of revoked certificates. This has historically been poorly supported for a variety of reasons, so another approach is to use the Online Certificate Status Protocol (OCSP), which requires both parties in the conversation to make use of it and provide and validate information. OCSP is in the process of being phased out to return to the older CRL approach.

One reason to use hybrid cryptosystems is because the certificate can prove that the website you are visiting is Transport Layer Security (TLS), which uses the public key to protect the initial interaction between the client and the server where the session parameters and keys are being negotiated and exchanged. Once the session keys have been exchanged, those keys are used to encrypt and decrypt the messages exchanged while the client continues to talk to the server. These session keys are generally symmetric keys. Historically, asymmetric encryption is more resource-intensive than symmetric, which explains why that type of encryption is used for session encryption since this would be data that would be more time-sensitive, where lag introduced by the encryption/decryption would impact the user experience. Smaller chunks of data used to set up the connection can take longer encryption/decryption times and more processing power.

Encryption algorithms

Because both the encryption types and the mechanisms by which they operate are so different, each type has different algorithms that are used. There are currently a couple of primary algorithms used for asymmetric encryption. The first is the Digital Signature Algorithm (DSA), though it has limitations. It is only used to verify signatures, meaning it is used for digitally signing documents or objects. This is useful to confirm the source of a piece of information. If you signed a document using your digital, cryptographic signature and that signature matches your confirmed identity, you can't say that it wasn't you who signed it. This is called non-repudiation. Basically, it is a cryptographic version of no take backs. If you sent it and it's your signature, you can't say you didn't send it.

A more common asymmetric algorithm is Rivest-Shamir-Adleman (RSA), which are the names of the inventors. This is a more general purpose algorithm that uses really long keys, which are commonly multiples of 1,024 bytes. These keys have two components, the public key and the private key. They are mathematically linked so that what is encrypted with one can be decrypted with the other. If I were to send you a message using public key cryptography, I would get your public key, which is intended to be public, meaning anyone can have it, then encrypt a message to you using that key. The only way it can be decrypted is by using the private key, which only you should have.

RSA was developed in the late 1970s and may not be the most efficient when it comes to cryptographic algorithms. This is not to denigrate it in any way, since it is still commonly used and gets the job done. However, mathematical advances have been made in the intervening decades. Where RSA makes use of the difficulties of breaking down large numbers into the prime numbers that can be multiplied together to create them, Elliptic Curve Cryptography (ECC) uses an entirely different mathematical process. ECC is based on elliptic curve discrete logarithm problems, which are much harder to solve when it comes to computation.

An elliptic curve is a graph generated by the mathematical function $y^2 = x^3 + ax + b$, where the values for a and b are constants. You can see an example of what that curve looks like in [Figure 4-13](#), which uses the values of 4 and 42 for a and b , respectively. The challenge is that you are starting at one point on the curve, called the base point, and you are trying to get to a different point, the known point. The challenge is trying to find the logarithm that can be used to apply to the base point (x,y) through point multiplication to get to the known point. This is a very difficult problem that can't be solved as easily as factoring large values into prime numbers. Moving to more difficult mathematical problems is essential as modern processors have gotten so much better at incredibly fast mathematical computations, especially in graphical processing units (GPUs).

Another advantage to using ECC is that much smaller keys are needed to get the same strength of encryption used by the older RSA algorithm. This also reduces the amount of storage needed. A 256-bit ECC key, for example, uses up only 32 bytes of storage, while an RSA key uses 384 bytes for a 3072-bit key. The encryption strength, meaning the computational difficulty in breaking messages using those keys, is equivalent.

Symmetric key encryption, by contrast, is easier, at least conceptually, since it isn't about having two keys that need to relate mathematically. Instead, you have just one key that is used for encryption and decryption. Symmetric key encryption also uses smaller key sizes than those historically used for asymmetric, though the move to ECC is changing that. The Advanced Encryption Standard (AES) is a common algorithm used for symmetric encryption today. It is fast and supports different key sizes, allowing it to adjust when vulnerabilities make smaller key sizes less practical.

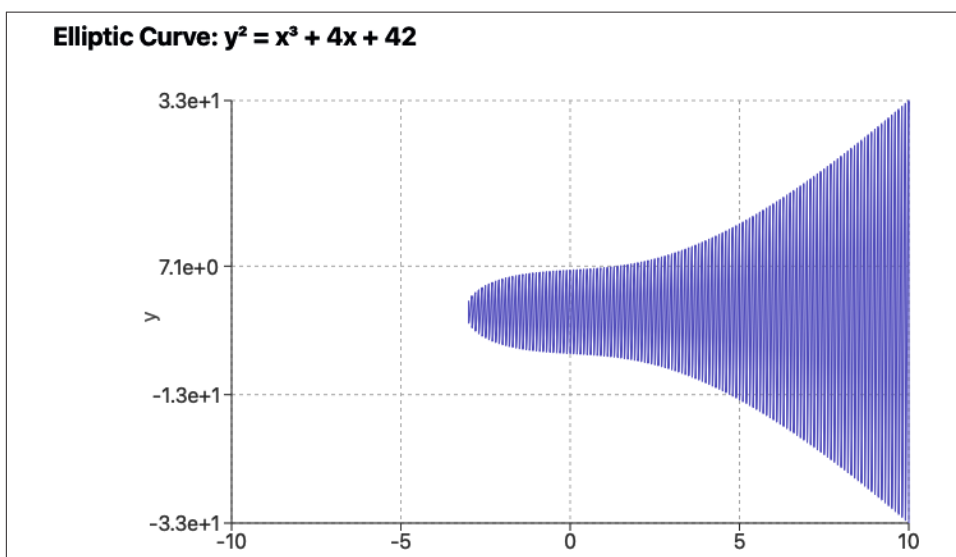


Figure 4-13. An elliptic curve graph

Symmetric key encryption ciphers may use block or stream encryption processes. With a block encryption, the data is broken into fixed-size blocks, using padding where necessary to fill out the block. Each block is then encrypted, sometimes using information from a previous block to chain them together. A stream cipher considers data as it arrives without necessarily having all the data together. Encryption may be handled a byte at a time. AES is a block cipher that can be used in a stream mode. Another common symmetric key cipher is ChaCha20, and it is a streaming algorithm.

Key and secrets management

Once you have certificates and keys, they need to be protected. Certificates are often protected by passwords, which should ensure they are not usable by anyone other than the legitimate owner. This ends up being problematic since you can create certificates without passwords. Additionally, when it comes to servers, having a password on the certificate can make it problematic for applications to load so they can be used. The password has to be handed to the application to effectively unlock the certificate for use, which may mean storing the password on a disk somewhere. This means it can be discoverable, which doesn't keep the certificate protected.

Fortunately, there are ways to manage this. You can use a key vault or a password vault. The use of identities can help protect your certificates and other secrets so the application can authenticate to the vault and retrieve the sensitive information without ever exposing any passwords. This is a very common approach used in cloud designs.

One of the challenges for symmetric encryption is that the key keeps changing, or at least should keep changing. The use of pre-shared keys—meaning you and I want to encrypt something so we share a key ahead of needing to encrypt or decrypt—has a lot of challenges. If it is a passphrase that is later used to help derive a key, that may be one thing, meaning we can discuss it so it isn't written down and stored somewhere. However, if it's a proper digital key, 256-bits long for instance, that's not the sort of thing you can just remember, especially since it's in binary and it is unlikely someone will reliably remember 256 1s and 0s of a key.

Hashing

Cryptographic hashing is a very common practice to ensure that data remains unchanged. Hashing is a type of machine authentication code that is used to validate data that has been presented. It is commonly used when information is transmitted using cryptographic techniques to demonstrate that the contents have not been tampered with. When you are downloading files from websites, you may see hash values which you can compare your download against to show that what you have is identical to what was on the website.

Hashing algorithms take an arbitrary quantity of data and return a fixed length result. It doesn't matter how much data you feed it, the algorithm will always return the same value. Different algorithms will return different results. As an example, Message Digest 5 (MD5) will always return 16 bytes, which is 128 bits. These values are commonly represented in hexadecimal because it is a convenient way to get printable results from what are really binary values. MD5 was developed in 1991 by Ron Rivest, one of the developers of RSA. It is capable of generating 3.4×10^{38} values. Try writing 3 followed by 38 zeroes to get a sense of how large that is if you can't quite picture it in scientific notation.

While that is an extraordinary number of values, the problem with cryptographic hashing is something called collisions, and this is where a problem called the Birthday Paradox comes in, which speaks to collisions. Imagine there is a party going on and people are all getting to know one another. You start walking around asking people what their birthday is, just the month and day. When there are 23 people in the room, the probability of having two people who share the same birthday is 50%. So, the curve for collisions of people sharing an identical day of birth, without considering the year, rises very quickly. However, it is then a much slower climb from there because to get to a certainty that two people share a birthday, meaning the probability is 100%, you need 367 people in that room. This doesn't seem possible, right? Well, there are 366 possible birthdays, since we have to account for February 29. It is possible, though the likelihood is extraordinarily small, for 366 people to gather without any overlaps in birthdays. To guarantee that collision, you need that 367th person.

Collisions are an important concept when it comes to hashing. In theory, you should be able to keep pumping data at a hashing algorithm throughout your life without ever getting the same result twice. It's just a probability problem combined with the comparative shortness of human life. It would take approximately 1.079×10^{31} years to run different sets of data through the MD5 algorithm every second for the number of possible values that MD5 can generate. However, MD5 is not considered a safe algorithm because the other problem with collisions is that there are people who are constantly looking to see if there are ways to generate the same hash value with a different set of data. The goal is to be able to fake someone who is checking values by intercepting the real data and sending something else in its place.

As a result, there are more modern hashing algorithms that are commonly used. This is not to say MD5 is no longer useful, though you will hear people say MD5 is broken. It just depends on the criticality of the data you are protecting. If you just want to show that two files are the same, MD5 will work fine. If you are trying to show that a file downloaded is the same as what was posted, it may still be OK. However, there are some attacks against MD5. Most notably, there was a vulnerability in the RADIUS protocol, which is used for authentication. If you really care about your data or it is sensitive in any way, which would normally be the case for information that is encrypted, you probably want to move to something else.

The Secure Hashing Algorithm 1 (SHA-1) was developed in 1995. There are now three SHA algorithms that can be used. The original SHA-1 algorithm generates 160 bits, or 20 bytes, generally represented in 40 hexadecimal characters since a single byte is 2 hexadecimal characters. SHA-2 will generate different outputs, depending on the variant you choose. You can get 224 bits all the way up to 512 bits. SHA-3 will similarly generate a different length of output depending on the variant, also between 224 and 512 bits. With both SHA-2 and SHA-3, you can select 224, 256, 384, or 512 bits for your output size.

Hashing algorithms only consider the contents of a file, meaning the actual data. And there is nothing linear about the algorithm. You can see this in [Example 4-2](#), where a small file with some text in it is hashed using SHA-1. After showing the hash, the file is changed so there is a single bit difference, since there is just one bit between the two ASCII values that are shown in the file variations. You can also see that the algorithm doesn't factor in any metadata like the filename because the hash value remains the same regardless of the filename. Similarly, any other metadata that is not contained in the file, like time and date stamps, will not be factored into the hash value.

Example 4-2. Hashing example

```
kilroy at bad-deathtongue in ~
$ cat wubble.txt
the rabid yellow fox ate the rotten hare 123

kilroy at bad-deathtongue in ~
$ sha1sum wubble.txt
79943e5e3c9c9138529a045ffbcb183c8d1fd8bf  wubble.txt

kilroy at bad-deathtongue in ~
$ vi wubble.txt

kilroy at bad-deathtongue in ~
$ cat wubble.txt
the rabid yellow fox ate the rotten hare 124

kilroy at bad-deathtongue in ~
$ sha1sum wubble.txt
ebbab9822109f21f9ac1f66e349d8f7410653cae  wubble.txt

kilroy at bad-deathtongue in ~
$ mv wubble.txt rubble.txt

kilroy at bad-deathtongue in ~
$ sha1sum rubble.txt
ebbab9822109f21f9ac1f66e349d8f7410653cae  rubble.txt
```

Cryptosystems will commonly use hash values, but they also have a lot of other uses outside of simply data encryption, as you can see. Often, when data is being backed up, files may be hashed because it's quicker to compare hashes to ensure the restore is the same as the original data than it is to try to do a byte-for-byte comparison. There are many other uses for hashing that can verify information authenticity.

Handling Production Data

Production data needs to be protected as best as it can be. While encryption may be useful, it isn't the only or even the best approach in many cases. Nonproduction systems are often not protected in the same ways as production systems, so they end up

being soft targets. If the same data is stored on nonproduction systems, like testing, staging, or development, attackers are going to go after the softer targets to get the same result. Without addressing the lack of adequate protections of the systems or services, storing production data on nonproduction systems is a bad approach. However, these systems usually need some sort of data to validate functionality or have the application function correctly. As a result, there is a need to have data that looks like it's real without actually containing anything sensitive.

One approach is to use data masking. Data masking is just the process of taking actual data and replacing the sensitive pieces with ones that look real but aren't. If, for example, you had a social security number that was 003-98-0120, you could do something like replacing those values with 000-00-0000 or 999-99-9999. The structure here may be critical, but the values don't matter. In cases where the actual values matter because you are doing something with them, such as performing mathematical operations, you could do something like add or subtract a random value to the real value. Data masking may be easier than trying to generate large data sets that are random.

Often, data sets will include personally identifiable information. You can use data anonymization to remove or alter the identifiable information in meaningful ways. You don't want to be able to get to the real information if the process used to anonymize is reversible. If you just flip names or numbers back to front, for example, that's easily undone. You need to be able to take any identity markers out of the data set. You may remove the data if that is possible. You may also just replace the identifying information with other data. Data anonymization is not intended to remove the usability of the overall data set but instead protects the information of the individuals referred to.

Another approach to protecting data that is being stored is to use tokenization. When you are tokenizing data, you generate random values and store those values. Those values are then used to look up the actual information. This helps protect the information because it isn't being transmitted, except where it needs to be sent for initial record creation. Instead, the token can be sent because it doesn't contain any sensitive information. It becomes a record locator to retrieve information from a vault. The vault is protected more strongly than other systems in the environment and is used to ensure that sensitive information is not shared within an application unless it is critical. The only location where sensitive information is ever retained is in the vault.

Data Loss Prevention

As you might expect, organizations are concerned about losing data. This may be their own information, whether it's financials that they don't want getting out, intellectual property, or other internal information that should only be seen by people in the company. It may also be the information of their customers or partners. They may

be storing information that really belongs to third parties as part of their normal business practices. It isn't theirs but it should be treated as if it were. This takes into account not only protecting the storage of the information but also its transmission.

A lot of this is about movement. When you transmit information, you are moving it. It may not be leaving its current location, as would be the case if someone asked you to pass the pepper at the dinner table where you would move the pepper mill from where it currently is to the person requesting it. Instead, this is perhaps more like the movement of wind. You can sense the wind is moving but nothing has left where it was in the process. Unless the wind is strong enough and starts pushing your grill around on your back deck, but that's a whole different story.

Because we aren't going to notice data that has left, we need to be able to notice it moving, so DLP is often about noticing when a file is sent somewhere, downloaded, emailed, or otherwise has essential information being sent from one location to another. Ideally, you would be able to prevent that transfer, but at a minimum, someone needs to know about it. This does, though, require knowing what is critical data. This means you need to do some sort of categorization. While different organizations may have different classification criteria, depending on their needs and on the regulatory and compliance requirements, some common ones are shown in [Table 4-2](#).

Table 4-2. Data classification categories

Data classification category	Description
Public	Data that is generally available to anyone. It can be freely shared without restriction and it wouldn't be sensitive. Examples would be marketing information and public filings.
Internal	Data that is intended for use within the organization but does not contain sensitive or confidential information. Unauthorized sharing could still be detrimental, but it does not have legal or regulatory implications (e.g., internal procedures, nonsensitive operational data).
Confidential	Data that is restricted to specific individuals or groups within the organization due to its sensitive nature. Disclosure could lead to significant harm, legal consequences, or competitive disadvantage (e.g., financial reports, employee records, internal strategies).
Restricted	Highly sensitive data with legal, regulatory, or contractual protections. Unauthorized disclosure or access could result in severe penalties or security breaches (e.g., personal identifiable information [PII], health information [PHI], trade secrets, intellectual property).
Highly restricted	Data that requires the highest level of protection due to its extreme sensitivity. Access is usually restricted to a very limited set of individuals with specific clearance or need-to-know. This may include national security information or data protected under strict laws and regulations (e.g., classified government information, national security data).

One of the challenges with data classification is that once you have identified the classifications, you need to be able to identify where all of the information that falls into those categories exists. This can be a difficult task. Fortunately, there are tools available for such data discovery, but it does require being able to clearly define rules that indicate what the different categories look like. There is some information that can be

really easy to identify. Social security numbers, credit cards, and other similar pieces of information have clear and well-understood structures. Other information is more nuanced. It is easier if the documents or data in question are already marked. If files include terms like proprietary or confidential, it can be easier to categorize them. Sometimes data is either unstructured or semi-structured, which can make it more difficult to categorize.

The advantage of categorization, though, is it allows you to put together information that has similar protection requirements. This makes it a lot easier to introduce access controls that will help protect all the information, either at the network or user-level. You don't have to worry about creating these controls at the level of each individual piece of information, because they are applied where the information is stored. Cloud storage introduces better capabilities around controlling access to and movement of classified data. Here are some controls that support DLP with a cloud provider that you wouldn't necessarily get with on-premises storage. These capabilities are typically native to cloud storage and do not need a DLP solution:

Access controls and authentication

The cloud provider provides fine-grained access controls, including the use of role-based access control. You may also be able to restrict access based on location. The use of multifactor authentication can be required to gain access to data storage, which would not necessarily be the case with on-premises file sharing.

File and folder level

A storage provider typically allows for versioning, which allows rolling back to older versions if a more current version was corrupted in some way. You may be able to get file or folder locking to prevent simultaneous edits. You can set retention policies to ensure critical data is not deleted.

Auditing and monitoring

You could get activity logs to review file access, as well as modification and any sharing of information. If you were reviewing the audit logs, you could set alerts for any suspicious activities like mass downloads or deletions. File integrity monitoring, which can be very challenging to implement well on premises, may be able to detect unauthorized changes.

Encryption

Cloud storage providers could support encryption for at-rest data as well as encrypting in-transit encryption. The cloud provider would also give you the ability to manage encryption keys to retain better control over who has access to them, as well as being sure you can rotate them when you need them.

As you are thinking about how to manage and control data to prevent it leaking, and once you have identified all the locations where your data is stored, you should think about creating data flow diagrams so you can understand how usage of applications

moves information around. Each application you use should have an associated data flow diagram. The same goes for any business processes, since those may involve multiple applications and can rely on humans to do some of the transferring. Get a solid understanding of where the information originates, the method of movement (including ports and protocols where possible), whether the information is encrypted in transit, and the identity of the recipient, whether it's a system, share, application, or individual.

You should be documenting any transformation as part of your diagrams. This includes encryption, of course, but if there is any step where, for example, a Word document is used to generate a PDF, that should be clearly documented. This is especially true for a situation like that since now there are two copies of the same information and you want to know the disposition of both. Along with your data flow diagrams, make sure you have clearly documented who has access to all of your information that you are trying to protect, so basically any information that isn't public.

As you are labeling your data, you may also consider at least identifying some other characteristics, which you can track separately from the data itself. You should also ensure you have handling requirements, though this may also be part of your data classification and handling policy. Metadata about ownership and retention requirements should also be tracked and kept updated, especially for more sensitive information. If you have data that has regulatory compliance impacts, you should have tags or documentation for that as well. A good practice for document creation is to ensure you have headers/footers that indicate the classification level and some of the other information that has been suggested here, if it's appropriate.

Information Rights Management

Information rights management (IRM) is a set of practices for further protecting sensitive information. As discussed earlier, generating a PDF from a Word document may be one way of getting around movement of the Word document. Additionally, printing it to paper or even collecting screen captures could be ways of getting sensitive information off systems, so you need IRM to ensure those sorts of protection bypasses don't happen.

With IRM, you can restrict those sorts of file operations as well as fully control which users or groups can access protected content. You could use IRM to set expiration dates for access to protected files, which you otherwise wouldn't be able to do. Using an IRM system, you could also revoke access rights even after distribution of the documents. The contents are encrypted to ensure there is no unauthorized access.

An IRM can integrate with any identity management system, so you can use existing identities. Access controls should also apply offline, otherwise it would be trivial to

bypass by just disconnecting the device from the network. Disconnection from the network should cause failures that would not allow any access.

The primary advantage of using an IRM is that the protection follows the data rather than relying on access controls built into the system. You should also have granular controls over document usage, so you have various permissions that could be assigned for different roles since not all document access is or should be the same, especially in the case of sensitive information where some people may just need to view it without needing to alter it or even create new information. A strong access management policy at the information level requires this level of granularity.

In addition to providing access control at the “what can I do” level, there are other access models to consider. We have been talking a little about a permission-based model, where individuals have a set of permissions, including view only, or edit/modify. Additionally, you can get even deeper with an IRM system since there are many ways to expose information. Printing, copy/paste, save as/export, and screen capture are all additional permissions that you should be able to control since each exposes the ability to either access or make changes to the information in the files protected by IRM.

Role-based access control is another factor that we have touched on lightly here. Each role encompasses a set of permissions, and individuals are assigned a role rather than the permissions being assigned to specific individuals. You would have roles like author/owner, editor, reviewer, or reader in addition to custom roles. An editor could change the contents without assigning new rights, and a reviewer could comment only without making any changes. Of course, a reader would be able to view the contents of the document.

In addition to permissions and roles, you may want to assign permissions that are time-bound so someone may have access for 24 hours, after which they have no rights. Perhaps they are only allowed to look at the contents between specific hours in a day or only on some days of the week. This would protect against someone coming in during off-hours to engage with the contents and be able to do other things that may compromise information security without anyone observing. Additionally, you may require that documents be opened only in certain locations. This may be a network location or a geographic location. You may also bind users to certain workstations.

All of these controls—and you can see how rich and detailed they can be when combined together—provide a lot of power for restricting access to documents. This can significantly enhance cases where really sensitive or confidential information is in play. The major cloud providers typically have some level of IRM built into their services, which you are able to use if you wanted to.

Visibility

Visibility is essential in any situation where you have multiple users accessing resources online (whether private network or across the public internet). This is also true, as has been suggested several times in this chapter, of anything to do with data. It's not only about accessing systems, especially in a cloud environment where the idea of system and system access may be meaningless between containers and serverless functions. The cloud world tries to abstract the idea of the underlying computing hardware and operating system as much as possible, so for our purposes, visibility around data storage and movement is essential. Here are some particular reasons for the need for visibility:

Auditing

Compliance, risk management, legal teams, and security staff should be particularly interested in auditing information. This should provide a detailed record of access and activity. It may help detect unauthorized information, help with regulatory compliance, and assist with operational integrity.

Traceability

Traceability is about being able to show a trail of where data was born and where it's been throughout its life: every time it changes, every movement it makes. Traceability is like a chain of custody for a case that isn't legal. You have a time-stamped trail of every time the information has been moved and touched. This timeline of changes, digitally preserved, allows for a comprehensive look at what happened during the lifespan of the document, which can be useful for compliance reasons, as well as where an incident occurred.

Accountability

You may notice that all three of these are tied closely together. Traceability, where individual documents can be tracked across their lifecycle, providing details about when they were created and when they were moved or modified, also should provide details about who did the creating and moving. After all, when the proverbial fecal matter comes into close physical contact with the rotating air movement device, you're going to want to know whodunnit. This is not to say that you have reached ground zero in laying any finger of blame you may be inclined to. Instead, it gives you a starting point and at least a person to start asking questions of to figure out what happened.

There are lots of essential pieces of information that should be collected. First, you need to know the identity responsible for any given access or action. Second, you need to know where they are. This typically means an IP address, which could also provide a physical location through the use of any geo-IP database. Of course, you should also know the resource in question, rather than just having a disjointed record of who and where. You will also need to know when it happened, so an accurate time

and date stamp is essential. Think of it as journalism for tracing activities in your cloud environments. Make sure you have the who, what, and when accurately captured so you can then go after the why and how, which may not be as easy to log.

Logs always need to be protected. This goes back to more logging so you know when logs were accessed and especially when they may have been cleared or deleted. Also, a little judicious cryptographic hashing may be beneficial here, particularly after the log file has been closed.

Speaking of cryptography, one of the challenges you are going to have when it comes to the auditing and accountability is that accounts can become compromised. It happens a lot. Wherever possible, using cryptographic keys that have been adequately protected is helpful. These keys should only be accessible by their proper owner if they have been password protected and stored with strong controls (physical access protections, password protections on the system, etc.). If you are sure that only the owner of the key has access to the account, then you have non-repudiation. The owner can't then say that when something happened, it wasn't them. Without that nonrepudiation, you get a whole lot of "it wasn't me" without any great ability to prove it actually was them, though the IP address may help some.

Finally, the cryptography thing that keeps coming up will also help with a chain of custody, which may be necessary if anything goes to a court of law. You will have to have all your logs properly stored and hashed so you can prove they were not tampered with. You will also need to have an audit trail of who had access to them and when they may have moved.

Summary

Data is the essential resource of almost all organizations. Systems will generally mean nothing without the information they are meant to process. You need to be aware of how best to protect information, as well as store and manage it across its lifecycle.

The data lifecycle starts with creation and goes all the way to destruction, with several stops in between. Each phase in the life of the data you need to protect will have different needs for controls to protect it. You will need to understand the different types of storage, as well as the varied threats to storage. There are several considerations when it comes to designing a well-protected solution in the cloud that compromises data storage.

Encryption is often discussed as a one-stop shop to protecting information, but it really isn't. There are simply too many ways to bypass encrypted information. The first is when the storage is encrypted. If you have authenticated access through, say, compromised credentials, the storage may not have been encrypted at all. If keys are poorly protected, you can decrypt information. It's simply not as easy as encrypt your

data and Bob's your uncle (whoever Bob is). Still, encrypt your data, but be aware of the different types of encryption and when to use them.

Information rights management is a good strategy for providing very fine-grained permissions far deeper than just whether you get access to a file and if you can write or read it. This is about whether you can save a copy, export it to PDF, take screen captures, copy data out of it, and a number of other ways of getting sensitive information out of controlled files.

While protecting access is all well and good, you should also have a lot of visibility so you can figure out when the barn door got open and maybe where all the livestock went. You need to have lots of logging and other telemetry so you have good auditing, traceability, and accountability. You should also ensure you have good practices for managing chain of custody in case something turns into a legal situation. This is where cryptographic functions can come in handy by using hashing to ensure data has not changed.

Other Resources

The following pages provide additional information about data security and cloud storage:

- “Top 10 Best Practices for Effective Data Protection,” The Hacker News, May 16, 2025 (https://oreil.ly/8q_Fh).
- “Introduction to IRM for Email Messages,” Microsoft (<https://oreil.ly/DXWio>).
- “What Is Cloud Storage?” Google Cloud (<https://oreil.ly/ivkhG>).
- “What Is Cloud Storage?” Amazon Web Services (<https://oreil.ly/Vf8dQ>).
- “What Is Encryption?” Google Cloud (<https://oreil.ly/0gDzJ>).

Cloud Platform and Infrastructure Security

Topics covered in this chapter include:

- Security architecture
- Data center security
- Virtualization security
- Network security in the cloud

One of the challenges with talking about cloud computing is it's easy to miss out on the case where you are using a private cloud. This means you need to take care of all security considerations related to physical infrastructure that you wouldn't normally think about with respect to cloud computing. This should include what goes into creating a well-protected data center. When it comes to data center security, there is a lot to factor in, because it comes down to making sure there are adequate resources so users can continue to use the services provided. When a company is developing its own cloud infrastructure for use, there are still the same expectations related to availability that you would want a cloud provider to offer. Local does not mean reduced requirements for availability.

There is a lot that goes into developing a fully reliable data center, however, that can withstand issues with power, weather, natural disasters, network outages, and failures without the infrastructure itself. Additionally, when you are creating your own data center, you are responsible for all the physical security control.

No matter where you are getting your services, though, there are some essential security functions that apply. These include identity and access management, data protection, logging, monitoring, configuration, and network security, as well as compliance capabilities. Each needs to be understood and applied across all services. Because of the Shared Responsibility Model, some of these functions will be on the customer, and some of them will be on the provider, whether your organization is the provider or whether you are using a traditional cloud provider.

It can be useful to start with a set of guiding principles that apply across all environments. Considering the amount of effort that many organizations put into thinking about this, you can reuse some of their work. Security is challenging because there is a lot to think about and you don't want to miss important aspects. Even without a reference architecture to work from, there are important considerations to develop controls around.

Infrastructure Security Architecture

A security architecture is an overall design that describes how security should be implemented within a system or application. This should include policies, systems, and controls that guide any implementations. What you are looking for is a definition of all the essential security components that should be involved in the design of an application or solution. This is more than just technology. You need more than firewalls and access controls, after all. A good solution should include technology along with people and processes. When it comes to security architectures, you're talking about essential controls without necessarily talking about specific implementations.

An architecture should start with security principles, meaning you should determine what you care most about. This includes your objectives, which will help determine whether your implementation is successful. After all, if you don't define a goal, you can't clearly show whether you have met that goal or not. You should also specify the control categories you care about and the ones you are going to define. These may include preventive, detective, or corrective controls. They may also be technical or administrative. You might not include controls from all those categories, depending on what your objectives are.

In addition to some level of detail for the controls, including what services and capabilities you expect to be offered, you should also define roles and responsibilities. After all, people are important to the overall implementation as well. Technology doesn't just operate itself.

Reference Architectures

You don't have to create all this from scratch, of course. Fortunately, several organizations have developed reference architectures. These are detailed specifications of all the information we have discussed earlier. Here are some reference architectures you can take a look at:

NIST Cloud Computing Security Reference Architecture

The NIST manages this guidance set that helps organizations identify threats and vulnerabilities to cloud implementations. Specifically, governmental agencies are expected to follow NIST guidance, though any organization can create appropriate security controls across different cloud service implementations.

CSA Enterprise Architecture

The Cloud Security Alliance is a nonprofit coalition of individuals who are focused on enhancing protections and security practices of cloud implementations. This framework categorizes security into domains like governance and data protection. You'll find guidance related to threat modeling in this framework, as well as implementing controls across multicloud environments. There is also a focus on compliance requirements as well as developing or emerging threats.

Microsoft Cloud Security Architecture

Microsoft uses zero trust as a foundation for its framework, with a focus on identity as a foundational control. Microsoft also uses a defense-in-depth approach to address threats to confidentiality, integrity, and availability within the Azure environment.

AWS Well-Architected Framework

AWS also has its own framework that is built around six pillars. The six pillars are operational excellence, security, reliability, performance efficiency, cost optimization, and sustainability. This is a very detailed and dense document that provides a lot of best practices. You can see, based on the pillars, that this extends beyond the security focus the other frameworks have. This is because AWS addresses the entire architecture rather than picking out individual pieces.

Google Cloud Security Foundations Guide

Google starts with a security-by-default stance, focusing on resource hierarchy and zero trust principles. Google also recommends automation to address vulnerabilities and threats.

IBM Cloud Security Architecture

IBM uses a threat-based approach to cloud security in its architecture. This architecture includes detailed guidance that is generally vendor agnostic, so there can be specifics around a multicloud implementation, since many organizations don't select a single cloud vendor to ensure they have better coverage for all customers around the world. IBM focuses on data protection, identity management, and continuous compliance monitoring. Similar to other frameworks, there is guidance on vulnerability management, which again highlights the importance of including ongoing support and maintenance of environments.

Depending on which cloud environment or environments you are planning to implement to, you may want to use one of these frameworks over another. For example, if you are deploying to AWS, you should consider the AWS Well-Architected Framework. If you are planning to deploy to multiple cloud environments, you should think about one of the frameworks or architectures that isn't tied to a specific vendor. However, you may end up learning from any of these, regardless of whether they are tied to a vendor like Microsoft, Google, or AWS.

Boundaries and Segmentation

Systems, networks, and applications are often constructed so there are components that carry different sensitivities of information. Additionally, the users that are accessing these individual components will have different needs, which may mean they should access information with levels of sensitivity different from other users. Keep in mind that ultimately, any system or application that is developed is usually about the information that it houses and how users get access to that information. This means you need to keep those levels of confidentiality and access in mind.

When you are developing something, whether it's a service, application, or a network where multiple users will be accessing information, it's essential to identify what the uses of the—let's just say system for convenience—will be. In the case of cloud access, you need to think about boundaries between the different components of your overall design. This is where it may be helpful to have something to look at. In [Figure 5-1](#), you see different levels of sensitivity and trust. The first place to be concerned with is the API gateway where requests come in from users. As these are coming in from individuals and devices we have no control over, these are untrusted connections. Not only the connection, but also any information that is passed to the API gateway should be considered untrusted.

This would typically mean you would put the API gateway into its own network segment, or at least on a segment with other components that have similar issues, meaning they are also public-facing and will take information from users at arbitrary locations. An API gateway alone is not going to get you very far. The API calls will need to be sent to other services to get the functionality of the application. This is

where you want to have other trust zones, but always be careful about the path the communication takes. You can see from [Figure 5-1](#) that the API gateway is in one network segment due to its untrusted nature.

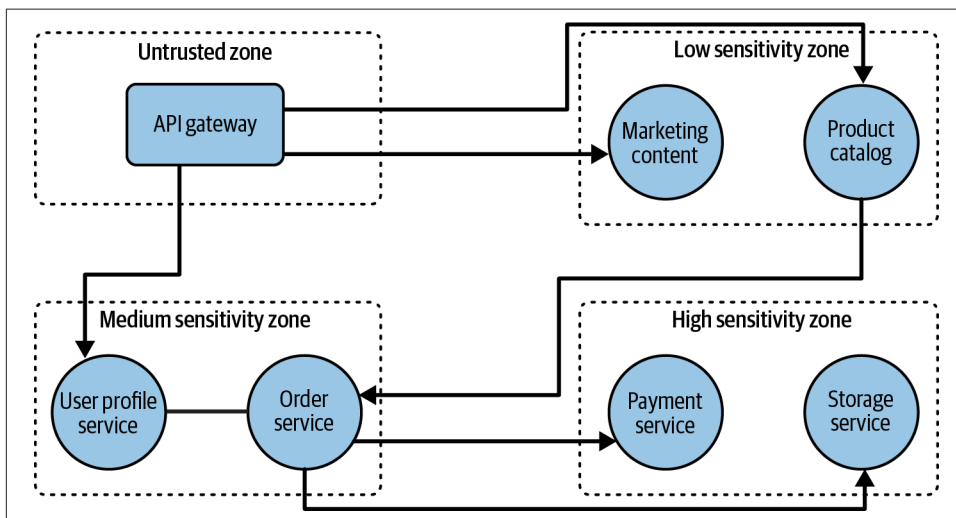


Figure 5-1. Trust boundaries and zones

Other segments include those for low-sensitivity services, like marketing content. This would mean there isn't anything on the system that is of particular concern if exposed publicly, but there may be information about access to other systems that would be problematic if exposed. Since there may be trusted network paths from those services to other services with more sensitive information, there needs to be a separate network segment to protect against lateral movement and monitoring information passing from one system to another. Certainly this is true when it comes to systems that contain confidential information, such as any database system or an identity repository.

Just knowing you need to segment systems doesn't necessarily help, though, without understanding how you do that. A common approach is to use virtual local area networks (VLANs), where you have systems with something in common on the same physical network, sometimes called the same broadcast domain. Effectively, these are Layer 2 networks, so all communication happens with the media access control (MAC) address. This assumes that all the IP addresses belong to the same network. The moment you have an IP address that does not fall into the same network, it can't exist on the same VLAN because it won't be able to communicate with any other device on the network.

Let's make this a little more visual. [Figure 5-2](#) shows a very simple VLAN. You see that the router, as well as systems A and B, are all on the same IP network. System C

is on a different IP network. Because System C can't get to the router, since it's on a different IP network, that device won't be able to communicate with any device off the network.

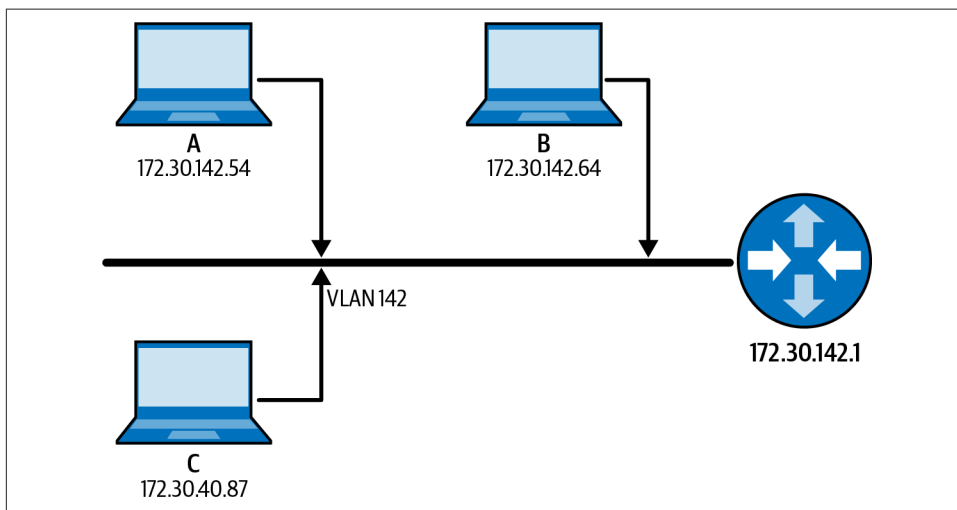


Figure 5-2. Simple VLAN

Here's the problem with a VLAN, though. It is a good way of organizing systems into coherent networks, which is great for management. However, it does not have any security controls. System A can send requests to System B in our diagram. Also, if this is all that is in place, there is nothing preventing someone from another network to send messages to the systems on this VLAN. This is where we need a firewall to protect against communications passing into or out of this network. Of course, we can implement firewalls on the hosts as well to help protect devices, but this doesn't necessarily achieve segmentation.

A common element of zero trust implementations is something called microsegmentation. This puts each device on its own network using firewalling at the host to restrict all access from outside devices. You can also use a software-defined network (SDN), which takes all the control out of the physical layer and puts it into software control. This works well when you are using virtual machines or cloud implementations, because most everything is software at that point anyway. You can still use SDN with physical devices using software on your endpoints, which may create tunnels through the physical network to other points. Traffic is then switched or routed through the tunnels, so the physical network is really the carrier for the tunnels, while the tunnels carry the user-based traffic.

When it comes to cloud environments, though, there are other ways of handling the kinds of isolation that would be beneficial. Since customers don't have access to the

networking hardware to create VLANs or IP networks directly, they are provided with their own software-based networking environment called a virtual private cloud (VPC). This provides the control necessary to put systems into separate networks with all the same controls that would normally come with VLANs. Additionally, security groups provide a way of controlling which ports are considered open. Once a security group has been created, it can be applied in different areas of the VPC so the configuration can easily be reused.

You may also be able to create network access control lists (ACLs) to control what traffic is allowed to enter one of your subnets. **Figure 5-3** shows what that might look like. At the edge of your VPC is a router, which allows the traffic in and out of your networks. The router determines which subnet any traffic needs to go to. Before it is allowed to enter the subnet, however, it will pass through network ACLs. This may restrict the source or destination address, as well as determine which ports or protocols are allowed or disallowed. ACLs are stateless, which means that decisions are made based on directionality of the traffic, not whether other communications were previously allowed or disallowed. Everything is on a case-by-case basis with a strict adherence to the rules that are in place.

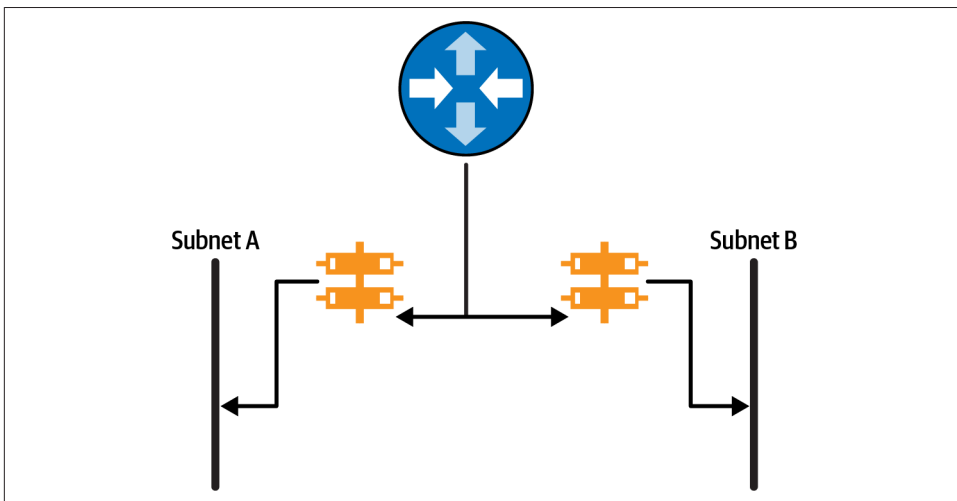


Figure 5-3. Network ACL Implementation

When you start layering all these different controls into a deployment, you get something called defense in depth (DiD). You may run across many definitions of defense in depth, depending on who you ask. Anytime I think about defense in depth, I am reminded of Minas Tirith, the seven-walled capital city of Gondor in *The Lord of the Rings* books (and subsequent movies). The idea of defense in depth isn't to put up protective measures like walls over and over again, which you can see in **Figure 5-4**. Once you've figured out how to get through one of these protective measures, you

will know how to get through the others. A better approach is to have different controls at different layers. As an example, you can have a stateful firewall, followed by a load balancer, then network ACLs and security groups to protect individual elements within the network.

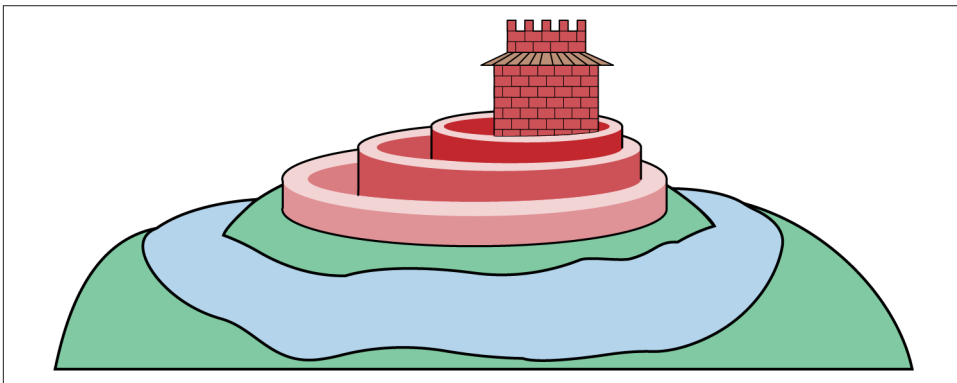


Figure 5-4. Defense in depth walls

There are many approaches to layering additional security controls within an environment or application. In addition to the network controls, like firewalls and access control lists, you can add in higher layer controls like a web application firewall (WAF) or even an API gateway. Each provides application-layer controls, though in different ways. An API gateway can control who has access, ensure there is rate limiting, and provide other protections against an API server. A WAF protects against application layer attacks by looking for malicious messages to either block them or alert on them.

There is another concept called defense in breadth (DiB), and sometimes you will see some overlap between defense in depth and defense in breadth. Defense in depth is meant to include layers of controls, but they may not always be technical controls. Sometimes you could have processes that help protect your infrastructure, such as a vulnerability management program. This helps keep your systems up-to-date with the latest software so known vulnerabilities are fixed before they can be updated. Defense in breadth will also factor in processes to keep systems and environments protected.

When you develop a complete security program, you will get inheritance that cascades down to all the components. We were talking about a good vulnerability management program. If you have one developed, it would apply to all the elements in your environment. The same would be true for other processes, such as logging and monitoring. You put it in place and it covers everything.

Inheritance is not only about processes, though. If you put firewalls and load balancers in place, other elements in your environment will be protected by them. You may

put a WAF in place in front of your web application, which will protect several elements behind the WAF. The same is true for an API gateway.

As you are thinking about your overall architecture, you can think about the best location to add controls to cover as many elements as possible, without having to duplicate coverage. This inheritance of protection is a good cost-savings measure. Make sure you have thought about how you are going to use the protections you have, though. Logging and monitoring, for example, are a great set of capabilities to have, but it means you need to ensure your systems are configured to log, and those logs need to be sent to your monitoring systems. Having a well-defined architecture to ensure you are protected across all the necessary components helps you think through what needs to be in place and where.

Data Center Security

Let's say you are creating your own data center. Suddenly, you have complete control over everything you are doing. This has some advantages if you prefer to have that level of control, but there is a lot to think about when you are building a data center and making sure you have everything you need. This starts with the location of the data center, all the physical security necessary, all the racks, power, cooling, networking hardware, and infrastructure, as well as every system and all the software needed to manage the cloud implementation to allow the clients to quickly deploy systems, like they would expect from any other cloud provider. Hosting it in-house won't change the expectations.

Physical Security Controls

Physical security controls start with the real estate agent's mantra—location, location, location. Your data center should be in a location that isn't likely to be exposed to natural disasters, to the extent you can control that. You don't want to place your data center on the open plains of Oklahoma, for instance. As nice a place as Oklahoma may be, it happens to be in the middle of Tornado Alley. This could dramatically increase the potential for damage to the building, as well as the likelihood of loss of power or upstream network connectivity.

It's not only about the geographic region you are in, though. There are other factors to take into consideration as well. You don't want to have your facilities located anywhere someone could gain unauthorized access in ways that would be different from what you'd normally expect. This includes any place where vehicles could smash into the building, like close to a busy intersection, for example. Similarly, you wouldn't want to be next to a parking garage, where someone could launch a vehicle into the building. These might sound like a bit of a stretch, but strange things do happen.

It's worth understanding all the potential threats when you select the location for your data center. You should also factor in additional physical considerations, like perimeter protections and how you can control access. Additionally, you want to ensure you have appropriate levels of monitoring to identify when your controls have failed or have been breached.

Perimeter design and access control

The perimeter of your data center begins outside the building. As noted previously, you need to protect against vehicles crashing into the building. Some of this is location, but some is also about putting physical controls outside the building. If you have ever been to a Target department store, you will see lots of large red balls outside the store. Similarly, in Washington, DC, you will see large concrete blocks that may have plants growing out the top. While there is a certain decorative aspect to these, they are actually bollards used to block access to a location. If someone tried to crash their car into the front of a Target store on a Black Friday because they were frustrated at not being able to get the latest hot toy because it had sold out earlier in the day, the vehicle would crash against the bollard, rather than into the glass entrance and into the building.

Depending on where your building is located, you may also want to ensure you can protect against humans trying to get to the building. While this can be accomplished with locks, you may also need to have gates and fences around the physical perimeter. These may not be required, but are often controls that are put in place around highly sensitive facilities.

Another element to consider when it comes to your perimeter is whether you have windows and their placement. Windows can impact the heating/cooling of a location. A window can also provide visibility into the facility, which could give someone an idea of the layout inside, internal security controls, or potential valuables. Additionally, windows are generally easier to break through than, say, concrete walls. A window, especially if it opens, is a potential entry point to the facility.

If you have complete control of the building, everything we discuss here will be your responsibility, but if you rent out space in an existing building, some of this will be the responsibility of the building owner. Considering you will have staff in and out of the data center, you will need to control who has physical access through the gates and into the building itself. Keys are not recommended. They are easy to copy and can be difficult to keep track of. Digital access mechanisms like badges or card keys are easier to manage, and access can be revoked as needed.

The room or rooms where the hardware and other infrastructure are located also need to have access controls. After all, there may be more in the building than the data center itself. Depending on the level of sensitivity or protection needed, you need to have access control like a badge, but you should also have a secondary form

of authentication. After all, badges can be swiped or given out to someone who shouldn't have access. A good secondary access mechanism is some form of biometrics. An iris scanner or fingerprint scanner would be good, since neither should be replicable. You'd also need a form of liveness detection to ensure that high-resolution scans of fingerprints or irises aren't used.

Tailgating is a common problem for physical access. You should have some means of guaranteeing that only the right person gets access. This could be something like a revolving door that only fits a single person and only engages in a quarter-turn rotation at a time. This does come with challenges, like handicapped access or if hardware needs to get into the facility. Your worry about tailgating depends on the sensitivity of what is in the data center or the Service Level Agreements in place with the customers of the systems.

Environmental monitoring

Even if you select a location that isn't prone to hurricanes or regular floods, you may still have problems with environmental issues. After all, there is nowhere on Earth that you'd want to put a data center that isn't subject to some form of environmental disaster. In 2024, there were places in Vermont that received two inches of rain an hour for a long period of time, resulting in extensive flooding and damage in many communities. Roswell, New Mexico, received half a year's worth of rainfall in 24 hours, also resulting in extensive flooding and damage. Kentucky, Alaska, Connecticut, and several other states also received extraordinary amounts of rainfall over short time periods. This is only to say that unexpected things happen and can cause a lot of damage.

Keeping track of environmental situations is important. Your organization should keep track of not only natural considerations like rainfall but any other environmental circumstances that could impact operations at your data center.

Security monitoring

Monitoring is important. Yes, it shouldn't need to be said, except that it continues to be amazing how often bad things happen and no one notices. When it comes to physical security, monitoring often takes the form of closed-circuit television (CCTV). That is to say that cameras observe behaviors. This may start outside to notice who is approaching the building or any suspicious activities. You will also want security cameras at the entry doors. [Figure 5-5](#) shows a facility door with access controls as well as a security camera to monitor anyone entering the building. The camera is housed in the darkened bubble above the door.



Figure 5-5. Security camera

Monitoring the cameras requires staff, however, which incurs costs that some businesses may not wish to pay. At a minimum, the cameras should be recording activity so it could be reviewed after the fact if something were to happen. This is not ideal, of course, since you'd want to catch misbehavior at the moment it occurs. This raises the question of security guards. In some cases, you might not have cameras because you have security guards at some locations, staffing entry points around the clock.

In addition to cameras and guards, you could also use monitors to detect open doors and potentially sound an alert if doors are open for too long. You may also have motion sensors in some areas that are set to alert when there is movement in the building.

Of course, monitoring should also extend to paying attention to badge swipes when someone is allowed into the facility. While a success may normally mean nothing, you may also want to pay attention when this success happens at, say, 3 a.m. when no one would normally be entering the data center. You may also want to monitor for successful badge swipes but unsuccessful biometric attempts. There are multiple locations where you can be monitoring activity, as well as the success and failure of access to the data center.

Operational Security

All of these security controls requires management. First, you need to have practices in place to determine who gets access to the facility. There should be clear guidance around what role should have access and what that staff needs to do to get and maintain that access. Additionally, these processes should include management of any means of authentication. If there are badges, how are badges distributed and how is access revoked as needed? If there are biometrics, how are they collected and protected? Anyone who has access to a data center would also have access to potentially sensitive information, so they should get background screening. This screening may need to be more rigorous than a standard employment background check. Staff with access to the data center should also have enhanced training around data loss prevention.

Invariably, there will be visitors to facilities. This is especially true if the data center is part of an office rather than a standalone building. There are several common approaches to managing visitors. Visitors should get some sort of badge or other visual identification. This helps employees or other authorized staff recognize when a visitor is in the vicinity. This can help prevent talking about sensitive information, and can also keep visitors from being in areas they shouldn't be in. Visitors should be logged, and the badge should either be collected after the visit or there should be some marker to indicate the badge has expired. Some temporary badges will automatically expire by either exposing red lines or the word VOID. These badges use migrating ink. After some period of time, like 12–24 hours, the ink migrates to the surface of the badge to clearly indicate it is no longer valid.

Vendors will also need to get access to the facilities and should be treated like visitors. They should be logged and monitored. Vendors, just like visitors, should be accompanied at all times. Vendor employees who have regular access to data centers should be subject to background checks. It is not unheard of for these vendor employees to use their jobs as a way to get into an organization without having to go through rigorous background checks.

When you have responsibility for the physical devices, you will need to take care of the destruction of those assets. This should start with being able to identify all assets. From an asset management perspective, all hardware should be identified, logged, and tracked from acquisition through retirement. From a security perspective, though, the most important components to track are the disks and any other media that may contain information. These should be destroyed. No matter the type of media, the storage should be destroyed to ensure no data can be recovered. While it's possible to do this locally, it may be more feasible to find a service that will take care of this in an industry-recognized fashion to be certain the data has been destroyed.

When it comes to disk drives, anything that is magnetic can theoretically be degaussed with strong magnets, effectively wiping the data off the disk, but there is no guarantee. You can also overwrite the data on the disk, but it takes several overwrites to fully destroy data. This assumes magnetic media. Solid state drives (SSDs) are becoming more common and the rules completely change for them. SSDs manage space differently than magnetic disks, using technology called wear leveling. There aren't defined cylinders using geometry from a circular disk. Instead, there are cells in the disk and it's up to the firmware on the disk to determine where the sectors are. Some cells may be taken out of usage to keep them from overuse. Even if you overwrite all the cells, there is a chance that some data remains because it was written to cells that were taken out of service. The best way to fully destroy disks is to physically shred them so they can't be put back together to recover any of the data.

All of the security controls should be monitored and tested on a regular basis to ensure they remain functional. You will need regular maintenance on devices like locks, badge scanners, security cameras, and anything else to do with physical security. You will also regularly ensure that human-related processes are being followed, including handing out visitor badges, logging visitors, and adequately destroying all storage media.

Redundancy and Reliability

A significant advantage of cloud providers is they take care of all the infrastructure that most people don't think about. When you put large numbers of computing devices into an enclosed space, especially when you stack them up in a rack, you will have a lot of heat that needs to be vented or cooled. Try walking behind one of these devices with chassis fans blowing heat out of the case. If you've ever been near a rack in a data center, you will be aware of how much heat there is. If you are building a data center, you will need to cool the room where the devices are. This generally can't be done by just venting since if you have adequate vents, you are then opening a potential avenue for an intruder to get access to the data center. Typically, cooling is done using large air conditioning systems. You will then need to take care of everything that comes with these systems, including any water that needs to be drained off since air conditioning works, in part, by removing moisture from the air.

Speaking of moisture in the air, you will also need to monitor moisture levels. Computing devices have specific operating parameters. You will need to monitor and control all environmental conditions to keep all computing systems within expected operational parameters. Otherwise, you will end up with system failures, which will certainly impact reliability.

Fundamental to computer systems, of course, is power. Some of this depends on location, making sure you are selecting a place for your data center where power is considered reliable. Ideally, you would have multiple providers with power coming from different sources. If one source fails, you will have a backup source to maintain power running to the data center. This is not always feasible, but having multiple entrances for power is a good idea in case of failure. Selecting a location for a data center where the power company commonly experiences power outages is a bad idea. States across the Midwest and southeast where tornadoes or hurricanes may be common could experience significant power outages. The northeast has a lot of power outages from winter storms and because some states lack sufficient generation capability.

Bad things happen, though, and sometimes you will have power outages in spite of your best efforts. Additionally, sometimes you'll see quick drops or spikes that could cause issues with your infrastructure, which could lead to significant failures and outages. Having additional protections on the power is beneficial. You may want power conditioners to protect against power spikes, which could destroy computing devices. You may also want an uninterruptible power supply (UPS), which can supply power by storing it in batteries in case there are power dips, which could cause systems to lose power in spite of the power coming back quickly. Finally, you should consider generators. Even if the location isn't prone to significant natural events that could cause long-term power failures, there are many circumstances that could lead to failures. A generator could quickly start up to continue to supply power in case the electric company is no longer able to supply it. The UPS should be able to ensure there is power to bridge the time between the failure and the generators starting up to supply power. Generators can't start before the power failure, so there will always be a gap. That should be handled with a power supply.

Figure 5-6 shows a diagram of what the power supply should look like. The power grid is in the upper left of the diagram, while the generator is in the upper right. In the middle is the automatic transfer switch, which is used to determine where the power comes from. This determines whether the generator needs to come on and provide power to the data center. The power then goes into the data center and into the UPSes, which then distribute power to the racks and systems.

While we are on the topic of redundancy, we should talk about network redundancy. Data centers should have multiple upstream providers to give them access to other networks. Again, there should be multiple entrance points into the facilities to protect against the destruction or disabling of one of the entrance points. Additionally, having multiple providers protects against a failure or problem with one of the providers to ensure continued network connectivity.

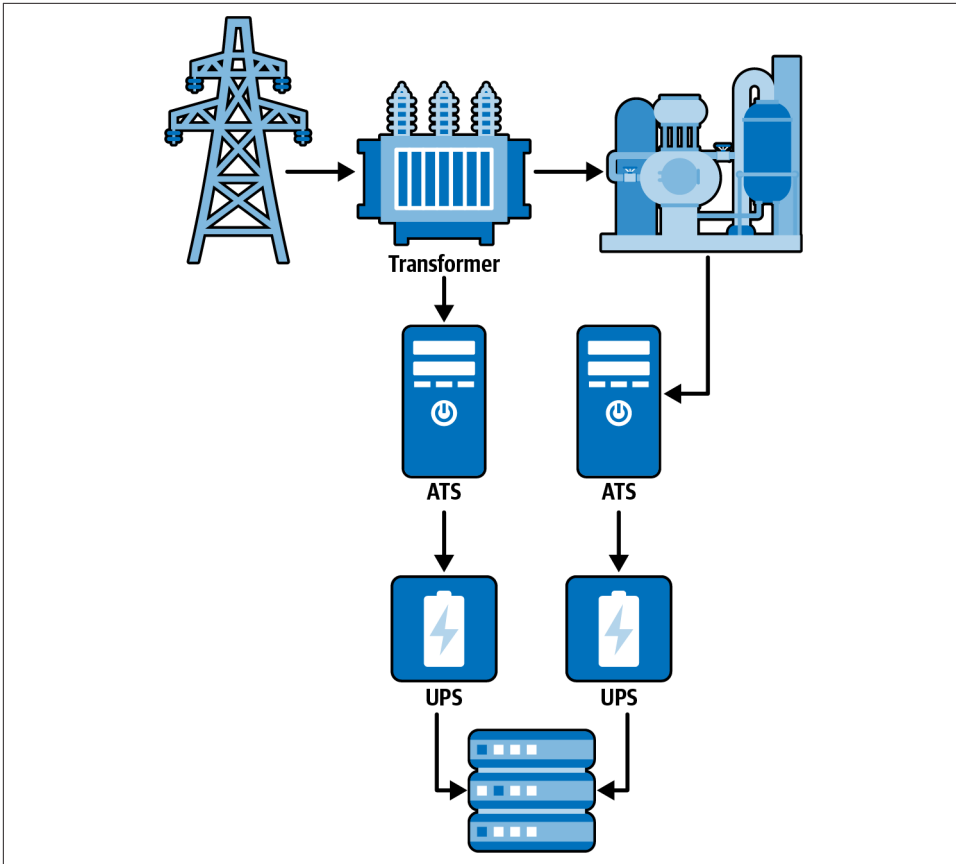


Figure 5-6. Power distribution

Even inside the building, there should be redundant network connections: multiple routers in high availability configurations, redundant routers, redundant switches, etc. This protects against failure at any level of the network infrastructure.

When you have electricity, there is a possibility of fire, so you should always have fire suppression systems in your data centers. Not only is it a good idea, but it's generally mandated by fire and building codes. Fire suppression starts with detection, so data centers should have both smoke detectors as well as heat detectors, since fires may not necessarily have smoke that can be detected first. Smoke detectors also don't work very well in some areas because of the way they operate. The detection capabilities should do more than simply create an alert. Any alert should be monitored, but should also trigger the fire suppression.

It's important to understand that fire requires three components: heat, fuel, and oxygen. When you remove any of those, you stop the fire. Fire suppression systems work

by trying to disrupt the chemical process. If you think about extinguishing a fire, you may think about pouring water on it, or from a fire suppression system perspective, using water sprinklers. Water works because it takes the heat out of the chain, since it can absorb a lot of heat. You aren't making the fuel more difficult to burn, you are taking the heat away.

Water and electrical devices don't get along very well, though. Water tends to destroy electrical devices. This means we need to think about other legs of the triangle to remove. Inert gases can be used to remove the oxygen, starving the fire. Argonite and Inergen are two inert gases that can be used. There are some powder-based suppression agents that also separate the fire from oxygen. Other suppression agents disrupt the chemical chain of combustion, while also providing a cooling effect to remove the heat.

In short, any fire solution should include detection of combustion, followed by fire suppression that removes one of the three legs of the triangle: heat, fuel, and oxygen. Water should not be used as a fire suppression mechanism in a data center, since it will destroy the electronics.

Disaster Recovery and Business Continuity

You can't guarantee that you can avert all disasters that impact business operations. This means you shouldn't focus on prevention as the only path. You will need to plan on operations failing, so you can recover in that eventuality. You should have selected a site that is less likely to be impacted by a natural disaster. You should also make sure you have redundancies built in in case of smaller failures, like individual devices. If an entire facility is impacted, you will need to have backups.

The first thing to do is develop a disaster recovery plan that assesses the potential threats to the facility and business operations. Based on those identified threats, the recovery plan should document contingencies to ensure the business can recover after the threat has passed. These will depend largely on what the threat is.

In the meantime, perhaps more important, plans for continued business operations should also be documented. This includes the possibility of manual interventions. If systems have completely failed for, say, transaction processing, you will need manual processes to continue business operations. This may include taking orders on paper. The disaster recovery plan should indicate how those paper transactions get converted back into the digital systems in the end. [Figure 5-7](#) is a simple flowchart to indicate how the disaster recovery and business continuity plans interrelate. The short version is that when a disaster or significant business failure happens, the business continuity plan should be engaged, since that is what is going to keep everything operational until the crisis passes. The disaster recovery plan may provide some interim guidance, but ultimately, its goal is to return the business to complete functionality.

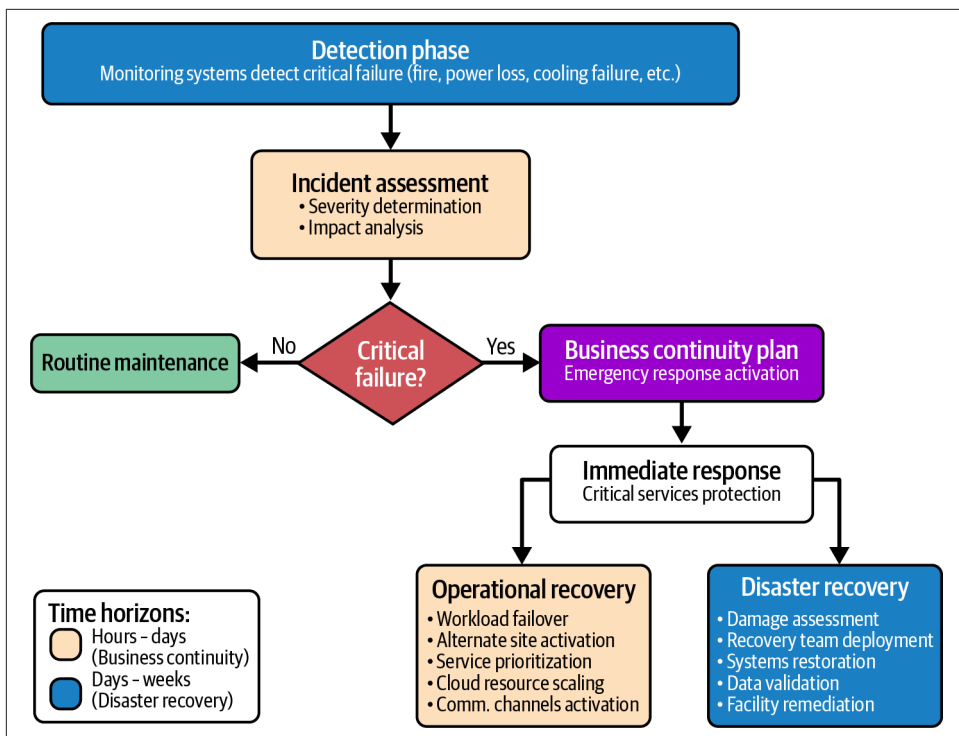


Figure 5-7. Disaster recovery/business continuity

While plans and processes are important, you will also need to have implementations in place. This includes backups where all data is backed up regularly. Because backups are regularly targeted by attackers, they should be stored offline or at least be immutable. In addition to backing up data, you may need secondary facilities that can be used as a failover. This could be a hot site, where the secondary facility is used in conjunction with the primary site as a sort of high availability setup. It could be a warm site, where data and systems are replicated to the secondary site so operations can be switched over the moment a failure occurs in the primary site. Finally, you could have a cold site where all the systems and infrastructure are in place, but everything needs to be restored to get them functional. You can see how each will have a different time to restore, which typically impacts the cost of each solution.

Plans and processes are great and important, but they should be tested. Creating a plan or process simply by developing it and writing it down is necessary, but there are essential elements that may be overlooked. Humans often make assumptions based on their own knowledge and experience. This means testing is essential. You can do structured walkthroughs of the plans, where people talk through the plan steps and components. Getting all the stakeholders involved can help flesh out missing or changed pieces. Tabletop exercises are the next step up from a structured walk-

through. In a tabletop exercise, a scenario is developed to stress test the plan. Based on the scenario, participants should respond with steps from the plan, making necessary decisions and calling in essential staff as needed.

Finally, there are simulations where you would actually fail or pretend to fail a system so you can actually fail to backups and practice the actual steps, rather than just talking about them. This will help identify areas where there may be significant problems that need to be addressed ahead of actual failures.

While there is some benefit to walking through these different testing scenarios as a training exercise to ensure there is some familiarity with secondary processes, even better than just practicing is to use the exercise as a means to make improvements. The goal of any of these tests should be to identify gaps, updates, or failures so all documentation gets updated. It's not all about documentation, though. In some cases systems need to be updated or added to ensure the business can be successful.

Identity and Access Management

Identity and Access Management (IAM) is a critical foundational component to any system implementation. No matter whether you are developing your own implementation of a cloud environment or using a public cloud, you need a strong IAM solution. This is more than just provisioning users and being done. Identities have a lifecycle, whether they are users, services, or other principals. The lifecycle should start with the provisioning process and follow all the way through deprovisioning. You can see a visual representation of a lifecycle in [Figure 5-8](#). Keep in mind that much of the work shown in this lifecycle can, and should be, automated. This starts with provisioning, includes auditing, and finishes with deprovisioning.

The first step is to provision a user. This should include verifying that the individual is who they are expected to be. If an individual is hired, before they are provided an identity on any computer system, their identity should be verified. After all, in cases where hires are often remote, you don't want to be providing an identity to someone who purports to be legitimate but may be interested in engaging in illegal or illicit activities. This may include performing a background check, and verifying an identification like a driver's license or passport against their actual appearance as checked with a video call. The hiring manager should specify, as part of the provisioning process, what rights and groups the user account should have. Any privileged rights should follow standard processes in use by the organization. A good practice is for any account with elevated privileges to use a separate account from one used for normal user activities that don't require additional rights.

The next step is authentication. This is verifying the identity of a user. This commonly uses multiple factors, such as something you know (username and password), something you have (token, device), and something you are (biometrics). When you

have multiple factors, you are using multifactor authentication (MFA). This may include something you know like a username and password followed by something you have. This may include a mobile device with an authenticator app that can request a number provided by the system or application requesting authentication. MFA is a good practice. Other practices for authentication include using an identity provider so you might see the use of tokens that demonstrate a user has been authenticated without a system actually performing the authentication itself.

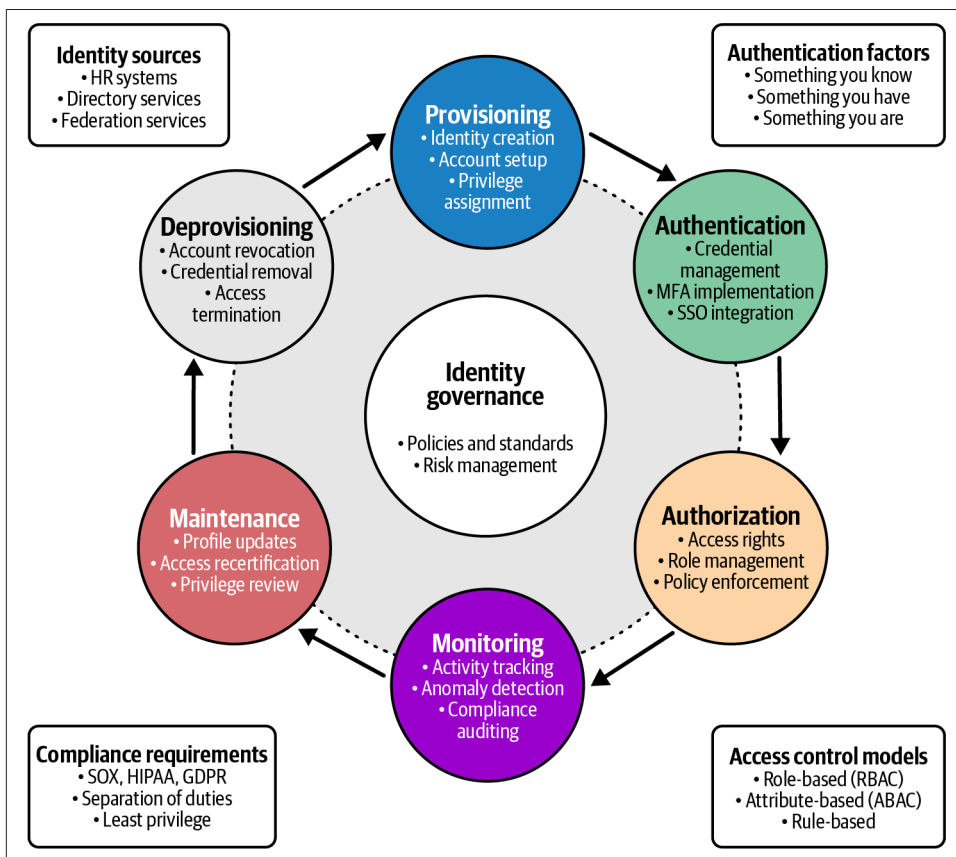


Figure 5-8. Identity management lifecycle

Once a user has been authenticated, they need to be authorized. This includes checking their rights and permissions against the resource being requested. Just because a user can log in doesn't mean they can perform all tasks or get access to all data stored within a system. Roles and groups play a significant factor here. These roles should be aligned with their positions within the company to ensure that they can only perform their duties, and don't get access to more than they should. This is called the principle

of least privilege. Users should get access to exactly what they need, and only what they need. Anything beyond this could lead to data leakage or misuse.

Companies may include conditional access policies. These conditional policies could ensure that the access request is coming from a corporate device or a geographically acceptable location. This includes a concept called impossible travel. If a user authenticates from Peoria, Illinois, and then two hours later attempts to authenticate from Seoul, South Korea, one of those is clearly a problem since it's not possible for a user to be in both places within that short span of time. Conditional access policies provide more fine-grained control over not only what a user can access but under what conditions they can get access.

When determining the right level of access, some common access control models should be considered. A very common one is to use role-based access control (RBAC), where users are added to roles, and those roles have the right sets of permissions. This makes permissions easier to manage since you aren't checking individual users. You could also use attributes to manage permissions, where users have specific attributes like location and group that can be used to determine the level of access. Often, systems use discretionary access control, where the level of access is determined by individual users. The alternate approach is mandatory access control where the level of access is determined by policy, and the policy is developed and implemented by management.

Monitoring is an essential practice across the board, and identity management is no exception. The entire lifecycle should be monitored for anomalies, including looking for unexpected user creation or user logins. Tracking activities for events like failures or even successes should be logged, since these activities may be useful for incident investigations. When you institute a monitoring program, it is also useful for compliance. You can show the principle of least privilege as well as separation of duties when you are logging and monitoring identity and access events.

You will need to maintain users throughout their active lifetime. This includes continuing to ensure the right level of access, often through audits by sending the list of users and their roles to the owners of the roles to ensure the right people are in the right roles. Additionally, the roles should be verified to have the right permissions. This is especially true when it comes to privileged users. Privileged users should only have access as long as they need it. One way to manage that access is to not have persistent accounts, even if they are using MFA. Privileged users could check out access that is time-limited so they only have that elevated access for a short period of time. This ensures they don't lose track of what user they are logged in as and try to perform normal user functions like checking email or browsing the web, both of which could result in compromise.

Finally, users should be deprovisioned. This may simply be removing the level of permissions a user has, but more commonly it is removing all system access. This is

another area that probably should be automated to help remove the potential for human error. The automation of deprovisioning, just as the provisioning, should be triggered through the human resources system. Automation could help ensure almost instantaneous removal of access or permissions. Automation can also allow verification of the removal so there is a certification that the account was deprovisioned.

Identities are not necessarily stored in a single repository. This is especially true in large, complex organizations or business to business situations. You might need a federated approach. Federation is where a trust relationship is set up between multiple sources of identity. The authentication is provided by the system of record for the identity, while the level of access may be provided by a different system that owns the resource being accessed.

Network Security in Cloud

No matter which cloud you are using, private or public, you need to be able to protect data transmissions. In addition to the segmentation previously discussed, other controls will need to be implemented. This typically only applies to infrastructure as a service, platform as a service, or private cloud implementations. As a consumer of software services or storage in the cloud, you would typically not have any control over or responsibility for network security. **Figure 5-9** shows a layered approach to network security controls you would commonly find in a cloud environment.

A virtual private cloud (VPC) is the common building block for network security in cloud environments. This is effectively a virtual network container. Within the VPC are all the networking elements that you would typically find in a physical environment. Starting from the perimeter of the VPC, you could have a traditional firewall, a web application firewall, protection against distributed denial of services (DDoS), and an API gateway. All of these provide filtering of requests coming in from the internet or other connected networks. Transport Layer Security (TLS) termination may also be necessary to monitor the actual traffic.

As discussed earlier, you can segment your network within the cloud. This may include subnets and network access control lists. Within the segmentation, you may also need to perform filtering. This could include the use of security groups. A security group is a definition of a host-based firewall that can be applied across multiple computing instances. If you have virtual machines or containers that provide web services, you could create a security group with a default deny policy that allows communication to TCP ports 80 and 443.

You may also introduce a firewall into a network segment, especially if you have a number of elements into the network segment that have the same classification or application requirements. It makes sense to have standard configurations that can easily be applied in situations where they are relevant, rather than trying to have individual configurations for every host.

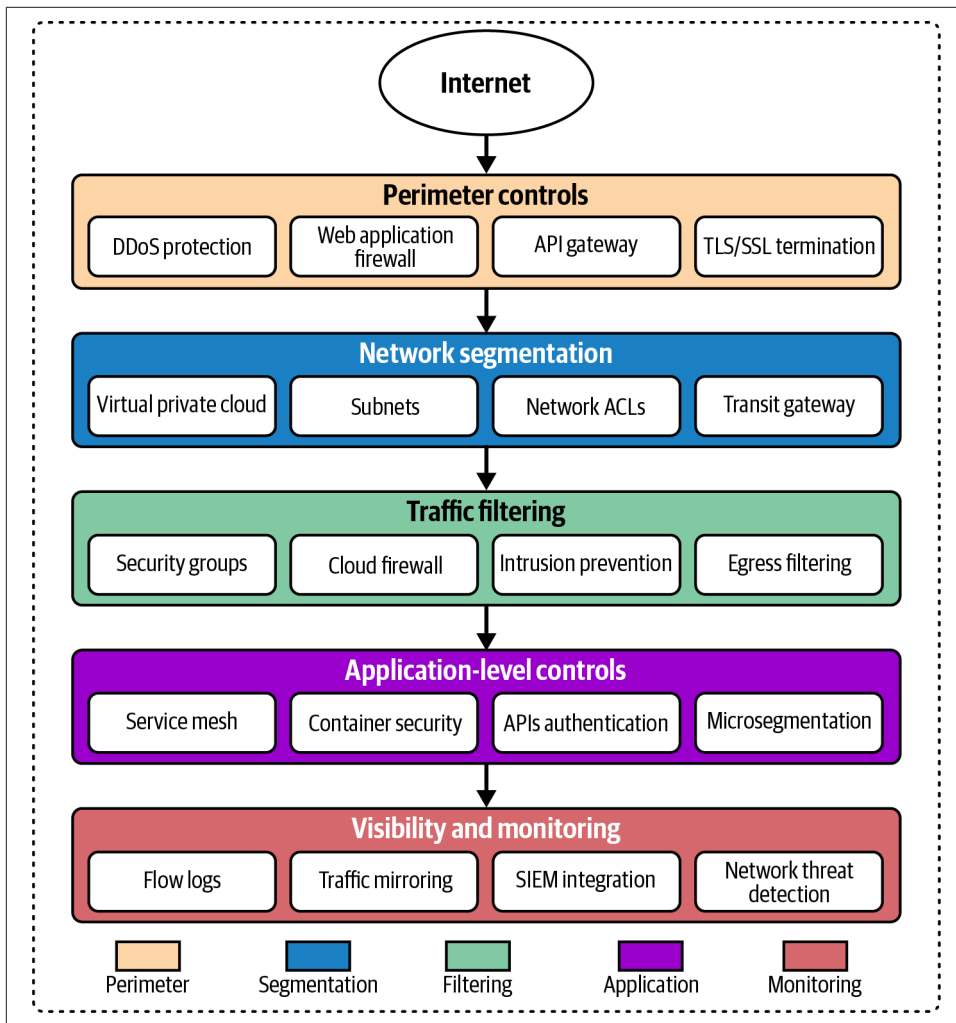


Figure 5-9. Network cloud security controls

In addition to the preventive controls, you should consider detective controls. This includes logging from the controls mentioned already. Additionally, different network elements should have flow logs that are sent to a centralized monitoring solution, like a security information and event management (SIEM) system. The flow logs provide overview information about the different communication streams that are passing through the environment. This includes packet counts and sizes based on the directionality of the flow. It should also include ports and protocols.

Logging alone won't achieve detection, which is another reason to have a SIEM. With the SIEM, you can create alerts based on rules and anomalous behaviors. Having logs and network statistics can help inform investigations into incidents. As discussed previously, you want to make sure you are implementing layers of controls.

Virtualization Security

Clouds are, almost by their nature, virtualized. Systems, networks, and applications can all be virtualized, which means all the components are abstracted by software. A virtual machine presents the different components of a computer system as though they are real hardware, when in fact, they are controlled by software. Network traffic is not necessarily passed over cables and hardware. Instead, it may simply pass through software applications.

Virtualization creates new problems. In addition to operating systems and applications that need to be protected, the virtualization platform itself needs to be protected. Infrastructure as a service (IaaS) uses a hypervisor to abstract the hardware from the operating system. The hypervisor itself could be compromised. If the hypervisor is compromised by an attacker, the attacker then gets access to all the virtual machines running inside that hypervisor. There is not generally a one-to-one relationship between hypervisors and virtual machines. If there were, it wouldn't make a lot of sense since you'd just run the operating system directly on the hardware and cut the middleman (the hypervisor) out since it gets you nothing but additional complications.

This means you need to be able to fully isolate one virtual machine from another. The hypervisor is required to intercept system calls from each virtual machine and know what sets of hardware belong to the virtual machine. This includes memory, which is highly sensitive because it contains data with running applications. The hypervisor has a virtual memory page table for each of the virtual machines. This keeps memory from being accessed from one virtual machine to another.

Similarly, virtual disks are stored as files within the physical hardware. Access to the disk within the virtual machine is caught and the location on disk refers to locations within the file. The hypervisor again prevents access to information that belongs to

another virtual machine. Isolation of one system and the data associated with it from another is an essential task of a hypervisor.

The problem comes when you can escape from within the guest operating system to gain access to the hypervisor management. Theoretically, it would take a vulnerability in the hypervisor software to allow an escape from the guest system into the hypervisor. However, if there are inadequate network protections, the guest could gain access to the management interfaces of the hypervisor. This may be a web interface or through a console-based interface like Secure Shell (SSH). If an attacker or user were to gain access to the management interface, it would behave like an escape from the guest operating system.

This brings up virtual network security. All networking within a hypervisor is, by definition, software defined. Each host within a virtual machine should be on its own network segment, meaning it gets a separate IP network. Ideally, all networks from the hypervisor into the physical network would be tagged to further ensure network separation. The protocol 802.1q allows for network traffic to be tagged as being part of a particular VLAN. This means switches must abide by the tagging to keep traffic on different VLANs separate unless the switch is specifically configured to allow it.

The users are responsible for allocating and managing resources, though the overall management software that controls the user interface and determines where workloads exist also monitors oversubscription. While oversubscription is expected, since that's the point—taking one resource and spreading it across multiple systems and applications—it can be taken too far so it's not an abstract concept but an actual bottleneck. This is the responsibility of the hypervisor and all management software. The resources need to be allocated efficiently across all hardware and virtual machines to ensure the necessary work is accomplished.

Container Security

Virtual machines are perhaps easy to understand, since you just take a computer system and abstract it into software. A container is slightly different. It is still a form of virtualization but rather than abstracting the operating system and accessing it as though you are accessing a real computer system, you are virtualizing just an application. The application runs in a virtual environment called a container. It still believes it is running on a real host and has access to all the same hardware if it was running on a physical system. However, management of the application is very different. You don't connect to an operating system to run the application. Instead, you interface with the application through the container management software. The only interaction with the application is whatever functionality the application provides.

Containers are separated from the host operating system and from one another by isolating them in memory. A container typically uses something like a namespace, which is a type of metadata managed by the operating system. The namespace is just

a way to tag memory addresses. Access to those locations in memory is only possible from any application that is similarly tagged. You can see a graphical representation of how the container interacts with the operating system, through container management software like Docker, in [Figure 5-10](#). The namespace also controls access to other resources, like disk and memory.

Gaining access to a container requires a vulnerability in the application running inside the container, but the only access from the compromise is a fake system with only the essentials needed to run the application. Additionally, containers are often ephemeral, meaning they disappear after a time, so there is no persistence. Anything that is potentially imposed within the container from a compromise would disappear when the container instance went away. This is beneficial from a security perspective but not necessarily adequate.

There are similar problems with containers as with virtual machines. Escape from a container is possible if there is a vulnerability in the kernel which allows memory access from different namespaces. Additionally, if the management interfaces in the host operating system are exposed, it's possible to escape from the container to the host, where you get more control of the containers and any data that may be transmitted.

There are ways to better control the containers. With control groups (cgroups), you can establish quotas to protect against denial-of-service attacks from resource over-use. A cgroup also gives control over prioritization. These cgroups are not sufficient, though. Additional controls are necessary. This could include mandatory access control like SELinux, which allows you to establish control over any resources on a Linux system by tagging them with labels that indicate policies. You can also set capabilities on resources, which can similarly limit behaviors. Containers should have limited capabilities, which includes dropping `CAP_SYS_ADMIN`, `CAP_NET_ADMIN`, and others that could provide an attacker with enhanced privileges should the container be compromised.

Containers should also have secure computing (seccomp) profiles established. These profiles block certain system calls. The ability to mount or unmount devices, trace processes, change system time, manage swap storage, and other system calls should be blocked to prevent misuse from within the container.

Using these techniques, containers can offer enhanced security by limiting what any attacker can get access to, even if they can compromise the application. It also minimizes the potential attack surface by removing some capabilities that could be used to compromise the application and container.

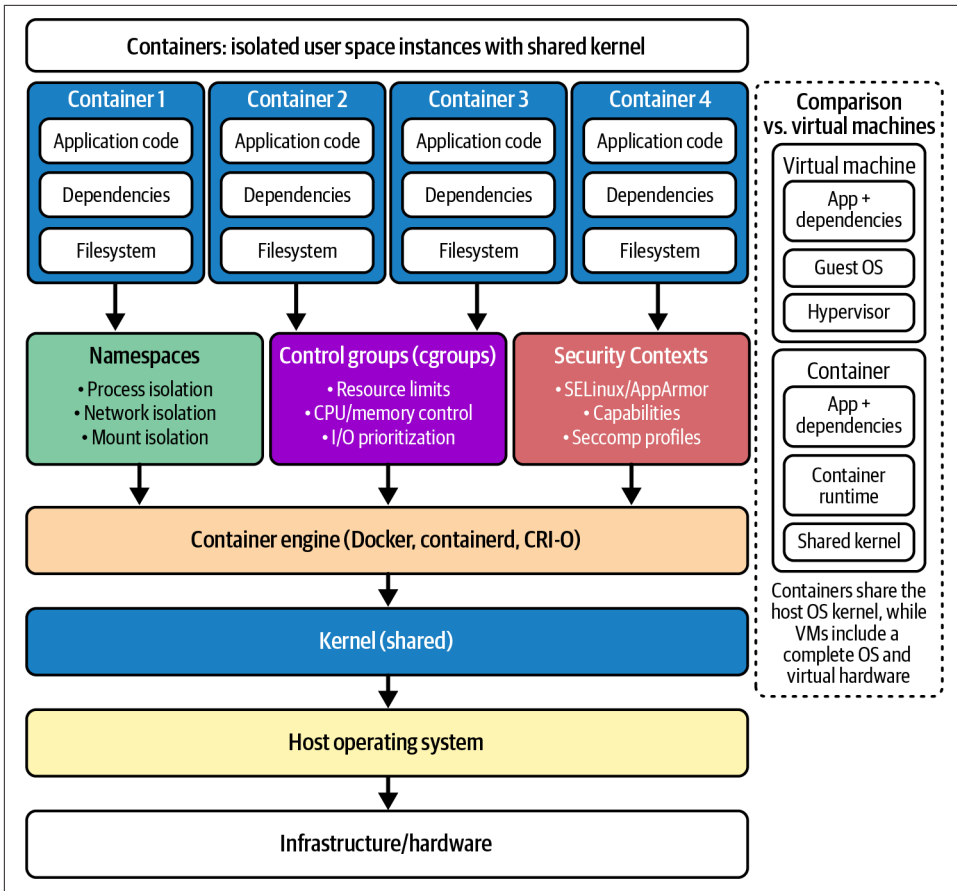


Figure 5-10. Container security

Summary

Starting with a security framework or architecture can be beneficial, since it will save you from a lot of thinking and work, focusing on practices and essential elements that have been proven through long-standing industry practices. NIST, the CSA, Microsoft, AWS, Google, and IBM all have cloud security architectures or frameworks. While the vendor-specific ones are often related to their own offerings, it doesn't mean there aren't broader ideas that can be used. Reviewing the recommendations and implementation ideas can help ensure you are providing the best protection for your own systems or applications.

Any well-designed environment, whether for infrastructure, an enterprise, or a single application, will include a set of good practices, like isolation and segmentation. There are ways to segment within the network using VLANs, firewalls, and access control lists. Systems should be segmented based on their sensitivity and the associated data. Different security and network controls can protect access. Layering these different controls can provide defense in depth and defense in breadth, two larger concepts that are meant to ensure you have full coverage from a protection, detection, and response perspective.

You may choose to use a private data center for your cloud implementation. There is a lot that goes into creating a data center, including location identification, power, cooling, physical security, monitoring, access control, and redundancy. You also need to think about fire detection and suppression. Also, you need to think about not only preventing disasters but being able to handle them when they happen. This should include developing and testing disaster recover and business continuity plans. Testing should focus on improvement of capabilities and not focus exclusively on paper exercises like structured walkthroughs or tabletops, and should include simulations to test the physical implementations and not just the plans and processes.

Identity and access management is a foundational principle for any security implementation. There is an identity lifecycle that should be considered. It includes provisioning, authentication, authorization, monitoring, maintenance, and deprovisioning. Automation should be a focus of all of these phases of the lifecycle, as it helps to reduce or eliminate human error.

Clouds run on virtualization, whether it's virtual machines, virtual networks, virtual storage, or virtual applications. There should be protections in place to prevent breaking out of virtualized environments. The virtualizations already have several protections by the nature of their virtualization, but other protections are necessary. A virtualized environment, by its nature, can provide access to several systems and data sets at once. This makes these systems and applications prime targets.

Other Resources

The following pages offer additional information about data center security and different cloud architectures:

- “What Is Data Center Security?” Cisco (<https://oreil.ly/0yZgl>).
- “What Is Cloud Architecture?” Google Cloud (<https://oreil.ly/jW7KK>).
- “Cloud Security Technical Reference Architecture, Version 2,” Cybersecurity and Infrastructure Security Agency (CISA), June 21, 2022 (<https://oreil.ly/9CuID>).
- “Cloud Native Reference Architecture,” Cloud Native Reference Architecture/CNCF End User Technical Advisory Board (<https://oreil.ly/pa2nX>).

Cloud Application Security

Topics covered in this chapter include:

- Application security threats
- Cloud security control mechanisms
- Web application security
- Using APIs

More and more organizations seem to be moving their primary infrastructure to cloud environments. This includes offloading previous in-house instances of mail servers and identity repositories through services like Google Workspace for email and Entra ID for identity services. It's not only foundational infrastructure, though, that companies are pushing out to cloud providers. Getting rid of data centers saves companies a lot of money and also migrates a lot of responsibility to the provider. In addition to infrastructure, companies have been pushing other services into cloud environments. In for a penny, in for a pound, as they say. Once you start outsourcing, especially as you start downsizing your on-premises data center footprint, you start thinking about everything else you don't need to be hosting yourself because it means one less set of systems in your data center.

Most organizations are not in the business of either real estate or information technology. They want their businesses to operate. Because everything is digital today, and you can stop me if you've heard this before, the businesses require applications to manage all the information they run on. Almost any application you need today can be acquired without having to invest in infrastructure. Just get your software from a provider, store it somewhere else, and don't worry about all the headaches that come from having to maintain your own infrastructure.

This is not to say that there are no problems with cloud-based applications. There are limits to the liability you can push off to a vendor. Keep the Shared Responsibility Model in mind. Your data and your users are your responsibility. Additionally, your policies are your responsibility. There are just some things you can't push off to your providers.

You may not actually use providers for everything. Often, companies have needs for their organization that are filled by developing applications internally. These applications can still be hosted with cloud providers and taken out of the data center or off premises. That means, though, that the application and all the protections necessary are your responsibility. This means the entire secure software development lifecycle, not just the data.

When it comes to applications, it is never as straightforward as where the applications are located, or who has responsibility for which pieces. Ultimately, the business is responsible for what happens to customers, employees, and data. This means that no matter whether you've chosen to use cloud providers for managing applications, you will be responsible for the end result to at least some degree. That's why it's essential to understand the threats to your applications, whether developed internally or using a provider. It's also essential to understand how you can implement controls to protect your applications, no matter where they are, and ultimately, your customers, employees, and data.

Application Security Threats

Applications are a pathway to data, whether you are a user or an attacker. There are many common threats to applications, and they exist no matter where the application is hosted. There are differences in how the threat may manifest, but the threat remains the threat. The impact to the business is largely the same. This means you should already be familiar with these threats but we can talk about some of the nuances when it comes to cloud implementations.

Identity and Access Management

The biggest threat is associated with identity and access management. Attacks against usernames and passwords remain incredibly common and are one of the top means for attackers to gain access to resources. Much of this comes from a combination of bad practices. The first is the use of weak passwords. Anytime you use a short password, you are potentially exposing your account to compromise. This is especially true if you are using one of the most commonly used passwords. There are password dumps all over the internet, and with processing speed being what it is today, it's trivial to perform password attacks, especially if a credential artifact can be captured.

Secrets are often hashed, meaning they are taken from the plain-text form and passed through a cryptographic function to return a consistent length value. A commonly used word list is RockYou, which usually comes as a package with security-oriented Linux distributions like Kali Linux. According to the 2024 version, the current one as of this writing, there are roughly 10 billion commonly used passwords in the list. Given a modern processor with, say, 8 cores, it would easily take under an hour to calculate the hash for those 10 billion passwords and compare against a known hash. Graphical processing units (GPUs) are considerably faster for mathematical operations, like those required to calculate a cryptographic hash. Running that same word list through a GPU results in the hashes being calculated in seconds rather than minutes.

It's even easier and faster if you are comparing against precomputed hashes. Rainbow tables are databases where precomputed hashes are stored along with the password that matches them. In that case, all the computational work has been done up front and all you are doing is a lookup. This makes compromising password hashes trivial. You're just trading storage for compute. If you have enough storage, you can store enormous numbers of precomputed password hashes.

All of this is to say that passwords are weak, in part because users can be tricked by social engineering to give them up. In addition, there are several attacks that can yield password hashes that could be cracked. Users who regularly reuse passwords are exposed to having additional accounts compromised. Using multifactor authentication can be one way of making life harder for attackers who want to compromise accounts.

Password compromise is not the only threat that falls under identity and access management, though. Ensuring that users have the right level of permissions and access is important. Even without credential compromise, data loss and other negative impacts can happen if users mishandle information.

Of course, each cloud platform has different capabilities for identity and access management. Having good processes regardless of the specific technology is important. Focus on ensuring you have solid identity and access management policies and practices in place to protect the identity across the entire lifecycle. This includes not just using strong passwords that are easily managed by your users, since strong password practices, including regular rotations, can actually work against you. Strong password practices force people who struggle to keep rotating complex passwords and keep track of dozens of constantly changing credentials to use bad password hygiene just to keep up. Using multifactor authentication can also protect against bad habits.

One of the worst cases of poor identity and access management is the misuse of privileged credentials. Unfortunately, all the same problems with standard user accounts exist for privileged credentials, but the impacts are significantly worse. Fortunately,

there are ways to address these concerns with stronger controls over these credentials, including password vaulting and just-in-time access control.

Misconfiguration

Complexity always comes at a cost. Cloud environments, with all their capability and configuration options, can be some of the most complex you've seen. This complexity opens the door to misconfiguration. Obviously, misconfiguration is not something people plan for. Sometimes it's just mistakes made because we are human and we make mistakes. Sometimes it's not understanding the ramifications of choices that are made or the configurations that are set. It is easy enough to get lost in the large numbers of settings, and not all of them are straightforward.

One very common misconfiguration is allowing public access to information. Storage is fundamental to pretty much everything business does with computing infrastructure. It is after all called data processing, not machine handling. Providing a storage bucket with a public IP address is one way to misconfigure if there is no reason for that storage to be accessible directly to anyone outside of the application space. Additionally, without the right access controls, meaning allowing anyone who can get to the bucket can have access to what is stored there, you are exposing anything stored there to public consumption.

Encryption is another area where misconfiguration happens. This may include not enabling encryption where it is essential, as well as enabling weak encryption protocols, which can lead to information exposure. Encryption is challenging. The whole point is to make it impossible to read the information that was encrypted. Misconfiguration can also be mishandling keys by allowing the passwords used to unlock them to be stored in plain text without adequate protections.

Default credentials have been a problem for a long time. This is where a system or device comes with hardcoded credentials with the expectation that the user would change at least the password. Of course, it's often easier to just leave the default credentials since they are usually easier to remember and manage (you can always look them up online if you've forgotten). While vendors have generally addressed this old issue, it may still be possible to find systems that have default credentials, so they are always a concern.

Poor Vulnerability Management

All you have to do is read the mainstream news on a regular basis to know that there are plenty of vulnerabilities that get repaired and reported on regularly. Microsoft's Patch Tuesday, for a start, often makes it to nontechnical news outlets. Software has vulnerabilities, which means organizations need to have processes to manage and remediate them. Migrating to the cloud doesn't remove that problem. Some of these vulnerabilities become the problem of the cloud provider. However, in many cases,

you as the consumer will have to make sure you are monitoring the vulnerabilities and repairing them. Also, your provider needs to ensure they are keeping vulnerabilities remediated by updating the software with fixes.

If your organization is developing applications, you will need to have management processes for updating all libraries and products used in the development of the application. This is also true of any container being used as part of the application. Any container source will have to keep up with all vulnerabilities so the underlying applications are patched against security issues.

Vulnerability management is ultimately about process. This is because there are usually considerations beyond just how to technically keep software up-to-date. There will invariably be dependencies on the software, so it's not as simple as installing fixes. Software implementations are complex, and there can be a lot of unforeseen interactions from new software. The threat of unpatched vulnerabilities is complicated by the potential threat of fixed software causing incompatibilities with other software.

Insufficient Logging and Monitoring

Visibility is an essential component of any security program. You can't react to something you don't see. More and more organizations have figured this out over time so they are better at detecting intrusions. However, they usually need a security information and event management (SIEM) system, and those vendors have figured out the best way to price them is to charge by volume. This means organizations are not always collecting all the logs they may need for complete visibility. Logs consume space, after all, and a good practice is to maintain enough logs beyond the possible amount of time an attacker may be in the environment before being detected so you have a trail you can follow back to understand the full scope of the impact. Large numbers of systems result in large volumes of logs.

There is a possibility that organizations may not be logging in their cloud environment, assuming that the cloud provider takes care of that. This is where it's important to understand who is responsible for what. If you are assuming that your cloud provider is taking care of all the patching, but there are components that you are actually responsible for, there may be gaps in what you can see and your ability to respond when something happens.

Of course logging alone isn't sufficient. You can log all the data available but unless you are taking a look at it, it's only good for maybe figuring out what happened after it happened. This means you need a system that will monitor the logs and generate alerts. Just having humans watching screens of log messages as they flash by is not going to be effective. Even one system generating a full load of logs will overwhelm someone watching the log messages fly by. Our eyes and brains don't work that fast. This means you need a system that will pay attention to all the logs being generated

and create alerts that someone can then look at. Even that can be challenging if the alerts aren't for events that are worth looking at.

It takes a lot of work to find the right logs to be collecting and the right messages to generate alerts from. It may be tempting to just find anything related to MITRE's ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework. The ATT&CK framework is a compendium of all the known adversary tactics, techniques, and procedures. Techniques are defined as the why, or the reason for performing an action. This is not the overall goal, but instead, it is the goal of a step. After all, complete attacks generally include multiple steps. One step may be credential compromise. This is the tactic. The technique is how the attacker is going to go about compromising credentials. This may be something like phishing or dumping credentials from a system. Finally, the procedure is the specific implementation. This may be using a tool like mimikatz, for instance.

As of mid-2025, MITRE has identified 14 tactics. This represents the top level of the ATT&CK matrix. Beneath the tactics, there are currently 211 techniques and under that there are 468 subtechniques that are specific to situations. Each technique could have multiple procedures and not all of those may be catalogued, since they could be unique to individual attack groups, especially those who write their own tools.

Given the large number of ways an attacker can operate, this would be a lot of rules that any monitoring system would need to pay attention to and try to correlate log entries against. Additionally, even if you did end up following this approach, an extraordinary number of alerts could get generated and should be chased down to determine whether they are incidents. You can overwhelm your security operations center staff with alerts for events that don't matter. While it's always better to catch bad circumstances from happening earlier in the attack lifecycle, there are many events that are going to fatigue your staff and potentially create misses of actual incidents. Catching a ping sweep, for example, is unlikely to be worth anyone's time. It is considered a type of reconnaissance activity, but it is more likely to be a nuisance event that should be blocked by your firewall anyway.

When it comes to logging and monitoring and overall visibility, it's necessary to think of the entire stack. This means from the network all the way up to the application, and should definitely include not only security controls like firewalls, access controls, security groups on virtual private clouds, and any intrusion detection, but also application logging with particular attention to anything to do with authentication and access control.

Poor Segmentation

Network segmentation and system isolation has long been an important aspect for providing overall protection to systems and applications. A traditional n-tier application placed the web server, application, server, database server, and others into separate network segments. Today, with microservice architectures and even serverless designs, segmentation remains essential. Without segmentation, you have what is referred to as a flat network. The problem with a flat network is there are usually limited controls to prevent someone from moving from one system to another (lateral movement, sometimes called east-west).

Effective segmentation isn't just about putting systems and services on separate VLANs, though. Effective segmentation gives you the ability to control and restrict what traffic gets from one segment to another. This requires at least access control lists, but firewalls are better. [Figure 6-1](#) shows using firewalls to control access from one segment to another.

There are many approaches to how to segment, but it's often useful to consider the sensitivity levels of one system to another. You should have the same level of protection on one system within a network segmentation as you do on another. In other words, you don't want public data stored on one system where you don't care as much about restricting access alongside another system where, for example, personally identifiable information is stored. These are two separate trust levels, and those systems should be on different network segmentations to protect the sensitive data.

You could use host-based firewalls to better isolate hosts from one another, and that could be a good control in addition to network-based controls like network firewalls. One problem with host-based firewalls is there may not be effective central management of them, which means each host could have rule sets that aren't known or understood. This can expose holes that attackers can make use of.

This brings up the idea of microsegmentation. Microsegmentation is a way of isolating systems at the host level. You can use a good microsegmentation implementation to keep systems protected and isolated from one another, only allowing the right applications to talk to one another from system to system. Microsegmentation implementations generally allow for centralized control, so you are using the right policies within your implementations.

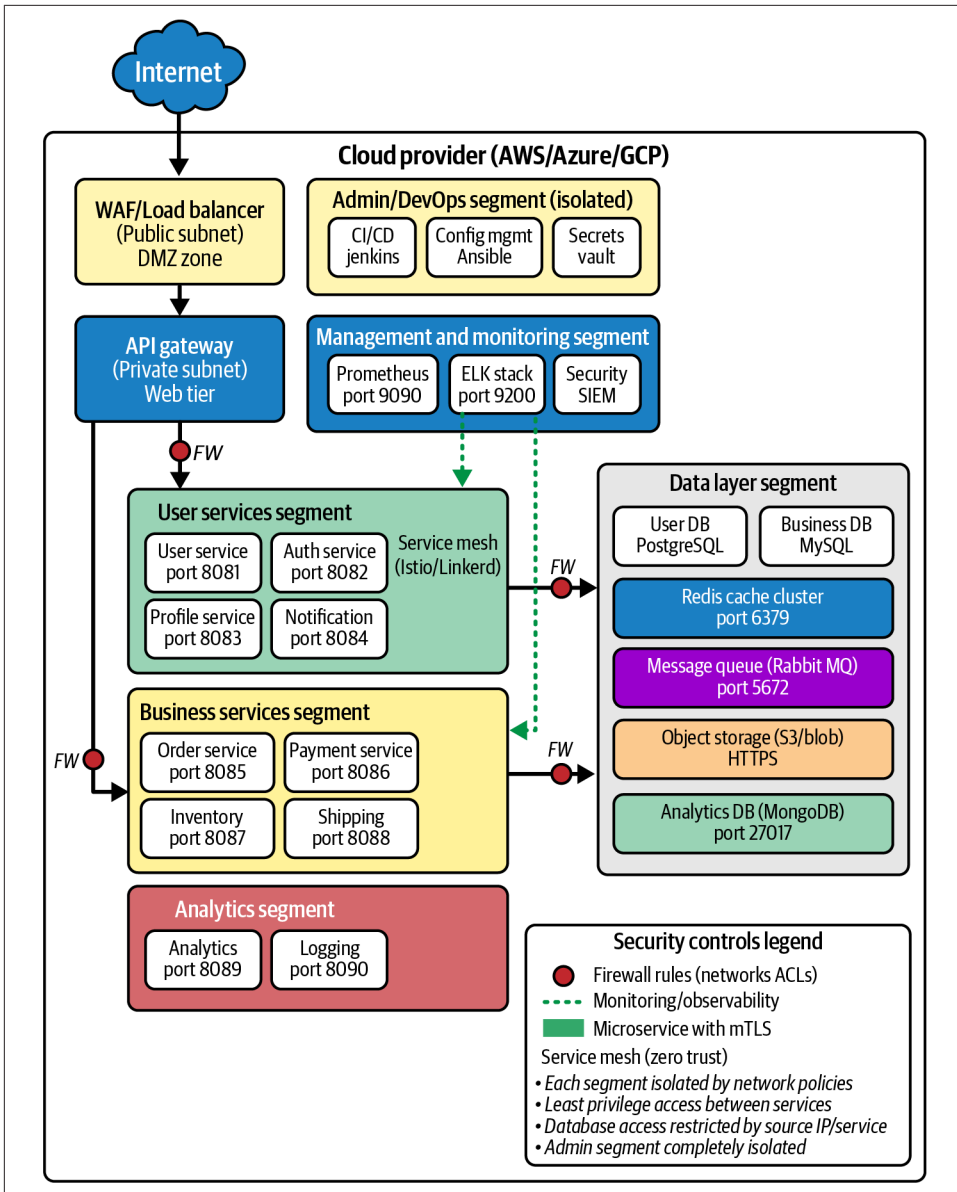


Figure 6-1. Effective network segmentation

Infrastructure Misconfigurations

The biggest issue here is having an effective patching process in place. This is more than vulnerabilities and vulnerability management. Patching isn't always about vulnerabilities, because not every fix is security related. Patching is also about ensuring you have the latest software since software companies don't support versions indefinitely and at some point, the version that is installed loses support. Many organizations lack effective patch management practices. This may be especially true for development organizations because it can be a lot of work to keep dependencies updated, which requires testing and potentially recoding. This should always be part of the cost of developing software, but it's not a cost many organizations carry.

Beyond patch management, though, there are many ways infrastructure can be misconfigured. Any firewall or security group that allows access into networks and systems can be easily misconfigured, allowing excess access. Not all services should be open to everywhere in the world, even if all ports except essential ones are otherwise locked down. It's also easy enough to misconfigure by opening systems and ports through these rules. This is especially true in large implementations, since it may be difficult to keep track of what information needs to traverse to which part of the application, crossing security boundaries and into different subnets.

Underpinning almost all network access is the Domain Name System (DNS), which translates fully qualified domain names or sometimes hostnames to IP addresses and vice versa in some cases. It is easy to misconfigure DNS, which can allow too much insight into network configurations. Additionally, misconfigurations may allow for subdomain takeovers, where an attacker could get control of a subdomain. This would allow the attacker to serve up their IP addresses for endpoints in your domains.

Cloud Security Control Mechanisms

When it comes to cloud security, there are several controls that are either specific to cloud implementations, or are often implemented in conjunction with cloud providers. Some of these controls include cloud access security brokers (CASB), Secure Access Service Edge (SASE), Security Service Edge (SSE), and Zero Trust Network Access (ZTNA). Each of these may factor into how your enterprise interacts with the cloud provider of your choice. Each of these controls can provide better protections in your overall cloud implementations.

Cloud Access Security Broker

Close your eyes and imagine you work for a mid-sized enterprise, perhaps something to do with health care. Actually, don't close your eyes, since you won't be able to keep reading. So imagine you work for a small to medium-sized organization that is associated with health care. You have issues with your information technology (IT) organization, as most organizations do, because there are so many demands on the IT team. Additionally, you have to be concerned with the Health Insurance and Portability Accountability Act (HIPAA) and maybe other regulations like some privacy regulations. You have a lot to deal with.

One of the advantages of cloud computing providers also makes it a nightmare for enterprise organizations. Because of its ease of use and speed of implementation, cloud providers are enticing for non-IT organizations because they can get their IT needs met without having to deal with the internal IT organization. From an enterprise perspective, this is a nightmare because it means data is being processed outside the scope and control of information security and compliance functions.

Enter the CASB, which is a control that sits between endpoints and cloud providers to ensure company policy is applied and enforced. There are different approaches to implement a CASB. The first is to use a proxy, either on the enterprise network or in the cloud. This forces traffic through the proxy to ensure all traffic to cloud providers follows requirements set by the business. However, there are limitations to the proxy approach, so another approach is to use agents on each endpoint. [Figure 6-2](#) shows a high-level diagram of a CASB implementation. It shows a hospital network for our example use case, along with remote workers. They all have a CASB agent running on their devices.

This diagram assumes a cloud-based implementation where the policy engine and management console are hosted in a cloud environment, rather than being on premises. Using a CASB, you can control who gets access to what cloud providers and which tenants within the cloud providers the users are accessing. CASB providers should offer awareness of the internals of your implementations within a cloud environment, including the tenants you have, combined with granular access controls. These granular access controls include time-based controls, meaning you can control who gets access to which tenant when.

The CASB provides the centralized control that is necessary for most organizations to ensure regulations and laws are complied with to the extent this falls within the control of the CASB. Additionally, it helps to protect against the shadow IT problem where data may be exposed with a lack of essential security controls, like strong access control and encryption. A CASB may also have some understanding of threats in the world that need to be protected against.

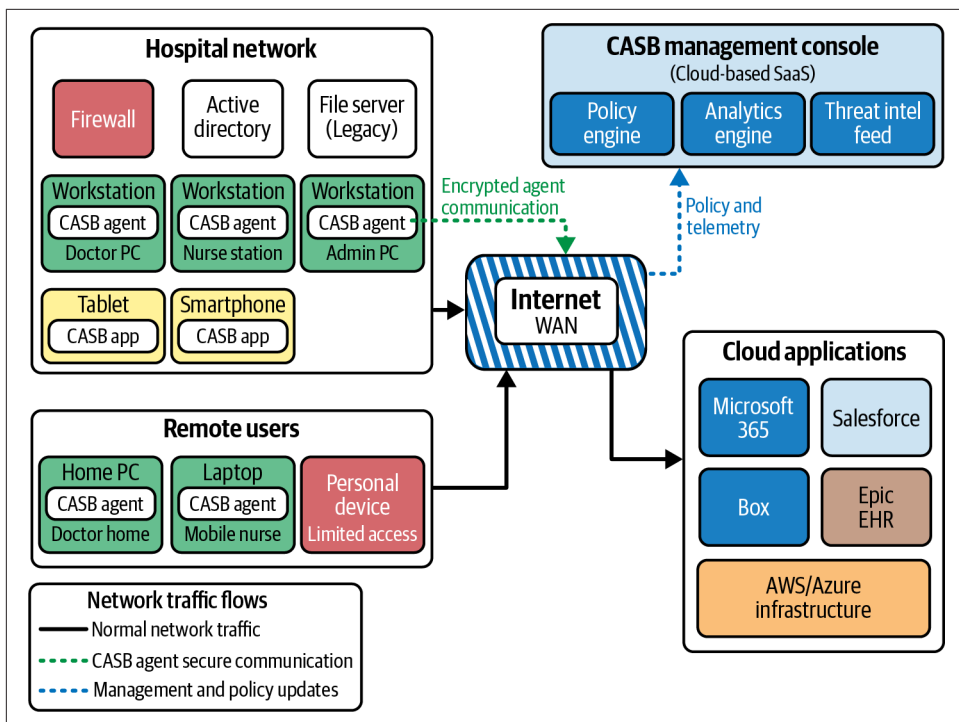


Figure 6-2. Implementation of CASB

The CASB allows protections outside of an on-premises environment so you can be sure remote workers are also following company policies. Even when people are on premises, it is hard to maintain protections against the challenges that may come from cloud providers. You can't just block access to cloud providers from the firewall, since some people do need access to the cloud environments. This means the CASB gives not only broader protection against threats that may be introduced from indiscriminate use of cloud resources, but also gives protection no matter where the workers are sitting.

The CASB can also provide additional visibility since it can log activity. This can be another way to understand what is happening within the organization and would be central, since a CASB can manage multiple cloud environments so it becomes a single place where some of this information can be collected and stored.

Zero Trust Network Access

Let's face it. Security is challenging. And users often rebel when security controls become too onerous. There has always been a fine balancing act between allowing the users to get their work done and protecting the business. After all, security should always be an enabler, rather than the function that just gets to say no to everything.

The objective is always to allow the organization to be functional, otherwise why does it exist? But enough of soapboxes and speeches. The point is that if we don't enable users, they are going to find ways to rebel, and that's perhaps part of the reason why for a long time there was a bias toward "if you are inside, you must be trustworthy." There was perhaps a belief that physical controls were adequate for logical protection.

However, as soon as you start introducing network access into the equation, that belief no longer holds water. For too long, organizations trusted any device or user that initiated a request from inside the network. If someone sitting on the local network reached out to the file server, they were trusted simply by virtue of where they were. You locked the outside doors tight and assumed that everyone inside *must* be trustworthy, almost by definition.

This is a fallacy. It was always a fallacy and was never good practice, but far too many businesses had what was considered a candy structure where you might have a hard outer shell but inside was sweet, yummy goodness with no protection or restraint. If you could get in, you were in. This was true whether you were sitting on the corporate network or connected via VPN. This is not good defense in depth, however. Defense in depth is not, and should not, be focused on castle and moat strategies. Once you are inside, you should not be automatically guaranteed to be trustworthy.

This leads us to zero trust. The term zero trust was coined by John Kindervag at Forrester Research in 2010. The idea is never trust, always verify. This means you should always be forced to demonstrate you are who you say you are. Zero trust may mean different things, at least in implementation, depending on who you are talking to and what vendor's products you are looking at.

The core of zero trust comes down to identity. You should have a digital identity and demonstrate you are who you say you are. This means strong authentication. Of course, good practice today is to use multifactor authentication wherever possible. The identity should be presented and authenticated beyond just logging in to a device. This means there should be a strong link between the identity and the application. Application access should always be based on a user's identity and access rights. This presumes the principle of least privilege is being applied.

Security Service Edge

Businesses are spread all over the place today, among multiple locations and, of course, remote workers. When you extend your perimeter, you need a way to ensure everything is protected. After all, the perimeter is not where you load up on protections anymore. You need to ensure protections are in place right up to the endpoints. A Security Service Edge (SSE) is a way to deliver security services from the cloud to users accessing applications. Going back to our health care organization as an example, [Figure 6-3](#) shows the different services and how they may protect users and the organization overall.

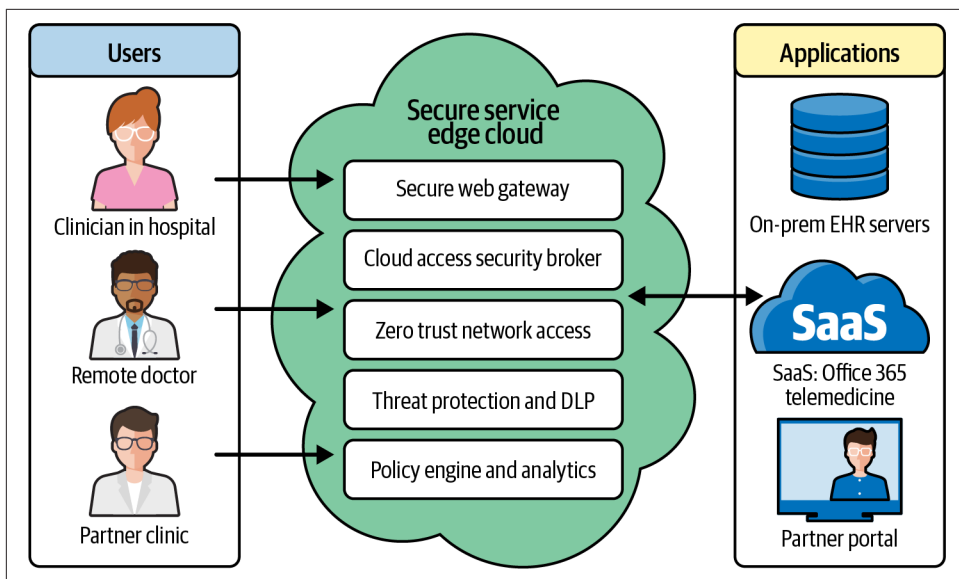


Figure 6-3. Security Service Edge usage

There are some essential elements to an SSE implementation. These are the core components:

Secure Web Gateway

In the old days, we used proxies. These were systems where all web requests were sent so they could be evaluated. This included checking requests against categories for the site being accessed to determine whether it is a business-focused site or one that is potentially malicious. Today, Secure Web Gateways provide that filtering capability as well as malware scanning and the ability to monitor encrypted web traffic. Almost all traffic is encrypted today, so unless you can sit in the middle of the encrypted communication, you're not going to see anything. The Secure Web Gateway should also protect against bypass so all web traffic will have to pass through.

Cloud access security broker

As discussed, the CASB ensures that all cloud access follows organizational policies.

Zero Trust Network Access

Ensures that all interactions between users and applications or systems follow strong authentication practices. Additionally, a zero trust implementation may include microsegmentation, so each endpoint appears to be on its own segment.

Firewall as a service

Provides next-generation firewall services to any enterprise location, whether the user is on an enterprise network or working remotely. Traditional host-based firewalls will do what traditional firewalls do, like stateful packet filtering focused on applications, ports, and protocols.

All of these services combined provide a simple architecture that is location independent. No matter where the user is, they will have protections as if they were sitting on the corporate network. You can think about it as extending the perimeter to each individual endpoint. Using cloud-based services, you are no longer required to back-haul all traffic to the corporate network to ensure that it then runs through all of those devices.

Most importantly, all endpoints now get the same protection because everything is managed centrally and delivered by cloud services. You don't have to be concerned about one location having firewall software or hardware that is not the same as other locations. When you are delivering everything from the same cloud-based services, everyone gets the same protection and experience. You also have complete centralized control over the implementation and experience for your users, which should be based on corporate policies.

Secure Access Service Edge

Pre-COVID, employees were generally on premises, which made it easier to provide network controls across all employees. Larger organizations ended up having some challenges because they had many sites, which meant that either the same network controls had to be implemented across all sites or all network traffic had to be back-hauled to a single site to provide firewalling, intrusion detection, and other network controls. This may be because these hardware devices, especially if you are worried about fault tolerance, are expensive. When COVID struck, workers were remote, which was another way of backhauling traffic to a single location, but it generally put a burden on the VPN concentrators, which suddenly had to handle connections from most, if not all, employees.

Effectively, you have a wide area network (WAN) when you have multiple sites that are connected together. This may be done by direct connections, by using a provider's network, or using services like Multiprotocol Label Switching (MPLS), which just gives you a connection to your service provider, then the service provider gets your traffic to your other site. You may also have each site get a normal internet connection, then you can run VPN connections from site to site.

As cloud services came to be more prevalent, network traffic wasn't necessarily going to be headed to the enterprise network and corporate data centers. Suddenly, traffic that would be going to cloud providers is being sent to the enterprise network first to be run through firewalls and intrusion detection systems.

A different way to approach all of this network traffic is to use a software-defined wide area network (SD-WAN). An SD-WAN is a way of creating a custom WAN for an enterprise by overlaying tunnels on top of internet connections, which are usually less expensive than more targeted approaches like MPLS. An SD-WAN consists of edges, gateways, orchestrators, and controllers. These are different functions that would be implemented in a device. The different devices end up constructing the SD-WAN as designed by, perhaps, a network architecture team, based on the business needs and the different sites that need to be connected.

In 2019, Gartner came up with the term Secure Access Service Edge (SASE). We've talked about most of the elements, so now we can bring it all together. SASE is primarily a marketing term that uses the SD-WAN and also rolls in other technologies that we have previously discussed that organizations use to fully protect the enterprise across the whole estate, no matter the location and what capabilities that location may have. Basically, a SASE recognizes that many services may be implemented in the cloud or at least managed from a cloud provider network. It also helps to consolidate services and define delivery with software and configurations. Using an SD-WAN can offer resilience in cheaper ways than using older or more traditional connection mechanisms.

While it is primarily a marketing term and collects multiple products or technologies, it is still something you should expect to see in the industry. Several vendors now have full-fledged products they are referring to as SASE solutions. In fact, they are packaged offerings of what are likely existing solutions. What you should know about SASE is that it is an SD-WAN solution at its core that also bundles in additional security technologies like antivirus, CASB, firewalls, intrusion detection, and other solutions. These may help protect the enterprise since the enterprise perimeter has changed and central control is overall a better solution generally. All offices and locations get the same protection without having to implement hardware or management solutions into each point of presence the organization has.

Just because you are using a cloud-based offering, and people will often use it to tie together a lot of cloud-based services, does not mean you are going to be restricted to everything being cloud-based. You may deploy fully to cloud if that is the way you are going, and many companies are living in the cloud these days, so applications are no longer resident on premises, whether that's native on the user's workstation or in the data center on servers. However, you may also want to include some on-premises components, so you will be able to use a hybrid approach. The overall objective is to consolidate a lot of functions into a centrally managed solution that serves all your locations equally.

Outsourcing Applications

Outsourcing applications is very common today. Of course, this has long been the case. Businesses have to weigh the costs of acquiring infrastructure and managing applications against finding providers to implement and manage them. Rather than just finding a provider that may host an application, of course, cloud providers have infrastructure to support generally managed systems where applications can be deployed. In addition, application vendors today will often provide managed instances for customers. This provides them with annual recurring revenue, which so many businesses are looking for.

There are a lot of factors that should go into the decision to outsource applications. One of the first is data governance. Keep in mind that just because you are using a cloud provider for applications, you need to think about the Shared Responsibility Model. Application management doesn't relieve the requirement to manage the data the application will operate on. Data governance is a critical consideration.

Data governance should factor in location and sovereignty. Where is the data being stored and what laws have jurisdiction? How is that going to impact your business? It's not only about where the data is stored, though. It's also about where the data is processed. When you are using a cloud provider, the location of the data may be different from where it is managed. All good data governance practices should include data classification policies as well as handling requirements based on those policies. Any provider you select should follow the data handling requirements you have to the extent that they manage the data. For example, if you have a requirement that all of your data is encrypted at rest, that would be a responsibility of the provider. Similarly, retention and destruction policies would have to be adhered to.

Access to data will be associated with identities. This may be user identities or it could be principals associated with services or applications. Either way, identities are involved. This means someone is responsible for protecting those identities. Identity misuse is a common attack path. When you start outsourcing applications, you need to think about where the identities are going to be managed. Some application providers will require you to create your users within their infrastructure. However, this then puts the burden on the provider to appropriately protect these identities. Given that attackers like to grab identities since it gives them access to the information they want, any identity repository is going to be a target, and not every provider has strong protection practices for identities.

Application providers may allow you to use another identity source. This could be an identity provider (IdP). This means that the application must be able to interact with the IdP. One way this is done is using the Security Assertion Markup Language (SAML) to let the IdP handle the authentication, and the application provider then gets to know the outcome without being in the middle of the transaction. SAML puts

the authentication access flow between the user and the IdP. Figure 6-4 shows a diagram of what that process looks like.

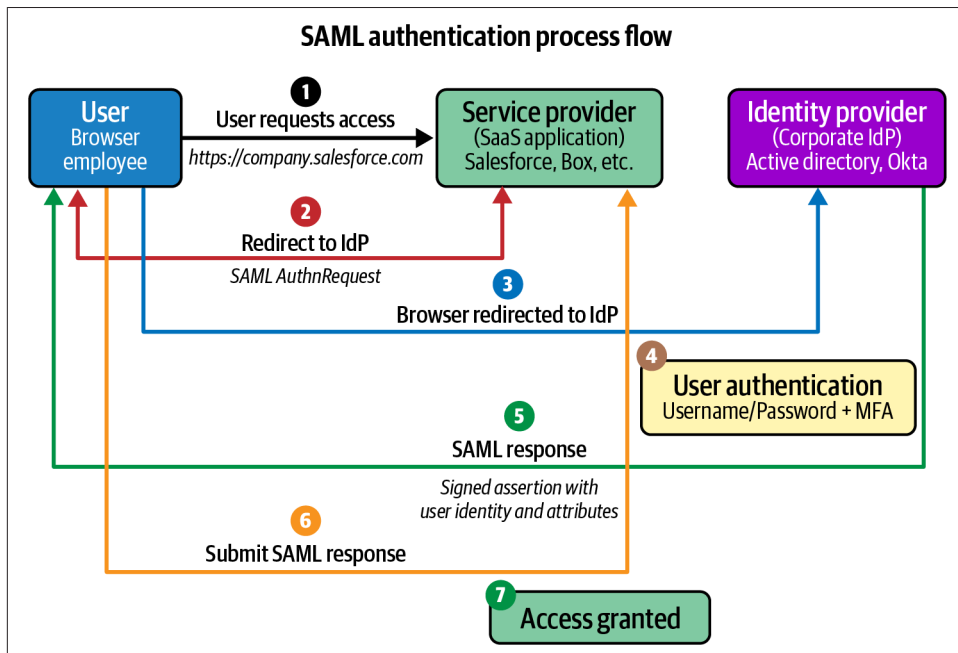


Figure 6-4. SAML process flow

First, the user tries to access the cloud-based application. The application recognizes the user hasn't authenticated since no proof of authentication has been provided, usually with a token of some sort. The application responds to the user with an authentication request. This will redirect the user to the IdP to authenticate. The user then authenticates with the IdP, using strong authentication practices, ideally, including multifactor authentication. Once the authentication has completed, the IdP provides a signed assertion with the identity and attributes that will help the application provider grant the right level of access to the user.

SAML isn't the only protocol and practice that is used commonly. OAuth achieves the same end, and there are other ways to use strong authentication practices to gain access to resources like applications using IdPs that are set up to appropriately handle identity information, keeping it protected. This also will ensure well-known protocols and practices are used to protect the authentication practice to keep someone from being in the middle of the flow of credential data, which might be misused later.

There are often regulatory considerations to factor in as well, including the common privacy laws like the General Data Protection Regulation (GDPR), which protects all

Europeans and their information. These should be considered, along with data governance, to ensure you are correctly complying with all necessary laws and regulations.

Finally, think about good vendor management practices. Always get your needs in writing, whether that is compliance with your data handling requirements, or other considerations like right to audit or notification. Your contracts team should have guidance on the types of issues they should have in all their contracts. Of course, you might not have a lot of say in what you can get out of large vendors like AWS, Microsoft, and Google, but you should still have a solid policy for vetting and managing vendors. Each vendor should have a security scorecard with answers to essential questions about how they handle data management, vulnerability management, and other critical security practices. These answers should be evaluated at least yearly to ensure the vendor meets basic requirements.

This is also where contracts are valuable. Contracts should have remediation guidance when the vendor fails to meet the basic security requirements from the organization. This may allow you to get out of contracts so you can find a vendor that will support the overall security goals of the organization. Vendors require ongoing monitoring and management, which will usually be something that the security organization or the legal team takes care of, often in conjunction with one another.

Web Application Security

Web-based protocols have significantly increased the capability of organizations to deliver essential services for their employees, partners, and customers. As functions increasingly move to the web, security is critical. Many of the security practices that have developed from on-premises deployments of applications remain relevant for cloud deployments. Of course, when you move to cloud deployments, you end up getting a lot more capabilities for less money in most cases. This means you can have a complete stack of protections for your web applications. **Figure 6-5** shows the different layers of protection, starting from the first point where the user request enters the provider's network.

The user sends a request over the internet, where it potentially enters a content delivery network (CDN), which provides reliability and geolocation services to give fast access to the user. The CDN also gives the application provider protection against large-scale denial-of-service attacks. Once you get through the CDN, you may hit a web application firewall (WAF), which should be looking for common attack traffic. The WAF will look at the HTTP for malicious behaviors and block anything that could be an attack. The WAF would commonly look for common vulnerabilities, as identified by the Open Worldwide Application Security Project (OWASP).

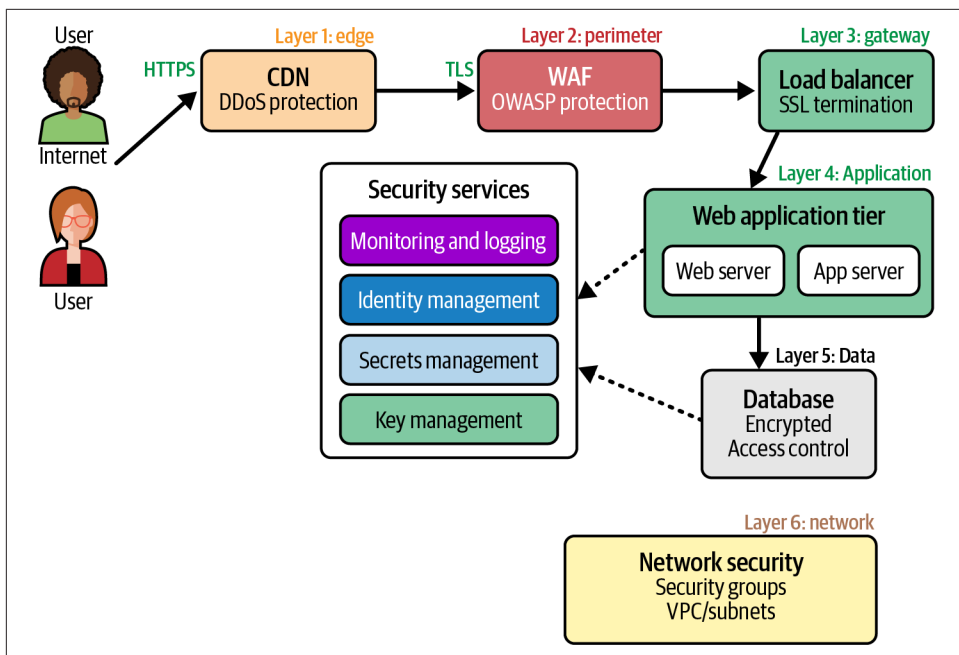


Figure 6-5. Web security diagram

If the traffic gets through the WAF, it may then hit a load balancer to keep the application traffic from overloading any individual system within the application, spreading the load across multiple systems and components. The load balancer may terminate the TLS request, so plain-text is then transmitted inside the application space. Beyond the load balancer, there would commonly be a web server that can take the HTTP request and process it. The web server may serve up static pages from its own storage or it may pass the request on to systems behind it, like an application server. The load balancer may also provide this redirection, depending on the architecture and the request.

Any dynamic request where there is some programmatic access required, like querying a database or storing information in it, would usually be handled by an application server. The application server then interacts with the database. All response traffic follows the same flow back out to the user. Based on Figure 6-5 you can see there may be multiple zones. These zones would be represented in real life as network segments and security groups. This keeps systems with different levels of security needs separate from one another and should protect the more sensitive systems.

Of course, those are just the pieces that the user would interact with in a more or less direct way. Beyond those pieces, you have logging and associated monitoring, which should be in place for all web applications. Identity management is always going to be a factor throughout the deployed application. This not only applies to users who are

accessing the application but also to those managing it. Secrets management should also be in place to protect access from one system to another. For instance, when the application server requests information from the database server, it needs to authenticate. If the credentials for accessing the database are just stored on the application server, it's really little better than simply keeping the two systems on the same network. The credentials will usually provide the attacker what they need to get what they want, which is usually the data stored in the database. Finally, you need key management to store and manage keys for encryption.

All of these elements should be in place within a web application. This example is very simplistic, following a standard n-tier web application deployment, usually broken out by web server, application server, and database server as the core elements. However, the same rules apply even if you are going serverless or using microservices or an API.

Using Application Programming Interfaces

As more functionality has been moving to web delivery, using just web pages and the technologies used to create them has become insufficient. More traditional ways of developing applications are being deployed to deliver more functionality while still making use of protocols and technologies used as the underpinnings for web communications. This includes breaking applications apart from the monolithic approach of putting all functionality into a single executable. With web deployments, this is supported better by allowing individual components to be deployed using the web communications protocols to transfer messages between the components.

However, you need to develop the means to be able to send messages between the components. This is done using an API. The API defines the functionality that is exposed to either other applications or to other components within the same application. One of the foundational problems with HTTP is that it is stateless, which means every request is essentially standalone from the perspective of the web server. No mechanism was ever added to HTTP to allow the client and the server to maintain an awareness of what had happened before. This was very much by design, since it kept things simple. Once you have state, you make it harder to do things like load balancing, since load balancers don't need to worry about where they send a request to. Every request should stand on its own.

Without the support from the core protocol used to transfer information from the client to the server and back, it was necessary to come up with other solutions that could allow applications to transfer state information from the client to the server and back. One way of doing this is through an architectural style known as Representational State Transfer (REST). Applications that support this architecture are considered RESTful.

RESTful applications recognize a client and a server, and support the means for transmitting complex information between the client and the server. This is often done using data languages like the eXtensible Markup Language (XML), which HTML is based on, and JavaScript Object Notation (JSON). REST also expects a uniform implementation. All of these elements fit nicely with an API implementation. API endpoints, which are effectively the methods being called, can be stateless, and also support data transfers through XML, JSON, and other semi-structured data languages.

The API not only supports development for web applications, it also puts more control into the hands of the client. Rather than a request going to the server where it then can be passed to other components, with an API, the client can decide which endpoint it needs based on user interaction with the application.

Mobile devices are very common today, and much of the web's traffic comes from mobile devices talking to server infrastructure in the cloud. APIs expose critical functionality for the application to use. Some of the application logic is in the mobile piece, but anything related to data manipulation will be done on the server. The mobile application will construct API requests that include data packaged into JSON (or XML), then send those requests off to the elements hosted at the cloud provider. The mobile application can keep track of the state, meaning what request has been made, and what the status of the request is (succeeded, failed, needs another request for another stage, etc.). This means the client is really in control and the server is effectively there to store and retrieve data, perhaps performing some manipulation along the way.

Of course, the APIs can be implemented in several different ways. The only thing that unifies them is the technologies they are using. The building blocks of web technologies and protocols have allowed applications to be developed and delivered in many different ways.

Summary

Cloud applications encompass those being developed by organizations for their own use, or as products for the use of others. This means a cloud application could be consumed by businesses or users, so effectively you can have internal or external users for cloud applications. Since cloud applications are generally exposed to the open internet, security must be core to their development and consumption. Also, cloud deployment is a way to deliver more effective security for endpoints and businesses, as the traditional idea of the perimeter of a business's network no longer exists. The perimeter extends beyond the corporate network to the cloud and all remote endpoints and small offices.

There are many threats that cloud applications are exposed to, and in general, these are the same threats that internal resources are exposed to. They include identity compromise and misuse, vulnerabilities, poor governance, misconfiguration, and several other practices that can lead to infrastructure and data being compromised.

Security can be deployed more effectively using cloud delivery mechanisms. Additionally, the centralized model of the cloud can mean protections can be universal. This means you can have a CASB that ensures all cloud application and infrastructure access follows organizational policies. This can cut down on shadow IT, where teams and groups decide to deploy applications in the cloud on their own to get around working with internal IT.

The SSE implements a secure web gateway to ensure all web-based traffic is protected from threats, as well as providing firewall as a service. Because these functions can be deployed and managed from a cloud platform, it helps to ensure the same level of protection whether the user and endpoint is on the corporate network, in a small satellite office, or fully remote. When you start thinking about SSEs, CASBs, and approaches to security like zero trust, you can start looking at bundled protections like the SASE, which offers full protection across the estate to include next-generation firewall capabilities and other threat protections, secure web gateways, and CASBs to ensure all users are following company policies.

Today, many web-based applications are being implemented with APIs to fully decouple functionality into different components. This can put better control at the edge rather than requiring everything to go through application servers where business logic is implemented and controlled. Mobile devices can make use of APIs to take some of the load off the local device and put it in the cloud, with access to application logic and data management functionality running through the API.

Other Resources

The following pages provide more details about threats and application security practices:

- “OWASP Top Ten Web Application Security Risks,” OWASP, 2025 (<https://oreil.ly/HfVw->).
- Gyan Chawdhary, “Top 15 Application Security Best Practices,” Security Compass, March 21, 2025 (<https://oreil.ly/TqgRd>).
- “What Is Zero Trust Architecture?” Microsoft (<https://oreil.ly/18nUH>).
- What Is Secure Access Service Edge (SASE)? Microsoft (<https://oreil.ly/KDX16>).
- Shikha Dhingra, “Why Every Enterprise Needs a Strong API Security Strategy?” Security Boulevard, March 3, 2026 (<https://oreil.ly/hW6V5>).

Cloud Development

Topics covered in this chapter include:

- DevOps and DevSecOps
- Software development lifecycle
- Infrastructure as code
- Shifting left
- Design styles

While the majority of cloud users are on the consumption side, there is still a significant number of users who are vendors or providers. Any provider who wants to deliver software as a service (SaaS) will need to develop their service within a cloud environment, using practices that are suitable for delivering software to be consumed via cloud or web technologies. This is not to say that discussion around development in the cloud is only relevant to providers. Many enterprises develop their own applications for their own use. It can't be overstated that use of the cloud makes it considerably easier to develop a complete application. It also takes the burden of needing storage space and the logistics of managing remote users away from the consumers of the application.

All of this is to say that cloud development is not a niche field solely for development providers. Even with all the SaaS services and providers, organizations still need to develop their own solutions. With all of the automation and tools available, development is often within easier reach of nondevelopers.

Security is an essential element of software or systems development, but it is often overlooked. Security is a process, just as large-scale development is a process. Finding the right places for those processes to work together is essential, but this may not

come easily. There may also be multiple places where you can introduce security, but this requires planning and also buy-in, meaning that security teams need to work closely with the development teams.

Software development has changed significantly over the decades; where it used to take years to develop software, today new features are expected to be available within hours or days. This is part of the purpose of DevOps and DevSecOps—to deliver software reliably, quickly, and consistently.

Software development and deployment have been moving to web delivery for decades now, and of course cloud providers and the ease of uptake have further enabled that process to move faster. Where there were previously n-tier applications, with a clear design modeled on traditional software principles, cloud providers have introduced newer technologies that can provide more flexibility and power. This has created different software deployment strategies because it is now easier to fully decouple functionality from design, which allows for additional security to be factored into the overall environment.

Security and development don't naturally go together, unfortunately. This means security needs to understand development practices and also work to help developers and development teams understand the goals of security. Ultimately, everyone should be working toward business objectives.

Security and the Software Development Lifecycle

Software development is a complex process that involves a number of individuals with different skills, beyond just the people writing the code. Large projects involve a lot of people and teams, so it's helpful to have a process to help with coordination. This process is called a software development lifecycle (SDLC). Over time, there have been many different approaches to software development. Additionally, as networked communications and multiple users have become more common, security has become more of a priority. We have moved, over time, from ad hoc development, to waterfall, to iterative and collaborative approaches, to now, with DevOps and DevSecOps as ways to help with speed, quality, and collaboration.

Software Development Lifecycle Methodologies

Software development goes back decades; certainly over 70 years. It didn't take long before large projects required structure around how the software was being developed. Because larger software projects consisted of many teams working together, they needed to find ways to coordinate. Additionally, as software became a business, users had expectations and requirements, which meant even more coordination. Software started to move from updating programs in real time to full-blown releases. Keep in mind the software development at that time was being done on mainframes

and a little later on minicomputers (as compared with microcomputers, which is what we used to call a personal computer or PC). Rather than taking up an entire room with components, the hardware would generally be a couple of refrigerator-sized devices.

Waterfall

These devices wouldn't always allow multiple users access at the same time, so it took a lot of scheduling and coordination. One of the most well-known and largest software development projects was undertaken by IBM for the OS/360 operating system for its incredibly popular mainframe line. Development for this operating system took years to complete, ran over on time and budget, and provided many lessons in running software development practices. In part because of the potentially limited access to the system, development followed what is called a waterfall methodology. You can see a visual representation of what a waterfall process looks like in [Figure 7-1](#).

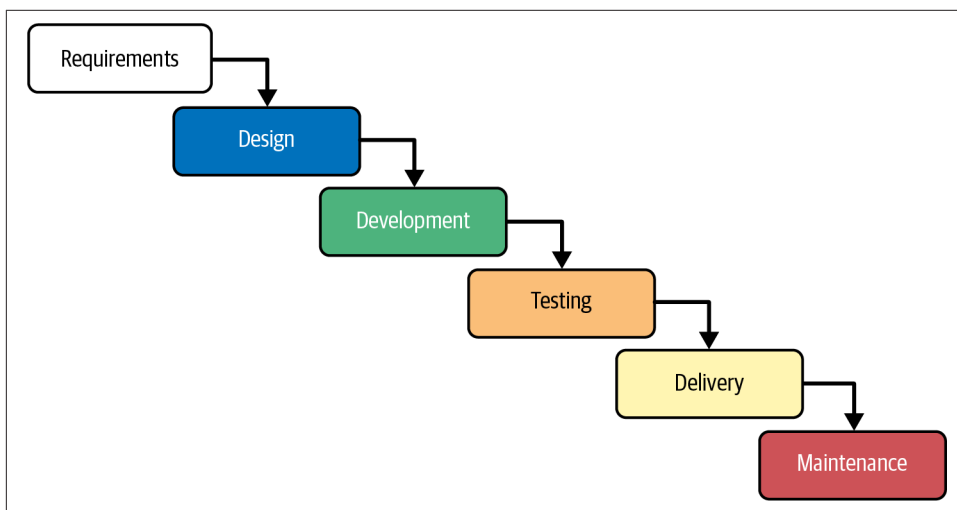


Figure 7-1. Waterfall process

You can see why it has been called a waterfall. The output of one stage “falls” into the next stage. This generally means that each phase has to complete before the following phase can start. You can't start without knowing what you are working on. This prolongs the output if different teams need to wait for the previous team to complete. The different stages in a common waterfall, as shown in [Figure 7-1](#), are:

Requirements

Requirements may be collected from users based on what they need, or set by the business, which may know what users want or what may be most likely to sell.

Design

The design should be based on what the requirements are so the completed design fulfills all the needs of the business and the users. The design document that results should be used to guide the development.

Development

The development stage could include not only writing software but also performing systems integration for projects that are more turnkey or, as in the case of web applications, involve systems deployments.

Testing

Testing should be performed to ensure the objectives of the product or application meet the expectations outlined in the requirements.

Deployment

Deployment could look different depending on the type of product. This may be a software package that previously would be written to some sort of physical media. It could also be a complete web application with systems.

Maintenance

The maintenance phase keeps everything running. This may include identifying bugs and getting them fixed for updates.

In the 1990s, many businesses, developers, and project leaders were getting tired of the problems associated with the waterfall. First, the waterfall tends to isolate teams from one another. This lack of coordination and communication means problems aren't addressed in a collaborative way. By the time any real communication happened, it was too late to make changes. Additionally, there was nothing in the basic waterfall process that incorporated any lessons learned or process improvements, so any mistakes would just continue every couple of years when the software would go through another version.

Agile development

As a result, Rapid Application Development (RAD) and Extreme Programming (XP) were introduced as ways to improve overall quality and speed, focusing strongly on communication and collaboration, and removing the isolation that a waterfall typically introduced. Additionally, both espoused iterative approaches to software development, where small, incremental changes were introduced rather than trying to make significant changes all at once. Clearly there was something in the air, since about the same time, a group of software practitioners wrote the *Manifesto for Agile Software Development*. Today, there is generally a misunderstanding of what Agile software development is. It is really a set of beliefs outlined in a document and includes the following principles:

- Satisfying the customer through early and continuous release of software
- Allowing requirements to change no matter where in the process they occur
- Working software is the primary measure of success
- Simplicity is essential
- Teams should regularly review progress, look for improvements, and implement them
- Continuous attention to technical details

The Agile manifesto valued people and collaboration over process and tools, working software over documentation, customer collaboration over contract negotiation, and responding to change over following a plan. The objective was to get to working software faster by working closely with the customer to get features that are needed, rather than working from a comprehensive list of features and requirements provided by a marketing team trying to sell something once it's complete.

There have been different approaches to implementing the Agile principles. A common misconception is that Agile development means short development cycles, often called sprints, and regular meetings with all the stakeholders. A visual representation of that is seen in [Figure 7-2](#). This shows a single iteration or work unit. Often these sprints are short in duration, like 2–3 weeks. The general expectation is that all phases of a traditional SDLC would be taken care of in that single sprint. This keeps the amount of work to a minimum if it is going to be planned, designed, developed, tested, and released within those 2–3 weeks.

Each of these work units, or sprints, should have working code at the end. If you can't get to working code in the time allowed, you haven't planned adequately. At the end of the sprint, there may be a demo to show off the new functionality. The goal should be to get feedback from the customer to use as input into the next cycle.

In real life, many organizations are using a hybrid approach. They may be working from a monolithic set of requirements provided by someone in the organization rather than having a clearly defined customer who can provide feedback on what is needed to keep to a minimum viable product (MVP) that is focused on what the customer needs rather than what someone hopes may sell once it's in place. Once they have their large set of requirements, they break up the work into 2–3 week chunks. At the end of that time, they probably don't demo to the customer to get feedback on what needs to be improved.

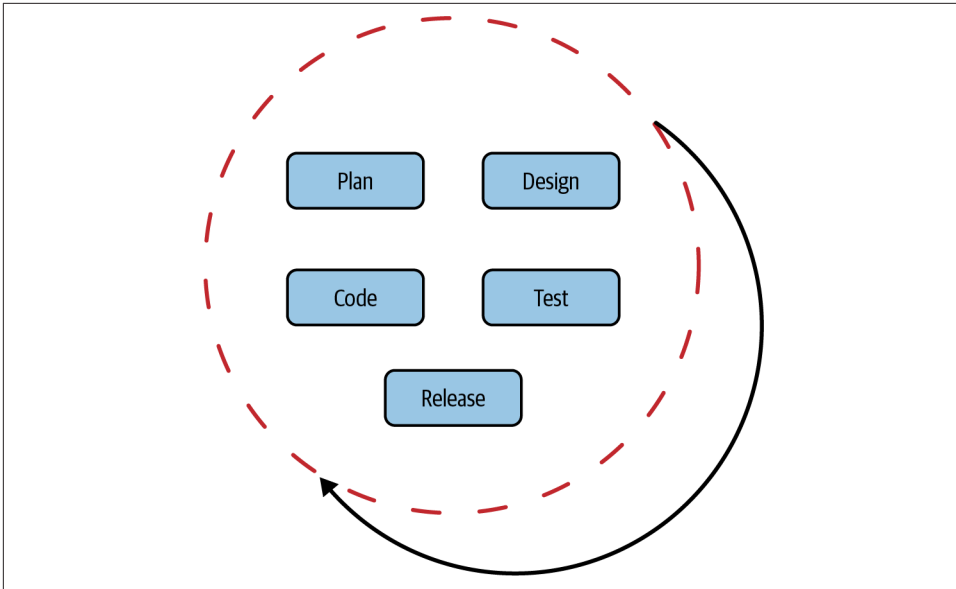


Figure 7-2. Agile work unit

Also, in practice, saying an organization is using Agile processes is an excuse to dispose of traditional artifacts like process and documentation. While this may be beneficial for development, it is unlikely to be good from a security perspective. The lack of process and repeatability may result in poor quality control. The lack of documentation leads to inadequate understanding of the final product. Saying you break your work into 2–3 week sprints and use Slack is not really the same as the intention of the Agile manifesto.

There are several frameworks that are said to follow Agile principles. Some of these include:

Scrum

Focuses on self-organizing teams and moving the decision-making authority to an operational level

Kanban

Focuses on visual workflow management and reducing work conflicts

Lean software development

Takes lean manufacturing principles and translates them to software development

Scrumban

A hybrid of Scrum and Kanban

These are just a few of the frameworks that work toward some of the same goals outlined in the Agile manifesto. There are several others, each with a slightly different focus, but all with the goal of faster software development with higher quality and more of a customer focus.

DevOps and DevSecOps

One of the biggest challenges of the waterfall methodology is the lack of collaboration, which is why many of the Agile frameworks focus strongly on unified teams. When you don't have teams working together, it's harder to ensure they are all pulling in the same direction. For a long time, software was distributed to end users. This meant that it was up to the consumer, for the most part, to manage installation and upkeep of software. When software started to be delivered via web applications, that moved the care and feeding of the software to the same organization that was developing it. Suddenly, operations became a stakeholder in the whole software management chain.

Having worked in organizations where operations had to live with what engineering developed, I can tell you that they are not fans of not having say and allowing engineering to determine how the solution is to be managed. This is why, when I led a development team in 2001 to develop a managed security solution, I made sure to include the operations team in the complete development team. Operations was to provide requirements they would need to have in place to effectively manage customers and the offering. The goal should be to enhance customer satisfaction and provide a good experience to them. The customer won't be happy overall if the service they are getting is less than stellar because the operations staff can't manage or monitor it effectively.

One of the goals of DevOps is to increase the quality of software products. While it may be tempting to think that DevOps is as simple as stuffing the engineering/development team into a room with the operations staff and letting them all figure it out, DevOps is, just as Agile, a set of principles and practices. In general, DevOps aligns well with Agile because some of the objectives end up being the same. Not only that, but the speed at which Agile development is expected to move is well supported by DevOps practices.

One of the significant principles for DevOps is automation. Prior to the DevOps movement, infrastructure deployments may have been managed by hand. Getting a consistent deployment has been a goal for a long time. Even before organizations started taking on DevOps practices, cases where systems had to be deployed regularly were managed using system images and different techniques to get those system images onto the hardware. In fact, there have been protocols that have supported these practices for decades. Prior to the Dynamic Host Configuration Protocol (DHCP) was BOOTP.

The BOOTP protocol was used to help diskless workstations boot from a known image. You can see the flow in the ladder diagram in [Figure 7-3](#). The client system sends a broadcast message to the network, looking for configuration details. The BOOTP server, which usually has a mapping of physical network address to a configuration, responds with an Internet Protocol (IP) address for the system, as well as the IP address of the server that holds the boot image. This would be a Trivial File Transfer Protocol (TFTP) server, which is a very simple file server. The file server provides the image to be booted. The system can then boot the provided image. It resides in memory while the system is powered up.

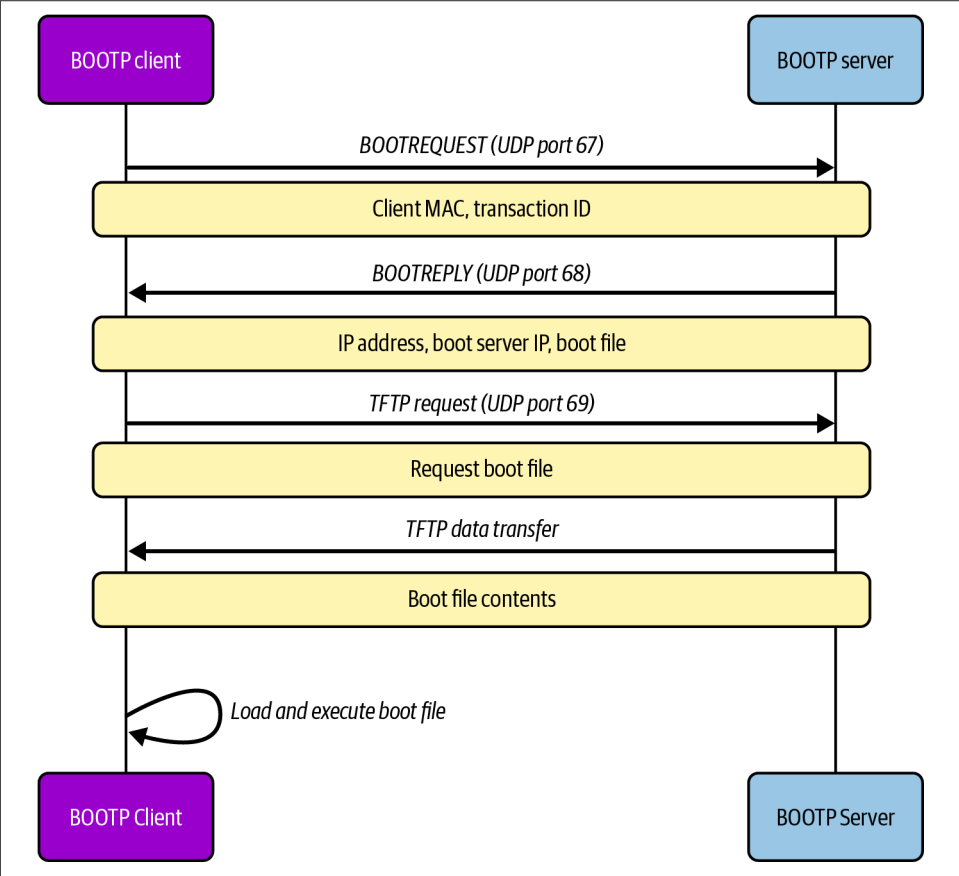


Figure 7-3. BOOTP boot process

This is just the foundation for other processes. Another way to get systems running is the Preboot eXecution Environment (PXE). This works similarly to BOOTP and uses DHCP and TFTP. Red Hat built on top of those basic protocols and created Kickstart, which was a way of booting up a basic image to get a system installed on a target

system. This allowed for a core image to be created that would then be installed, exactly the same, on multiple (dozens, hundreds, or thousands) of systems. They would all be configured the same with the same packages and application software installed.

The basic idea is that you have a system image and different startup, and transfer protocols are used to get systems configured quickly and consistently. Because these were physical machines, they required someone to rack and stack, get them plugged into the network, and turned on. The virtual machine made this process even easier. Once you have built a system, you can just clone it as many times as you need to have the same image every time you need a new instance.

So, we have system image creation automation, but there are so many other elements of system creation and management that require automation. One of the problems with system image deployment is that the moment you deploy it, you start to have drift. This drift can cause problems with system performance, complexity, and potential introduction of vulnerabilities. Using automation to install the system image doesn't make sure everything is kept up-to-date after installation.

DevOps teams work toward quality and speed to delivery, but security is not necessarily a factor. This is how we end up with DevSecOps, by adding in security to the overall team. The security team should be focused on ensuring the platform being used has been developed with security in mind by using strong identity and access management practices everywhere, hardening all system images, and implementing security testing. The security team should also be involved in developing requirements.

One important practice that security teams can make use of, especially with DevSecOps and Agile implementations, is threat modeling. The goal of threat modeling is to identify threats to the application. A threat is any circumstance that may cause harm to a system, user, or piece of data stored within an overall system. The term "system" can be used in this context to refer to a collection of virtual machines, physical machines, applications, connections, and any other element necessary for the overall functionality of the solution.

Threat Modeling

There are several approaches when it comes to threat modeling. Often, organizations will use an unstructured approach to identifying threats within an application, but I find it easier to have a taxonomy to work from since identifying threats don't necessarily come naturally to a lot of people, including development teams. For this reason, using a well-known framework can be very beneficial. In the late 1990s, Microsoft developed the STRIDE framework for threat modeling. This framework provides categories that can help people think about threats. [Figure 7-4](#) shows the different categories and an example of the type of threat that may fall under each category.

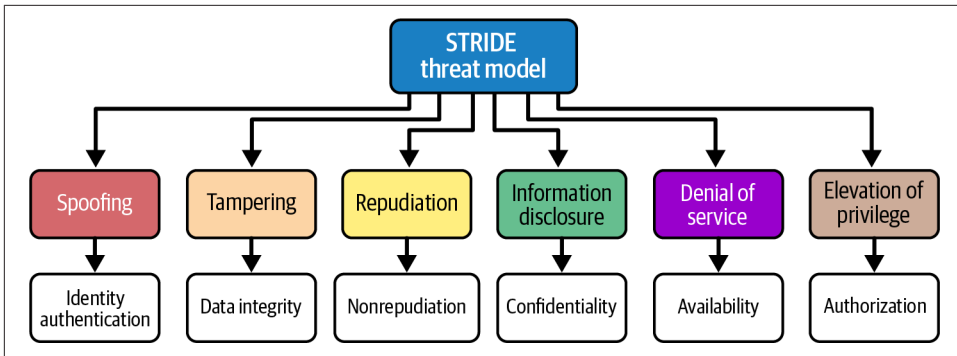


Figure 7-4. STRIDE threat modeling

The categories identified for the STRIDE threat modeling framework are:

Spoofing

Attempting to act as a different entity

Tampering

Unauthorized manipulation of information

Repudiation

Being able to know who any entity is and guarantee their identity

Information disclosure

When data is available that shouldn't be to those who shouldn't have access to it

Denial of service

Preventing access to systems or data

Elevation of privilege

Getting additional permissions and privileges to perform actions or get access to data

Any threat model should start with an application decomposition. This is part of the PASTA approach to threat modeling. PASTA stands for Process for Attack Simulation and Threat Analysis. It doesn't have to be separate from a framework like STRIDE. PASTA is a process that uses the following steps:

Define objectives

The business, security, and compliance needs for the systems or applications in scope should be clearly identified to track against

Define technical scope

This should clearly identify all the components that will be part of the overall application

Application decomposition

Diagramming the application to include all the trust boundaries and components

Threat analysis

Using threat intelligence and the application decomposition, identify and categorize threats

Vulnerability analysis

Based on the threats identified, identify vulnerabilities that could be exploited

Attack modeling and simulation

Using identified threats, map the attack vectors and identify how any vulnerabilities could be exploited

Risk and impact analysis

The identified threats should be prioritized based on the potential impact and likelihood (risk), with a plan to remediate

As part of PASTA, it is useful to be able to determine priorities. It's also important to understand the difference between threat and vulnerability. We have discussed what a threat is. A vulnerability is a weakness in an application or system. A threat requires a vulnerability to be exploited. The threat alone is insufficient. You may think of the threat as the theoretical problem, while the vulnerability is the practical realization of the threat. One way to prioritize any identified threats or vulnerabilities once they have been identified is to use another framework called DREAD, which stands for:

Damage potential

Based on the threat, what is the potential impact to the application, organization, data, or customers?

Reproducibility

How easily can the vulnerability be reproduced?

Exploitability

How easily can the vulnerability be exploited? This should include the skill level needed to exploit the vulnerability as well as availability of tools for exploitation.

Affected users

Users who have a higher level of access or privilege would lead to more impact.

Discoverability

How easily could an attacker discover the vulnerability?

You can use the DREAD framework to assess the potential impact, as well as the likelihood of a particular threat being manifested. When you take the PASTA process and layer in STRIDE as a taxonomy to help identify potential threats, then add DREAD to prioritize the ones that need to be remediated in some way, you have a really good

approach to threat modeling. For some organizations, this may feel too structured, but in reality, there is nothing in any of this that requires a lot of structure or formality. PASTA doesn't have to be an over-managed process with a lot of meetings and rigor. It can just be a loose concept to apply to the idea of threat modeling. Similarly, while there are tools that can help clearly identify threats within your applications or systems, it doesn't have to be a rigid approach. The important thing is to put some time into identifying potential issues that need to be addressed.

This is where a security practitioner can be helpful in a DevSecOps team. The person who understands security should be working closely with those who understand the application to clearly identify threats. The development team should know the application and can provide insight into how it is put together, while the security professional can help to identify threats. The security practitioner should be helping the rest of the team understand security requirements and practices to improve the overall protection of the application.

Continuous Integration/Continuous Deployment

Since we have moved to web applications, delivery of the applications falls completely within the control of the developer. It's not the same as developing a native application and expecting someone to download or acquire physical media, then need to update to get the latest version. With web applications, the control of what version and when falls into the hands of users. This means almost within minutes of a fix being made or a feature added, it can be in the hands of the end user. This is all possible with the automation that is the focus of DevOps. The process of moving quickly through development, build, test, and deployment is called continuous integration/continuous deployment (CI/CD).

The CI/CD pipeline begins with a developer writing code and storing it somewhere. While version control and source code repositories have long been essential components of team development to prevent different developers from clobbering each other's work, today, Git has become the dominant version control system. This is a version control system developed by Linus Torvalds for use in developing the Linux kernel source code, since the previous version control system they were using was no longer available due to licensing issues. Today, it seems most organizations are using Git as their code repository/version control system.

While it is possible to have Git repos that are local, or even hosted on premises, organizations often use hosted implementations so developers anywhere can access the code. This requires strong authentication practices to ensure source code is protected, usually using at least two-factor authentication. These hosted repositories also enable automated pipelines. You can see a CI/CD pipeline in [Figure 7-5](#).

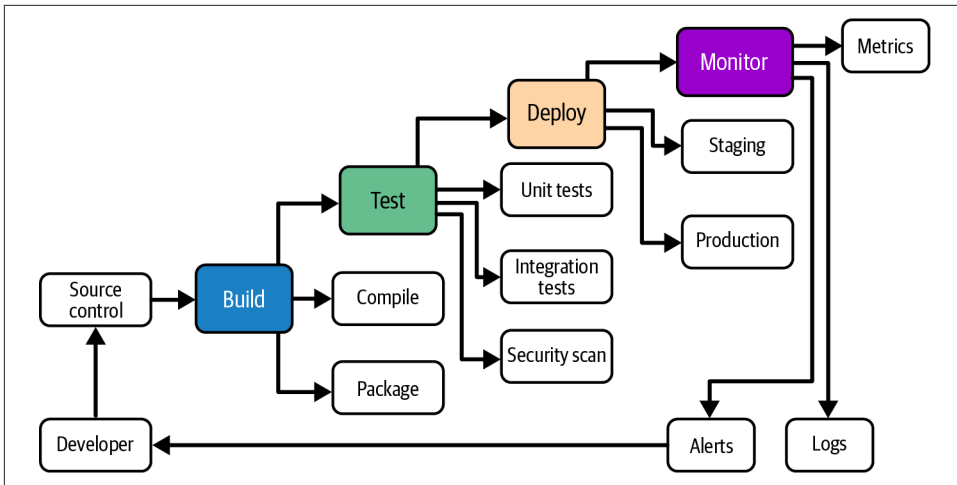


Figure 7-5. CI/CD pipeline

Once the code has been written, the developer creates a pull request. This should trigger a code review, where at least one other developer looks at the newly written or introduced code as the first line of identifying potential problems. This is also a way for developers to help improve overall coding practices and the first time potential vulnerabilities are caught. Once the code review is complete and the new code is merged into the primary codebase, static application security testing (SAST) is triggered to use tools to find vulnerabilities in the source code.

Then, the software is built, which may mean compiling in the case of a binary package, or doing a sanity test to ensure it will run if the code is interpreted, as in the case of Python or Ruby, for instance. Once the entire package is available, basic tests can be run, including unit tests. A unit test is written by the developer to evaluate introduced functionality. While these unit tests are good for checking that the code works as expected, there are also ways to look for security uses by developing security-focused unit tests using misuse cases. A misuse case is a test case that could be turned into code to evaluate whether the software can protect itself against bad behavior.

Other automated testing can be performed in the pipeline as well. This should include performing security testing. Web applications can be tested by integrating tools like the Zed Attack Proxy (ZAP) and Burp Suite into the pipeline. Automated tests can be developed to evaluate an application, and the pipeline can trigger those tests. Finally, once all the testing has been completed, the result can be pushed to a deployment state.

At any step along the pipeline, a negative result can force the pipeline to stop. This will help to make sure failures aren't allowed through to deployment. It also protects against potential vulnerabilities being released to production.

While it's possible to fully automate all the way to deployment, you may not want released code to be pushed to production without any intervention. One approach is to use a phased release where the deployment is pushed to a staging environment. The team may perform a smoke test to run the full solution through a set of evaluation criteria before determining it is ready for a production release. Some organizations may decide to deploy in stages, depending on how significant an update is. This means different users will get a different release to evaluate a release or feature set.

Applications developed to use web technologies, including mobile apps that use APIs, end up being more than just code, though. They will require system components to accept the code being developed. System development, though, needs to be able to move as fast as code development. And, of course, DevOps principles say automate, automate, automate.

Infrastructure as Code

When everything is virtual, it is easier for everything to be software. This includes configuration of all elements of a complete system, whether it's processing, storage, networking, or anything else required to provide compute capabilities to applications. And to follow, when everything is some version of software, you can automate it. Once you automate it, you can treat it like code, meaning you put it into source control and test it. It also means everything is consistent, no matter how many times you deploy it. It also makes changes a lot easier; for example, you don't have to swap hardware components—you just make changes to the code you are using.

There are many platforms that will help you use Infrastructure as Code (IaC). While it's a big term, IaC just means you are using configurations that are written down to define and deploy all the elements you have in your environment. This is not limited to just deploying systems. IaC will also allow you to deploy and configure software to run on the devices. Most IaC platforms will also support local configurations, virtual machines, containers, and cloud services. All you need is the right settings and access to your target of choice to be able to configure everything in your environment using code.

A very common language to use to specify configurations is Terraform. **Example 7-1** shows a snippet of code written in the HashiCorp Configuration Language (HCL), which is the underlying language of Terraform. You'll see that you create blocks to provide details about specific pieces of your configuration. At the top, we indicate the required provider is AWS, since that's the target for our infrastructure. After that, you need to define regions, name your cluster, and then we can start to add additional elements.

Example 7-1. Example of Terraform

```
# Provider configuration
terraform {
  required_providers {
    aws = {
      source = "hashicorp/aws"
      version = "~> 5.0"
    }
  }
}

provider "aws" {
  region = var.aws_region
}

# Variables
variable "aws_region" {
  description = "AWS region"
  type        = string
  default     = "us-west-2"
}

variable "cluster_name" {
  description = "ECS cluster name"
  type        = string
  default     = "small-container-cluster"
}
```

IaC environments will generally keep track of the target state, so when you make changes to the configuration, the entire environment doesn't get torn down and rebuilt. Instead, just the changes get applied. After you've created your updated code, you use Terraform to plan, which helps determine the changes that need to be made. Once you're sure about what it is going to do, you just apply the new code and Terraform takes care of changing what needs to be changed.

Terraform is, of course, not the only IaC platform. There are several, and they generally use different languages to document your infrastructure. Salt and Ansible both use YAML to document the infrastructure and all settings. Puppet and Chef use their own proprietary languages that are based on Ruby. Of course, you could also use a language like PowerShell, which is Microsoft's scripting language often used for system management development. While it is a Microsoft product, it can also be used on platforms other than Windows, like Linux and macOS. You can get modules that will support cloud providers other than Microsoft's Azure, so you can use PowerShell. The other IaC platforms are primarily configuration settings that get applied by some sort of server infrastructure. PowerShell is a proper coding language. Of course, using APIs and modules provided by cloud providers, you could also use other

programming languages, like Python. This would require actual code, though, which may potentially make the IaC less readable.

IaC works great in code pipelines. First, you can run IaC through code pipelines when changes are pushed into the repository to evaluate the code, look for potential problems, and then actually apply the IaC to build out environments or just make changes to existing environments. Second, you can run IaC through a code pipeline to be evaluated. Several tools can be used to look for errors or potential misconfigurations. Additionally, tools to look for credentials and other secrets can and should be deployed to code pipelines. As you might expect, having secrets kept on disk even in protected code repositories is a bad idea.

You can see several benefits from using IaC. It's repeatable, consistent, can be tested, can be evaluated against expected outcomes, and provides clear documentation for the process. Process is generally important since it means you have a repeatable pattern, which will lead to consistent results.

Site Reliability Engineering

Site Reliability Engineering (SRE) is a practice that was introduced by Google. It takes typical operations practices and introduces engineering concepts and rigor. There are a lot of infrastructure and operations challenges to cloud environments, and when you are following DevOps practices, software development, engineering, operations, and infrastructure management all come together. As you are deploying an environment, you want to be sure you are keeping an eye on all the elements so they are performing as you would expect. This is where SRE comes in. SRE is about helping to ensure the reliability of a deployment so it is always available to development teams and customers. A foundational approach with SRE is it approaches operating an environment from a software development perspective.

Two core principles when it comes to SRE are Service Level Objectives (SLOs) and Service Level Indicators (SLIs). SRE is about continuous monitoring to be able to ensure reliability of the platform or application. SLIs are the metrics that demonstrate how the environment is behaving. Typically, you would have SLIs for latency, throughput, availability, and error rates. All of these together provide a better picture for how the environment is responding. Using these SLIs, you should be able to tell if there are degradations in performance or substantial increases in usage.

An SLO is a range of acceptable values that an SLI should fall into. This would indicate normal operating parameters. This is similar to various foods that have a temperature the food is safe to be stored at. Coconut oil, for example, will become solid at temperatures below 74–76° F. Above those temperatures, it becomes a liquid. While coconut oil isn't so unstable as to be potentially dangerous if you aren't within a specified range of temperatures, the quality of the product can't be guaranteed if it falls outside the range of normal room temperatures. In other words, it may become

rancid or not have the same effective properties if you are not storing it at room temperature. This is an SLO. If you fall outside the expected parameters of an SLI, outcomes and performance can't be guaranteed.

When you enter into an agreement with a service provider, you are generally given a Service Level Agreement (SLA). This SLA is really a collection of SLOs. Each SLO is just the expected range for an SLI. To be able to show this visually, you can see the encompassing SLA in [Figure 7-6](#) along with all the SLIs being measured. Each SLI has an expected SLO. If any of those SLIs are ever measured outside of the range expected by the SLO, the SLA may be violated.

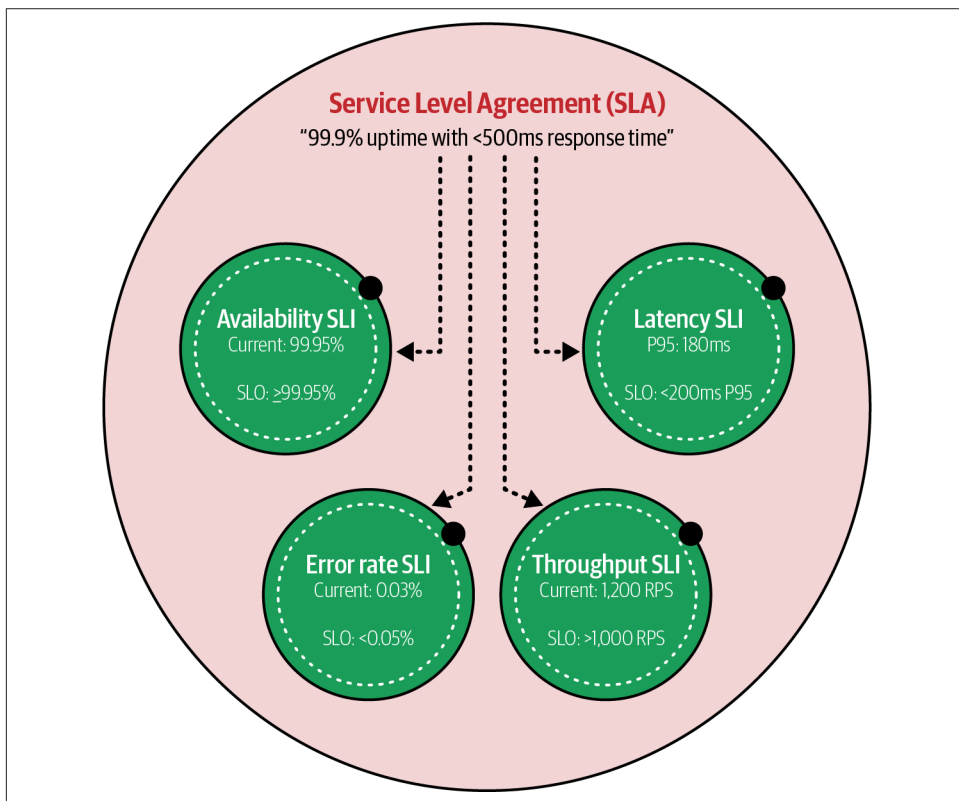


Figure 7-6. SLA relationship to SLOs and SLIs

It is not necessary to get an external provider to have SLAs. If you think about a business as being broken up into multiple organizational units, these units end up being providers of services consumed by other units. That provides an opportunity to have even informal SLAs so business becomes predictable. An information technology (IT) team may be expected to keep all infrastructure available to a level of five nines of reliability. This means all systems and data need to be available to users 99.999% of

the time (five nines). This translates to a little over five minutes of downtime allowed per year. When IT people talk about availability, it may often be in the context of the number of nines, which is basically just the precision of the decimal place being measured. **Table 7-1** shows the different levels of availability.

Table 7-1. Uptime levels and maximum annual downtime

Uptime level	Annual downtime
99.9% (Three nines)	8.76 hours
99.99% (Four nines)	52.56 minutes
99.999% (Five nines)	5.26 minutes

Each time you lose a nine, you add fairly significant downtime. There is a vast difference between 5.26 minutes and 52.56 minutes, which is nearly an hour. After that, it becomes more than a standard workday. Obviously, if you are doing things like maintenance windows for fixes, it becomes harder to hit those availability targets.

Metrics don't collect themselves, though. You need to be able to monitor your performance. This often means engineering in the right controls to be able to keep track of what is happening. This could be logging, and the logs could be ingested into a system capable of analyzing what is happening based on the logs. It could also be external monitoring systems, like a system that sends out web requests to web servers to ensure the server is up and fully operational. Even when you have collected the metrics, you need a place to be able to store and report on them. Additionally, you may want a place to alert when each SLI has fallen out of acceptable parameters. There are several logging systems that can be used to search for information, as well as generate alerts. This may be something like a security information and event management (SIEM) system.

Code Repositories

Teams need a place to store their code. This ends up being more than just about code storage. Invariably, there are going to be multiple files involved in team projects, and different team members may work on several files at the same time. A code repository should allow collaboration by ensuring changes made by one person aren't clobbered by another. Older-style code repositories required a user to check out a file. This put a lock on it so no one else could make changes. To make changes, one developer had to talk to another to get the file released, likely with a set of changes. Collaboration in an Agile/DevOps environment, where everything happens so fast, means users need to be able to work on the same files at the same time. This is one reason why Git is often used as the application to manage these projects. Collaboration may require merging multiple changes if the same file is changed by two different people. Automatic merges may be possible, though manual merges may be required to

deconflict two sets of changes and come up with a single file with all the relevant changes.

Code repositories provide central storage. This means the repository should have strong access control. Ideally, multifactor authentication should be required. This means you can control who gets to view or change files. Once you have introduced authentication with usernames, those usernames can be attached to any changes that were made. This provides an audit trail of changes so a chain of events can be constructed in case something bad has happened with this source code. This may not be malicious behavior. Sometimes, significant problems are introduced with a code change, so it may be essential to unwind the changes and find the point of origin. An appropriate code repository should provide this information, if needed.

A code repository, like those managed by Git, may be automated. This has been discussed previously, but changes to the source code can trigger events. This may include a code review requirement if any changes to the code need to be reviewed by another developer before the change is accepted into the full code base. Hopefully, these code reviews are done by senior developers and they are looking for changes that may cause issues. Otherwise, it is possible to implement changes in the code that can cause breakage or outages.

Centralized code repositories can be backed up in case of a failure. It also helps protect against code that is stored on end devices, which may have other issues. There are also sites like GitHub and GitLab that will host your Git repository with a SaaS solution. This will mean your developers can reach the repository from anywhere, and the SaaS provider will generally offer strong IAM solutions, which may include federation with your own IAM implementation. These SaaS providers will probably also have a lot of integrations and provide the ability to implement automation to your repository.

Introducing Security

Security is essential, and in traditional development practices, it may have been either neglected or an afterthought. When we introduce security as a full-fledged team member, we can start making inroads into the entire process of software and systems development. If you think about all the phases that have to be accomplished during software development, you can start to introduce security into each phase:

Planning

During planning, the security team should be involved to ensure existing requirements have been thought about from a security perspective. This may include identity and access management, encryption, architecture designs to ensure isolation, and several other areas of a complete solution where security should be part of the process. Security may also have its own requirements,

depending on the solution. This is a good opportunity for security practitioners to work with the development team to help them think about the solution and requirements from a security perspective.

Design

Earlier, we talked about threat modeling. This is a good place to introduce threat modeling. Additionally, any design should be reviewed to ensure the solution has appropriate boundaries so isolation and other protections have been considered. The design should also consider appropriate access controls, as well as roles necessary for users and administrators, if needed.

Development

Development may include creation of source code, but it may also include systems development, where the underlying environment and all its components are developed. The security team can be involved in different ways in this phase. To begin with, security can work with software developers on secure development practices, security-oriented unit tests, and style guides, along with other security support. The security team should work to implement static code analysis tools into the code pipeline. The security team should also help implement scanning tools that may look for secrets beyond the source code scanning, which should also be happening.

Testing

While security testing should be a common practice in software development, the security team can also work with the testing team to introduce security test cases. Additionally, the security team should be working on automating as many security tests as possible, using different tools. There are several dynamic security testing tools that are possible and should be implemented into the development pipeline.

Deployment

The security team should be working with the team responsible for IaC to ensure scanning of all the components, especially those from third parties, looking for misconfigurations and vulnerabilities.

In most cases, security will have to work to reduce vulnerabilities that come in via dependencies. There are lots of places to get components for your software that will make development and implementation go a lot faster. Always use trusted sources where possible. This includes having a process to evaluate any software. Any software source has the potential to be compromised, whether it's open source or commercial. Along with the other processes, develop a process to create a software bill of materials (SBOM). This is a comprehensive inventory of all the components used in your software and is beneficial for evaluating whether there are potential vulnerabilities. The SBOM should always be updated when anything changes in the software. This is

something that can be managed automatically during the build process. If it's automated, it is always up-to-date, based on what was built.



Source Code Repositories

In the past few years, multiple instances of malicious code have been discovered. In 2022, well over one thousand packages available using the Node Package Manager (NPM) were discovered to have been compromised. Additional packages that were compromised have been found in the meantime. These are packages often used in web applications. It's not just Node.js, though. Python has also been hit. Again in 2022, more than 12,000 different packages available through the Python Package Index (PyPI) were known to be compromised.

In some cases, these repositories have been compromised by malicious users because the best way to compromise software is to go as far upstream as possible. In cases where the repositories couldn't be compromised with malicious new source code directly, other packages were created with similar names. This attack is referred to as typosquatting, where some names are known to be mistyped. When they are mistyped, the unsuspecting user gets the malicious code. The same sort of attack is used with websites. With domain names that are known to be mistyped a lot, the attacker will register the mistyped domain and establish a malicious site that looks like the legitimate one.

There are many ways for security to work with the development team. If you think about the different stages as diagrammed horizontally, as you can see in [Figure 7-7](#), and pushing security further back to the earlier stages in the process, you will notice you are moving left. The idea of getting security in earlier stages is commonly referred to as shifting left. Security teams are trying to get further and further left in the process.

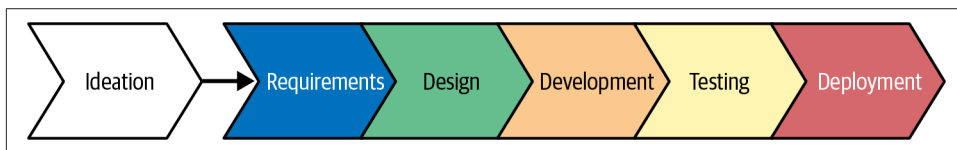


Figure 7-7. Shifting left

Each organization will have its own processes and ways of integrating security, but it has long been known that fixing security issues is considerably less expensive the earlier in the process they are addressed. This is why strategies like application decomposition and threat modeling are important. They help identify issues early so they can be remediated either in the requirements or design phase if at all possible. This is

perhaps especially important when it comes to defining the application design and architecture.

Design Styles

There was a time when applications ran on a single system. There was one user interface. Many decades ago, the single system was a mainframe and the user interface was a dumb terminal. Multiple users were on the system at the same time running different applications. Today, even with personal computers and mobile devices being single user devices, we have swung back to applications running on centralized systems, but the users are actually remote, as was often the case with mainframe systems. Today, though, we have networks, and systems are considerably cheaper. This has allowed multiple design patterns. Between comparatively inexpensive compute, memory, and network, as well as standardized protocols, new design patterns have emerged over the years.

Multitier Architecture

Back in the days when compute was expensive, it was common for a client-server model to be used for some applications. The client didn't need much computing power, while the server had a lot of compute and/or storage demands. Additionally, you might use a client-server if there was a need for a mediated communication between multiple users or some centralized storage.

Using a multitier design isn't only about the different compute requirements. It's also a way to introduce some security, since different elements of the application design have different levels of sensitivity. This means you can separate elements based on a need-to-know basis. If you have designed the network around the systems correctly, it also provides protections for the most sensitive information. While one approach is something called a three-tier architecture, that can be abstracted to something called an n-tier design. The following are common ways of breaking this design up:

- Presentation layer
- Application layer
- Business logic layer
- Data access layer

Figure 7-8 shows how this might be implemented. This is a high-level view, without any of the networking controls that would normally be in place. This design may also have network controls like load balancers and certainly routers and firewalls. These additional network and security controls should include isolating the different layers onto their own networks to protect against something like an attacker gaining access to the web server, the layer with the least sensitive information, and jumping straight

to the database server. Firewalls or access control lists (ACLs) prevent access to these more sensitive systems.

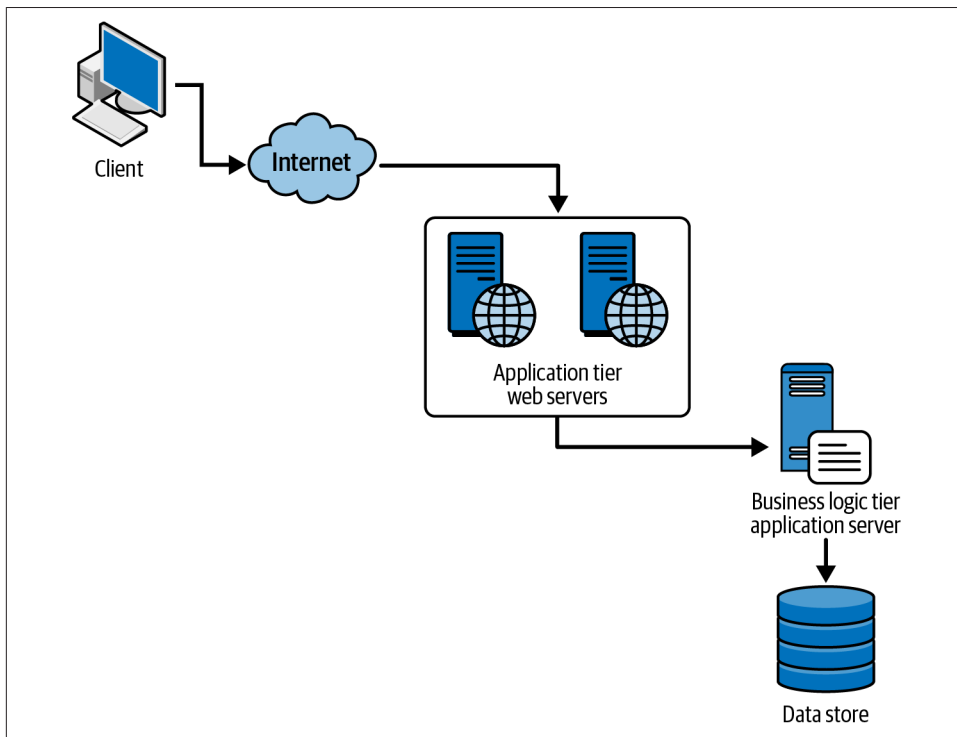


Figure 7-8. n-tier design

If we start from the least sensitive layer in **Figure 7-8**, the presentation layer is where the application owner has no control. It belongs to the user. Once we are inside the application network, control belongs to the application owner. The least sensitive of those systems is the application layer where the web server is. This should contain static content and generally minimal protection for data on those servers. After all, they are public facing. The next tier in is the business logic layer. Perhaps confusingly, this is where the application server is stored and where programmatic content is located. Any data passed into this tier would be passed into the actual application, where it is processed by business logic rules. Finally, the data access layer is where there is persistent storage. Typically, this would be a type of database so information can be stored and retrieved. With a database, the data access is programmatic, meaning it's not simply file storage and retrieval. You create queries against the data store to either store data or retrieve it from the database.

This has long been a common design pattern when it comes to applications, and it is still in use. Even since we moved away from the physical implementations that were used for this implementation, we can still effectively implement an n-tier design. You can easily implement this using a cloud architecture, but it may not be the most efficient way to design a modern application since technology has changed, with much more power implemented in the end-user's hands.

Application Programming Interface

Where web applications were viewed through web browsers on desktop systems in the late 1990s and early 2000s, today the user landscape has changed significantly. Rather than desktop systems, there are now laptops, tablets, and mobile phones. All of these are significantly more capable than the systems used 25 or so years ago, with more compute power, more memory, and significantly faster networking in most cases. As a result, it is possible to move more of the application capabilities into the end user devices and away from the central computing infrastructure. In fact, storage may not even exist wholly in the data access tier at the service provider. Instead, you may have a lot of storage aligned with the presentation layer.

When you have an application that may have both mobile app and web presentation modes, you need to think about how you are going to handle the infrastructure so you aren't duplicating it. One way is to create an API. APIs have been around for decades. In fact, when you are developing a native application, you are using an API. Interfacing with the operating system to do simple things like input/output is done using an API that provides you access to operating system capabilities. Of course, anytime you are working with a user interface, you are probably using an API of some sort. Where these sorts of APIs are handled on the local system, and even sometimes over network protocols like Remote Procedure Calls (RPC), it is also possible to use standard web technologies to implement an API.

Figure 7-9 shows what a high-level implementation of an API for mobile and web might look like. You have the presentation layer, which may be a mobile app or a web browser where the user interacts with the interface. The interface makes API calls to a web server or an API gateway. Either is handling HTTP requests, since the API call will be made over common HTTP messaging. Behind the API gateway or web server that takes in the HTTP request is an API handler. The gateway functions as a router to know where to send the API request. This may all be done on the same system, which is not to say that it would all be in the same application. Finally, there may be a data store and the API handler code will interact with that. There may be another intermediary between them, but there is no reason to overly complicate things.

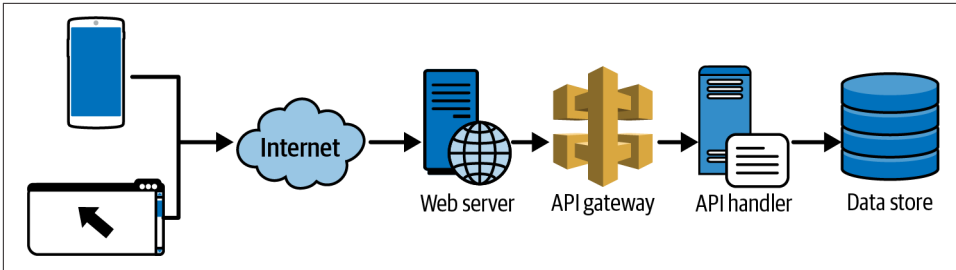


Figure 7-9. API infrastructure

HTTP uses verbs to interact with the server. The verb tells the server what to do. The verbs used by an API server would be GET, POST, PUT, and DELETE. In normal web interactions, you would use GET and POST. GET requests a resource to be retrieved, while POST sends data to the server. PUT, similarly, sends data to the server, while DELETE requests that a resource be deleted. [Example 7-2](#) shows a sample POST request being sent to an API gateway.

Example 7-2. Sample API request

```
POST /api/v1/verify_user HTTP/1.1
Host: api.wubble.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9Fj
Content-Type: application/json
Accept: application/json
Content-Length: 83
```

```
{
  "name": "Holden Caulfield",
  "email": "holden@wubble.com",
  "role": "user"
}
```

There are some elements that are important to mention in this request. First, you'll see the verb and then the resource being requested. Each API likely has multiple endpoints. The endpoint tells the router on the server end where to send the request. You'll also see an `Authorization:` header, which provides a token to indicate the authentication had happened already and the server just needs to verify the token with other data about the request to ensure it is valid and comes from an authenticated user or service. The content type is `application/json`. This tells the receiving server that there will be JSON attached. The JSON is used as a self-documenting way of wrapping information, which generally leaves it in text form. The request body follows the headers. In this case, the request body is the JSON that is provided to the API handler to be processed.

Each request type, based on the verb used, will look similar to this one. You may not always get a request body. There may be a value provided in the URL to indicate a specific resource. For example, `DELETE /api/v2/userdel/4292 HTTP/1.1` would tell the API handler to remove the user with the identification number 4292.

The authentication tokens may be a JSON web token (JWT) or an OAuth token. A JWT is Base64-encoded and commonly includes information about the token type and signing algorithm, as well as claims related to the user, permissions, and expiration. OAuth is a protocol that shares authorization information. The authentication is typically handled using a different protocol, like the Security Assertion Markup Language (SAML), but OAuth uses a token to share between the client and server to indicate the authentication happened and provide information about the access the user has.

User-based authentication is not the only way to get access to an API. In many cases, an API key is used. This is a random value that is provisioned ahead of time. It is associated with an application or service. The API token could be revoked at any time and that would restrict the access to any application or service that was using the token. The token is also sent in the HTTP headers. This may be something like:

X-API-Key:

51H7qY2eZvKYlo2C8x9F3mN4pQ6rS8tU7vW1aB2cD3eF4gH5iJ6kL7mN8o
P9qR0sT1uV2wX3yZ4.

Cloud Native Design

Virtualization has made cloud computing a reality. It also has allowed the development of applications to mature and evolve. First, we started with large applications built primarily on individual systems because virtualization wasn't feasible initially and because multiple systems meant hardware costs. Then, we moved to virtual machines. We can have multiple operating system instances running on the same hardware so you could in theory have a multiple-tier application running on a single system, even though the different components were actually implemented on separate operating system instances.

Today, though, we have moved beyond virtualizing operating systems. We can virtualize a single application. This means multiple applications can be run inside one operating system instance and still be protected from each other. This is done using namespaces within the operating system kernel. Each virtualized container gets a namespace, and the operating system should enforce controls to prevent any memory request from passing out of its own namespace. The application continues to believe that it has the same access to the operating system as a nonvirtualized application. The application is kept within a container. These containers include all the relevant

binaries, libraries, and other supporting files necessary for the application to run. Docker is a common piece of software that manages containers.

The great thing about containers is they are very lightweight, since you don't have to spin up all the supporting operating system files and other support. Virtual machines suffer from having a lot of supporting files and services, so they take time to boot up. If you are starting up a virtual machine and allowing it to run nonstop, this isn't a problem. You incur the startup penalty once and then all you have to pay for is the application usage for disk, memory, and network. Containers, on the other hand, can start up very quickly. They should be able to start up as fast as it takes to load any application. This means you don't have to keep applications running all the time. You can containerize them and then they get started up as needed.

This requires another piece of software to manage the containers. There are different orchestration packages, like Kubernetes (K8S), that will ensure the containers are running when they are needed. With containers, you can have multiple instances to manage the load. If you think about the API implementation, your API gateway and router take the request in and then hand it off to a container. The orchestration platforms put multiple containers into a pod. On top of the pod is a service. The service handles the inbound request and hands it off to the pod, which distributes it to a running container instance. You can see what that may look like in [Figure 7-10](#). Above the pod is a service. In this case, you have a listener for HTTP/HTTPS traffic. When a request hits the service, it is handed into the pod. Inside the pod are multiple containers that have a web server running. In this case, it is the *nginx* web server application.

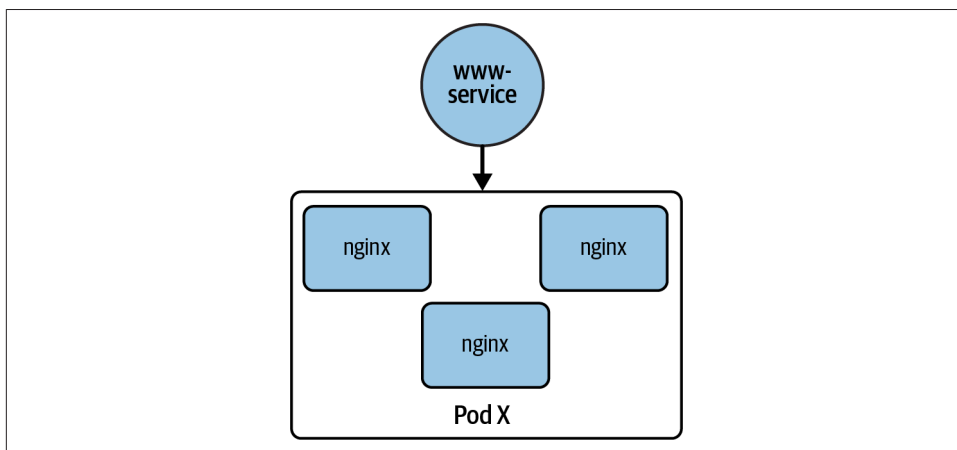


Figure 7-10. Container implementation

Since a container can be started quickly, it doesn't have to be running all the time. This means you don't necessarily have an application that is sitting and waiting for an attacker to get a foothold. Additionally, if an attacker does manage to compromise the

running application, a container may terminate, effectively booting the attacker out. Also, the container doesn't have access to the operating system, so a foothold in the container may not be able to accomplish much. The fact that containers aren't always running makes them easier to update, in theory. You can replace the code running in the container so the next time it starts up, the latest code will be in place.

Small, lightweight containers for applications also means developers can rethink how they develop their applications. Rather than monolithic designs where all the application code is put into a single binary, you can break the code up into smaller chunks. This is referred to as a microservice architecture. A microservice may implement a single function, and the different services will interact with one another. Rather than calling a function inside of an application, each service may directly call other services. While this could happen using direct calls to a listening service, another approach is to use a bus architecture. A bus is a way of passing messages between different application components. One service sends a message onto the bus where other services can pick up the message if it is meant for that service. That message is effectively like a function call. The message may be a request along with data. The request gets handled and any responding data is put back on the bus.

Containers are not the only way to implement microservices, though. Cloud providers also offer serverless functions. This means only the code exists. There is no container to hold the code. Instead, there is a service that listens for triggers. When the trigger arrives, the service starts up a runtime engine that will execute the code meant to handle the request the trigger is related to. This runtime engine could be something that will execute Python, Java, or .NET code.

Another aspect of cloud native is the move away from strictly relational databases. Where Structured Query Language (SQL)-based servers have traditionally been used for web applications, cloud native applications may use something called NoSQL. This means ways of storing data that are not restricted to columns and rows like a SQL-based database. There are four types of NoSQL databases you will run into:

Document-based

Data is stored as a document rather than parsed out to columns. This document may be JSON, XML, or other types of semi-structured data. The data is bundled up into these data languages and then stored in these databases, like MongoDB and some of the cloud provider-specific software offerings. This may be useful for content management systems, catalogs, or user profiles.

Key-value stores

A key-value store is basically a dictionary. A key is a way of getting access to the data, which is the value. A dictionary is a collection of these key-value pairs. Redis is an example of a key-value database. Shopping carts, session storage, and caching are all use cases for this type of database.

Column-family

You may be used to the table structure of a SQL database where the columns define the database structure and each row is a separate instance of a record. A column-family turns the standard table by 90 degrees. The row becomes the definition of the database, but each row may include different columns. It provides a lot more flexibility than a standard table-based database. This may be useful for any time-series data or from information coming from Internet of Things (IoT) devices.

Graph

A graph database is where data is stored as a node and then related to other nodes with edges. These relationships become the way you traverse the data to locate information. Social networks will use graph databases. A graph database can also be used for fraud detection.

Cloud native isn't only about the technologies used, though. The essential elements of cloud native design are:

Scalability

Applications can be scaled up or down based on need. This helps to keep costs lower and more accurately based on actual usage. Containers are very helpful in this regard, since they can be spun up or down based on whether they are required. Similarly, serverless functions can help with rapid scaling.

Microservices architecture

Breaks up the application into constituent components that can then be containerized. This also supports scaling.

Containerization

Each microservice is implemented in a container. This reduces the application footprint since only what is necessary to support execution of the service is included in the container, reducing the attack surface.

Dynamic orchestration

Once you have implemented containers and microservices, the only way to get scalability and costs savings is with dynamic orchestration. Dynamic orchestration is managed with Kubernetes and similar orchestration software. These orchestration engines will take care of auto-scaling by spinning up and tearing down containers as they are needed.

Observability

Monitoring is essential to ensuring the overall application is functional. This requires monitoring (network requests, etc.), logging, and tracing to know whether the application is performing as expected and whether it is operational.

Summary

Software development, when done at scale, requires a process. This is generally called a software development lifecycle (SDLC). The SDLC commonly includes the following phases: requirements, design, development, testing, deployment, maintenance. Some common SDLC processes include waterfall, rapid application development, extreme programming, and styles of Agile development.

DevOps is a way to ensure operations and their requirements are included in the development efforts. This is necessary when the organization is responsible for the development of the application as well as the deployment, operation, and support. DevOps is a set of essential characteristics and a philosophy. One of the critical components is communication between development and operations. Additionally, DevOps prioritizes automation. This includes the development pipeline, which leads to continuous integration/continuous deployment. This means everything from code check-in through build, test, security testing, and deployment is automated.

Applications have generally moved from n-tier applications where the presentation layer is with the user, the application layer starts with the web server, the business logic layer is in the application server, and the data access layer houses the database. Instead, cloud computing has moved to more virtualization. This includes containers, which are ways for applications to be virtualized. Cloud native design moves to a more resilient design that is scalable and responsible. This helps not only with user experience, but also with costs.

Other Resources

The following pages provide additional information related to software development practices and architectures:

- “What Is DevSecOps?” Red Hat, March 10, 2023 (<https://oreil.ly/Oq8a5>).
- “What Is SDLC?” Amazon Web Services (<https://oreil.ly/NmUtS>).
- “N-Tier Architecture Style,” Microsoft (<https://oreil.ly/eQtIO>).
- “What Is Microservices Architecture?” Google Cloud (<https://oreil.ly/RXK1y>).
- “What Is Site Reliability Engineering (SRE)?” Amazon Web Services (<https://oreil.ly/oCNoC>).

Cloud Security Operations

Topics covered in this chapter include:

- Adversary types
- Cyber kill chain
- Attack lifecycle
- Security operations
- Security engineering

We covered operations in the last chapter, but keeping systems up and running is different from ensuring bad things don't happen. Ultimately, the reason for this book, frankly, is because protecting information assets is a critical function for all organizations. There are adversaries in the world looking to obtain resources. There are many reasons for that. Information can be resold in illicit ways to obtain money. It could be about influence, including political. All you need to do is to pay even a little attention to the news to know that everyone is a potential target. This is primarily businesses today simply because the attackers can get more from going after collections of people rather than individuals.

Security operations is about the people, process, and technology required to identify, detect, and respond to attempts at attacking the organization. This requires a lot of information and coordination, which will vary by organization because some companies are more prone to being attacked than others. What they have, from information to access, is more valuable. This means they are going to be targeted more frequently because there are more groups interested in them.

While it may be quaint to think about the so-called fat kid in his parents' basement, this is not the profile of a modern attacker and, quite frankly, really never was the profile of a serious adversary. The shady character with a hoodie in a darkened room —also not realistic. There are basically three types of attackers organizations should be concerned with. The type matters, because what each is after is going to be different. Additionally, how they operate will vary, along with who they are going to be targeting.

Fortunately, there are ways of thinking about security operations. First, it's helpful to understand how attackers operate, meaning they will generally have a process. This is because some things naturally come before others. If I want to go running, I probably need to put my socks on before my shoes and also need to put my shoes on before I lace them up. There is a natural order of operations if you want to be successful. This does not mean that there is a playbook that all attackers follow because there are thousands of types of attacks and they will all vary, but at a high level, there will be an order each step falls into. Once you understand how the attacks operate, you can think about how to organize yourself and your processes. Using the NIST Cybersecurity Framework (CSF) is a good way to think about what you need to be doing and what people, process, and technology you need to map against the attack processes.

There are some essential technologies or practices that are required to be successful at monitoring and response. Much of it comes down to visibility. After all, you can't respond to something you can't see, so you need to be able to see as much as you can. Once you have information about what has happened, you can start thinking about what to do about it. Again, knowing who the attacker is and how they operate can be useful in being able to identify and track their activities.

Types of Adversaries

While there can be a lot of noise on the internet, and at any given time, probably millions of individuals just trying something to see if it will work, which can look like bad behavior to your monitoring team, there are essentially three different types of attackers you should be concerned about: hacktivists, organized crime, and government sponsored groups. Depending on what type of organization you are responsible for, you may be more concerned about one than another. Generally, you should think about each of these adversaries as organizations. Perhaps individuals exist, but these three types of adversaries will be more problematic for you and they will not be individuals.

Hacktivists

Hacktivists are people with a cause. They are upset about something and they are going to do something about it, whether the action makes a lot of sense in response to the offense or not. A good example here is the Izz ad-Din al-Qassam Cyber Fighters. There was a YouTube video titled “Innocence of Muslims” that was apparently anti-Islam in nature. In response to this video being available on YouTube, a group of hacktivists, thought to be based in the Middle East, launched enormous denial-of-service (DoS) attacks against Bank of America, JP Morgan Chase, Wells Fargo, Citigroup, and other financial institutions.

These attackers were able to sustain 65–140 gigabits per second (GBps) over weeks, which was the most sustained attack traffic ever seen to that point. These attacks received minimal press coverage given the unprecedented scale. Most consumers wouldn’t have known they were happening. In the end, the video was not taken down and the attacks abated over time, though they stretched from late 2012 well into 2013.

You may also recall the efforts of Anonymous, who attacked multiple organizations in response to their activities. LulzSec was an offshoot group from Anonymous and they attacked Sony, stealing millions of usernames and passwords from the Sony PlayStation Network (PSN), releasing them online. This was in protest against Sony’s prosecution of George Hotz, who had identified a way to jailbreak the Sony PlayStation 3. LulzSec was looking to embarrass Sony by exposing its lack of security. LulzSec and Anonymous have both been involved in multiple social campaigns in protest against organizations like the Westboro Baptist Church, InfraGard, Fox, and many others.

Attacks by hacktivists will vary according to the skills of the group, as well as the impact they are trying to have. In the case of LulzSec and Sony, for example, LulzSec compromised Sony to steal information to embarrass the company. In the case of the bank attacks, the attackers seemed to expect that attacking large capitalist symbols like enormous banks would get someone’s attention.

Organized Crime

When you see the term “organized crime,” you may think *The Godfather*, *GoodFellas*, or other movies or stories related to the Mafia. In this case, organized crime simply means an organization whose primary purpose is criminal activity. This includes stealing information, creating or hijacking infrastructure to rent it out for malicious or nefarious purposes, or many other illegal activities. These are often large organizations that operate like a business. They have employees, they have research and development teams, they may have contractors, and the employees often work shifts. They are able to fund their operations with the money they get from their actions.

While selling stolen goods or stolen information, acting like a service provider, and initiating other actions are common, these groups are often involved in ransomware as well. Ransomware has become a lucrative activity, in spite of pressure from law enforcement and many others to not pay the ransom. Without adequate recovery procedures in place, many organizations feel they have no other recourse but to pay the ransom. Where ransomware may have begun as encrypting information and selling keys, it pivoted to the outright theft of data with the threat of exposing it to the public. Where you can recover from ransomware when the data has been encrypted by having good backups that you can restore from, stolen data is a different story. Exposing sensitive information or data belonging to customers can have a significant impact on companies.

Keep in mind that money is ultimately the motivation here. This changes the diligence of the attackers. If you are seen to have resources that will be lucrative for the criminal organization, they will keep after you. This is the same as a salesperson keeping after a company they feel will generate a large sale for them. Saying no (or kicking the attackers out) doesn't change the fact that there is money there.

Government-Sponsored Groups

This category gets the most press coverage because it's sexy in a world where spies and geopolitical tensions make for good stories that consumers want to read about. These may be portions of a legitimate government, as in the case of the National Security Agency (NSA) of the United States. They may also be part of the national military, as would be the case with the US as well as China, known to have military groups that are responsible for attacking enemy countries.

The motivations here vary. In some cases, they are to obtain influence with other countries to get what they need. They may be looking to undermine a political situation in a foreign country because they see that country as an adversary or enemy. In some cases, such as North Korea, they use cybercrime as a way of funding other operations.

The one fact that should be considered with these organizations (you will see them called nation-state actors sometimes, though that feels misleading) is that they are well-funded, just like the cybercrime organizations. This means they may have proper research and development arms, much like the NSA does, to create new compromise possibilities. They may be constantly hunting for new vulnerabilities and ways to exploit them. Rather than relying on off-the-shelf, commodity attacks and malware, they are creating novel attacks. This is what makes them advanced as compared with other adversaries. The new attack types makes them difficult to identify.

Security Operations Frameworks

There are different frameworks that are helpful to understand both what the adversary does, as well as how to organize your response to it. Adversaries will follow a process. Understanding where they are in the process helps to identify urgency in your response. Additionally, once you have an understanding of the process attackers use, you can use another framework to map your own response and identify where you may have gaps in your operational practices. We'll take a look at two ways of thinking about how attackers operate. One of them is based on a military understanding of adversary operations. The other one is based on observations of how attackers operate in the real world. Finally, we will look at a solid model for essential functions you should have in your security organization.

Cyber Kill Chain

The Cyber Kill Chain is a concept developed by Lockheed Martin, a defense contractor for the United States military. The idea of a kill chain is a military one, where you identify the different elements of an attack by breaking it down into a process flow. By identifying the different stages, you can identify where to break the chain or interfere with the process flow. Effectively, you are identifying where you can kill the chain. This military concept was taken into the digital space with the Cyber Kill Chain. According to Lockheed Martin, defensive actions taken at each phase will help disrupt the chain and prevent the attack from being successful. **Figure 8-1** shows the different phases in the order they would happen as an attacker moves.

The phases, with their explanations are:

Reconnaissance

Target selection, information gathering

Weaponization

Malware development and pairing with a delivery vehicle

Delivery

Getting the malware to the target using the network, USB stick, etc.

Exploitation

Having the malware execute on the target system

Installation

Installing a backdoor onto a target system so the attacker has remote control to that system

Command and control

Allowing the attacker to have remote control of the compromised systems so commands can be sent into the targets

Actions on objectives

The attacker doing what their objective was initially, which may be data theft, additional credential compromise, or other activities

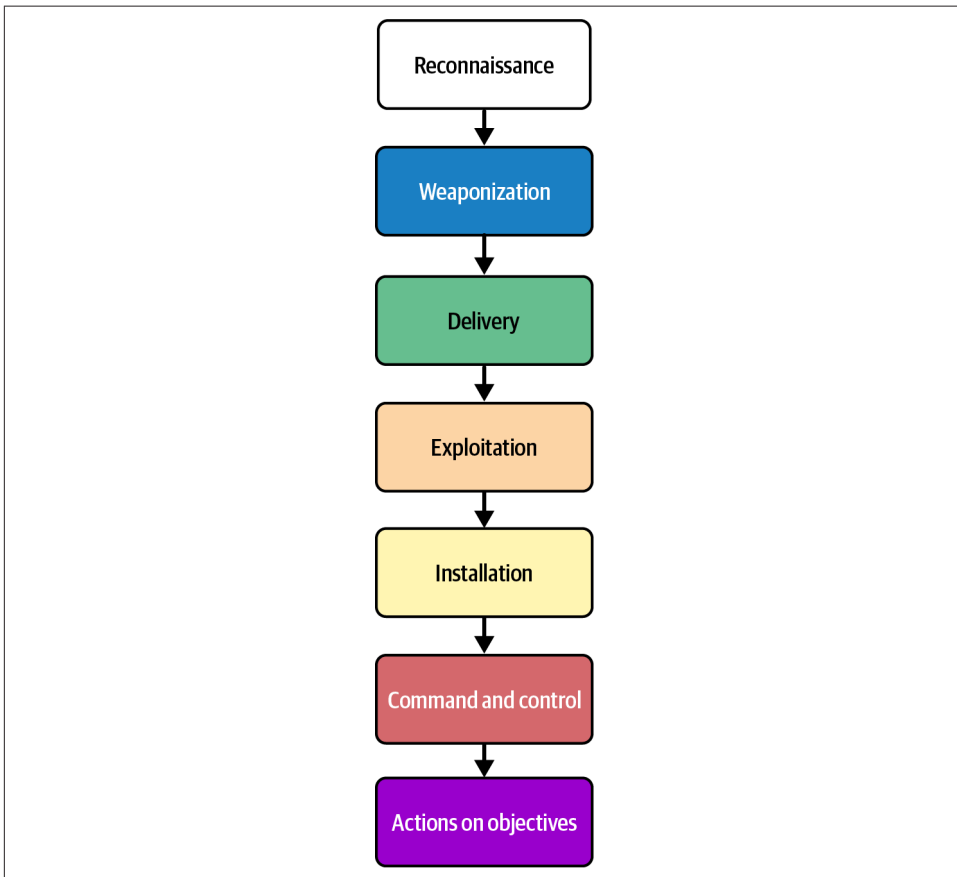


Figure 8-1. Cyber Kill Chain phases

While identifying the phases in the Cyber Kill Chain may be useful, you still need to know what you should do once you have identified the phases. Lockheed Martin has identified the following defensive actions that may be taken:

Detect

Identify whether an attacker is present

Deny

Prevent unauthorized access and information disclosure

Disrupt

Stop or change attack traffic

Degrade

Counter attack and control

Deceive

Interfere with command and control

Contain

Network segmentation

In theory, you should be able to apply these defensive actions across the Cyber Kill Chain to hopefully prevent attacks, or at least make it difficult for the attacker to action their objectives. From a practical standpoint, though, there are significant gaps in the approach of the Cyber Kill Chain and it is a theoretical framework that has been informed by kinetic warfare rather than observations about what attackers actually do. Also, the first two steps in the chain are almost entirely outside of the control of the target organization. There is also too much focus on malware, which is not always present in modern attacks.

Attack Lifecycle

In contrast with the Cyber Kill Chain, the attack lifecycle, largely proposed by Fire-Eye/Mandiant, is a model of observed attacker behavior, and everything that happens within the attack lifecycle is entirely within the defender's control. If you go back and analyze behaviors of large-scale attacks going back to at least the 1980s with Kevin Mitnick and the Chaos Computer Club, for instance, you will be able to perfectly map those compromises to the attack lifecycle. The attack lifecycle applies without regard to the attacker, victim, system being targeted, or specific tactics, techniques, and procedures. **Figure 8-2** shows the attack lifecycle.

The diagram shows the first point where the attacker enters the target environment, though there is also a phase that comes before this, which is initial reconnaissance. That includes all the usual identification of targets, as well as collecting information about them. One of the advantages of the attack lifecycle is it recognizes that the attacker, especially the advanced persistent threat actors many organizations are particularly concerned with, will generally try to spread their influence within the environment and remain there as long as possible. The attack lifecycle also doesn't focus on malware since there are other techniques attackers may use.

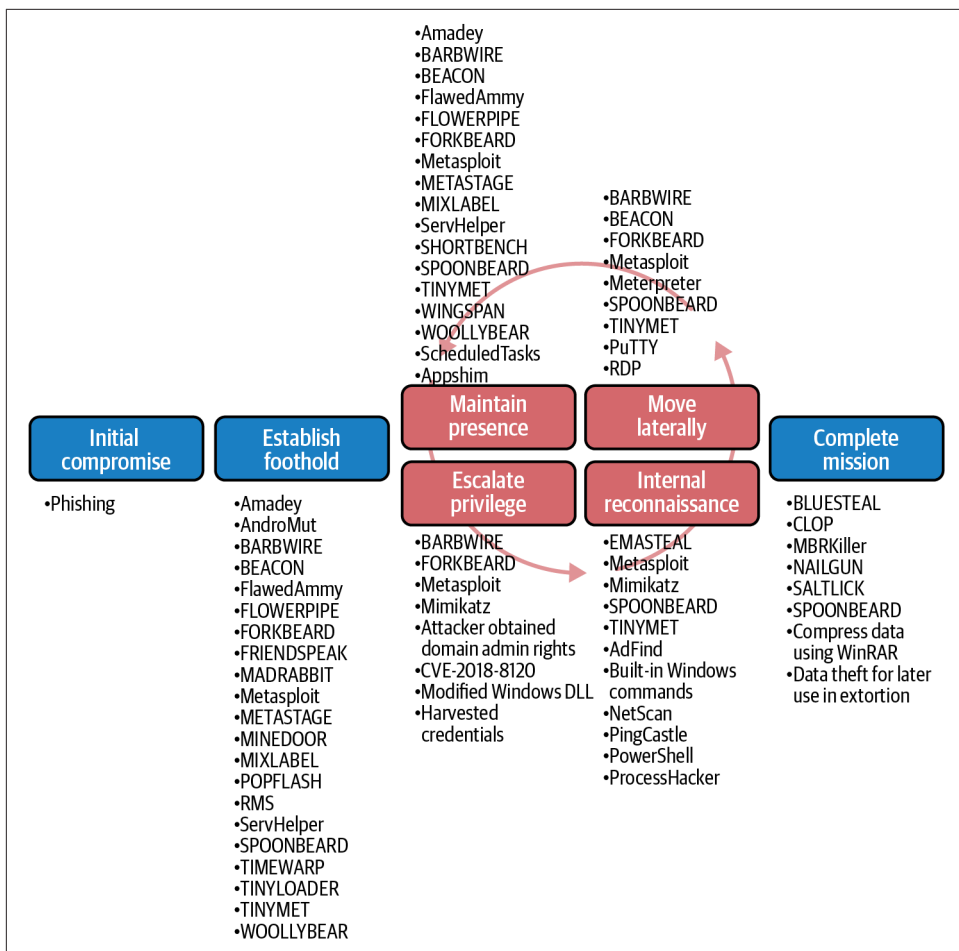


Figure 8-2. Attack lifecycle

The steps of the attack lifecycle are as follows:

Initial reconnaissance

Identifying the target, collecting hostnames, employees, email addresses, and other information about the target that may be beneficial for the attack.

Establish foothold

This is where the attacker gains access to the environment using compromised credentials, phishing attacks, application compromises, or malware.

Escalate privileges

The next steps in the attack lifecycle will often require administrative privileges, so the attacker will usually try to escalate from normal user permissions.

Internal reconnaissance

Once the attacker is inside the environment, they will try to gather information about network shares their compromised user knows about, other users, other systems, and any other information they can find that will help them in their subsequent steps.

Move laterally

A single system is not generally going to be the only target. Once an attacker has access, they will try to gain entry to other systems, since that provides them access to more information, more systems, etc.

Maintain presence

This could be adding backdoors or other persistence mechanisms to ensure the attacker can continue to have access to the compromised system.

Complete mission

This is perhaps misleading, since it almost suggests it is the end, except that attackers will stay within an environment for years, if possible. In 2018, Starwood/Marriott, for example, was found to have been compromised for over four years.

The attack lifecycle is not only useful to identify how attackers operate, it provides additional information. Each phase comes with a different set of behaviors. If you detect one of these behaviors, you will know how far along in the attack they are, which will give you a sense of urgency. The MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework is a collection of Tactics, Techniques and Procedures (TTPs). A tactic is the goal of an attacker, such as gaining initial access. This is not a long-term objective but what they are trying to accomplish next. The technique is the method used to achieve the objective. If the tactic is initial access, the technique may be using a phishing attack. The procedure is the specific details, like the exact type of email being used to gather credentials.

While identifying the specific TTPs being used can help you figure out where in the attack lifecycle the attacker is, it's not very satisfying to rely on figuring out how far along an attacker is. For a start, ideally you'd be stopping the attacker from getting access to begin with. This is not always realistic, of course. You have to assume you will get breached, so you are prepared to handle it if you are.

NIST Cybersecurity Framework

While there are other approaches to a comprehensive cybersecurity program within an enterprise, the NIST CSF is easy to understand and covers all the important elements, focusing on getting the organization into a position to deter attacks and respond if they do happen. It is arguably more useful than other approaches since you can cleanly and easily map the different CSF functions to an attack lifecycle to ensure

you have the right coverage. You can also organize your overall information security program around the CSF by checking people, process, and technology for each of the functions to have adequate coverage. **Figure 8-3** shows a common representation of the CSF.

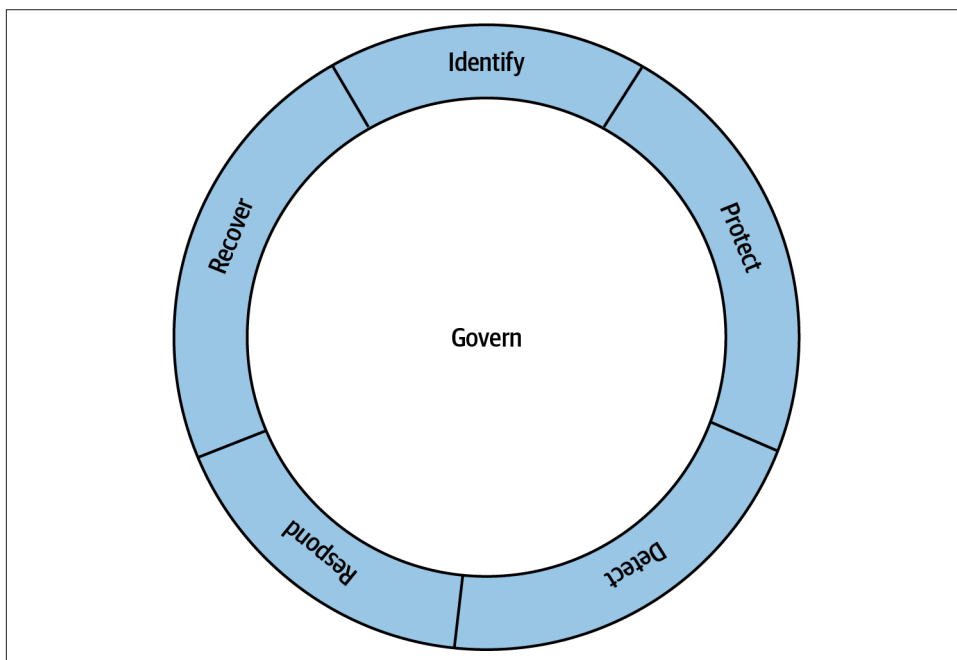


Figure 8-3. NIST cybersecurity framework

The five essential functions, as you can see, all wrap around the core of governance. This means you have documentation, management, metrics, and all the other essential business functions in place. The CSF focuses on the essential capabilities a well-rounded information security program should have. Rather than saying each of these capabilities should have its own governance elements, they make governance a foundational element that applies to all of them. These are the essential capabilities, according to the CSF:

Identify

Before the organization takes on any other activity, it needs to identify assets, threats, and capabilities. This should be an ongoing activity, since assets and threats are likely changing on a regular basis. Ideally, assets, threats, mitigations, and other essential information necessary to the information security program should be documented and revised on a regular basis. If you think about your house, this is noting all of your windows and doors or any other entry point (dog

door, for instance). Additionally, it is noting the level of criminal activity that would be common in your neighborhood.

Protect

Ideally, attackers would never get in, so there need to be protective controls in place to keep them out. This has long been thought to be the primary goal of information security programs since the expectation has been that attacks can be prevented through strong perimeters. While this is essential, since you aren't going to just leave all your doors and windows unlocked with no monitoring in place at your house, it is not where it ends.

Detect

Detection controls are all the logging and monitoring that are essential to be aware when an attacker starts trying to break in. This is the same as having sensors on your doors and windows in the house, alongside systems to alert you when the doors or windows are opened unexpectedly. Detection relies not only on visibility, but also on alerting so someone is aware when unexpected activities occur.

Respond

As you'd expect, monitoring alone isn't sufficient. You can generate alerts all day, but if no one does anything, it's like not even knowing, or probably worse than not even knowing. Once an alert occurs, there should be a response team to identify whether the attack was successful or not. The goal of this capability is to not only perform the investigation, but also to eject the attacker. It may go without saying, but this would be the equivalent of either an alarm on your central security monitoring station at the house, or sending the alert to a third-party, who may call police. The police would be dispatched to your home to respond to the alert.

Recover

Response is inadequate. Once you have identified what happened, you need to clean up. This may be notifying people that their information may have been compromised. It should also be identifying how the attacker got in, so those doors can be closed and nailed shut. You should perform an analysis of where any failure may have occurred to remediate those failures so they don't happen again.

Now that you see the different capabilities for the NIST CSF, it's an easy jump to understand your capabilities by mapping the controls you have for each step of the attack lifecycle against the different phases from the CSF. You can see an example in [Table 8-1](#).

Table 8-1. CSF mapping to attack lifecycle

Attack phase	Identify	Protect	Detect	Respond	Recover
Initial compromise	- Asset inventory and classification - Vulnerability assessments - Threat intelligence feeds	- Email security gateways - Web application firewalls - Endpoint protection platforms - Network firewalls	- Logging - User behavior analytics - Security events	- Isolate compromised systems - Block malicious domains/IPs - Identify initial entry	- Remediate initial entry - Reset credentials
Establish foothold	- Baseline system configurations - Normal user behavior patterns	- Application whitelisting - Endpoint protection	- Process monitoring - Registry/filesystem changes - Unusual service installations	- Kill malicious processes - Remove persistence mechanisms - Quarantine affected systems	- Identify root cause - Configuration restoration - Security control validation - Lessons learned integration
Escalate privileges	- Privileged account inventory - Administrative access mapping - Service account catalogs	- Just-in-time access - Multifactor authentication - Privileged access workstations - Admin-only accounts - Service account rotation	- Log administrative activities - Identify unusual activity - Detect unexpected service use	- Disable compromised accounts - Force password resets - Review admin group membership - Audit privilege grants	- Reset admin credentials - Privilege minimization - Access control validation
Internal reconnaissance	- Network topology mapping - Data classification schemes - Service discovery baselines	- Network access control - Micro-segmentation	- Identify unexpected tool usage (WMI, etc.) - Identify unknown apps (PowerShell scripts, etc.)	- Isolate systems - Wipe and restore compromised systems	- Network architecture review - Segmentation improvements - Monitor gap closure

Attack phase	Identify	Protect	Detect	Respond	Recover
Move laterally	• Document data flows • Network traffic baselines • Document credential usage patterns	• Network segmentation • Credential vaulting • Zero trust network architecture	• Identify unusual network connections • Identify pass-the-hash attempts • Detect remote access tool usage • Detect cross-system authentication	• Isolate systems • Isolate compromised segments • Network containment	• Network redesign • Trust relationship validation • Segmentation testing • Document data flows
Maintain presence	• Credential documentation (users, services, etc.) • Change management processes • Document system monitoring	• System integrity monitoring • Configuration management • Anti-tamper controls	• Backdoor installation • Scheduled task creation • System file modifications • Covert channel detection	• Remove persistence mechanisms • System integrity restoration • Backup validation • Access revocation	• Restore from backup • Integrity baseline updates • Change control strengthening • Monitor enhancement • Recovery procedure testing
Complete mission	• Data inventory and classification • Data flow mapping • Intellectual property catalogs	• Data encryption • Data loss prevention • Principle of least privilege • Access controls • DNS controls, blackholing known malicious domains	• Egress monitoring • Looking for large data transfers, compression/encryption • Activities, external communications • Data staging detection looking for large files	• Block data exfiltration • Restrict DNS requests • Quarantine staged data • Preserve evidence	• Data restoration • Stakeholder notification • Regulatory reporting • Business continuity activation

This is just a simple set of controls that may be used within an organization. A complete set would be exhaustive and should always be maintained. Controls mappings are important to understand where there are gaps, and using a framework like this provides structure that can be useful to understand exactly where you have shortcomings. Expect that you will be breached, so you aren't front-loading your controls and have nothing on the backend. Missing controls throughout the set of capabilities are how attackers find their way through the attack lifecycle. This is not to say that you will be completely successful in preventing or even detecting attackers, but this is how you can keep going back to a document like this and ensuring you have controls in the right places. As soon as you have any activity within the attack lifecycle, you

should be revisiting this document to implement additional controls to prevent that attack from happening.

Security Operations

While many organizations will outsource their security operations, larger businesses will create their own security operations programs. This means they will have to take on the people, process, and technology to support the essential task of handling any intrusion attempts from detection through resolution. As you might expect, there is generally an order of operations. This is true whether you are talking about on-premises or cloud events. While the process is the same no matter where you are, there are differences when it comes to a cloud environment simply because you don't own anything in the cloud, so there are elements you will not be able to look at. **Figure 8-4** provides a diagram showing what the rough process would look like.

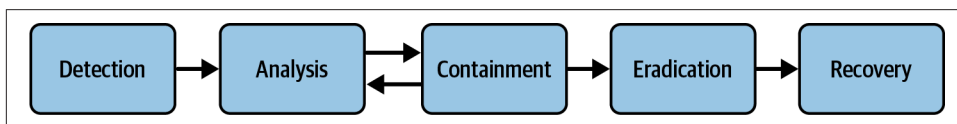


Figure 8-4. Security operations process

This is a rough process only because you may bounce around between steps based on what you find. Where the CSF starts with identification then protection, we are only focused here on what happens after something has been noticed. We should start with the definitions of those things that happen. First, there is an event. An event is an observable occurrence. This does not imply that there is anything wrong. An event could be as simple as a computer was powered on, or someone initiated a web browsing session. A login is an event. You can't say any of these is something to be worried about particularly, at least not without some additional context.

You aren't going to go looking at every single event that happens because, as defined, an event is anything that is noticeable. There isn't time or resources to spend a lot of time on every event. This means you need to narrow down the list of events that you are going to be spending your time on. This may be something like a number of failed logins, or logins from unexpected locations—something out of the ordinary. These would be events of interest. An event of interest is something worth taking a look at, going deeper to understand whether it's truly problematic behavior or just an anomaly. You can see we are distilling as we go.

The final distillation is an incident. This is an event that is an event of interest that also rises to the level of "we need to figure out what happened here." You can see the relationship among events, events of interest, and incidents in **Figure 8-5**.

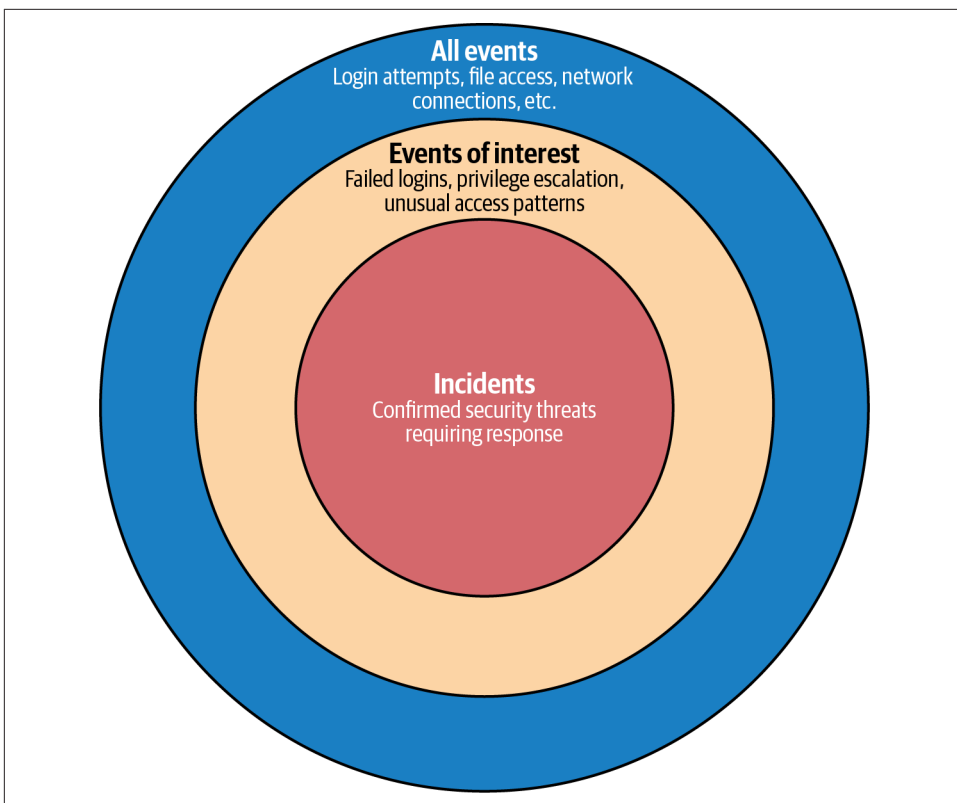


Figure 8-5. How we get to incidents

The detection phase is where we start with the security operations process. This is where an event of interest comes in, since I'd assume you aren't detecting every event. Once you have identified your events of interest, you should have detection capabilities for each event of interest. This detection may come in the form of an alert. An alert may look like a ding noise and a box on screen or flashing red text, or it may be a text message, or an email. Anything that gets you to pay attention to it. Once the detection happens, it should kick off an analysis. The analysis should be done to determine whether the event of interest is an actual incident or not. This is usually done by performing triage.

Once you have performed the analysis and determined you have an incident on your hands (otherwise you clear the alert and move on to the next one), you should look closer at the event to determine whether there are actions that may be necessary based on that event. You may think of the analysis here as the investigation phase since the analysis relies on the collection of information from the place where the event of interest happened.

Assuming you have found that you have an attacker in your environment based on your investigation, you may have determined, based on your findings, what phase of the attack lifecycle the attacker is in. You should contain the attacker. The purpose of containment is to keep the infection from spreading any further. Until you have a complete understanding of the extent of the infestation, you want to make sure you have limited what the attacker can do. Just removing their access to a single system doesn't do anything because the attacker (in reality, it could very well be an organization, so multiple individuals) may have footholds in other systems. Containment is often done with software like an Endpoint Detection and Response (EDR) solution, which can restrict network access. It may also be done at the network layer by restricting access.

This is where the loop is likely to come in. You identify a system that may have been compromised. You perform containment to restrict what the attacker can do on that system (booting the attacker off will indicate that you know they are there, which may cause them to change what they are doing, so it may make it more difficult to detect where else they are), and also limit their access to other parts of the network. You still need to continue to investigate until you strongly believe you have found every place the attacker has been able to get access. This is also where the attack lifecycle comes in handy. It admits to the idea of attackers moving laterally within an environment.

This is different in a cloud environment, where you don't have the same set of desktops that exist on the same network segments and are largely visible to one another. This doesn't mean that lateral movement is impossible, but the behaviors necessary for lateral movement are different from an on-premises environment where workers are sitting at their desks, their computers wired into the network on orderly VLANs, likely organized by their desk location. Since virtual machines, containers, and serverless functions are going to be on different virtual network segments with different rules for access, the investigation will be associated with permissions and access from a credential perspective.

Many would be inclined to boot the intruder out as soon as they are found. This is a mistake without understanding the full scope of the intrusion. If you boot them out, you may find that you are facing another detection several months down the road because the attacker is likely watching what you are doing. If you start removing all the footholds and changing passwords on accounts, as well as deleting any additional accounts that may have been created, the attacker is going to squirrel away the ones you don't know about and also change the way they behave. This means they will still be in your environment, but dormant. This is why it's essential to have a complete understanding of the scope of the intrusion before moving to the next stage.

This is also where it's helpful to talk about indicators of compromise. An indicator of compromise (IoC) is a piece of information showing that the environment has an attacker inside. It may be a log entry with an account login from an unexpected

location. Or it may be a VPN login while the account owner was sitting at their desk in the office. Any piece of evidence suggesting the attacker is in the environment could be an IoC. As the investigation continues, more and more IoCs will be collected, providing a trail of activity. When a new IoC is discovered, the entire environment should be scanned for that IoC to identify other systems that haven't previously been identified as being in scope. While different incident responders may have different guidance, and certainly businesses are free to operate their systems the way they see fit, a good rule of thumb for identifying when you have the complete scope of an incident is when you have stopped finding new IoCs. Assuming you have been scanning the entire environment for those IoCs, you have the complete collection of systems, accounts, services, etc. that have been compromised.

Once you have the complete list of everything that has been impacted, you can move to eradication. This means a full cleanup. The challenge is that while you are cleaning up, forcing credential resets, wiping and restoring systems, the attacker may be following along behind you, recompromising, and reestablishing footholds. One approach to prevent this is to pull the plug on the network and do the cleanup work completely offline. This can help ensure you have an attacker-free environment.

Eradication isn't only about wiping the online systems. You also need to consider any disaster recovery plans since warm or hot sites may also have picked up the compromised environments. Additionally, backups need to be marked as suspect so at some point you aren't restoring artifacts that may allow the attacker to get back in.

Speaking of getting back in, the last stage is recovery. This is not only getting rid of the attacker but getting the business back up and operational again. Everything is restored to normal operations, including switching back from any secondary measures you may have needed to take to stay in business during the investigation and eradication. Sometimes, in the case of significant intrusions, this may be switching back to digital operations from manual or analog.

Recovery isn't only about making sure the business is back up and running, though. It is, or should be, also about ensuring you fully understand what happened. This may be performing a root cause analysis to identify, to the best extent possible, how the attacker was able to get in to begin with, as well as how they were able to move from one system to another. This means you need to conduct not only the root cause analysis investigation but also create a plan to remediate any exposures that allowed the attacker to operate. As you'd expect, you should be identifying any gaps in people, process, or technology. Once these gaps have been identified, they need to be filled so either this attacker can't get back in or another attacker can't come along, find these exposures, and use them.

All findings should be prioritized and remediated based on a clear framework. The threat model DREAD (Damage Potential, Reproducibility, Exploitability, Affected Users, Discoverability) may be a good framework to use. If it is trivial for an attacker

to find a vulnerable system and exploit it, that should be a high priority finding that is remediated quickly. All findings should be fully remediated to completely close out the recovery stage.

Security Engineering

Security engineering is an expression that may have different meanings depending on who you are in an organization. In the early 2000s, I led a security engineering team. We were responsible for developing managed security offerings. Since we were building products and solutions, we were engineering, and since they were security-related, we were considered security engineering. With more of a focus on security operations and incident response, though, many organizations have security engineering teams that are more closely related to security operations than development.

When it comes to the engineering teams usually associated with security operations, we are talking about a focus on tools. Any tool that the security operations team is going to use would fall under security engineering. This includes all the logging systems that are collecting information, as well as any alerting systems that are in use. Security engineering may be responsible for taking in threat intelligence from different sources and creating rules that generate alerts based on events of interest.

Security engineering teams may be responsible for a whole chain of tools and any rules that may be necessary for them to operate. **Figure 8-6** shows the chain of systems and processes that the security engineering teams may be responsible for. This particular diagram has examples from an AWS ecosystem, but the same would be true no matter what the cloud environment.

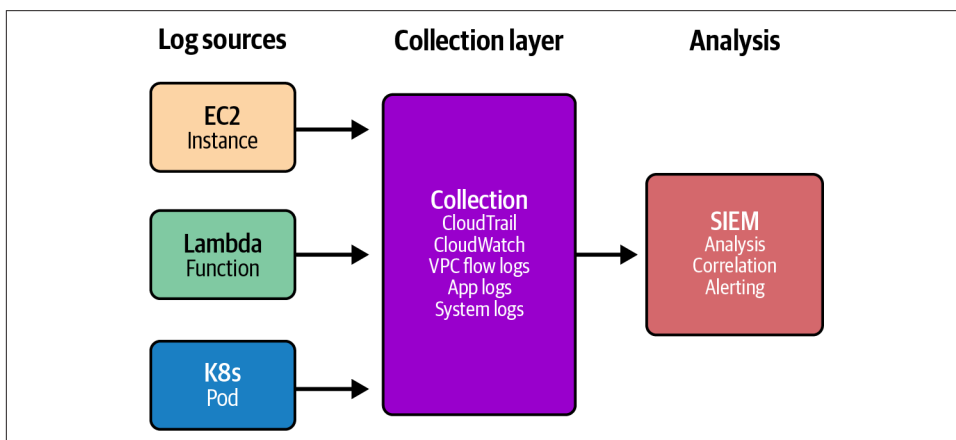


Figure 8-6. Security engineering tools

Logging

Visibility is essential to security operations. You can't detect where you can't see. Visibility starts with logging. On premises, you would be logging on each endpoint, whether it is a desktop, server, router, firewall, printer, or other device. This changes in the cloud environment, where you still have computing objects that have events. They are likely to be different computing objects and the types of logs will be different. For instance, in an on-premises environment, there are generally a lot of operating systems. These operating systems will be sources of potential compromise and also generate a lot of logs that need to be parsed.

When it comes to a cloud environment, the focus is often going to be the applications that are abstracted from the operating systems. The users and their desktops are also missing for the most part. Some organizations are moving to virtual desktop environments in cloud environments, so the desktop environment is not entirely missing from the cloud space, but logs are generally going to be coming from the application space, since the underlying network is owned by the cloud provider and is their responsibility, as are the systems the containers and virtual machines run on.

When it comes to logging, though, there are still plenty of sources of information. This includes flow logs from the networks that you do control which are related to your virtual cloud environment. Logs will also be generated by any security element, like security groups. Also, load balancers, web servers, and application servers will generate logs from the network requests that come into the environment.

Many logging formats may be used. Two very common ones are syslog, which is historically a Unix-like logging format, and Windows Event logs. These are not the only logging formats, though, and logging servers will often have listening capabilities for events that are forwarded to them, as well as collection agents that may run on devices that are expected to store logs locally.

While local logs have their benefits, they should not be relied on. An attacker who gains access to any device that stores logs locally may make an effort to corrupt those logs. Logs should always be reliable so they can be used to investigate events to determine what happened. Corrupted logs will weaken the trail of events, making it much harder, if not impossible, to determine what actually happened. This means logs should be sent remotely to a log server or other collection point. Cloud providers offer log collection services like Azure Monitor and Google Cloud Logging. These are services provided by the cloud provider to collect, store, and allow log searching.

This is not to say that you are restricted to the log collection services provided by the cloud providers. If you have a log collection service on premises, you can often forward logs to them. This allows you to have a single location for storing, correlating, and searching through logs. Having a single place to contain all of your events, no matter where they are sourced, has some benefits.

Monitoring

While logging has its place, just having logs around isn't sufficient. If you happen to be notified that you have been breached, you can use the logs to look for historical markers, but you need some near real-time detection to determine when you have an event of interest. This is where monitoring comes in. Monitoring starts with logging, as you can see in [Figure 8-7](#), which shows the different elements required to support getting an event in front of a person to look at it.

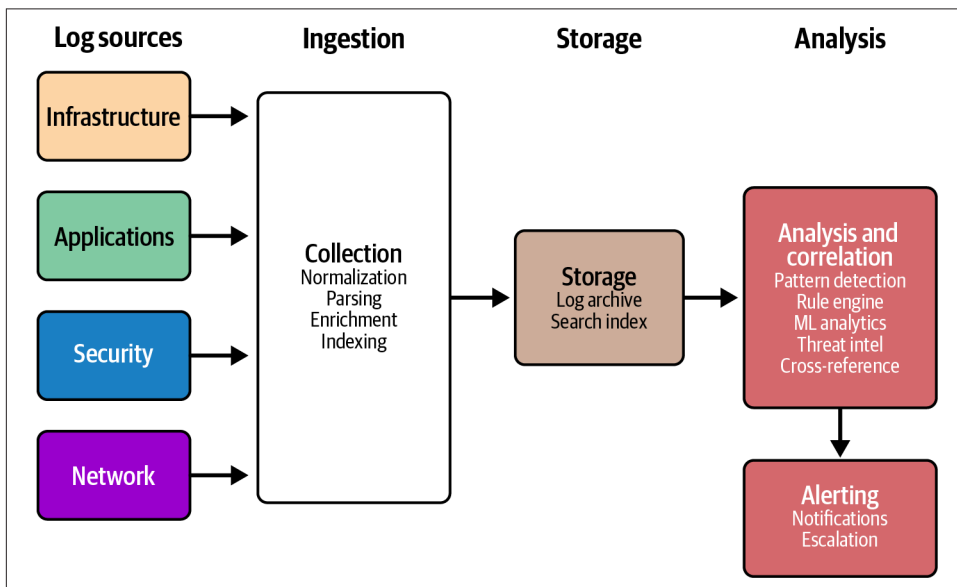


Figure 8-7. Monitoring process

The logs get generated on the endpoint where the events happen. While they may stay on that endpoint, they should also be sent to a log collector. This log collector may be responsible for normalizing them and should also be responsible for getting the logs stored somewhere. In many cases, you will find the logs are stored in some sort of searchable database rather than in flat files, which may otherwise be the case on the endpoint. This storage should provide the ability to index the logs so events of interest and associated data can easily be found.

This still only gets us to where log information can be located and searched. One of the problems with logs is they consume a lot of space, and mostly consist of information you don't care about. Robin logged in today. Again. Yes, very consistent with her behavior. You still need to log the information so you can later go look for anomalies. Anomalies aren't always easy find or know what to do with, though. Suddenly, one day, Robin doesn't log in. That's an anomaly but what exactly does it mean? It may mean she is on vacation. It could mean she is no longer employed at the company.

The same is true when we are talking about applications in the cloud. Each request to the application is an event, but the vast majority are just business as usual.

In cases where you have multiple elements in your application, such as when you have a microservice-based application, you will see the chain of events as a request hits the application and then hits every service along the way. Each one of those stops is an event because a log entry was likely generated indicating the service processed a request, but they are all related. It is helpful to have all of them in case something happened, but you want something in your monitoring chain that will correlate a lot of data that is related rather than presenting individual events that you need to chase down and manually put together.

Finally, you need a human looking at events of interest. While you could put someone in front of a monitor to watch log events scroll by, you're not going to get a lot of value out of that unless you have a really small environment without a lot of activity. Even then, it's likely the events are going to scroll off the screen faster than anyone could notice what may be happening.

This is where security engineering may play a role. Your monitoring platform should have the ability to store rules, which are used to correlate information and notice patterns that have been discovered to be troublesome. The rules should generate an alert, and rather than going crazy from staring at logs that have been scrolling by way too fast, the person staring at the monitor should be looking at alerts. These alerts would be based on what the organization has determined to be events of interest. These are what would then get triaged, assigned, and investigated.

Security Information and Event Management

The question at this point may be what kind of magical software is capable of handling all of that. Let me introduce you to something called security information and event management (SIEM). This is a system, often a collection of related software packages, that will take in log data and correlate, normalize, and store it so it can be searched, store rules, and generate alerts based on those rules. In addition, a good SIEM should also enrich the data that is being collected. Let's say you get a request in your web application. The request will come from an IP address, since that is what is transmitted through the network. Hostnames and domain names are human things. The computers speak in numbers. However, a human will need to take a look at the information and make sense of it, so a SIEM may enrich the IP address by providing a fully qualified domain name (FQDN) from a reverse DNS lookup, should one exist. The SIEM may also do a whois lookup and a geographic lookup to determine where the IP addresses exists in the world and who owns it.

Figure 8-8 shows the different actions that a SIEM would be responsible for. We start off with ingesting log information, threat intelligence, vulnerability data, and other outside information. All of the ingested data goes into the engine where it is stored

and indexed for searching. The data is also compared against rules that are stored as well to determine if the event coming in is of interest. Finally, the SIEM will generate an alert if what is happening is of concern, as defined by the stored rules. These rules may be generated by the organization but they may also be generated by a threat feed into the SIEM where specific IoCs map to known threat actors.

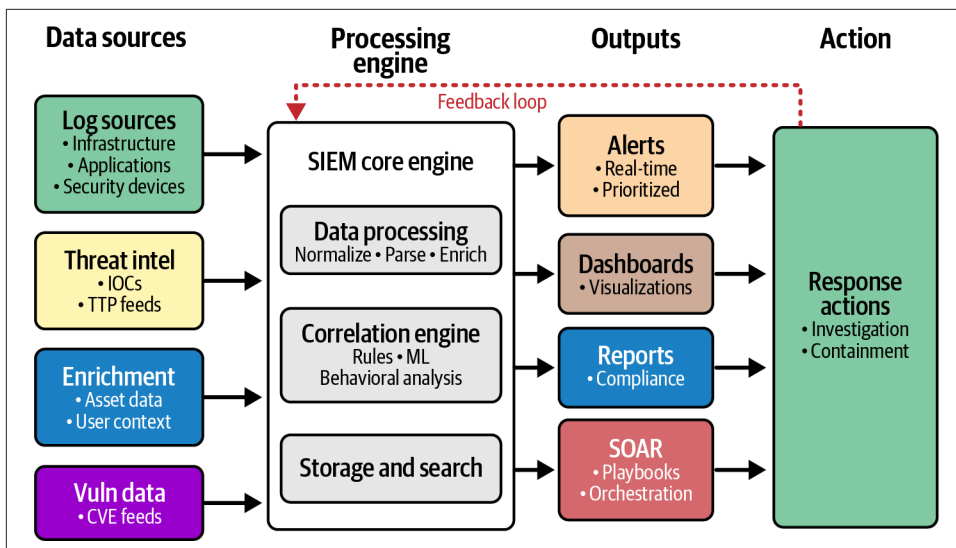


Figure 8-8. SIEM process

The SIEM isn't just an alerting engine, though. One of the challenges with alerts is that they are based on pattern matching, which can be fuzzy. This means you may end up with false positives, where the SIEM generates an alert but the analyst determines it isn't real or of concern. The analyst may flag the alert as a false positive, or may also flag the alert for follow-up by someone. The SIEM may keep track of these so it can enrich future alerts with additional data about the disposition of previous and similar alerts. The last time this alert came up, it was flagged as a false positive.

The SIEM should also generate reports based on the number of alerts generated, the speed of response, final disposition, and whatever else the business cares about. The SIEM may also generate charts and graphs on an ongoing basis in a dashboard for those not staring at alerts to look at to get a sense of how everything is operating. The reports from the SIEM can also be used as artifacts for compliance.

You can imagine this can be incredibly time-consuming for humans, and very often the tickets are routed or processed fairly easily. Many SIEMs also support automated actions. This may be done using additional software called Security Orchestration, Automation, and Response (SOAR). The SOAR software can be used to do some preliminary investigation by grabbing additional data from the endpoint. SOAR should

also be capable of responding based on a set of provided rules. These rules may be called playbooks. They are a set of automated actions SOAR should take, based on the alert. In some cases, SOAR may be able to handle an event of interest from initial alert all the way through closure.

The different cloud providers have their own SIEM solutions, which generally include SOAR capabilities. In general, you should be able to ingest data from one provider's solutions to another provider's SIEM implementation, but you will want to consider how you design your network to ensure all of your log data is protected and not just shipped over the open internet. This may require interconnections from one provider to another.

Summary

Security operations is the process of maintaining solutions in production, performing monitoring to ensure you are detecting any unauthorized access. This is easier said than done, of course. Security operations requires a lot of planning, and there are frameworks that can help here. One of the biggest frameworks is the NIST CSF, which specifies the essential functions of a security program: identify, protect, detect, respond, recover, and govern. In general, security operations will be involved in the last three, with some feedback into the first two. The CSF can be used to determine whether you have adequate coverage for people, process, and technology.

You can also align the CSF with either the Cyber Kill Chain or the attack lifecycle to help ensure you have coverage against the different phases of an attack. Using the MITRE ATT&CK framework can also be beneficial here to understand the different TTPs. These TTPs may also have IoCs associated with them since each TTP would have a signature.

The security operations process is detection, analysis, containment, eradication, and recovery. This isn't a rigid process and you may find that you are bouncing around between analysis and containment to start. Not all intrusions will necessarily follow this process.

Security engineering teams are generally responsible for managing the tools that the security operations teams require. This includes the logging platform, as well as monitoring systems to include potentially managing rules for the monitoring platforms. This includes SIEM systems, which these days are often used to collect logs, manage rules, take in threat intelligence feeds, and generate alerts and reports.

Other Resources

The pages here provide additional details about security operations, including the different ways of thinking about attacks:

- “Cybersecurity Framework,” National Institute of Standards and Technology (<https://oreil.ly/ydOl->).
- “The Cyber Kill Chain,” Lockheed Martin (<https://oreil.ly/Py36R>).
- “Targeted Attack Life Cycle,” Google Cloud (<https://oreil.ly/6EMHf>).
- “What Is Security Operations (SecOps)?” Red Canary (<https://oreil.ly/L8g84>).
- J.J. Cranford, “What Is Security Engineering?” CrowdStrike, September 10, 2024 (https://oreil.ly/z_hPU).

Cloud Security Governance and Risk Management

Topics covered in this chapter include:

- Risk management
- Compliance
- Policies, standards, and procedures
- Business continuity
- Disaster recovery

A good security program requires oversight. Ultimately, information security serves at the pleasure of the business, if you will. The objective is to help the business achieve its objectives, regardless of what they are. If the information security program is not aligned with the business, it can get completely out of sync to the point where the information security function can become an obstacle, which may slow or hamper the business in achieving its expected outcomes.

This requires information security to follow the lead of the business rather than vice versa. Without insight from the business about what the overall objectives are, how can the security team know what they are protecting or why? This means the business needs to establish the overall vision for the security function and ensure there is sufficient interaction so both parts of the equation understand what the other is doing.

Fortunately, there are frameworks available to help ensure there is alignment between the business and the security function. To begin with, the business is generally going to want to understand how its information technology assets incur risk. This is an area where there may be misalignment unless the information security function clearly follows the business and they are using the same language of risk. Using a

standardized approach to risk can help here to be certain the business and technology people are using the same language, since it is easy to get the business and information security functions speaking entirely different languages without realizing it.

Businesses also generally have regulations and other requirements they have to adhere to. This means the businesses have to demonstrate their compliance with these regulations and requirements. This may be a security function, though depending on the organization, the compliance team may fall outside of information security. However, the two functions generally have to work closely together, since the information security team has to demonstrate the controls that are in place.

When it comes to compliance, the business may have to demonstrate it is doing what it says it is doing, in addition to demonstrating it is following regulations and laws. Businesses are generally expected to have basic controls like policies and standards. These provide overall guidance to the organization about what the business expects from employees. This cascades down from policies to standards to procedures. Each gets into more detail, starting with policies being the most generic.

Another aspect of governance that is essential is business continuity and disaster recovery. While they may be conflated sometimes, and you will often see them referred to as BCDR, they are two distinct, though related, functions and serve different needs within the business.

Risk Management

“Risk” is a term that is widely misused, which makes it difficult to ensure the business and information security are on the same page, and security is providing useful information to the enterprise risk team so the potential impact to the organization can be properly evaluated. When you turn on the news while you are lying in bed, you may hear the weather person say there is a risk of thunderstorms. What they really mean is there is a chance of thunderstorms. Likelihood is only one aspect of risk. Using the word as a synonym for chance or likelihood dilutes what the word actually means, since people will start to talk about risk as though if something were even remotely possible (<10% probability), there is a risk to it.

The important part of the equation that is missing is the impact. Risk at its core is likelihood times impact, where likelihood is a probability and impact is a monetary value. **Figure 9-1** shows how we can take the thunderstorm example and apply actual risk assessment to it. When your local weather person says there is a risk of thunderstorms, what they really mean is there is a strong likelihood of a thunderstorm hitting, and since thunderstorms have the potential to cause damage, it’s something to be concerned with. However, what you really want to do is understand the risk from a monetary perspective, so you should get the impact of a lightning strike, which is where the damage from a thunderstorm is likely to come from, unless you live in an

area like I do where enormous hailstorms are also possible. **Figure 9-1** shows how to apply a basic risk calculation based on the likelihood of the thunderstorm and the impact (cost) of damage to your house.

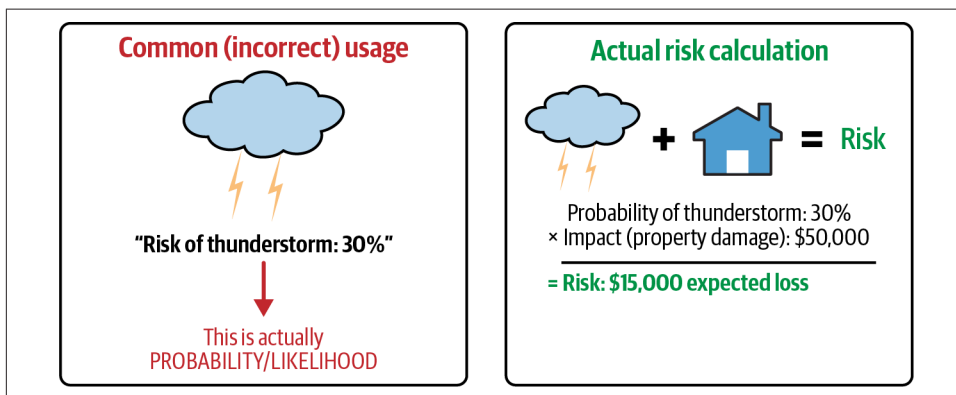


Figure 9-1. Likelihood versus risk

When it comes to information security events in particular, you can further break risk down quantitatively to get a real risk value that you can then compare against other risks. This also works well in other parts of the business, but since we are talking about information security, we can apply it here. First, you start with a potentially adverse event. You want to get a dollar value from that event from the perspective of how much it would cost the business. You start by calculating the Single Loss Expectancy (SLE), which is what you get when you multiply the Asset Value (AV) by the Exposure Factor (EF). The EF is the percentage loss if the event occurs. In the case of our house, if lightning struck, you may expect an EF of maybe 10% because it may cause damage to wiring and appliances. You could expand this, of course, and figure out another adverse event, which may be if the lightning strike caused the house to burn down. That's a different adverse event and you'd calculate it differently.

From the SLE, we move onto the Annualized Rate of Occurrence (ARO). This is how often you expect the event to occur over the course of a year. Based on the ARO, you can calculate the Annualized Loss Expectancy (ALE). The ALE is the exposure to the business from the adverse event since it is the actual cost. This doesn't guarantee these events would cost the identified amount. Probabilities are used to identify the likelihood of an event occurring. As an example, as I was writing this section, I happened to check the forecast and noticed there was no chance of rain over the next 10 days. Within half an hour of seeing that, though, a strong thunderstorm rolled in with heavy rain and hail. We calculate probability to help with preparation but shouldn't expect you have all possibilities identified or that you know exactly what will happen. Identifying the ALE is a way of identifying priorities to the business and help with determining appropriate treatments.

This is why risk is the essential intersection of likelihood and impact. If you just calculated likelihood, there are several events that are highly likely but they may not have any significant impact to the organization. On the other end of the scale are events that would have a massive impact to the business, like every facility going up in flames at the same time as a result of a coordinated arson attack. This, though, would be so unlikely as to not be worth even talking about.

Once risks have been identified with their associated values, they should be documented. This is often done using something called a risk register. A risk register is effectively a list of all identified risks and their prioritization. The risk register should also identify the treatment of the risk. Commonly, a business avoids a risk by not engaging in the activity that would incur it; reduce it by introducing controls to cut down either the likelihood or impact; transfer it by getting someone else, like insurance, to take on some of the financial impact; or accept it. Acceptance may be the result of hoping the event is not actualized, or the expectation that the business could survive whatever the impact was. [Table 9-1](#) shows a sample risk register.

Table 9-1. Sample risk register

Threat	Likelihood	Impact	ALE	Treatment	Rationale
Data breach through misconfigured S3 bucket	Medium (30%)	High (\$250,000)	\$75,000	Mitigate	Implement bucket policies, access controls, and automated configuration scanning
DDoS attack on web application	Low (10%)	Medium (\$100,000)	\$10,000	Transfer	Purchase DDoS protection service and cybersecurity insurance coverage
Sensitive data exfiltration	Low (5%)	Very high (\$500,000)	\$25,000	Mitigate	Deploy DLP, enhance monitoring, implement zero trust access controls
Ransomware attack on file servers	Medium (25%)	High (\$300,000)	\$75,000	Mitigate/transfer	Implement endpoint protection, backup strategy, and incident response plan; purchase cybersecurity insurance
Natural disaster affecting primary data center	Very low (2%)	Very high (\$1,000,000)	\$20,000	Transfer	Maintain cybersecurity insurance and geographic redundancy through cloud provider
Third-party vendor security breach exposing customer data	Medium (20%)	High (\$400,000)	\$80,000	Transfer	Require vendor security certifications and maintain cyber liability insurance
Phishing attack leading to credential compromise	High (60%)	Medium (\$50,000)	\$30,000	Mitigate	Deploy MFA, security awareness training, and email filtering
Regulatory compliance violation (GDPR)	Low (15%)	Very high (\$2,000,000)	\$300,000	Mitigate	Implement privacy controls, conduct regular audits, hire compliance officer

Threat	Likelihood	Impact	ALE	Treatment	Rationale
Legacy system vulnerability exploitation	Medium (35%)	Medium (\$150,000)	\$52,500	Accept	System scheduled for replacement in six months; temporary monitoring in place
Cloud service provider outage	Low (8%)	High (\$200,000)	\$16,000	Avoid	Implement multicloud strategy with automated failover capabilities

In the examples shown, you can see that the business may choose more than one treatment. With ransomware, for example, you are going to implement controls to protect against attackers executing a ransomware attack, while also purchasing cyber-security insurance to reduce the cost to the business in the case of a successful ransomware attack.

While the calculations may be easy enough once you have the numbers, you still need a process to identify which events to look at. This is where we are limited in our understanding of where the threats to an organization are. While some organizations create their own, perhaps ill-informed, method for identifying risk, there are multiple well-developed and implemented approaches to risk management.

NIST Risk Management

The NIST has developed a process for risk management. This is documented in Special Publication (SP) 800-37, which has undergone revisions since its initial release. The Risk Management Framework (RMF) is a seven-step process, and you may recognize some of the Cybersecurity Framework in the RMF. Before we get into describing the steps, you can see what the process would look like in [Figure 9-2](#) so you can follow along with the diagram.

The first step in the process is Prepare. The preparation step gets the overall organization ready by identifying and documenting all roles and responsibilities, ensuring they are staffed. The preparation step should also ensure that all staff are familiar with the RMF and capable of executing against it. This may include hiring the right people or training as needed to get existing staff ready to support the RMF implementation. After all, it's not common for organizations to implement something like the RMF when the business is founded. Businesses are usually well along in their existence before they recognize the need for a risk management process.

Before you can identify the potential threats to the business to assign a relevant risk rating by assessing likelihood and impact, you need to know what assets the business has. During the Categorize phase, you identify all information assets and data flows to determine areas where there are threats to those assets. The location and protection of the assets are necessary pieces of information to document, since it will help to identify potential threats and their severity. The severity of the threat should include the sensitivity or criticality of the asset. Sensitivity relates to whether the asset

is protected information, like personal information or intellectual property. Criticality is based on how essential the asset is to the operation of the business.

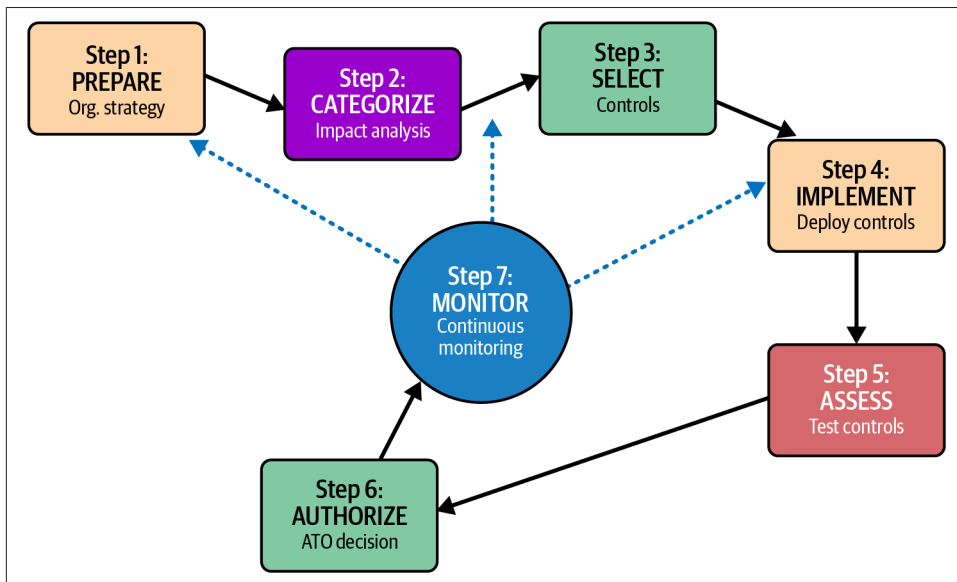


Figure 9-2. NIST RMF process

Risk assessment has to factor in any controls you may have in place. If you don't have controls, you must determine what you need to do to protect your assets. This is where the Select stage comes in. Once you have categorized your assets and identified the sensitivity and criticality, you determine how you need to protect them. Focus on not only protective controls, but also on detective controls for your most important assets to identify when those assets are being tampered with. Once the controls have been selected, you can work on the Implement stage, where you deploy the controls you have selected.

When you select the controls, you should always keep in mind what it would take to reduce the overall risk. This means you are reducing either the likelihood of the negative event or the impact of it. Of course, controls may also transfer some of the impact to another entity, as in the case of cybersecurity insurance. When you calculate the overall risk of your risk register, you should be certain that the controls you are implementing are reducing that. Ideally, you should evaluate the cost of the control to the amount of risk you are reducing. If you are spending \$1,000 on a control, for instance, but only getting \$10 in risk reduction, it doesn't make fiscal sense to use that control. This may be a case where the business needs to accept some of the risk as is.

Controls, whether they are technical or administrative, should never be assumed to be fully functional. There may be ways to bypass or deactivate them. For instance, if

you have a home security system, you have a code to disable the alarm to keep it from going off when you open the door or to keep it from going off when you enter. Given there is a code to disable the alarm, if someone could guess the code, they could disable the alarm (let's say you had it set to 0000, for instance, bypassing the security system). This also makes the assumption that the control works to begin with, or continues to work over time. The Assess phase determines whether all the implemented controls are functional. If any control is not functioning as expected, it increases the likelihood of the threat being actualized.

Any security program requires senior management to Authorize decisions that have been made. This involves management fully understanding the likelihood and impact of an event happening against business assets. Without informed consent, they are exposing the business to more impact, which means there could be significant financial consequences, which may be catastrophic to the organization.

Finally, we move to Monitor. This encompasses the complete process, because you don't do this just once. Risk management is an ongoing affair. It's not like businesses remain stagnant. Assets change constantly, and controls should be evolving with them. Additionally, threats to resources will change. The monitoring phase means you are monitoring assets, controls, and assessments of the controls. This will help the business stay on top of all the risks and their evaluations.

ISO Risk Management

You can use a combination of ISO 31000 and ISO 27005. ISO 31000 is the document for the Risk Management Framework, while ISO 27005 is part of the 27000 series related to Information Security Management Systems (ISMS), and that document in particular provides guidance on how to manage information security risks. ISO 27001 recommends a Plan-Do-Check-Act for implementation of an ISMS and all the recommended controls. The ISO risk management guidelines follow a different process from the one outlined in 27001.

You will find that the ISO risk management process has similarities to the one NIST recommends, though a slightly different emphasis is used by the ISO. **Figure 9-3** shows a diagram of the overall process, including the loops that are necessary to keep the organization's understanding of risk up-to-date.

The ISO risk management process requires leadership commitment to the process, which should include not only buy-in but also the authority to make it happen within the organization. ISO believes risk management should be integrated into everything the organization does, requiring the framework to be implemented across the entire organization. The implementation should be evaluated on an ongoing basis to ensure there is continual improvement. As noted previously, the organization and threats to it will not remain stagnant, so there should be continual evolution, including ensuring the process and all the associated controls are functioning.

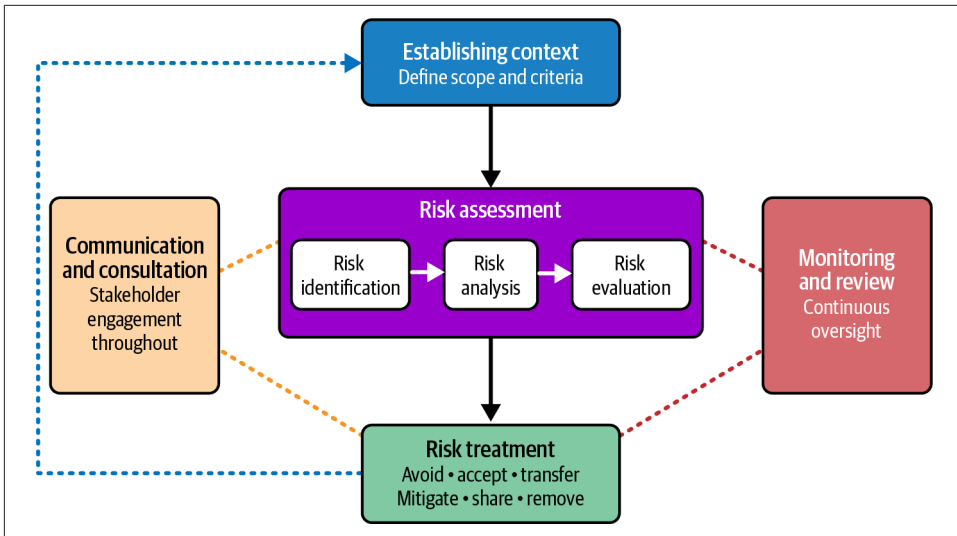


Figure 9-3. ISO risk management

When you begin the risk management process, according to ISO, you begin by establishing context. This includes understanding what risk means to the organization, and identifying and communicating the overall impact to the different teams and individuals. Leadership should set clear objectives for the risk management process. Part of the context also includes definitions for likelihood and impact, including the scales used for assessment. Even when you get a numeric value if you are using a full quantitative approach, you still need something that will tell people what it means. You might use t-shirt sizing, for example, for an impact rating, clearly identifying the monetary values that would be associated with each size (S, M, L, XL). The same is true for likelihood. This makes it easier to communicate in plain language when talking to executives, the board, and the organization as a whole. If you say there is an impact of \$100,000, for example, it doesn't have a lot of meaning without something to compare it to. There needs to be some context to weigh that amount against.

Once all the criteria have been identified, the business should identify what its risk level or appetite is. This includes the impact the business can withstand without causing an existential crisis or too much of a burden, causing a lack of confidence with stakeholders and customers. This will help when it comes to determining risk treatments for the different risks that have been identified.

The risk assessment itself includes three subprocesses. The first is identifying risks. This ends up being the biggest problem for many organizations, because they don't fully grasp what a risk is. To many technology organizations, problems they are having become risks and get listed in a risk register. Unpatched Windows systems, for example, are not risks. They may be a pathway to a potential impact to the

organization, but in themselves they are not risks. The best approach to risk identification is to start with, as NIST suggests, a complete catalog of assets. Then you start thinking about threats. You can do this with a series of questions:

- Who wants to cause harm to us? (threat identification)
- What are they trying to achieve? (motivation)
- What assets would they target? (asset identification)
- How would they attack? (attack vectors/vulnerabilities)
- What would be the impact to the business? (consequence assessment)

Using this structured approach, you could end up with complete and clear risk statements like “threat actor X uses compromised credentials to gain access to our automated manufacturing systems to encrypt them, causing a loss of productivity of \$1 million per day.” This sort of risk statement is clear and actionable. It also gives the actual impact to the business, which isn’t being guessed at because the business would know how much potential revenue is being generated by manufacturing systems. This also includes the risk analysis, because a clear threat has been identified and an impact is also called out. The only aspect missing here is the likelihood. This may require some external help since companies wouldn’t have their own data for the likelihood of a ransomware attack to be able to get quantitative values.

Based on the criteria identified before you began, you can start to evaluate risks against each other. The likelihood will be a problem since, when it comes to information security, it can be difficult to really evaluate the probability of an event. Given the number of threat groups in the world, many, if not most, organizations are under fairly constant evaluation and attack. Mitigating controls also makes it hard to effectively evaluate likelihood, but once you have your list of threats and associated risks the business is most concerned with, you can start to do the rest of the risk management work.

Each risk should have at least one risk treatment. The following are common risk treatments:

Avoidance

Not engaging in the activity that would incur the risk

Acceptance

Accepting the risk based on an informed evaluation and decision

Opportunity cost

Accepting the risk because the upside of the activity outweighs the potential cost

Mitigation

Engaging in activities that will reduce the likelihood or impact, such as introducing controls around an activity

Removal

Removing the source of the risk

Transfer/share

Choosing to share the potential impact with someone, including transferring the entire impact to another organization

There is a subtle distinction between risk avoidance and risk removal. Perhaps the clearest example is the risk that is associated with data theft and other similar threats as a result of credential compromise because of the use of passwords for authentication. As long as you are using passwords, you can't avoid the threat of password compromise, though you can mitigate it by using multifactor authentication. You can remove the risk entirely, though, by switching to passwordless authentication using certificates, biometrics, and other authentication mechanisms that don't require the use of weak and easily compromised passwords.

When it comes to sharing and transferring, there are some good examples that may help make those treatment options clearer. Cloud computing is an example of risk sharing or transferring. If you move your infrastructure to a cloud provider, you are sharing the risk because the cloud provider has to have controls in place, and if something were to happen that was a result of negligence on the part of the provider, they would have to own some of the impact. Since you will always own the data and other aspects of the assets, you will always share some of the responsibility if something happens. Cybersecurity insurance is a good example of risk transference. The insurance company promises to indemnify you in the case of a significant security incident, in exchange for your premiums.

Just as with NIST, you then move into monitoring to ensure the risks remain as you have identified them. You may find over time that some risks will drop off your list while you add others. Essential business activities that use digital assets are going to incur some level of risk, though you may be able to implement controls that mitigate the risk to a level that is not significant to the company. Or at least, senior leadership is comfortable with the level of potential risk that is left after mitigation. This level of risk after mitigations and control implementation is referred to as residual risk.

FAIR

The Factor Analysis of Information Risk (FAIR) is a taxonomy for risk, meaning it creates a clear set of definitions any organization can use to ensure everyone is using language that is understood by everyone else. This ensures different parts of a company don't decide to use competing risk management frameworks that may use dif-

ferent terms, which can then make it difficult to effectively communicate actual risk to the business leaders so they can make appropriately informed decisions. While using qualitative assessment (this feels like a moderate impact) can be easier for some people, FAIR prefers a quantitative approach. However, FAIR recognizes that quantitative analysis can be difficult for some of the reasons previously discussed. This includes the difficulty of identifying the likelihood of an event, because probability in the absence of adequate data is no better than throwing a dart at a wall of numbers.

FAIR identifies the primary risk equation to be Loss Event Frequency $\times$ Loss Magnitude. This is another way of phrasing what we have already talked about—likelihood multiplied by impact. However, FAIR also breaks this equation down to define Loss Event Frequency (LEF) as the Threat Event Frequency (how often an asset is targeted by a threat actor) multiplied by Vulnerability, which is the probability that a threat action results in loss. The Loss Magnitude (LM) broadens the idea of loss by adding Primary Loss, which is the direct losses from productivity or replacement costs, to the Secondary Loss, which is indirect losses, such as fines or loss of sales to customers.

You can keep drilling into these definitions until you have a complete taxonomy, so you have a fine-grained understanding of how FAIR views risk and how to calculate and evaluate it. In addition to the taxonomy, which is just a collection of definitions, FAIR also has a process it advocates:

Define scenario

Create specific threat/asset combinations that will be impacted.

Gather information

Collect the information needed for the assessment.

Determine the Loss Event Frequency

Calculate the Loss Event Frequency based on data that was gathered.

Determine the Loss Magnitude

Calculate primary and secondary losses to get the Loss Magnitude.

Calculate risk

Based on the LM and the LEF, calculate the risk of the scenario.

Present the results

Use the results that have been calculated, presenting them to stakeholders and making appropriate decisions.

FAIR focuses on quantitative assessments, using numbers rather than categories, which would be used with qualitative assessments. As noted previously, this can be really difficult when it comes to assessing the likelihood of a threat being actualized. For this reason, FAIR recommends the use of Monte Carlo simulations to determine probabilities. A Monte Carlo simulation uses repeated random sampling to model the uncertainty that is common in risk associated with information technology. You

would run a Monte Carlo simulation thousands of times to get a range of likely values that would help assess where the likelihood should be. This gives better outcomes than just making up point values to have a numeric value to plug in.

FAIR uses decomposition into subtasks that can help organizations more easily come to terms with the enormous task that risk management can feel like. It also forces specificity so everyone knows what everyone else is talking about. Likelihood is more specifically quantified than just a probability, because you can see what goes into it. You can also see what the impact comes from, and FAIR also is very clear about both direct and indirect losses, since both will be relevant.

Compliance

Regulations. It makes me think of the movie *Fletch*: “It’s all about the ball bearings nowadays.” The reality of the modern world is there are a lot of regulations in place to protect consumers, businesses, governments, and anyone else who might interact with you or your business. Including, and perhaps especially, shareholders. There are a lot of regulations that businesses have to comply with. Additionally, many businesses want to be able to demonstrate they have competence in information security, so there are frameworks that businesses can achieve compliance in. This allows them to get a certification, which is a little gold star they can pin up to show everyone they know how to InfoSec.

Compliance is a tricky topic, though, because just being compliant with a regulation or a framework does not guarantee you are protected against anything. A good example is the Payment Card Industry (PCI) Data Security Standard (DSS), which businesses that handle payment cards are expected to comply with and demonstrate their compliance. However, a large number of businesses have been breached, with millions of credit card numbers and associated payment card holder information stolen. You’d be hard-pressed to find one of these breaches where the target business wasn’t also PCI-compliant.

This is not at all to say that you should ignore compliance, since your business could be fined heavily for not submitting the right proofs that you are doing the right things. When it comes to compliance, big companies can keep dozens of people busy with compliance work. Some of the regulations, like some of the financial regulations, have actual expectations and negative impacts associated with them. Others are more driven by opting into something that may have some business benefit.

When it comes to compliance, you may need to generate artifacts, which are proofs that you have implemented a set of controls that are specified by the regulatory agency or overseeing body. You may have to demonstrate the efficacy of controls or demonstrate that your documentation matches your actual practices. This will vary based on the regulatory body responsible. This is an area best practiced with legal

counsel, since you may be working with laws that have repercussions. Additionally, there may be contracts in place or other agreements that could be impacted based on what you are expected to comply with. All in all, it's best to work with legal counsel.

NIST and ISO

While we have previously discussed NIST and ISO in other contexts, people will often say things like they are NIST-compliant or they follow NIST. It is worth clarifying this. Some people use the NIST CSF as a framework for how they structure their information security program. Used in conjunction with other guidance, it can be a good way to ensure you have a robust security program. You can't go through an accreditation, though, to prove that you are NIST CSF certified. The same is true with NIST 800-53, which is a controls framework. There are over 1,000 controls across 20 control families that align with the 5 essential functions outlined in NIST CSF. Again, NIST 800-53 is a great guide document, though it is not required anywhere that you implement all 1,000 controls. You can, though, ask your cloud service providers whether they adhere to NIST 800-53 to get a sense of what security controls they have in place.

Where NIST and ISO differ is that ISO publishes standards that can become auditable and can lead to accreditation. This can be an onerous task for organizations, but in some cases it is either essential or so valuable it is worth the impact and costs. [Figure 9-4](#) shows a high-level overview of the certification process for ISO.

Getting certified against any of the ISO standards, but specifically for 27001, which is the one most applicable to security organizations, requires clearly documenting the scope. ISO 27001 relates to Information Security Management Systems (ISMS), but that doesn't mean you can't scope your assessment even more tightly. You can scope it to strictly the customer relationship management systems in your Bangladesh office if that's what you want to do. As long as the scope is documented and clearly understood, it is acceptable to scope the assessment to a subset of the organization. In practice, large organizations may want to tightly scope the overall effort because of the amount of documentation and work that could go into looking across the entire business and all the different teams and groups. This is especially true for global businesses. Wrangling the entire business for this effort may simply be too much.

Once the scope has been identified, the organization gathers all of its documentation. This should include policies, standards, and procedures. Additionally, the organization should provide a Statement of Applicability (SOA). The SOA indicates which of the controls outlined in ISO 27001 Annex A the business is implementing. In many cases, some of the controls simply won't be applicable. The SOA should indicate which of the 93 controls from ISO 27001:2022 (down from 114 in ISO 27001:2013) across 4 themes (organizational, people, physical, technological) are applicable to the scope of the assessment.

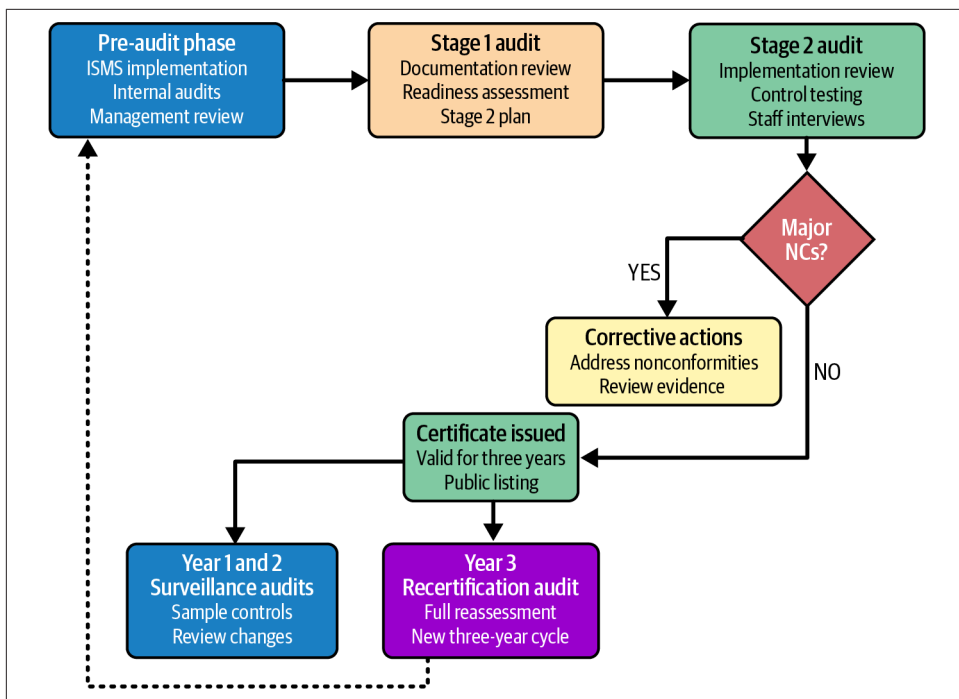


Figure 9-4. ISO certification process overview

Once all the documentation has been collected and provided, an auditor will review it to understand the scope and identify any gaps based on what they have seen. They will also review the risk management practices in use. Major gaps are identified here before moving on to the next stage, which is the on-site assessment. The on-site assessment involves interviews with staff; review of evidence, which includes logs, meeting minutes, and records; as well as testing controls. The testing will be determined by the type of control. If the control states that the organization classifies information based on legal requirements, value, criticality, and sensitivity, testing will involve ensuring there is a policy that outlines the different classification levels. The testing will also validate that documents are actually classified using the policy.

Once the audit has been completed, the auditor will determine whether there are any major nonconformities. In addition, minor nonconformities may be noted. The decision whether to award the certification is based on the nonconformities found. If no major nonconformities are found, the business will generally be awarded the certification. This certification is valid for three years before a recertification is due.

One of the challenges with ISO certification, if you understand it, is that it doesn't guarantee a perfectly clean bill of health. What it says is that your organization generally has controls in place, they are what you have said they are, and they generally

work as expected. It doesn't indicate that these controls are in place across an entire organization, just in the part of the business that the assessment was scoped to. It also doesn't say the controls are 100% reliable or that they are guaranteed to protect the business.

Cloud Security Alliance Cloud Control Matrix

The Cloud Security Alliance (CSA) nonprofit organization started in 2008. It has the mission of promoting best practices with regard to cloud computing. It has over 150,000 members around the world and has developed a Cloud Control Matrix (CCM) that is focused specifically on cloud security. Where other frameworks are general-purpose and can apply easily to cloud implementations, the CCM is focused on issues that are especially relevant to cloud implementations. The framework contains controls across 16 control domains:

- Application and Interface Security (AIS)
- Audit Assurance and Compliance (AAC)
- Business Continuity Management and Operational Resilience (BCR)
- Change Control and Configuration Management (CCC)
- Data Security and Privacy Lifecycle Management (DSP)
- Datacenter Security (DCS)
- Encryption and Key Management (EKM)
- Governance and Risk Management (GRM)
- Human Resources (HRS)
- Identity and Access Management (IAM)
- Infrastructure and Virtualization Security (IVS)
- Logging and Monitoring (LOG)
- Mobile Security (MOS)
- Security Incident Management (SEF)
- Supply Chain Management (SCM)
- Threat and Vulnerability Management (TVM)

One of the biggest differences between cloud and enterprise is multitenancy. While a large chunk of issues applies to enterprise and cloud environments since you need to have policies, procedures, identity and access management practices, and all the other things essential to an information security program, multitenancy is a complication because your cloud providers need to ensure they do not allow any access across customers. If you are providing cloud services yourself in the form of a software service

or any other offering, you need to be certain you have controls in place to protect mingling of data across tenants, even if more than one tenant is owned and managed by the same company. There is likely a reason they are kept separate so one tenant shouldn't have access to another unless explicitly allowed.

The other difference between regular enterprise security and cloud computing is the Shared Responsibility Model. While you may have service providers for an on-premises, standard enterprise deployment, it is probably still ultimately your responsibility all the way up the stack from the physical location, to the network, to the systems, all the way to the data and users.

Just as with ISO, you can pursue certification in the CSA's Security, Trust, Assurance, and Risk (STAR) program. This program has multiple levels. The first is a self-assessment using the CAIQ (Consensus Assessment Initiative Questionnaire). The next level is undergoing an audit by a third party for either a certification or an attestation. Both levels have multiple options and features, depending on what you are looking for.

Financial Requirements

There are requirements for compliance when it comes to finance. The Sarbanes-Oxley Act (SOX) is relevant for all public companies and their IT controls. When it comes to SOX, the major requirements relate to limiting the impact on shareholders and any other financial stakeholders. This means risk management is in play, as well as the entire information security function and especially incident management since any major incident is a reportable event under SOX. The Federal Financial Institutions Examination Council (FFIEC) also has regulations it expects banks to adhere to, so that may be in scope for you. The Gramm-Leach-Bliley Act (GLBA) is also relevant to financial institutions, even above and beyond banks. Of course, the PCI DSS was mentioned earlier.

System and Organization Controls 2

One worth mentioning in more detail, though, is System and Organization Controls (SOC) 2. SOC 2 is an auditing standard developed by the American Institute of Certified Public Accountants (AICPA). As you may have gotten from the name, service organizations have to comply with SOC 2. This includes cloud providers, including any business that offers software as a service, which is a lot of them today, since many companies have pivoted from offering native software to web-based delivery. Additionally, any managed service provider would have to comply with SOC 2.

The purpose of SOC 2 is to have a standardized way for service providers, no matter what kind of service they provide, to demonstrate their security posture and operational controls. Getting SOC 2 certification demonstrates to customers that you have a security program and operational controls in place. This is more comprehensive

than the ISO, since it covers a broader range of controls than just the ISMS that the ISO is focused on. Additionally, you get to say you are SOC 2 certified, which you can't say with NIST.

There are two types of SOC 2, Type I and Type II. Type I is where you do a point in time assessment that effectively focuses on the effectiveness of the design of your security program. A SOC 2 Type I audit validates that the controls have been properly designed to meet documented criteria. It also determines whether the controls exist on paper and in policies, rather than just concepts. The audit also determines whether the controls would be effective if implemented properly.

A Type II audit, however, goes beyond design and looks at operational effectiveness. This requires looking beyond the point in time when the audit takes place. The organization is evaluated against how it operates over a span of several months. Unlike the Type I evaluation, not only does the Type II look at a longer span of time, but you are also expected to provide evidence of the effectiveness of your controls. This evidence could be in the form of logs, monitoring reports, incident records, training records, and more, depending on what the control is.

A Type I audit takes 1–3 months to complete and tells customers you say you have controls. These controls are documented but they have not been evaluated. A SOC 2 Type II audit takes the 6–12 months of operating with those controls as well as the time it takes for auditors to come in and evaluate the controls you indicated you have. This would add at least the 1–3 months of a Type I audit. However, what you get at the end is something that tells customers your controls are not only in place and documented, but they work over time. Requiring a SOC 2 Type II certification is very common for service providers like Azure, AWS, GCP, and any software as a service provider.

Cloud Support for Compliance

Compliance can be onerous for companies because it not only takes time to establish and document the controls, which would be necessary for a solid information security program no matter what, but also a lot of time to create artifacts to prove the implementation of controls and their effectiveness. This is something a mature security program would be doing during the monitoring phase of their security program lifecycle, though many organizations are not that mature and may not be monitoring their program for control effectiveness. Where you step outside the normal day-to-day operational duties is in managing the audit. The time and resources it can take should not be underestimated.

Full-featured service providers like Microsoft, Google, and Amazon have tools available in their platforms to support compliance efforts. AWS has Config, Security Hub, Systems Manager Compliance, and Audit Manager, which will help organizations determine their compliance requirements, as well as give them visibility into how well

their AWS implementation is complying with organizational requirements. As an example, [Figure 9-5](#) shows how you can create rules to determine whether operating systems are within compliance for an expected patching policy. This helps implement and monitor a vulnerability management program, an essential aspect of a solid information security program.

Approval rules for operating systems

Create auto-approval rules to specify that certain types of operating system patches are approved automatically.

Operating system rule 1

✕ Remove rule

Products

Select patches by product

Select products

All ✕

Classification

Select patches by classification

Select classifications

Severity

Select patches by severity

Select severities

Auto-approval

Specify how to select updates for automatic approval

☒ Approve patches after a specified number of days

☐ Approve patches released up to a specific date

Specify the number of days

0 days

Compliance reporting - optional

Specify the severity level to report for patches that match this rule.

Unspecified

Add rule

9 remaining

Figure 9-5. AWS patching policy

Microsoft Azure, which may be more enterprise focused than the other common cloud providers given its extensive history with on-premises infrastructure, starts with Azure Policy, which allows you to define a set of controls, then applies those controls to what has been implemented within Azure. Microsoft also has a Security Center and templates for the normal regulatory requirements that organizations would have to comply with, including NIST, SOC, PCI DSS, and many others. Having clear definitions of the policies and controls, then getting them applied to different cloud components, will help to quickly create the artifacts necessary for audits. This can end up saving considerable time rounding up logs and other artifacts. [Figure 9-6](#) shows one of the policies that comes predefined in Azure.

[Home](#) > [Policy | Definitions](#) >

Audit virtual machines without disaster recovery configured ...

Policy definition

 Assign policy
  Edit definition
  Duplicate definition
  Select version (preview)
  Delete definition

^ Essentials

Name	: Audit virtual machines without disaster recovery configured
Version (preview)	: 1.0.0
Description	: Audit virtual machines which do not have disaster recovery configured. To learn more about di...
Available Effects	: AuditIfNotExists
Category	: Compute

Figure 9-6. Predefined Azure policy

GCP also has security and compliance features as AWS and Azure do. You may be required to pay for higher tiers of service to gain access to some of these services. Since these are commonly enterprise activities, you may need to subscribe to a higher tier of Microsoft 365, for instance, to gain the complete range of capabilities for your entire estate, though you can also use a pay-as-you-go tier if all you have is a web-based application in Azure or one of the others. It will all depend on what overall services you have implemented in the different cloud services.

Policies, Standards, and Procedures

Any information security program should begin with a clear definition. You can't have governance without rules, after all. The best place to start is with a mission statement so you are clearly defining what you are trying to accomplish as an organization. This provides the vision for what you are looking to achieve within the information security function. The business, though (meaning leaders who are responsible for the performance of the organization as a whole), also needs to provide guidance to not only the security function, but also the entire company. This is usually done through policies.

Policies should not be where the guidance ends, though. Implementation details should be provided in standards. Once you have standards, each standard should have a process or procedure associated with it. The further we cascade down, the more detailed and specific each document should get.

Policies

A security policy should have some essential characteristics. It should have authority, meaning it should have the support of executive leadership, which carries the weight of mandates to the staff. A good security policy should also be specific. It should have guidance that isn't vague or doesn't mean anything and can be measured. Policies should also cover people, process, and technology. Policies are also living documents. They should be reviewed periodically on a schedule defined by the policy. This is necessary because the business is likely evolving, so policies should evolve along with the business. If policies don't need to change with the business, the policy may not be specific to how the business operates.

Each policy should have some essential elements. This includes the identification, which should have a name and effective date of the policy, as well as the date of the last review. The purpose and scope include the reason the policy exists and what it expects to achieve, along with who and what the policy applies to. The purpose and scope also include the security goals the policy addresses. After the purpose and scope, there should be a definitions section that defines key terms that readers may not be familiar with. These definitions should take into consideration that most readers aren't going to be familiar with common information security terminology, so having more definitions can be helpful.

Policy statements should have specific, mandatory actions using language like *shall* and *will*. *Shall* is a mandatory requirement. *Will* refers to an intention, something the organization expects to do. A policy statement may also include prohibitions like *must not* or *shall not*. Not all policy statements are going to be requirements. In cases where they are optional, you would use *should* or *may*. Again, *should* refers to actions, while *may* refers to intents. A policy statement may also refer to specific technical requirements, though implementation details are best saved for standards, which are more specific.

Compliance requirements in a policy provide guidance on how to measure and monitor the policy to ensure the organization is following the requirements in the policy. If there are violations to the policy, sanctions should be defined in the policy. Often this suggests disciplinary actions to staff, up to and including termination. Violations should be reported, and the policy should define escalation paths and when and how to report. Finally, the policy should have document control, which includes when the document was reviewed and updated, and who it was approved by.

Given all that, a policy would normally include the following sections:

1. Policy header/identification
2. Purpose and scope
3. Definitions

4. Policy statements
5. Compliance and enforcement
6. Document control

Some of the regulations and frameworks that organizations would be expected to comply with normally look for the following policies:

Information Security Policy

Establishes the security program, its scope and authority

Acceptable Use Policy (AUP)

Specifies the appropriate use of information technology resources within the organization

Data Classification Policy

Documents the different data categories, and handling requirements

Risk Management Policy

Defines the approach to risk within the information security program

Identity and Access Management Policy

This may be broken up into multiple policies, but there should be guidance on passwords and their management, access control, privileged access management, and the use of multifactor authentication

Network Security Policy

Specifies how firewalls are implemented and managed, the use of segmentation, and any monitoring requirements

Mobile Device Management Policy

Defines the requirements for the use of mobile devices within the organization

Cloud Security Policy

Defines how the use of the cloud is controlled and managed

Training Policy

Defines the requirements for security awareness training, and any other specific training based on roles

Remote Access Policy

Defines the controls that are required to allow workers to access information technology from remote locations, like home or hotels

There may be several other policies used by organizations, depending on their industry. When writing policies, no matter the industry, it's essential for them to be specific and measurable. The policy statements should actually say something, rather than making vague references or not including any policy statements at all. Having a policy

just to have a policy does nothing to ensure the organization is protected, nor will it help the organization achieve compliance with relevant frameworks and regulations.

Standards and Procedures

Once you have a policy, you should have an associated standard. Each standard should provide implementation guidance on how to achieve the policy statements. Any policy statement may have multiple requirements that allow the organization to achieve the goals of that policy statement. Each standard then has multiple procedures that relate to how to implement and manage the standard requirement. You can see how the policies, standards, and procedures relate to one another, using an access control policy, in [Figure 9-7](#). This shows multiple policy statements that create multiple standards, which then have procedures associated with them.

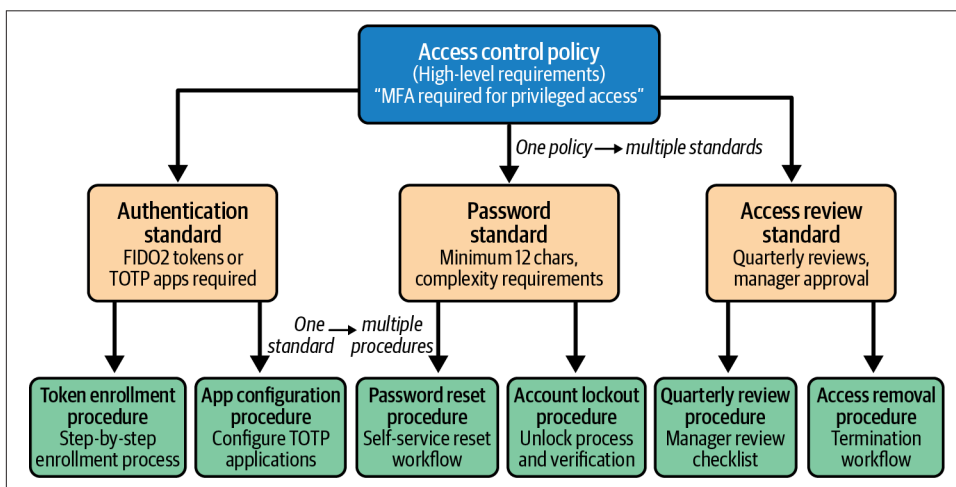


Figure 9-7. Policies, standards, and procedures

A standard uses the same sort of language that a policy uses, except that each standard statement refers to implementation details. Implementation details may refer to specific technology. Where you wouldn't normally indicate technology or implementation in policies because the idea is you want a policy to apply across the organization, you can provide that level of detail within a standard.

Procedures are the specifics for how to implement, monitor, and manage the people, process, and technology indicated as required in the standards. There should be a tight relationship among policies, standards, and procedures. The standards should include adequate detail to ensure the organization will be in compliance with the policy. If you have written a standard that doesn't map to a policy statement, consider why that is and maybe either remove the standard or add a policy statement.

Business Continuity and Disaster Recovery

Business continuity and disaster recovery are closely related but they have different goals. The goal of business continuity is to keep the business operational in the face of difficulties, like those you might find in a security incident. Business continuity should be owned by the groups that are responsible for the different business functions and applications. Business continuity would not be owned, generally, by the information technology teams since this is about process and not technology. You can see some of the essential characteristics of business continuity in [Figure 9-8](#). In many cases, a business continuity plan should include nontechnology options to ensure critical business functions remain operational.

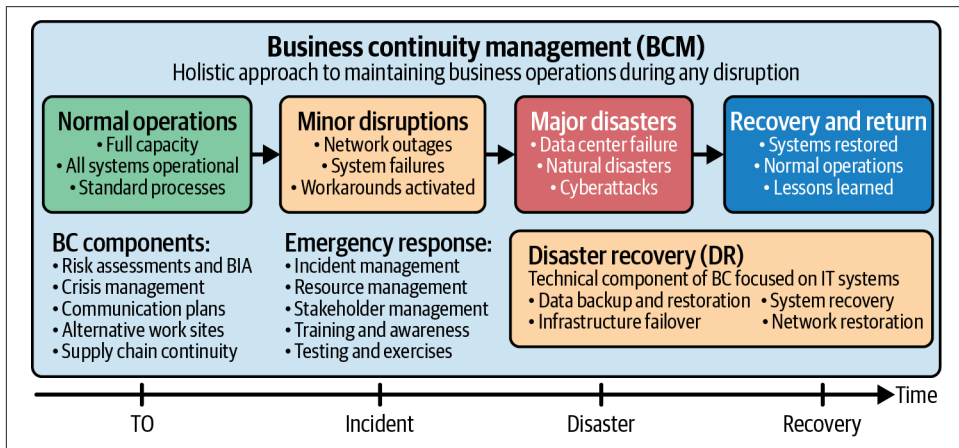


Figure 9-8. Business continuity/disaster recovery

Think of business continuity as the strategic framework that is necessary to keep the business functions working, no matter what happens. You start by identifying all the business functions and processes that keep the organization able to serve critical stakeholders, like customers. From there, you perform a business impact analysis (BIA). This is used to identify the following characteristics related to that function or process:

- Purpose
- Dependencies
- Impact
- Resources
- Criticality

Once you have identified all the different functions and processes, you can start to identify the different priorities. Any organization has only so many resources, so in the face of significant impact to the organization, the focus should be on the functions that are essential to support customers and generate revenue, including collecting that revenue.

For each BIA, you also need to identify the maximum tolerable outage (MTO), which is the amount of time the function can be unavailable before it poses an existential threat to the company. You also identify the recovery time objective (RTO), which is the amount of time following an outage before you expect to get the function operational again. This would be less than or equal to the MTO. You also need to determine the recovery point objective (RPO), which is the amount of data loss, measured in time, you could sustain before it poses an existential threat to the business. “Existential threat” means it causes such a significant impact that the business may not recover from the loss. These data points should help guide the creation of the business continuity plans and processes.

Disaster recovery is a subset of business continuity. Business continuity is about making sure the business can stay operational during an outage, but disaster recovery is about restoring all functions to their pre-outage capabilities, including recovering any lost data. This also means you have restored any offline data that was collected during the outage.

Business continuity and disaster recovery can be tightly connected to cloud services, because many enterprises may use cloud services to both protect against outages and provide a way to quickly spin up new instances of essential applications to keep the business operational.

Summary

Governance is essential for maintaining business control over information technology resources, and information security is about protecting those resources from impact. Impact is a critical element of risk, which is often misunderstood. Risk should include both likelihood and impact, since it should be calculated as the dollar value loss that could be incurred by an adverse event.

Multiple frameworks can be used to help guide the implementation of risk management within an organization. NIST and ISO both have risk management frameworks that define risk in similar ways, though how they recommend managing risk is different. Ultimately, both provide some useful guidance to help clearly identify and prioritize threats and the associated risks. FAIR is a taxonomy that goes deep into the definition of risk. Based on that definition, FAIR also has a recommended risk management process.

Compliance is an essential business function. A business should not only know how to measure compliance against its own policies and standards, but also how to ensure it is complying with any regulations or industry guidance. Additionally, businesses may choose to obtain certifications based on security frameworks like ISO 27001. These will typically involve providing documentation related to their policies and standards, as well as proof of the existence of their controls. SOC 2 Type II will also expect demonstration that the implemented controls are effective.

Policies are statements of intent and expectation made by the business, ideally with executive leadership sponsorship. Standards are statements intended to provide guidance as to how to ensure the policies have been implemented. Procedures are how to implement and manage the controls mandated by the standards.

Business continuity is about how to ensure the business remains operational, supporting stakeholders, like customers. Disaster recovery is a subset of business continuity, meant to provide guidance on how to get the business fully operational again after a significant outage.

Other Resources

The following pages include more details about risk frameworks, like FAIR, NIST, and ISO. Additionally, there are more details about other governance documentation requirements:

- Sean Atkinson, “FAIR: A Framework for Revolutionizing Your Risk Analysis,” Center for Internet Security (<https://oreil.ly/wmpGM>).
- “NIST Risk Management Framework,” Computer Security Resource Center, National Institute of Standards and Technology, updated August 27, 2025 (<https://oreil.ly/8ZJNY>).
- “The Basics of ISO 31000—Risk Management,” Riskconnect (<https://oreil.ly/U3043>).
- Chad Spoden, “Security Policies, Standards, Procedures, and Guidelines,” FRSecure, August 22, 2017 (<https://oreil.ly/ih4ll>).
- Mesh Flinders and Ian Smalley, “What Is Business Continuity Disaster Recovery (BCDR)?” IBM Think (https://oreil.ly/_DxYq).

Legal and Regulatory Considerations

Topics covered in this chapter include:

- Data privacy regulations
- Service Level Agreements (SLAs)
- Vendor management
- Legal compliance
- Digital investigations

In the last chapter, we discussed compliance. This is where we need to make sure the business is in compliance with regulations and frameworks to demonstrate that it has a functional security program. Compliance may be legal or regulatory, but that doesn't mean that all legal and regulatory issues are related to compliance. There are many laws that apply to businesses and other organizations, including privacy considerations, for a start. The more the world moves to networks being online, the more information is stored with businesses. This includes all manner of personal data, as well as business data. Many regions and countries are introducing their own data privacy laws. This brings up significant jurisdictional issues, which need to be factored into business decisions and information security controls.

Contractual issues also need to be factored in. This relates not only to the contracts you have with your cloud service providers, but also to any contracts you have with your customers. Security clauses are becoming more essential, especially with more guidance, frameworks, and regulations related to how information security programs are managed. This creates an interesting intersection between lawyers and security practitioners, where they need to work together. Security professionals aren't going to be writing contracts, and lawyers shouldn't be expected to understand information security and security controls.

Just as your customers will have contracts with you, you will have contracts with your vendors. Not all vendors are created equal. They have their own security programs, their own business drivers against those security programs, and they also don't have the same controls in place as you do. But since they are potentially holding information on your behalf, they would need to have at least equivalent controls as you do, because you will need to ensure everything you provide to your vendors is protected to the same level as you are protecting it. This means a solid vendor management program.

While it's not strictly legal in nature, necessarily, digital investigations are at least legal adjacent. After all, the word forensics, often applied to these investigations, comes from the Latin word "forensis," meaning of or before the forum. So, forensics means suitable for a court of law. Digital investigations is a better term, since most investigations won't have anything to do with the police, much less a court. However, that doesn't mean that even if a court case occurs, legal counsel won't be involved. In fact, given that customer data may be involved, not to mention the intellectual property of businesses and many other issues, your corporate lawyers are going to be essential to protect the business.

Data Privacy Regulations

Data privacy has become a significant challenge as companies have shifted to engaging with customers digitally. Companies are storing and processing more and more information, and often that processing is not being done in-house on company-owned systems or employee-managed software from the top to the bottom of the stack. At the same time, criminal organizations see opportunities to take advantage of all of this for material gain or even leverage. This is why many regions have found it necessary to enact legislation to protect individuals who otherwise would have no rights once they provide details to a company. Some of the most significant legislation, and one of the first, is the General Data Protection Regulation (GDPR). Another is the California Consumer Protection Act (CCPA). China and Brazil also have their own regulations related to data privacy. Each of these will come with different jurisdictional considerations.

General Data Protection Regulation

In 2016, the European Union (EU) Parliament and Council on the European Union adopted the GDPR, effective in 2018. GDPR is based on six principles in Article 5. The first principle is that data must be processed in a lawful, fair, and transparent manner. GDPR also requires that data be minimized and its purpose be limited. Overall, GDPR intends to identify clearly who owns information, who is responsible for it, and what constitutes lawful purposes for its use. The EU is trying to better protect consumers by requiring they be aware of the extent of data collection and usage, as well as what is being stored. The GDPR also provides consumers the ability to review information that is being stored and the right to have that data deleted.

The GDPR defines roles related to data collection and usage. You can see the different roles and their relationships in **Figure 10-1**. The first role is the data subject. This is commonly a consumer, though not exclusively. A data subject is any entity whose information is being collected, processed, or stored. This information may be name, address, contact information, and other sensitive information like identification numbers. Data subjects have rights, including access, portability, and deletion. A data controller is often the company that the consumer interacts with. The data controller determines the purposes for collecting the information, as well as how that information will be processed. For our purposes, this may be a cloud consumer.

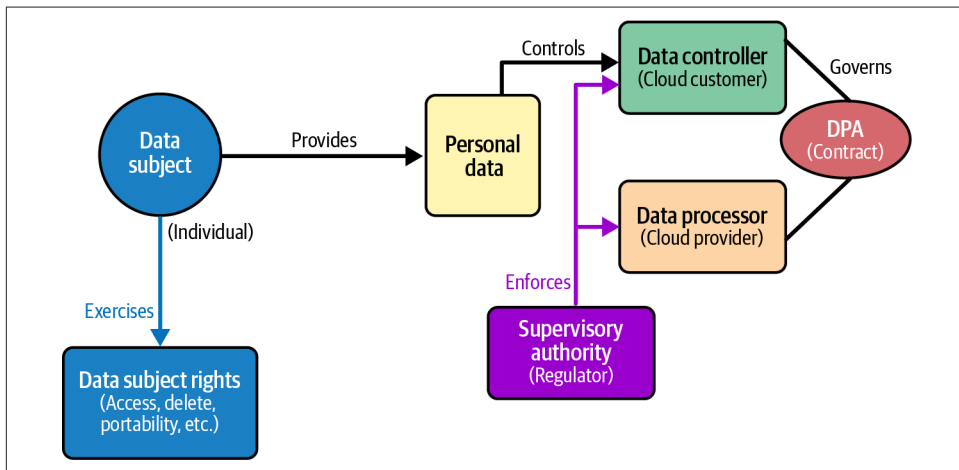


Figure 10-1. GDPR roles and relationships

The data processor is the organization responsible for processing the information. Again, for our purposes, this could be the cloud provider. It owns the infrastructure and services that perform the processing, even if it is the data controller that determines which services and capabilities within the cloud provider are used and how

they are used. The data processing agreement (DPA) governs the relationship between the controller and the processor, indicating who is responsible for what.

Beyond those directly involved, there are also Supervisory Authorities (SAs), which are governing bodies. They are regional, which may mean they are responsible for a particular country, and are responsible for compliance with the regulation. Additionally, in the case of a suspected data breach, the target of the breach must notify the SA as soon as possible. The SA has responsibility for both processors and controllers.

GDPR also requires a Data Protection Officer (DPO), but it isn't always clear in what contexts a DPO is required. Being required and being used in practice are two different things. Many organizations have named DPOs even if they are not necessarily required to have one. A DPO is required for public authorities, except for courts. It is also required when core activities involve regular and systematic monitoring of data subjects on a large scale. This is where it may get gray, since "large scale" isn't clearly defined. If activities involve large-scale processing of special categories of information, like health or biometrics, a DPO is also required.

Cloud providers generally need to have a DPO because they normally process large amounts of information belonging to a data subject. Cloud customers may not have to have a DPO, depending on what they are doing with the data. Small businesses that make use of cloud services may not require a DPO, since what they do isn't large scale. This can reduce the amount of overhead required by GDPR for smaller businesses. This does not mean a DPO isn't a good idea, even if the DPO has other duties, but is available in case of a data breach. The DPO should be responsible for GDPR compliance, training, conducting privacy assessments, and other similar responsibilities.

Because so much business has become global, jurisdiction is a consideration. When it comes to the GDPR, there are clear areas where it is applicable. If data processing occurs in the EU, regardless of where the data subject is located, GDPR applies. If United States or Canadian citizens, for example, are doing business with a company in the EU, that company has to comply with the GDPR even though the data subjects themselves are not EU citizens. This is considered territorial scope. Extraterritorial scope applies in cases where the processing occurs outside the EU, but goods or services are being offered to EU residents. If EU citizens are being monitored, the GDPR applies as well. This means if a GCP customer selects us-east-1 for their services region and the services are being provided to EU residents, Google would have to comply with GDPR.

There can be significant penalties for data breaches or not complying with the GDPR. Additionally, the more laws there are relating to privacy, the more complicated it gets for businesses.

California Consumer Privacy Act

In 2018, California enacted the California Consumer Privacy Act (CCPA), which recognizes that data is not only processed and may be exposed inadvertently, but that data itself is a commodity and is often sold from one business or organization to another. This is a different focus from GDPR, and because it is within a single state, there is no need for supervisory authorities and coordination between countries like there is with GDPR. Instead, the California Attorney General (AG) is the primary enforcer of the law, a single entity responsible for enforcement, rather than multiple SAs as with GDPR.

The CCPA is focused primarily on the commercial aspect of data, since data can be a revenue source for organizations that collect it from their customers and others who may have had some interaction with them. As such, CCPA is about business transactions and sales of information. Unlike with GDPR, consumers in California can opt out of having their information sold, in addition to the rights assigned by GDPR.

Figure 10-2 shows the different entities and how they are related in California.

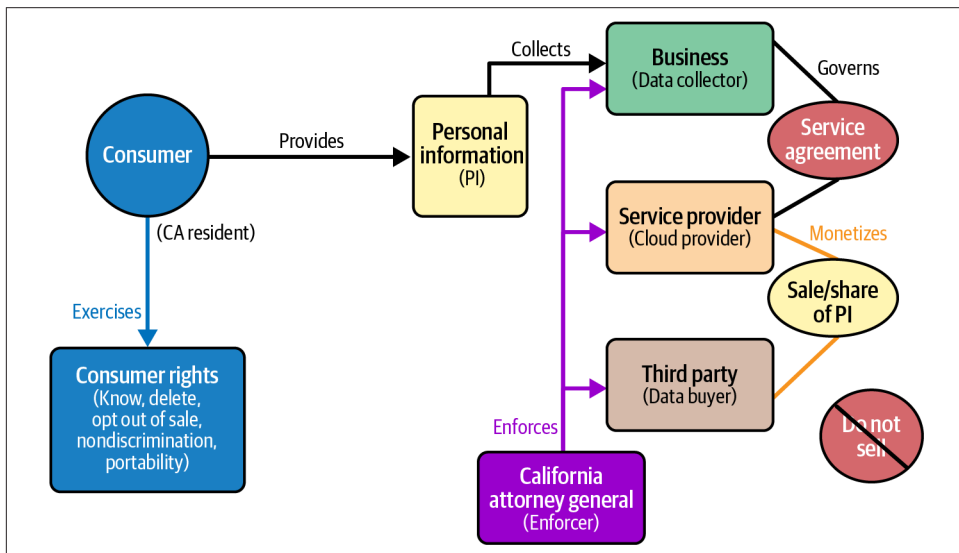


Figure 10-2. CCPA entities and relationships

According to the CCPA, there is the consumer, whose information is primarily the focus of the CCPA. Consumers have a set of rights with respect to the personal information that has been collected. Additionally, there is the business that is doing the collecting of the personal information. For our purposes, there is also a service provider, since we are concerned with cloud computing and cloud service providers. Finally, there is the third party, which would be a data buyer. The AG interacts with

three business entities to ensure the law has been enforced, and of course also takes complaints from the consumer.

The CCPA sets out a set of rights consumers have. These are:

Right to know

The right to know what data is being collected and why

Right to delete

The right to have their data deleted by the business

Right to opt out

The right to opt out of having their information sold

Right to nondiscrimination

The right to not be discriminated against or penalized for exercising their privacy rights

Right to portability

The right to receive personal information in a portable format

Not all businesses in California fall under the CCPA, though. The law specifies that a business has to meet one of the following conditions:

- Annual gross revenue of \$25 million
- Buy or sell personal information of 50,000 or more consumers annually
- Derive 50% of revenue from selling personal information

A service provider is limited to using personal information for specific business purposes only. Each violation of the CCPA will cost the business \$2,500, according to the law, while deliberate violations are \$7,500. When determining which law may be applicable, it comes down to where the data subject resides. For someone living in California, CCPA applies, even if the data processor may reside in Ireland or Germany. The location of the controller and processor may be applicable for penalties and legal proceedings, though, in the case where the processor and controller are located within the EU.

Other Privacy Laws (New York, China, etc.)

Other countries and states have their own privacy laws and regulations. New York state, for instance, has the New York SHIELD (Stop Hacks and Improve Electronic Data Security) Act. The intent of this legislation is to require businesses of any size to implement reasonable security controls. The act applies to all residents of New York. In addition to requiring reasonable security controls, the SHIELD law also requires that businesses notify those impacted when a data breach occurs. As of mid-2025, there are other laws in process in New York but none of them have been enacted.

Brazil has its own privacy law that applies to residents of Brazil, Lei Geral de Proteção de Dados (LGPD), which is similar to GDPR. If you have cloud deployments in South America, this law would possibly apply to you. Canada has the Personal Information Protection and Electronic Documents Act (PIPEDA), which is a federal law that applies to Canadian citizens and is relevant to Canadian businesses as well as United States businesses that have Canadian customers.

In China, the Personal Information Protection Law (PIPL) applies to Chinese citizens and is relevant to any business that provides products or services in China. A business that analyzes or assesses behavior of individuals in China, and in some other circumstances, also falls under PIPL. China uses a broad definition of personal information (PI). Any information related to identified or identifiable individuals would be considered PI. Sensitive personal information includes biometrics, religion, health, financial accounts, and location tracking, for a start. The law also defines a data controller similarly to GDPR. The PIPL aims to require businesses to store data in China if they are considered a critical information infrastructure operator. Large-scale processors must also localize data storage in China.

Any data capture and storage requires explicit consent. Additionally, sensitive PI requires an additional consent. The consent must be specific, clear, and informed. If an individual chooses to withdraw consent, the process for withdrawal must be as easy as giving consent to begin with. The law also provides for the same rights as we have covered previously. This includes the right to know and access, the right to correction and deletion, the right to restrict processing, the right to data portability, and the right to explanation for automated decisions.

China has tight restrictions on cross-border transfers. There has to be an application made to the Cyberspace Administration of China (CAC) with detailed documentation. When the CAC receives the application, it performs a security assessment by reviewing the documentation, any technical or organizational measures, the necessity, and impact. It can take months to get the review processed. The approval must be renewed every 2–3 years.

With regard to cloud computing providers, data residency requirements are strict. Many companies will require China-based cloud infrastructure. Vendor assessments have to include PIPL compliance verification. PIPL mandates breach notifications to authorities and individuals. Because of the localization requirements, any multi-national deployment becomes complex.

Fines are significant, which may be up to 5% of annual revenue. Businesses may be suspended in cases of serious violations, and individuals can be held personally liable for responsible individuals.

These are not the only privacy laws that are relevant, but they are some of the most significant ones. It's also worth mentioning the Health Insurance Portability and

Accountability Act (HIPAA). This is meant to ensure losing a job doesn't impact access to health insurance, as well as the prevention of declining coverage for pre-existing conditions. Most importantly, for our purposes, HIPAA is meant to protect health care data, known as protected health information (PHI). This would include medical records, billing information, or any other information that could help to identify an individual. Health care businesses are required to comply with HIPAA.

Contracts and Service Level Agreements

Businesses maintain contracts with customers, which also means they have contracts with their own vendors. The contracts include requirements for the arrangements between the business and its customers. This should include definitions of goods and services provided, as well as any details about what a breach of the contract would look like and what remedies may be due in that case. Security clauses have become important in most contracts. The following are security-related considerations that are commonly included in modern contracts:

Data protection and privacy

The arrangement between a provider and a customer may include data classification and handling requirements. A contract may also specify where data can be stored and processed, which would be relevant to some highly regulated businesses. There may also be prohibitions on data access or use outlined in the contract. Privacy compliance should be spelled out in the contract. This should include any laws or regulations that the business arrangement will be bound by. This includes GDPR, CCPA, HIPAA, or other privacy laws. Any data processing agreements (DPAs) should be specified as well.

Security controls and standards

This includes the expectation that organizations will comply with security frameworks like ISO 27001 or SOC 2 Type II. These requirements, and ensuring compliance with others like the PCI DSS, help ensure at least a known set of controls have been implemented. Contracts should also include expectations around data management, such as how data is protected at rest and in transit. You should ensure appropriate access controls like multifactor authentication are in use. If there is a control you care about, including patch management, make sure to specify in the contract that your vendor must have a similar control.

Incident response and breach notification

Not all jurisdictions have breach notification laws in place so you need to ensure the contract you have with your vendor provides guidance on what constitutes an incident or breach and how quickly you are notified. Additionally, the contract must specify in the case of an incident on your side that your cloud provider must provide access and details if something has happened within the elements you have control over.

Audit and monitoring

The contract must specify you have a right to audit, especially if that is a requirement you have due to your own regulatory considerations. This may include on-site in some cases, but should certainly allow for documentation review. It should also include the expectation that any relevant audit reports or certifications like those for SOC, for instance, should be provided to you in a timely manner. The contracts should also include requirements for monitoring and logging, which may need to be provided to you for services you are consuming. This might include access to a dashboard that provides access to essential information and performance metrics.

Vendor management

This should include any expectations for managing the vendor, like performance reviews, as well as expectations for personnel, like background checks and required security and awareness training. This should also include confidentiality and nondisclosure requirements.

Liability and risk allocation

Clauses related to these topics would include vendor liability to cap the amount the vendor would owe the customer. There may also be requirements for insurance coverage and exclusions for some types of damage. There may be vendor indemnification for security failures as well as specifications for how to handle regulatory violations. The contract may also specify protection for intellectual property.

Data lifecycle management

This may not always apply since data is often under the control of the customer, but in cases like some types of SaaS solutions and certain storage solutions, the vendor should be responsible for backing up data in case of failure on the vendor side. If customers require deleted data to be fully destroyed because of their data retention requirements, the vendor has to ensure they can comply with those requirements. This should also include expectations for how the vendor destroys not only data but also media that contained customer information.

Termination and transition

When the contract terminates, customers may want to move their services to another provider. This should be possible, which means all information stored by the customer, including not only data but also account/credential information, should be available to move to the new provider. Contracts should ensure there is no vendor lock-in, and data and service can always be migrated to another provider. Migrating to another vendor may be a challenging process, so the vendor should be required to support all transitions to other vendors, including ensuring service is not lost until the customer is ready.

While these are high-level subjects that should be considered for contract inclusion, it is important that legal counsel be retained to draft or review all contracts. This will help protect the business by making sure the contracts have the right language that is necessary based on business and regulatory requirements.

Contracts should also specify any Service Level Agreements (SLAs). SLAs are expectations for performance. This may be expectations for availability of the service. It may also be the availability of support and how quickly support tickets get picked up. Vendors may commonly have their expected availability metrics, like their services are expected to be up and useable by customers. The contract should specify any penalties or refunds provided to the customer by the vendor in case they don't meet their obligations.

Vendor Management

Vendor management is a practice that businesses should already have in place, but it can be a difficult topic since there is a lot involved with vendor management. In fact, it is a lifecycle that begins with due diligence and continues until the vendor is off-boarded, meaning the business is no longer a customer of the vendor. **Figure 10-3** shows the complete lifecycle. Based on this diagram, you can see how much can be involved. All of these actions may be difficult for a smaller company to maintain, especially if there are multiple vendors in place, since each vendor will need to be managed in the same way.

Due diligence should be about ensuring the vendor selected will be able to live up to the expectations of the customer. This includes identifying essential criteria and verifying that the company being selected has the necessary security controls and compliance requirements in place. This also includes verifying the financial validity of the vendor. Essentially, you are ensuring that all the elements discussed earlier about contracting can be in place. This brings us to contracting: once you have verified that that company is likely able to perform, you move to the contracting stage. This includes ensuring that all the clauses discussed are in the contract.

When vendors are onboarded, they are entered into the database or record used to keep track of all vendors. This also includes getting an initial security baseline. It is common for businesses to have a security questionnaire. This includes questions about the security program and controls in place at the vendor. If there is a contractual requirement, it should be in the security questionnaire. The questionnaire is used to verify performance against the contract and potentially against SLAs. Onboarding may also include security testing and verification of expected controls.

After onboarding is ongoing management. This includes periodic assessments and additional security questionnaires. These would likely be sent annually. The point of this activity is not just to collect paper. The answers should be evaluated against

contractual requirements and SLAs. If there is a degradation of performance, meaning any deviation from expectations in the answers, the vendor management team works with the vendor to ensure they are getting their program back on track and in alignment with expectations.

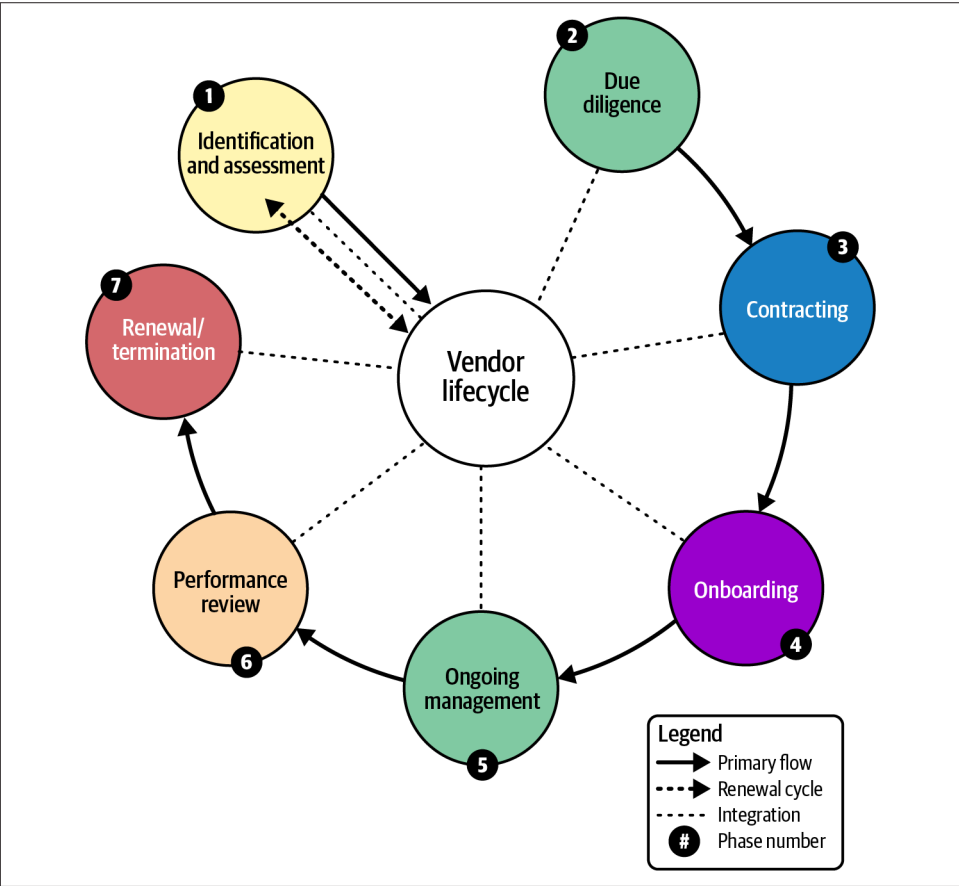


Figure 10-3. Vendor management lifecycle

Ongoing maintenance also includes security testing to validate the documentation. Additionally, vendor management monitors compliance and performance against SLAs. If the contract specifies penalties for non-performance, vendor management works with the vendor to ensure remedies are enforced.

Of course, it's not all about penalties and enforcement. Vendor management is also about managing relationships. During the course of any contract, there are minor issues that arise. Be able to track these issues and ensure they are resolved. This includes issues on both sides. Vendor management is not only about managing the

vendor but also about managing the relationship so both sides are getting what they need to ensure a productive working relationship.

Regular performance reviews are necessary and part of the ongoing maintenance of the relationship. This includes evaluating the performance against the SLAs. As with other contractual concerns, expected performance is documented and tracked. Performance reviews also include evaluation of the security questionnaire to compare it against expected answers. While the performance reviews primarily match the expectation against the reality, which could be done by the customer, the results of the performance review are discussed with the vendor as well, regardless of the outcome, as part of the ongoing relationship management.

At some point the contract will come to an end. This may result in either renewal or termination. Vendor management should be involved in discussing the renewal to be able to discuss performance against the existing contract to achieve favorable terms and ensure continued performance against the new contract. Renewal also includes any potential new considerations from a security perspective, which may result in the compliance landscape changing.

Of course, termination is also possible when the contract ends. When the contract comes to an end, the company data needs to be retrieved. Data destruction needs to be considered as part of the contract. This is managed between the company and the vendor to get the data retrieved and then destroyed from vendor resources.

Vendor management should also be involved in the case of a security incident. They should work with the vendor to understand the impact and be a liaison between the vendor and the company. This may mean working with the security team and legal, as well as other teams within the organization as necessary to ensure the least impact and the right level of communication with other essential stakeholders.

In many cases, businesses will use multiple cloud providers. A strong vendor management program can help ensure there is parity among the different cloud providers with the same or similar security controls in place across all of them. This includes protecting against vendor lock-in, where the vendor makes it very difficult to move from one vendor to another.

Legal Compliance Best Practices

There are several practices that will help keep the security practice out of trouble, including keeping the organization within legal and regulatory compliance. The first is ensuring you have good governance practices, like policies, procedures, and standards that are informed by the laws and industry practices your organization is required to comply with. In addition, a solid organizational structure can help. Legal and compliance teams should be well-integrated with the information security team. This doesn't mean that they should all be one big happy family, but that there is

alignment across the different teams. Security and compliance are entirely different activities with different goals, but they are associated with one another. While grass-roots alignment is certainly possible, it is far more beneficial to begin at the top and ensure there is executive sponsorship and alignment on the goals of the compliance team. While the security team is generally tasked with protecting the organization overall, compliance failures can be costly as well.

Documentation is essential for legal and compliance efforts in general, though it should be controlled. This is why legal engagement with the security function is essential, since some documentation can end up being problematic. There is a concept of discovery, which means if there is a legal action, opposition can expect to request documents that have been created and stored. Legal counsel should help with explaining what documentation is necessary to keep and what isn't. Legal can also help with protecting some kinds of information and communication using attorney-client privilege. This protects communications between a client and their attorney. This can't be used in all cases, but it can be critical during some situations, like when there has been a significant incident.

Legal can and should help when it comes to proper risk assessment. Remember that risk is ultimately a business concept since it should cover loss, which is often measured in monetary terms. Some circumstances will incur expenses outside of just the loss of value or reduced potential for generating income. This includes compliance misses since some of them can incur fines. Legal should be able to help identify where there may be fines and other costs that are incurred, and those costs should be factored into the potential loss for a more complete understanding of the impact to the business. When it comes to cloud deployments, since the cloud implementations may cross jurisdictional borders, legal should help with understanding the potential impact to the business in case there are breaches or other incidents that could create a material harm to the business.

Training and awareness are essential activities across the organization, but legal should help to inform what is essential from a legal and regulatory perspective. It is often a requirement for compliance. Not only that, but if you are a vendor, your customers are likely to want to know what your practices are with regard to training and awareness. One common area for training that is overlooked is role-based training. The same goes for the traditional security awareness training that most organizations require staff to take each year. Because some roles will be targeted more commonly than others, people in those roles should get different security and awareness training. Phishing and other attacks are likely to look different, and they may also be targets of other more sophisticated attacks because of the access they most likely have. Your legal team can help with the requirements for role-based training, but all security training should be targeted to the needs of the individual roles.

Management should be informed about compliance status, since it can have an impact on business decisions. Reports and dashboards can be valuable here for a quick understanding of the current status, especially if there are activities that are in process for either validating compliance or bringing parts of the organization back into compliance. Additionally, the business should maintain a strong relationship with regulatory agencies. This should be done either by the legal staff or at least in conjunction with the legal staff to help understand the ramifications of any regulatory changes, including reporting requirements, substantive control changes, or other changes that may have implications for how the business works on compliance.

Cloud services provide a Shared Responsibility Model, so legal should be aware of data storage and application usage. Specific precautions may be taken in the case of cloud storage. This includes logs and monitoring activities because sensitive information may be captured there, which means all logging platforms should be treated as sensitive.

Digital Investigations in the Cloud

Using cloud providers does not change the possibility of being compromised by an attacker, which means you need to be prepared to conduct digital investigations in the cloud. Using cloud providers can actually make the process of an investigation more complicated than a traditional investigation. **Figure 10-4** shows the basic process with some additional features. This is what we will use as a starting point to talk about how cloud investigations differ from a traditional on-prem investigation. Before we get started, though, the purpose of this process is to identify all the resources the attacker touched and, ultimately, how they got in and moved around. The purpose is to make sure you have removed them completely and then shored up your practices so it doesn't happen again. At least it won't happen again the same way it did this time.

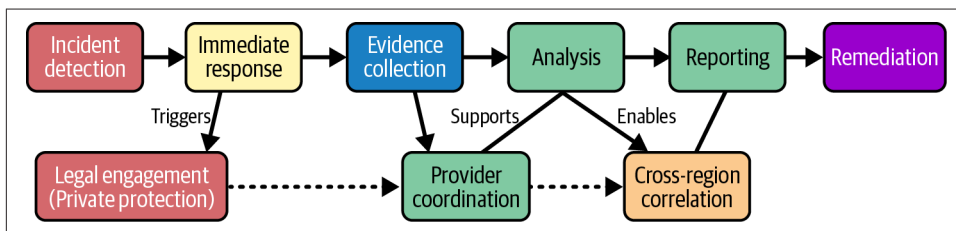


Figure 10-4. Digital investigation in the cloud process

We start with the detection of an event. This assumes you have appropriate logging, monitoring, and logic in place to support the detection. Even if the detection is just that law enforcement calls to let you know you've been breached, we can start with an event. This should start the investigation process, initially to do triage to determine

whether it progresses from an event into an incident. Assume that it is an incident, meaning something bad has happened, and action needs to be taken to stop the bad thing from continuing to happen and to remove the actor who started everything. One of the first actions to take in the case of an incident is to notify management and legal. They can help coordinate the necessary actions and provide essential protection, as needed. This may be invoking external relationships like cyberinsurance providers, breach coaches, incident response providers, and others.

Part of the initial response may be a containment. This means restricting the ability for any actor to gain access or move across systems, containers, applications. Once the investigation is under way and any immediate containment has happened, evidence needs to be collected. This means getting legal involved to help protect information and communication. Legal can also provide guidance on whether evidence needs to be protected. This may involve maintaining a chain of custody document for essential evidence. This practice is usually used for court cases, which wouldn't be very common here, but maintaining evidence integrity can be essential to being able to guarantee you can return to the collected information for further analysis.

With cloud deployments, especially for large organizations, you may have multiple providers and be implemented across multiple regions within each cloud provider. This requires coordination. You may need assistance from the cloud provider, depending on the circumstances. They may have information you don't have access to. This would be very rare, but not impossible, so engaging with the cloud provider can be essential.

In a traditional investigation, you can collect memory dumps and disk images. In a cloud deployment, neither of these are common, since you don't have control over the physical system. You are more likely to rely on logs and any events or alerts sent to the monitoring systems. The logs may be within the environment itself, meaning inside the virtual machine or container, but they may also be from your identity and access management provider or network logs and traces. All of this information should be analyzed and correlated. As always, collected information may lead to investigating other systems or sources of information. Lather. Rinse. Repeat. Investigations are never linear but involve a lot of cycles as you find new pieces of information that lead to more sources of data that lead to more and so on.

As with a traditional investigation, at some point, you will get to the end once you have found everything that has happened. Once you have your root cause and all the ways the attacker got access to the different components, you need to develop a plan for remediating any vulnerabilities, including resetting accounts. One significant advantage to cloud deployments is they are often based on some version of Infrastructure as Code. Rebuilding is actually easier since you aren't fully reimaging systems. Instead, with some changes to the infrastructure code if necessary, you can have

the entire environment back up with fixes, likely in a far shorter time than would happen on-site.

This does not mean, though, that everything is easy in a cloud environment. You don't have full control of everything, so you are restricted to the information you can get access to. You may need to pull service-specific logs that may not be fed into your normal monitoring platform. With virtualized environments, some evidence may simply be gone because of the ephemeral nature of those environments.

Getting playbooks in place ahead of time to ensure you have all the logs you are going to need will be beneficial. This should include collecting and storing as much as you can as it happens, rather than expecting that you will be able to go back to get it. If you are deployed in a fully orchestrated container environment, you won't have memory dumps to work from, nor will you have disk images. You will need to be able to rely on logs that are collected and stored.

Summary

While compliance is not security, it is an essential practice most organizations have to live with. These days, it is often about privacy. GDPR is a common privacy law organizations have to deal with. GDPR relates to entities in the European Union. The supervision of GDPR falls across supervisory authorities in the different countries of the EU. GDPR is not the only privacy law of note, though. California has a privacy law as well. In California, the privacy law is more about protecting against personal information being sold without any knowledge or consent on the part of the data subject. China has its own privacy laws that are about constraining where information can be stored. Many other jurisdictions have their own privacy laws.

Vendor management is an important practice. Vendors should have similar security controls, which usually means contracts should require the kinds of security provisions in place between the vendor and customer. Contracts should also specify appropriate levels of audit access, and notification if something happens at the vendor, especially if customer data is impacted.

Interaction between legal and the IT security team is important. This can help ensure there is alignment on business goals and objectives, since each team will have an impact on what the other does. Also, legal can help keep the security team protected and also the business when the security team has to perform investigations.

Digital investigations are largely the same, though you don't have the same level of control as you would on premises. This may require coordination with the cloud provider to gain access to information you may not otherwise have access to as a customer. Cloud environments, with so much focus on Infrastructure as Code and virtualization, can make evidence collection difficult. This means collecting logs and other telemetry ahead of time, and storing it somewhere protected is essential.

Other Resources

The following pages provide additional information about privacy regulations and requirements:

- Ben Welford, “What Is GDPR, the EU’s New Data Protection Law?” GDPR.EU (<https://oreil.ly/MWBOP>).
- Maria Korolov, “California Consumer Privacy Act (CCPA): What You Need to Know to Be Compliant,” CSO, July 7, 2020 (<https://oreil.ly/4W65Z>).
- “Mastering Vendor Management for Business Success,” J.P. Morgan, April 7, 2025 (<https://oreil.ly/r5dBS>).
- Annas Wasim Malik et al. “Cloud Digital Forensics: Beyond Tools, Techniques, and Challenges,” Sensors 24, no. 2 (2024):433 (<https://oreil.ly/sYpCr>).

Cloud Security Emerging Trends

Topics covered in this chapter include:

- Cloud native security
- Emerging identity and access management
- Zero trust architecture
- AI/ML in cloud security

Migrating compute and storage services to cloud providers, effectively outsourcing them, triggered significant changes in the way applications are developed and offered. This was, in part, because of the focus of resources by cloud providers that needed to ensure there would be services to offer their customers. This meant resources developing services that wouldn't normally be available because most organizations are focused on their own businesses. The same ends up being true for security offerings. Cloud providers must have services to provide their customers, and since application delivery can be different in the cloud than on premises, the way those applications and the data are protected can be different.

While fundamentals remain the same—following the NIST Cybersecurity Framework to ensure you have the right capabilities in place, for instance, and ensuring you have adequate visibility—how you protect and get that visibility may be different. The fact that cloud native services may be ephemeral requires some additional planning to ensure essential information isn't lost. Security controls for cloud native implementations can be different from on premises, and they are continuing to evolve as more services are offered.

Other changes in protection are based on how our understanding of modern attacks evolves, and on the changes in technology. One of these sets of changes relates to identity and access management, since attackers very commonly go after individuals

and their credentials. Vulnerabilities become harder to exploit, while the human path remains nearly as vulnerable as it has always been. Moving away from the traditional username and password that can easily be compromised is one way security is changing. While this isn't constrained to cloud environments, many cloud providers are enabling these types of authentication practices.

The same is more or less true when it comes to application and network design and architecture. Some of this is made considerably easier as a result of everything being done in software in cloud environments. Zero trust architecture is a term you will hear a lot today, and the deployment of a model like that is assisted by everything being done in software, which means you don't have a lot of extra hardware to acquire and configure. It is all done with configuration settings, and you aren't responsible for ensuring routers and switches are configured correctly to keep network segments isolated.

Artificial intelligence and machine learning (ML) have been of interest for computer scientists perhaps as long as we have had the idea of digital computers. Certainly since the 1950s, when the term AI was introduced at a conference at Dartmouth in 1956, followed by the development of Lisp as a programming language to support AI development by John McCarthy at MIT. Both MIT and Stanford were leaders in AI research from the 1950s. Computing devices have gotten much faster, especially with the development of special graphical processing units (GPUs) that are designed to perform complex mathematics, necessary for many graphical applications like high performing computer games. These GPUs have made the development of different styles of AI possible. These new styles of AI and ML have changed the landscape. This includes security practices: protection, detection, and how attacks happen.

All of these are evolving security practices within the cloud provider space. Again, when a company has the incentive to develop services to sell to customers, you will find resources available to push technology capabilities. Cloud providers have those resources and are not constrained by hardware like on-premises vendors might be. From the perspective of the customer, everything in the cloud is software and configurations.

Cloud Native Security

Keep in mind that cloud native deployment moves toward more abstraction and away from the traditional monolithic design running either on physical systems or inside virtual systems. One reason is this approach can reduce complexity and attack surface, minimizing the potential for attackers to gain access. Providing protection to these implementations can be more complex because of the distributed nature of cloud native applications. Essentially, there are more components that need to be protected in different ways. Before getting into the different controls that should be considered, let's take a look at a simple, basic cloud native application design using

containers and microservices, as well as a message queue to more easily pass information from one element in the application to another. **Figure 11-1** shows the different components we will be talking about to ensure we've fully covered security controls for cloud native applications.

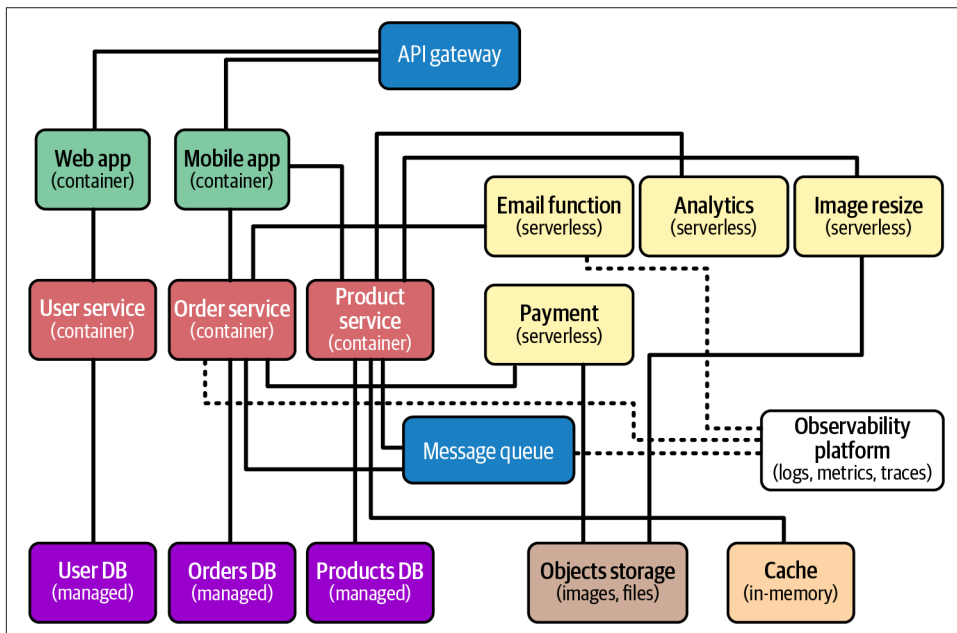


Figure 11-1. Cloud native design

First, we can start at what underpins most of the components. Each is generally managed using Infrastructure as Code (IaC). In cases like containers, the IaC will load images. Scanning and evaluating the IaC code for vulnerabilities and configuration issues should be part of the deployment process to help protect against issues in production. The same is true for the image for the container. Container images need a certain amount of runtime support, so there would be binaries beyond whatever has been developed for your application. While your code may be clean, the binaries required to support your application may have vulnerabilities. It doesn't matter if this is .NET, Python, Java, Ruby on Rails, or some other application platform. Larger projects will tend to develop bugs and vulnerabilities. Scanning the container foundations, whether it's a runtime platform or a minimal instance of an operating system like Linux, is a good strategy to identify any potential issues that could impact your application deployment. Scanning for dependencies and vulnerabilities they may introduce is also essential.

Runtime protection is another important control to get in place. This should include the use of seccomp, SELinux, or AppArmor if you are using Linux. Beyond that,

monitoring processes and their behaviors will help identify anomalies. File integrity monitoring can be challenging to manage, but it can help identify cases where tampering has occurred. All of these strategies should be done within the container itself if possible, but definitely within the container host. Network traffic monitoring is also beneficial to identify anomalies that can indicate potential attacks.

Kubernetes is a common platform used to manage containers. This includes its deployment, versioning, and auto-scaling for a start. Administrative-level access to Kubernetes provides an attacker the means to replace images, make changes to network controls, or take several other disruptive or destructive actions. This means you need strong role-based access controls using the principle of least privilege so each person with credentials only has the level of access they require to fulfill their job role. Kubernetes is a complex platform because of all the capabilities it offers. **Figure 11-2** shows you the different layers of security that may be required to protect a Kubernetes implementation.

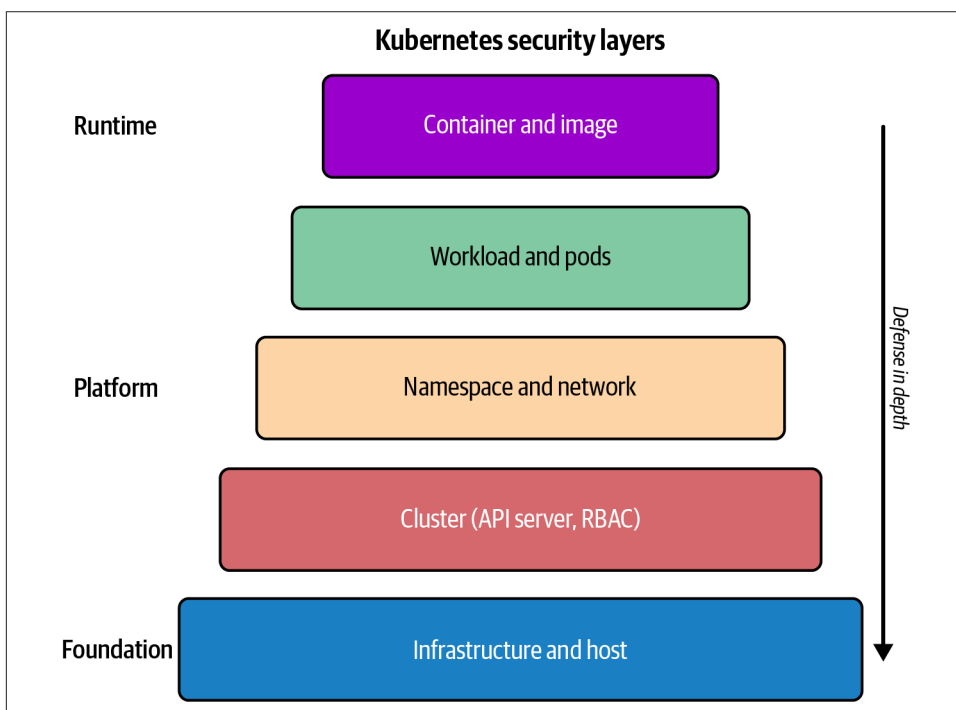


Figure 11-2. Kubernetes security

Using namespaces is another level of protection that can be implemented with Kubernetes. Using namespaces contains elements that are related to one another, keeping unrelated elements away. This is logical isolation that can keep development away from staging and away from production, for instance. This is also a way to manage

multitenancy by keeping customers separated from one another while using the same physical infrastructure. Namespaces also contain your access control and network controls so they apply to all the elements within the namespace.

In Kubernetes, a pod is an organizational unit containing one or more containers. Containers in a pod share the same namespace and may share storage or other resources. Workloads are a higher level of abstraction from pods and are ways of organizing related pods together. A workload may have six pods all running instances of a web application you have developed. A pod and a workload share the same security context, meaning the trust boundaries and requirements would be the same for all the elements within the workload.

There are other controls that can be implemented within a cloud native application, including those deployed within Kubernetes. One is the use of an API gateway. This is another abstraction layer. The API gateway takes requests and routes them based on the endpoint being requested. Each request may be sent to a different pod or workload to be processed. This way, you are protecting the actual application elements. The API gateway can control the level of input by using access controls, like authentication or rate-limiting, so the underlying application components don't have to implement all of those features.

Of course, all the infrastructure within a cloud application, including a Kubernetes deployment, needs to be protected. While your application may run inside containers or even serverless functions, underneath all that is actual computing hardware and general-purpose operating systems like Windows and Linux. These need to be protected the same way they always have been: with patch management, identity and access management, physical protections, backups, monitoring, incident response, and all the usual hygiene requirements that are necessary for all computing deployments, but perhaps especially for server deployments.

Modern/Emerging Identity and Access Management

Passwords have long been the bane of existence for security professionals, and managing them has been a problem, including the guidance for how to manage them. For years, it was thought that constant rotation of passwords was the best way to protect them. In reality, password rotation almost guarantees the worst behaviors by users, including minimal changes to passwords, password reuse, writing passwords down, and taking the shortest route to have any hope of remembering the dozens of passwords they may have for all the systems and services they have access to. Password rotation also does nothing to keep attackers out. Fortunately, NIST and others have recognized the errors in their ways and have stopped recommending password rotations, instead focusing on long, strong passwords and no password reuse across systems and services. This, however, isn't sufficient because all it takes is a really

well-constructed phishing message, and an attacker is collecting credentials from users.

In addition to the changes in how passwords are managed, many organizations are moving away from passwords altogether. At least, they are moving away from traditional passwords. The object is to never pass any credentials between a user and an identity provider. Instead, other information is provided to the provider. **Figure 11-3** shows the differences between traditional authentication with a username and password, and authentication using a passwordless approach. You can also see how it would work with service principals, since applications also need to be authenticated against other services. The application would have the identity of a service principal, rather than the identity of a traditional user. This helps to constrain what they can do, since normal users have rights and privileges that you don't want a service or application to have, including interactive logins.

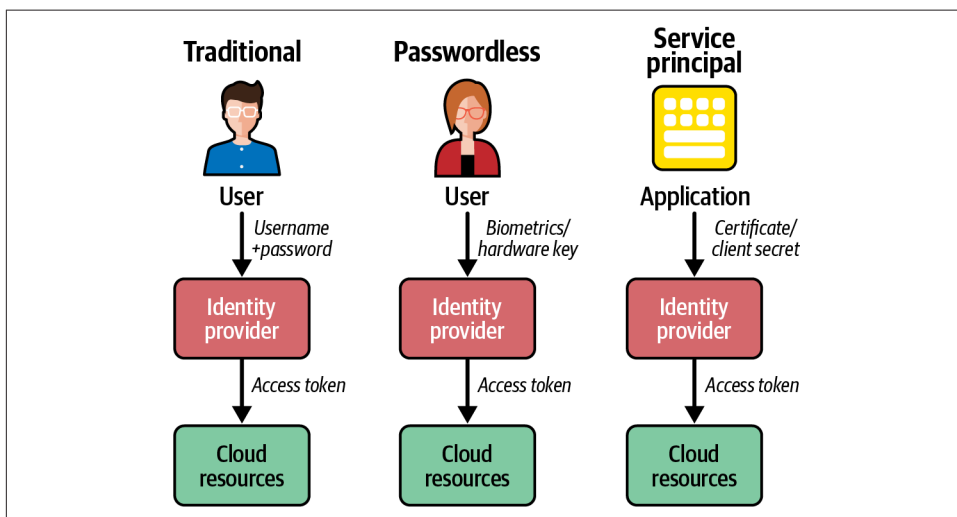


Figure 11-3. Authentication comparison

Multifactor authentication is a common requirement for authentication. This means you are using some combination of something you know, something you have, or something you are. Something you have may be a physical token that can be used to generate cryptographic material, which would be used rather than sending a password. This is becoming a common approach for passwordless authentication. These tokens may be USB devices and they have to be touched in some way to generate the key that is used for authentication. While it's called passwordless, the token press is normally accompanied by entering a PIN, which means it is still multifactor. The token is something you have, and the PIN is something you know. **Figure 11-4** shows what some of these tokens look like. Both are USB-C devices, but one is considerably larger than the other, though they have exactly the same functionality.

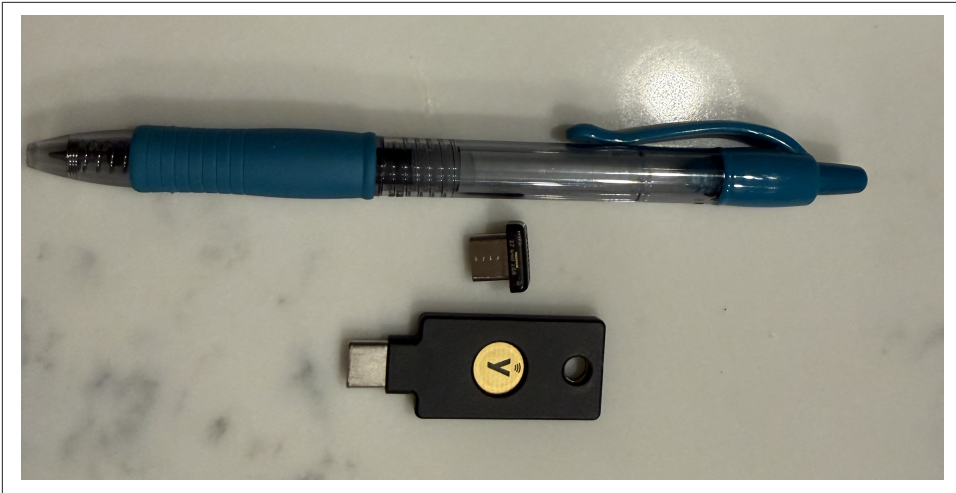


Figure 11-4. Authentication tokens

The advantage over passwords is that the information generated when the token is pressed is for one-time use. You get the advantage of using one-time passwords, which can't be replayed even if they are captured, and require the use of something the owner knows to protect them from being used if someone else gets access to them. The authentication provider knows about the token and they are synchronized, which means the authentication provider knows what should be expected. In some cases, you may have multiple accounts that need to be used and these keys can hold more than one user, so you could use the same token for multiple cloud platforms, for instance.

Nonhuman identities like applications, pods, workloads, or even systems, have forced the evolution of identity management practices. In the old days, there were times when some sort of password was required for something like installing a certificate for encryption. The password may have been stored on disk to unlock the certificate. This meant the password could be recovered if an unauthorized user got access to the system. The same was true for applications that needed to authenticate to databases. As applications became more distributed and needed to authenticate to one another, a better approach became necessary. As more applications migrated to being web-based, the exposure became too great to continue trying to manage authentication the old way. The result is service principals rather than regular user accounts.

Service principals are accounts that are attached to an application so it can have a set of permissions and rights assigned. Applications need to be able to authenticate, but the problem is they don't have fingers to type a password or touch a token. They also don't have any pockets to store tokens in. This means something else needs to be done to authenticate applications. Applications get service principal identifications,

but an identification still requires something beyond what is effectively a user ID. The service principal may have a secret or a cryptographic certificate. These are stored in a key vault that requires appropriate permissions and are accessed at runtime. In the end, authentication tokens are presented to the identity provider to authenticate the application or service so it can run.

JSON web tokens (JWTs) are commonly used for any type of authentication, and are used for a service principal to authenticate an application. The service principal is assigned an X.509 certificate that belongs to them. When it needs to authenticate to another application, it generates a JWT that includes the service principal identifier, the entity that will consume the token, and the expiration. The JWT is then signed using the certificate that belongs exclusively to that service. This means the JWT is authenticated by checking the signature of the certificate. If the signature is valid, the identity provider issues an access token that identifies what the service can have access to, based on the rights and permissions assigned.

When you have containers that are constantly spinning up and down, it doesn't make sense to issue long-term tokens that guarantee access. This is where using service mesh identity makes some sense. Secure Production Identity Framework for Everyone (SPIFFE) is an open source framework that can be used in microservices architectures. SPIFFE allows for automatic, short-term authentication without manual configuration. **Figure 11-5** shows the process to authenticate microservices.

With SPIFFE, there is a SPIFFE runtime environment (SPIRE). The SPIRE server is the certificate authority and also where the identities are registered. A SPIFFE identifier is a uniform resource identifier (URI) that uniquely identifies a workload. When a workload starts up, the SPIRE agent attests to the identity of the workload. This may include the Kubernetes service account, or the IAM role that is specific to the cloud provider. The SPIRE server issues a short-lived certificate, the SPIFFE verifiable identity document (SVID). This is an X.509 certificate that has an expiration date that isn't very far into the future. This certificate is then used for mutual TLS (mTLS) to guarantee that both parties in a conversation within the environment can trust that the other is who they say they are and that the conversation is protected.

Using this framework, each entity has a cryptographically verified identity. Credentials are rotated automatically as part of the process and given the ephemeral nature of microservice architectures; you don't have long-lived credentials that far outlive the lifetime of the service instance. Using this approach, there are no secrets to manage. You don't need a key vault. Everything is handled by the different components, and everything is cryptographically protected. This helps enable your architecture to never trust entities just because they may happen to be within the overall architecture.

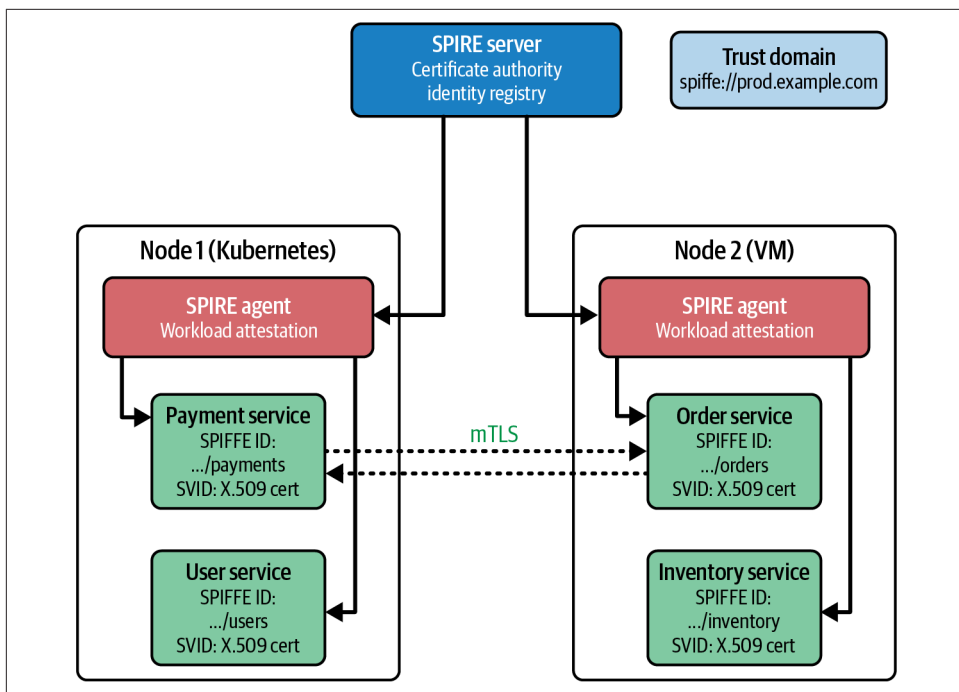


Figure 11-5. SPIFFE process flow

Zero Trust Architecture

When it came to on-premises networks, there was a tendency to believe that if you were inside, you were automatically trusted. After all, the perimeter is strong, and all of our people are trustworthy, so why not just expect we can trust anything on the inside of the network? While this was never a good approach, the move to a more distributed implementation, especially with more remote workers than ever before, changing the trust model has become essential. The move to a zero trust network architecture means that no endpoint is trusted. The motto for zero trust is “never trust, always verify.” This effectively means authentication everywhere. This may also include authenticating physical systems. A laptop or a desktop system, on premises, may have a certificate installed that would help to authenticate the device to protect against unauthorized devices from connecting to the network or any other endpoint.

One of the premises that zero trust architectures operate from is they assume any component has been compromised. If you assume compromise, you want to ensure you know who you are talking to at any point. This means you are always authenticating devices and users. A device may be able to automatically authenticate, but if you also require the user to authenticate, that helps protect against a compromised system from communicating with other devices on the network.

Figure 11-6 shows a simple diagram of the different elements that might be used in a zero trust network architecture for a cloud application. One of the essential elements shown here is the microsegmentation. This is true of cloud applications as well as on premises. The idea is to separate every element, with network rules to prevent any communication that is not specifically allowed. For the most part, different elements don't need to be sending network traffic directly to one another. The ones that do need that access will have rules defined to specifically allow the traffic, based on protocol and port. This is, of course, common with network firewalls, but the difference here is that network firewalls are generally at the network perimeter, exposing all systems on a local network to connection attempts.

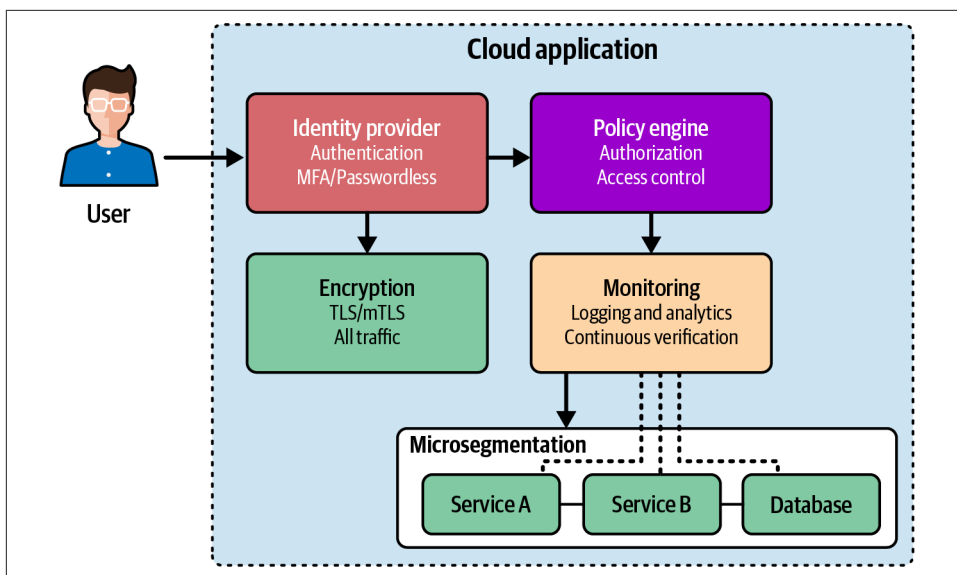


Figure 11-6. Zero trust cloud architecture

In addition to microsegmentation, you can see the policy engine. The policy engine contains the rules for what gets to communicate with what. This can include identity-based access, which defines the user, service account, and workload identity. Additionally, role-based access control (RBAC) defines access based on the roles. Beyond that, the policy engine contains rules about device posture. This includes rules defining whether the element meets security posture requirements, like patch level, specific operating system version, and other health check items. The policy engine includes the policy decision point (PDP), which evaluates all the policy elements in real time, determining whether to allow the access. The policy information point (PIP) collects information from the identity provider, device management systems, threat intelligence sources, and other necessary information.

In addition to microsegmentation, mTLS is used to mutually authenticate the endpoints. mTLS is not only used for authentication, based on X.509 certificates, but also to encrypt all network communications in case any communication is intercepted. This only includes network communications. Once the communication has reached the endpoint, it is decrypted to process it, which is where it may be read in plain text. However, you do get the authentication and network-level encryption.

We have discussed identity providers before. These are just as essential in zero trust as with any other network architecture. If you are constantly authenticating, whether it's user identities, device identities, or application identities, you need a good identity provider using strong authentication practices. Monitoring is always an essential component. When it comes to zero trust, you want to ensure you are looking at how all the elements are authenticating. This should, of course, include any failures.

One important note when it comes to zero trust is that this is not a product you can buy. Instead, it is a design philosophy as well as a set of operational practices. Focusing on isolating systems, and strong access controls at the network, system, and user layers, helps with a strong zero trust implementation. The objective of zero trust is not only to reduce the incidence of intrusions, but more importantly, to limit lateral movement since access to one system doesn't automatically lead to trusted access to others.

AI/ML in Cloud Security

While they can be very fuzzy terms, meaning roughly whatever the speaker/writer wants them to be in the moment, AI and/or ML have become essential to business practices. When marketing people get in the middle, everything becomes muddled. To be clear, AI is the idea that a computer can mimic a human experience. Alan Turing, a brilliant mathematician from the United Kingdom, constructed a thought experiment that has come to be known as the Turing Test. At its core, the idea is that computers can be said to have achieved AI when a person can be placed into a room with a terminal (input/output device using just text) and can't distinguish whether they are talking to a computer or a human on the other side of the conversation.

Industry visionaries like Marvin Minsky and John McCarthy took the idea of AI much further, expecting the computer to be able to solve problems or challenges that are perceived to require deep intelligence, problem solving, and creativity. One of these problems tackled early on, in the 1950s, was chess. They wanted to devise chess programs that were able to beat grandmasters, which would require pattern recognition and an ability to process multiple options, making the best choice based on an understanding of the game and winning move patterns. It would take decades, though, before these programs were capable of actually beating grandmasters. Machines were also built to play ping-pong, extending the idea of AI to take

significant inputs based on a position in a three-dimensional environment with a moving object.

AI is really just getting a computer to engage in conversations like a human, or solve problems in ways that humans might. Computer programs generally have a rigid set of rules to follow. AI would be when a computer can act in more flexible ways like a human may behave, including having conversations, reasoning, problem-solving, understanding language, and making decisions based on ambiguous rules or inputs.

ML is a form of AI. ML uses algorithms that identify patterns in data without having clear rules and categorizations. ML algorithms learn based on training data rather than based on strict and clear rules for what patterns look like. This allows them to extrapolate the pattern recognition to other data sets that may be similar. A subset of ML is large language models (LLMs).

An LLM is a complex representation of how language elements relate to one another. A chatbot like Claude, ChatGPT, or similar, makes use of an underlying model to put words together in ways that make sense given the starting point. The model helps the chatbot to “predict” the next meaningful word in the construction of the output. The model is built using a transformer algorithm that takes enormous data sets of text to create a statistical understanding of which words go together in what contexts.

How would any of this work when it comes to cloud security? Well, for the moment ML isn’t taking jobs over completely. One thing that ML is incredibly good at, though, that humans aren’t as good at because of the scale, is pattern recognition. You can feed terabytes of data at an ML algorithm and it will see patterns that humans can’t simply because the volume of data is so high. So we can think about using ML to improve security operations by looking at a flow like the one in [Figure 11-7](#). Applications and network usage can generate enormous volumes of data. Historically, we have used humans to create rules to flag anomalous behaviors. Humans may not see bad behaviors that are actually happening because they don’t know about them, not having seen them before. Instead, MLs can take the large data sets and identify patterns that may otherwise be missed.

Using this approach, you can feed the large data sets into an ML platform that has been trained on different application communications patterns. The ML can then identify anomalous behavior, and identify whether that behavior is malicious. Based on an understanding of critical business assets and potential threats against them, the ML can identify if the behavior is something worth raising for further evaluation. Additionally, based on an understanding of business appetite for impact from threats, the ML can provide a scoring to the behavior, which can help prioritize it.

In some cases, the ML may be able to make adjustments to the implementation, like blocking traffic or, potentially, allowing it, based on how it understands the environment, the business, and the needs of the application and its users.

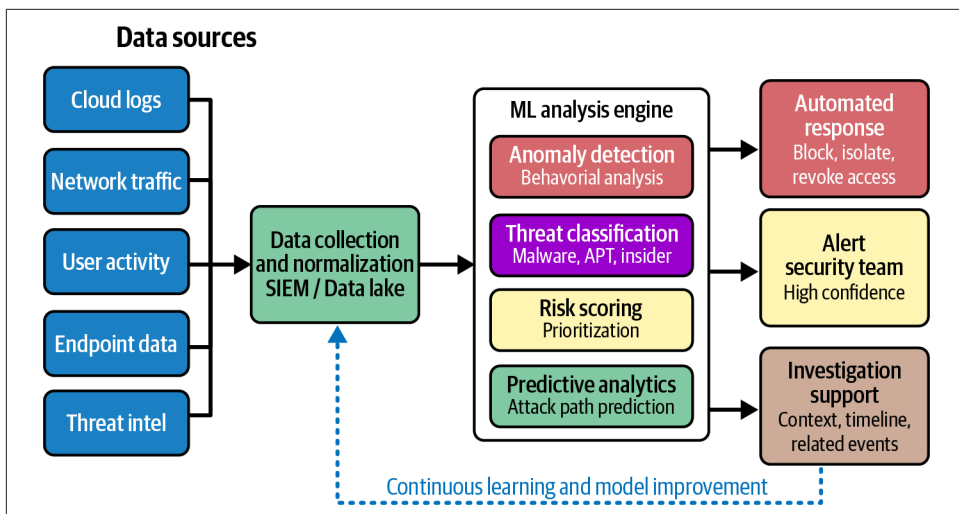


Figure 11-7. Security operations with ML

LLMs can also have a significant impact on how businesses approach security. The overall security posture of an organization can be negatively impacted through inconsistency of implementation. IaC can help ensure a consistency in the implementation. LLMs can help implement IaC and assist with the development of many other automation tasks. Additionally, for organizations that hate documentation, in spite of its obvious benefits, the LLM can be used to generate documentation, including process, policies, and standards.

Summary

Technology is constantly evolving. While foundations generally remain the same, their implementation can change a lot. While cloud providers are the next iteration of outsourcing, adding outsourcing with a product focus has allowed cloud providers to enhance their offerings that in turn make it much easier for companies to develop and deploy their own offerings. This increases speed to market and overall agility of organizations to respond to user demands. All of this means cloud security continues to evolve and will continue to evolve.

One of the ways security implementations are changing is through adapting to cloud native application designs, which have forced protective and detective controls to be able to work with components that are constantly appearing and reappearing. These elements may also have a much smaller footprint than previously, which means the attack surface has shrunk, which has a positive outcome for security organizations. However, cloud native designs also have other challenges, like solving the problem of identity and access control.

Identity and access control in the cloud is generally the same as in on-premises environments, but as always it is about details. Many organizations are moving toward passwordless implementations, which means rather than a password, you use something like a token. The authentication factors become something you have and something you are, in some cases, with less of an emphasis on what you know. Application architectures with a lot of moving pieces also require the applications to have identities since they will need to authenticate. This results in the need for service principal identities that can be used to identify and authenticate the application.

Zero trust designs have become more common, especially as the company perimeter has been moving outward because of more remote workers and more of the company's resources being moved to the cloud and out of the company-owned data centers. Zero trust is about never trusting any entity based on its location. Always verify, which means authentication and strong access control roles. Additionally, microsegmentation is where any host or other computing entity appears to be on its own network segment from the perspective of what other devices it can be reached by.

Finally, AI and ML may offer significant benefits to security operations teams by helping to more easily recognize patterns in enormous quantities of data, since that's what ML is really good at doing where humans can't because of the scale. Also, LLMs can help increase the speed of other tasks, like automation and documentation.

Other Resources

The following pages include details about cloud native security and new authentication trends:

- Matt Pacheco, “What Is Cloud-Native Security? Best Practices & 4 C’s Explained,” TierPoint, updated December 11, 2025 (<https://oreil.ly/rrVYa>).
- “Passkey vs. Password: What’s the Difference?” Bitwarden (<https://oreil.ly/ob0AR>).
- “What Is Zero Trust Architecture (ZTA)?” Palo Alto Networks (<https://oreil.ly/WXQLP>).
- “Supercharge Security with AI,” Google Cloud (<https://oreil.ly/uZ1vV>).

A

ABAC (attribute-based access control), 74

access control, 91

access outside of cloud operations team, 92

cloud provider support for data loss prevention, 142

for code in DevOps, 97

for code repositories, 217

common access control models, 169

conditional access control policies, 169

for containers, 174

coverage in contracts, 286

for data centers, 158

granular, using CASB in cloud environment, 186

in information rights management, 143

access control lists (ACLs), 76, 126

network ACL filtering traffic between router and subnets, 155

access management

access threats to cloud data storage, 124

Identity and Access Management program, 72-76

account management, 91

access threats to cloud data storage and, 125

accountability, 145

addresses (memory), 33

administrator's operational security, evaluating for cloud providers, 99

Advanced Encryption Standard (AES), 68, 136

adversaries, 230

types of, 230-232

government-sponsored groups, 232

hacktivists, 231

organized crime, 231

affected users (DREAD), 209

Agile development, 202

approaches to implementing Agile principles, 203

claiming use of, excuse to dispose of traditional artifacts, 204

frameworks following Agile principles, 204

goal of faster software development, higher quality and more customer focus, 203

principles of, 202

AI (artificial intelligence), 298

in cloud security, 307-309

solutions from cloud service providers, 43

alerts

excessive use of, 182

generated by rules in security engineering, 249

generated by SIEM, 250

monitoring logs and generating alerts, 181

SLI falling below acceptable parameters, 216

Amazon Web Services (AWS), 11

access control in S3 buckets, 124

AWS Well-Architected Framework, 151

EFS (Elastic File System), 123

inbound access control list, 76

network provisioning in, 27

public S3 buckets, exposure of sensitive data, 62

S3 Glacier storage, 121

security engineering, 246

Simple Storage Service (S3), 120

tools available to support compliance efforts, 269

- Well-Architected Framework, 88
 - pillars of, 89
- American Institute of Certified Public Accountants (AICPA), 268
- analytics
 - behavior analytics, 235
 - in cloud data lifecycle, 104, 107
- Annualized Loss Expectancy (ALE), 255
- Annualized Rate of Occurrence (ARO), 255
- anomalies, detecting, 300
 - in log information, 248
 - using machine learning, 308
- anonymization of data, 140
- Anonymous, attacks by, 231
- Ansible, 36, 213
- Apache Cloudstack, 51
- API gateways, 152, 156, 222
 - use in cloud native application deployments, 301
 - in virtual private clouds, 170
- APIs
 - access via API key, 224
 - authentication to, 224
 - for cloud providers, 36
 - high-level implementation for mobile and web, 222
 - sample API request, 222
 - security threats, 64
 - using in cloud applications, 196-197
- AppArmor (Linux), 299
- application decomposition, 208, 219
- application layer, 220
- application programming interfaces (see APIs)
- application security (cloud), 177-198
 - cloud security mechanisms, 185-191
 - outsourcing applications, 192-194
 - threats against, 178-185
 - identity and access management, 178-180
 - infrastructure misconfiguration, 185
 - insufficient monitoring and logging, 181
 - misconfiguration, 180
 - poor vulnerability management, 180
 - using APIs, 196-197
 - web application security, 194-196
- application security domain in CCSP, 8
- application servers, 195
- applications
 - application software security, 92
 - building in cloud PaaS, 41
 - cloud-based, advantages and limitations of, 177
 - delivered through cloud SaaS, 43
 - functional requirements for, 87
 - hardening, CIS controls for, 90
 - poor design, threats from, 64
 - responsibilities for in Shared Responsibility Model, 48
 - virtualization of, 36, 224
- architecture, 88
 - cloud, 7
 - cloud data storage architectures, 120-124
 - CSA Enterprise Architecture, 93
 - infrastructure security, 150-157
- archival storage, 121
- archive/retention stage in data lifecycle, 108
- artificial intelligence (see AI)
- asset management, 90
 - evaluation of cloud providers for removal of customer assets, 99
- Asset Value (AV), 255
- assets
 - identifying in NIST RMF, 257
 - managing at data centers, 161
- asymmetric encryption, 66, 135
- ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework, 182
- attack lifecycle, 235, 244
 - steps in, 236
- attackers, 79
 - (see also adversaries)
- attacks
 - against hypervisors, 173
 - identity misuse as common attack path, 192
 - against MD5 hashing algorithm, 138
 - modeling and simulating, 209
 - against usernames and passwords, 178
- attribute-based access control (ABAC), 74
- attributes, using to manage permissions, 169
- auditing, 145
 - auditing support by cloud service providers, 142
 - SOC 2 auditing standard, 268
- audits, 10
 - audit log management, 91
 - compliance and audit management layer, CSA architecture, 94
 - regulations requiring, 129

- right of audit in contracts, 287
- trackability of data, 8
- of users and their roles, 169
- authentication, 131
 - cloud provider support for data loss prevention, 142
 - in code repositories, 217
 - comparison of traditional, passwordless, and service principal, 302
 - of identities, 73
 - modern, emerging trends in, 301
 - of nonhuman identities, 303
 - passwordless, 262
 - protecting against compromised components in zero trust architecture, 305
 - redirected to identity provider for out-sourced application, 193
 - strong, in zero trust implementation, 188
 - tokens for, 224
 - (see also tokens)
 - of users in identity and access management, 167
 - in zero trust implementations, 82
- authorization, 168
 - information shared by OAuth protocol, 224
- Authorization header, 223
- automation, 3
 - in cloud computing, 36
 - DevOps focus on, aiding in implementing security testing, 96
 - hallmark of DevOps practices, 95
 - principle for DevOps, 205
 - of user deprovisioning, 169
- Autopsy tool, deleted files in, 109
- availability, 59, 60, 215
 - advantages of cloud adoption, 55
- awareness and skills training (security), 92
- AWS (see Amazon Web Services)
- Azure, 11
 - Azure Files, 123
 - cold storage, 121
 - Cool Storage, 120
 - geographic regions for, 49
 - network access controls on virtual machine, 126
 - runtimes you can build applications on, 41
 - tools available to support compliance efforts, 270

B

- backups, 128, 166
 - and alternate processing in disaster recovery, 86
 - considering in process of data destruction, 111
 - data dispersion and, 112
 - protection against loss of data versions, 126
- badge swipes at data centers, 160
- bare-metal hypervisors, 34
- BC plans (see business continuity and disaster recovery plans)
- BC/DR planning (see business continuity and disaster recovery plans)
- behavior analytics, 75
- behaviors in attack lifecycle phases, 237
- BIA (business impact analysis), 84, 275
- biometrics, 161
- bit boundary, 33
- bitmasks, 27
- block encryption, 136
- blocks (disk), 31
- BOOTP protocol, 205
- boundaries, 152
- Brazil, Lei Geral de Proteção de Dados (LGPD), 285
- breaches, 141, 158, 237, 241
 - assuming in zero trust, 83
 - handling under GDPR, 282
 - handling under other data privacy regulations, 284
 - notification of, covered in contracts, 286
 - in payment card industry, 264
 - using logs to investigate, 248
- builds, automation of in the cloud, 36
- Burp Suite, 211
- bus architecture, 226
- business and security, alignment of, 253
- business context for CCSP, 3
- business continuity and disaster recovery plans, 8, 60, 132, 254, 275
 - business continuity plan, 85
 - for data centers, 165-167
 - disaster recovery plan, 86
 - recovery stage in security operations, 245
- Business Continuity Management (BCM), stages in, 275
- business efficiency/continuity, 129
- business impact analysis (BIA), 84, 275

business logic layer, 220, 221

C

CA (certificate authority), 66

CAC (Cyberspace Administration of China), 285

Caesar cipher, 65

California Consumer Privacy Act (CCPA), 283
businesses falling under, 284
entities and relationships, 283
rights of consumers, 284

cameras, security cameras at data centers, 159, 162

Canada, Personal Information Protection and Electronic Documents Act (PIPEDA), 285

CASB (see cloud access security broker)

CCM (Cloud Control Matrix), 267

CCPA (see California Consumer Privacy Act)

CCSP (Certified Cloud Security Practitioner)

exam, 1

about CCSP and topics, 5

categories or topics, average weights for, 11

Cloud Application Security domain, 8

Cloud Concepts, Architecture, and Design domain, 7

Cloud Data Security domain, 7

Cloud Platform and Infrastructure domain, 8

Cloud Security Operations domain, 9

further resources, 12

Legal, Risk, and Compliance domain, 10

need for, 2-4

preparing for, 11

summary of contents, 12

CCTV (closed-circuit television), 159

CDNs (content delivery networks), 194

Center for Internet Security (CIS), 90

certificate authority (CA), 66

certificates, 67, 133

devices provisioned with, 83

lifespan, renewal, and revocation of, 134

management of, 137

service principals using with JWTs for authentication, 304

cgroups (control groups), 174

chat, 82

Chef, 36, 213

China, data privacy regulations, 119, 285

China, government-sponsored adversaries, 232

CHS (cylinder-head-sector) addressing method, 29

CI/CD (continuous integration/continuous deployment), 210-212

application software security and, 92

CI/CD pipelines

diagram of stages, 210

using phased releases in, 212

CIA (confidentiality, integrity, and availability), 60

CIDR (Classless Interdomain Routing), 27

ciphers, 65

asymmetric key encryption, examples of, 67

symmetric key encryption, 68

classification of data, 7, 129, 130

closed-circuit television (CCTV), 159

cloud access security broker (CASB), 186-187, 189

implementation of, 186

providing additional visibility, 187

cloud computing

about, 15

building block technologies, 22-39

automation, 36

logging and monitoring, 37

networking, 23

storage, 29-33

virtualization, 33

challenges and benefits of cloud adoption, 54-56

cloud models, 39-49

platform as a service, 41

Shared Responsibility Model, 47-49

software as a service, 43

storage as a service, 44

democratization of information processing, 3

evolution of outsourcing, 3

locations or geographic distribution of, 49-52

need for security professionals, 4

NIST definition of essential characteristics, 17

broad network access, 19

measured service, 22

on demand, self-service, 18

rapid elasticity, 21

resource pooling, 19

versus outsourcing computing resources, 16

- roles and responsibilities, 53
- security concepts and implications for, 7
- Cloud Computing Security Reference Architecture (NIST), 151
- Cloud Concepts, Architecture, and Design (CCSA domain), 7
- Cloud Control Matrix (CCM), 267
- Cloud Data Security domain (CCSP), 7
- cloud native design, 224-227
 - essential elements of, 227
 - NoSQL databases in, 226
- cloud partner, roles and responsibilities of, 53
- cloud platforms
 - CCSP exam and, 5
 - Cloud Platform and Infrastructure Security
 - topic on CCSP, 8
 - need for information security with, 4
 - practice at implementing technologies with, 11
- cloud providers
 - evaluating security of, 97
 - evaluation of, 60
- Cloud Security Alliance (CSA)
 - Cloud Control Matrix, 267
 - Enterprise Architecture, 93, 151
 - guidance on Implementing, 94
 - layers in, 93
- Cloud Security Architecture (Microsoft), 151
- cloud security operations, 9
- cloud security, emerging trends, 297-310
 - AI and ML, 298, 307
 - cloud native security, 298-301
 - identity and access management, 301-304
 - zero trust architecture, 305-307
- cloud service broker, roles and responsibilities of, 54
- cloud service customer data alignment, 99
- Cloudstack (Apache), 51
- clusters (disk blocks), 31
- code pipelines, use of IaC in, 214
- code repositories, 216
 - advantages of, 217
 - changes to source code in, 217
 - compromised, 219
 - strong access control for, 217
- code reviews, 211
- code, access control for, 96
- collaboration
 - in Agile development, 203
- cloud services for, 82
- code repositories and, 216
- in DevOps, 95
- lack of in waterfall development, 205
- collisions (in hashing), 138
- color combination demonstrating key creation, 71
- column-family databases, 227
- Common Criteria for Information Technology Security Evaluation, 99
- Common Log File System (CLFS) in Windows, 38
- communications protocols, 23
 - (see also OSI model)
- complexity
 - cloud native deployment and, 298
 - increase with cloud adoption, 56, 180
 - system image deployment and, 207
- compliance, 54, 254, 264-271
 - archiving data for, 109
 - challenge with cloud adoption, 56
 - cloud customer responsibility for, 53
 - cloud provider geographic distribution and, 49
- Cloud Security Alliance Cloud Control Matrix, 267
 - cloud support for, 269
- compliance and audit management layer, CSA architecture, 94
- compliance threats to cloud data storage and, 128
- data protection and privacy, in contracts, 286
- evaluating cloud providers for, 97
- financial requirements for, 268
- legal and regulatory, 279, 282, 285
- legal compliance and best practices, 290-292
- Legal, Risk, and Compliance topic on CCSP, 10
- NIST and ISO, 265-267
- policies for regulations and frameworks, 273
- requirements in a policy, 272
- System and Organization Controls 2, 268
- vendor monitoring for, 289
- vendor requirements for, 288

components

- access from, threats to cloud storage, 126
- sending messages between, using APIs, 196
- vulnerable components, threats from, 64

- computing resources
 - accessing on the cloud via HTTP, 18
 - cloud computing not limited to, 16
 - in the cloud, 16
 - excess, 20
- computing, network, and storage resources,
 - pooling in cloud, 19
- conditional access policies, 169
- confidential data, 141
- confidentiality, integrity, and availability (CIA), 60
- configurations
 - automation in the cloud, 36
 - in cloud Shared Responsibility model, 48
 - misconfiguration and human error, threats from, 61
 - SDN in the cloud, 29
 - secure configuration of enterprise assets and software, 91
 - standard rather than individual for hosts, 171
 - use in IaC, 212
 - configurations written in Terraform, 212
- container images, access control for, 97
- containers, 224
 - application virtualization in, 35
 - cloud native applications using, 298
 - diagram illustrating structure of implementation, 225
 - implementing microservices with, 226
 - modern identity and access management for, 304
 - orchestrators for, 225
 - Pods, 225
 - security, 173-174
 - limiting capabilities on, 174
 - problems similar to virtual machines, 174
 - used as part of cloud application, vulnerability management, 181
- containment phase (security operations), 244
- content delivery networks (CDNs), 194
- content type, 223
- context, establishing in ISO risk management, 260
- continuous integration/continuous deployment (CI/CD)
 - application software security and, 92
 - in DevOps, 95
- contracts, 286-288
 - considerations with cloud providers, 10
 - contractual issues, 280
 - in vendor management, 194
- control groups (cgroups), 174
- controls
 - Cloud Control Matrix of CSA, 267
 - factoring in risk assessment, 258
- controls framework (NIST 800-53), 265
- conversations with AI agents, 308
- core business focus, advantages of cloud adoption for, 55
- cost-effectiveness of cloud adoption, 54
- costs
 - challenges of cost management with cloud adoption, 56
 - cost optimization in AWS Well-Architected Framework, 90
 - reducing overall cost of cloud services, 22
- CPU utilization, 19
- creation/ingestion of data, 106
- credentials, 78
 - (see also authentication)
 - compromise of, 126, 182
 - credential stuffing, 62
 - credentialing practices, 131
 - in data flow diagram, 112
 - default, 180
 - usual issues with, 125
- critical security controls, 90
- crypto shredding, 111
- cryptographic hashing, 137
- cryptography, 65-72
 - asymmetric encryption, 66
 - challenges in auditing and accountability, 146
 - cloud data encryption, 111
 - cryptographic means of destroying data, 110
 - data encryption in transit and in storage
 - with cloud services, 125, 130
 - encryption in presentation layer, 24
 - entities having cryptographically verified identity, 304
 - FIPS 140 requirements for encryption of nonclassified data, 99
 - message encryption in VPNs, 78
 - misconfigurations in encryption, 180
 - physical authentication tokens generating, 302

- problems with encryption in cloud storage, 128
- simple, using ciphers, 65
- symmetric encryption, 68
- Transport Layer Security, 68
- CSA (see Cloud Security Alliance)
- CSF (see NIST, Cybersecurity Framework)
- customer focus in Agile development, 203
- customers (cloud), responsibilities of, 53
- Cyber Kill Chain, 233
 - defensive actions to be taken, 234
 - phases in, 233
- cyberattacks, 1
- Cybersecurity Framework (CSF) from NIST, 265 (see NIST)
- cybersecurity insurance, 257
- Cyberspace Administration of China (CAC), 285
- Cyberspace Workforce Qualification and Management Program manual (US Dept. of Defense), 5
- cylinder-head-sector (CHS) addressing method, 29

D

- DAC (discretionary access control), 74
- damage potential (DREAD), 209
- data
 - cloud capabilities with, 103
 - cloud data concepts, 104-119
 - different types of, 80
 - importance of, 103
 - lifecycle of, 80
 - types of, 114
 - semi-structured data, 115
 - structured data, 114
- data access layer, 220, 221
- data alignment between cloud service provider and customer, 99
- data anonymization, 140
- data centers
 - design on CCSP exam, 8
 - downsizing on-premises data center, 177
 - security, 157-167
 - disaster recovery and business continuity, 165-167
 - environmental monitoring, 159
 - operational security, 161
 - perimeter design and access control, 158
 - physical security controls, 157
 - redundancy and reliability, 162-165
- data classification, 129, 130
 - categories of data, 141
- data discovery, 7
- data dispersion, 112-114
 - data flow diagrams, 112
- data flow diagrams (DFDs), 112, 143
- data governance
 - NIST Cybersecurity Framework focusing on, 238
 - for outsourced applications, 192
- data languages, 197
- data lifecycles, 7, 131
 - cloud data lifecycle, 104-111
 - archive/retention, 108
 - data creation/ingestion, 106
 - deletion/destruction, 109
 - processing/organization stage, 107
 - stages of, 104
 - storage, 106
 - management of, coverage in contracts, 287
- data link layer (OSI model), 23
- data loss prevention (DLP), 140-143
 - classifying data, 141
 - controls supporting DLP with cloud provider, 142
 - creating data flow diagrams, 143
 - noticing data movement, 141
- data maps, 112
- data masking, 140
- data privacy regulations, 280
 - (see also compliance; privacy regulations on data)
- data processing agreement (DPA), 282
- data protection, 129
 - cloud providers not responsible for, 129
 - in contracts, 286
 - critical security control, 90
 - in network security, 79
 - technologies and strategies, 133-143
 - data loss prevention, 140-143
 - encryption, 133
 - handling production data, 139
 - hashing, 137-139
 - threats from in cloud data storage, 125
- Data Protection Officer (DPO), 282
- data recovery, 91
- data security (cloud), 7, 103-147

- Data Security Standard (DSS) of the Payment Card Industry (PCI) (see PCI DSS)
- data transformations
 - documenting in data flow diagrams, 113, 143
- databases, 107
 - cloud native design moving toward NoSQL, 226
 - in data flow diagram, 112
 - NoSQL, semi-structured data in, 115
 - SQL databases as structured data, 114
- DDoS (distributed denial of services), protection against in VPCs, 170
- declarative IaC, 36
- default credentials, 180
- defense in breadth (DiB), 79, 156
- defense in depth (DiD), 78, 155, 188
- defensible network architecture, 79
- DELETE requests, 223
- deletion/destruction of data, 80, 128
 - cloud data deletion and destruction, 111
 - in cloud data lifecycle, 109
 - deletion is not destruction, 109
 - destroying stored data at data centers, 161
 - destruction of data, considerations for backups, 111
 - logical and physical destruction of data, 110
- denial of service, 64, 208
- denial-of-service attacks, 127
 - CDNs protecting against, 194
 - launched by hackers, 231
 - protecting against in containers, 174
- dependencies, vulnerabilities from, 218
- deployment, 60
 - automation of in DevOps, 205
 - automation platforms in IaC, 81
 - changes in software deployment, 200
 - continuous, 92
 - (see also CI/CD)
 - deployment stage in development, 202, 218
- design considerations for cloud data protections, 129-132
- design patterns, 88-94
 - AWS Well-Architected Framework, 88
 - Cloud Security Alliance Enterprise Architecture, 93
 - critical security controls, 90
- design phase in software development, 218
- design principles, 83-97
 - business continuity/disaster recovery (BC/DR) planning, 85
 - business impact analysis, 84
 - functional requirements, 87
- design stage, 202
- design styles, 220-227
 - APIs, 222-224
 - cloud native design, 224-227
 - multitier architecture, 220-222
- design, security considerations coming before, 59
- detection phase (security operations), 243
- detective controls, 172
- development, 140
 - secure development practices, 8
 - updating all libraries and products used in application development, 181
- development (cloud), 199-228
 - design styles, 220-227
 - development stage, 202, 218
 - DevOps and DevSecOps, 205-217
 - introducing security, 217-220
 - security and software development cycle, 200-205
- devices, authentication in zero trust, 83
- DevOps
 - common elements of, 95
 - natural enhancements to security through DevOps practices, 96
 - security and, 96
- DevOps and DevSecOps, 205-217
 - CI/CD pipelines, 210-212
 - code repositories, 216
 - DevOps goal to increase quality of software, 205
 - DevSecOps, 96
 - Infrastructure as Code, 212-214
 - security introduced with DevSecOps, 207
 - Site Reliability Engineering, 214-216
 - threat modeling, 207-210
- DFDs (data flow diagrams), 112, 143
- DHCP (Dynamic Host Configuration Protocol), 205
- Diffie-Hellman key exchange process, 70
- digital investigations, 280
 - in the cloud, 292-294
- Digital Signature Algorithm (DSA), 135
- digital signatures, 67
- disaster recovery plans, 8, 60, 86, 254, 276

- flow chart showing interrelations with business continuity plan, 165
- discoverability of vulnerabilities (DREAD), 209
- discretionary access control (DAC), 74
- disks, 29
 - CHS addressing method, 29
 - destroying data on, 162
 - destruction of disks to destroy data, 111
 - filesystems on, 31
 - logical destruction of data on, 110
 - types of, 30
 - in virtual environments, 172
- dispersion of data, 112-114
 - data flow diagrams, 112
- distributed computing resources, 20
- distributed denial of services (DDoS), protection against in VPCs, 170
- DLP (see data loss prevention)
- DNS (Domain Name System), 185
- document-based databases, 226
- documentation
 - in Agile development, 203
 - following Agile principles as excuse to neglect, 204
 - for legal compliance efforts, 291
 - plans for business continuity, 165
 - regulations requiring, 129
- domains in CCSP, 6
- downtime, 216
- DPA (data processing agreement), 282
- DPO (Data Protection Officer), 282
- DR plans (see business continuity and disaster recovery plans)
- DREAD framework, 209, 245
- DSA (Digital Signature Algorithm), 135
- DSS (Data Security Standard), PCI (Payment Card Industry) (see PCI DSS)
- Dynamic Host Configuration Protocol (DHCP), 205

E

- ECC (Elliptic Curve Cryptography), 135
- EDR (Endpoint Detection and Response) software, 78, 244
- 802.1q protocol, 173
- elasticity (rapid), 21
- elevation of privilege, 208
- Elliptic Curve Cryptography (ECC), 135
- email

- hosted by cloud services, 82
- protections for, 91
- as semi-structured data, 116
- emerging trends in cloud security (see cloud security, emerging trends)
- encapsulation of data, 25
- encryption, 62, 133-137
 - (see also cryptography)
 - algorithms, 135-136
 - cloud provider providing for data loss prevention, 142
 - key and secrets management, 137
- Endpoint Detection and Response (EDR) software, 78, 244
- endpoints
 - API, 197, 223
 - getting same protection from cloud services, 190
- Enterprise Architecture (CSA) (see Cloud Security Alliance)
- enterprise assets, inventory and control of, 90
- environmental monitoring (data centers), 159
- eradication phase (security operations), 245
- escalation of privileges, 236
- ethics in information security, 4
- Europe, GDPR and privacy regulation, 118, 281-282
- Event logs (Windows), 247
- Event Viewer (Windows), 38
- events
 - chain of events in applications, 249
 - in security operations, 242
- Excel spreadsheets as structured data, 114
- experience requirement (ISC2), 10
- exploitability of vulnerabilities (DREAD), 209
- Exposure Factor (EF), 255
- Extreme Programming (XP), 202

F

- facilities (syslog messages), 37
- Factor Analysis of Information Risk (FAIR), 262
 - primary risk equation, 263
 - process recommended by, 263
 - quantitative analysis of risk, 263
 - taxonomy for risk management, 262
- failovers
 - BC plans containing failover to alternate processing, 86

- secondary facilities for data centers, 166
- FAT (file allocation table) system, 31
- Federal Financial Institutions Examination Council (FFIEC), 268
- Federal Information Processing Standard (FIPS) 140, 99
- federation between multiple sources of identity, 170
- file allocation table (FAT) system, 31
- file sharing, 82
- files
 - file and folder level locking for data loss prevention, 142
 - synchronizing locally with cloud storage as a service, 45
- filestores, 123
- filesystems, 31
 - allocation of space in clusters of blocks, 32
 - remote file systems to access filestores, 124
- financial or legal data, 80
- financial requirements for compliance, 268
- fire solutions at data centers, 164
- FireEye/Mandiant, 235
- firewalls
 - capturing packets at network entry points, 79
 - firewall as a service, 190
 - host-based, 183
 - misconfigured, 185
 - modern, 77
 - in network segments, 171
 - network security groups and, 77
 - simple, 76
 - stateful, 76, 156
 - in virtual private clouds, 170
- forensics, 280
- functional requirements, 87

G

- GCE (Google Compute Engine), machine types available in, 40
- GCP (see Google Cloud Platform)
- General Data Protection Regulation (GDPR), 118, 281
 - principles of, 281
 - roles and relationships, 281
- Generic Routing Encapsulation (GRE) protocol, 78

- geographic distribution of cloud providers, 49-52
- geographic locations of data centers, 157
- geolocation, use in user behavior analytics, 75
- GET requests, 223
- GitHub and GitLab, 217
- globally unique identifiers (GUIDs), 122
- Google
 - Google Cloud Security Foundation Guide, 151
 - tools available to support compliance efforts, 269
 - Google Cloud Platform (GCP), 11
 - security and compliance features, 271
 - storage, 120
 - storage regions, 118
 - Google Cold Storage, 121
 - Google Compute Engine (GCE), machine types available in, 40
 - Google Docs, 45
 - Google Filestore, 123
 - Google Workspace, adding a user, 73
 - governance (see data governance; security governance and risk management)
 - government-sponsored groups (adversaries), 232
 - GPUs (graphical processing units), 179
 - graph databases, 227
 - graphical processing units (GPUs), 179, 298
 - GRE (Generic Routing Encapsulation) protocol, 78
 - groups, 168
 - guards (security) at data centers, 160
 - GUIDs (globally unique identifiers), 122

H

- hacktivists, 231
- hard disks, 30
- hardening operating systems and applications, 90
 - virtual machine hardening, evaluating cloud providers for, 99
- hardware
 - failures of, 128
 - memory virtualization support, 34
 - tracking lifecycle of at data centers, 161
- hardware interrupts, 34
- hardware storage, 29

- HashiCorp Configuration Language (HCL), 212
- hashing, 137-139
 - algorithms, 137
 - collisions, 138
 - example of, 139
 - of secrets, 179
- headers, 25
- Health Insurance and Portability Accountability Act (HIPAA), 186, 285
- hexadecimal values in IPv6 addresses, 27
- highly restricted data, 141
- historical context for CCSP, 2
- hospital network with CASB implementation (example), 186
- host level, isolating systems at, 183
- host-based firewalls, 183
- HTTP
 - handling of HTTP requests, 222
 - headers, 25
 - stateless nature of, 196
 - use by cloud, 18
- HTTPS, 19
- human error, threats from, 61, 124
- human looking at events in security engineering, 249
- hygiene practices (information security), 80-82
- hypervisors, 34, 172
 - escaping from guest machine to access hypervisor management, 173
 - in private clouds, 50

I

- IaaS (infrastructure as a service), 40
- IaC (see Infrastructure as Code)
- IBM (International Business Machines), 2
- IBM Cloud Security Architecture, 152
- iCloud, 45
- identities
 - access to data in outsourced applications
 - focused on, 192
 - core of zero trust, 188
 - nonhuman, forcing evolution of IAM practices, 303
 - stored in multiple repositories, 170
- identity and access management
 - for cloud-based applications, 178-180
 - attacks against usernames and passwords, 178
 - different capabilities for different cloud platforms, 179
 - misuse of privileged credentials, 179
 - concerns in cloud data storage, 124
 - credentials, compromise of, 126
 - failures in, threats from, 62
 - identity management for web applications, 195
 - information rights management integrating into, 143
 - large language models aiding implementation, 309
 - modern, emerging trends in, 301-304
 - authenticating nonhuman identities, 303
 - containers, 304
 - strong, necessity for cloud data, 131
- Identity and Access Management (IAM) program, 72-76, 167-170
 - access permissions for identities, 74
 - account management via, 91
 - behavior analytics in, 75
 - identities, 72
 - identity management lifecycle, 167
 - password management, 75
- identity providers, 168, 192
 - in zero trust implementations, 307
- IdP (see identity providers)
- IDS (intrusion detection system), 77
- impact, 254, 260
 - monetary impact of risk, 254
- imperative IaC, 36
- incident response
 - coverage in contracts, 286
 - planning for, 92
- incidents, 242
 - vendor management involvement in, 290
- indicators of compromise (IoC), 244
- information disclosure, 208
- information rights management (IRM), 7
 - advantage of protection following data instead of relying on system access controls, 144
- Information rights management (IRM), 143-144
- information security management systems
 - Common Criteria framework for evaluating, 100
 - ISO guidelines and best practices for, 98

- Information Security Management Systems (ISMS), 259, 265
 - information security, competence in, 264
 - infrastructure
 - Cloud Platform and Infrastructure Security
 - topic on CCSP, 8
 - failures of, 65
 - misconfiguration affecting cloud application security, 185
 - network infrastructure management, 92
 - physical and logical, design and implementation of, 9
 - protecting in cloud native application deployments, 301
 - security architecture, 150-157
 - boundaries and segmentation, 152
 - reference architectures, 151
 - infrastructure as a service (IaaS), 40
 - Infrastructure as Code (IaC), 36, 95, 132, 212-214
 - benefits of using, 214
 - easier to rebuild after security incidents, 293
 - platforms aiding use of, 212
 - security of cloud applications deployed as, 299
 - use in code pipelines, 214
 - instance storage, 120
 - integrity, 60
 - internal data, 141
 - International Information System Security Certification Consortium (see ISC2)
 - International Organization for Standardization (see ISO)
 - Internet Protocol Suite (TCP/IP), 24
 - internet, access to cloud providers via, 126
 - interrupts, 34
 - intrusion detection system (IDS), 77
 - intrusion protection system (IPS), 77
 - inventory and control of enterprise assets, 90
 - inventory and control of software assets, 90
 - IP addresses
 - DNS translating fully qualified domain names or hostnames to, 185
 - IPv4, 26
 - IPv6, 27
 - not using IPv6 addresses in AWS virtual private cloud, 28
 - restricting access to cloud virtual machine to, 127
 - IP security extensions (IPsec), 68, 78
 - IRM (see information rights management)
 - ISC2 (International Information System Security Certification Consortium), 4
 - Code of Ethics, 5
 - continuing education requirements for certifications, 5
 - ethical precepts for security professionals, 4
 - experience requirement, 10
 - free resources to help study for CCSP, 11
 - ISMS (Information Security Management Systems), 259, 265
 - ISO (International Organization for Standardization), 23
 - NIST and, 265-267
 - certification process for ISO, 265
 - challenges with ISO certification, 266
 - risk management, 259-262
 - risk management process
 - establishing context, 260
 - identifying risk level, 260
 - monitoring risks, 262
 - risk assessment, 260
 - risk treatments, 261
 - standards and guidelines for information security management system, 98
 - ISO 27001, 265
 - ISO 27002, 98
 - ISO 27017, 98
 - IT
 - shadow IT problem, 186
 - technology implementations, management of, 9
- ## J
- JavaScript Object Notation (see JSON)
 - JSON, 115, 197, 223
 - example from larger document, 115
 - JSON web tokens (JWTs), 224, 304
 - jurisdiction, 279, 291
 - breach notification in contracts, 286
 - in GDPR, 282
- ## K
- Kanban, 204
 - Kano model, prioritizing requirements, 88
 - key-value stores, 226
 - keys (encryption), 66
 - advantages of ECC keys, 136

- for authentication and encryption, 51
- cloud customer as holder of keys, 111
- key management for web applications, 196
- management of, 137
- protecting, asymmetric encryption and, 69
- protections for, 126, 131
- public/private key pairs, 66
- Kubernetes, 225
 - security of cloud native applications
 - deployed in, 300
- KVM hypervisor, 50

L

- L2TP (Layer 2 Tunneling Protocol), 78
- labeling data, 143
- LANs (local area networks), 26
- large language models (LLMs), 308
 - effect on how businesses approach security, 309
- lateral movement, reduction with zero trust, 307
- Layer 2 Tunneling Protocol (L2TP), 78
- layers (OSI model), 23
- lean software development, 204
- legal and regulatory considerations, 279-295
 - data privacy regulations, 280
 - digital investigations in the cloud, 292-294
 - legal compliance and best practices, 290-292
- legal data, 80
- legal requirements, 10
- lifecycle of cloud data, 104-111
- lifecycle of identities, 167
- likelihood, 254, 260
 - difficulty of identifying for events, 263
 - versus risk, 254
- Linux
 - access controls over resources, 174
 - filesystem, 31
 - pseudofilesystem and creation of data, 106
 - runtime protections, 299
 - security-oriented distributions, 179
- LLMs (large language models), 308
 - effect on how businesses approach security, 309
- load balancers, 156, 195
- local area networks (see LANs; VLANs)
- locations of data centers, 157
- locations or geographic distribution of cloud data, 118

- locations or geographic distribution of cloud providers, 49-52
- locations or geographic distribution of cloud providers
- Lockheed Martin, Cyber Kill Chain, 233
- log collection services, 247
- logging, 91, 146, 156
 - (see also monitoring and logging)
 - cloud solutions for, 37
 - as detective control, 172
 - digital investigations in the cloud, use of logs, 293
 - importance for cloud data, 131
 - insufficient, affecting cloud application security, 181
 - log data as semi-structured data, 118
 - monitoring logs and generating alerts from, 181
 - practices in DevOps, 95
 - problems with lack of in cloud services, 128
 - in security engineering, 247
- logical destruction of data, 110
- long-term storage, 120
- Loss Event Frequency × Loss Magnitude risk equation, 263
- LulzSec attack on Sony, 231

M

- MAC (Media Access Control) addresses, 153
- machine learning (see ML)
- magnetic disks, destruction of data on, 110
- maintenance phase in development, 202
- malware, 64
 - defenses against, 91
 - protecting against in cloud network infrastructure, 82
 - protecting against in network security, 78
- manual processes to continue business operations, 165
- mapping data, 112
- masking (data), 140
- measured service (cloud), 22
- Media Access Control (MAC) addresses, 153
- memory, 33
 - belonging to virtual machines, tracking by hypervisors, 172
 - virtualization of, 33
- merges in code repositories, 216
- Message Digest 5 (MD5) algorithm, 137

- metadata
 - associated with network traffic, 79
 - file metadata in hashing, 139
- MFA (see multifactor authentication)
- microsegmentation, 154, 183
 - in zero trust cloud architecture, 306
- microservices, 226
 - cloud native applications using, 298
 - data encryption and, 130
 - security and, 96
 - segmentation and, 183
- Microsoft
 - PowerShell scripting language, 213
 - STRIDE framework for threat modeling, 207
 - tools available to support compliance efforts, 269
- Microsoft Azure (see Azure)
- Microsoft Cloud Security Architecture, 151
- Microsoft's Patch Tuesday, 180
- migration to the cloud
 - challenges of, 55
 - road map for with security controls at all levels, 94
- misconfiguration and human error, threats
 - from, 61, 124
 - infrastructure misconfiguration affecting
 - cloud application security, 185
 - misconfiguration affecting cloud application security, 180
- MITRE's ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework, 182, 237
- ML (machine learning), 298
 - capabilities introduced by cloud providers, 43
 - in cloud security, 307-309
 - pattern recognition expertise, 308
 - security operations with ML, 308
- mobile applications, APIs exposing critical functionality for, 197
- monitoring and logging, 21, 156
 - in cloud data protection design, 131
 - cloud provider monitoring support for
 - DLP, 142
 - cloud solutions for, 37
 - critical security controls, 91
 - in DevOps, 95
 - of identity and access events, 169
 - insufficient, affecting cloud application security, 181
 - legal team's awareness of data in, 292
 - logging in security engineering, 247
 - logs sent to central monitoring system like
 - STEM, 172
 - monitoring in security engineering, 248
 - monitoring of cloud services, evaluating
 - providers for, 99
 - monitoring phase of NIST risk management, 259
 - network monitoring and defense, 92
 - performance monitoring in SRE, 216
 - requirements for, coverage in contracts, 287
 - security monitoring at data centers, 159
 - supporting detection of security events, 292
 - thinking about the whole stack, 182
 - in web application security, 195
- MoSCoW method, prioritizing requirements, 88
- movement of data, 141
- multifactor authentication, 125, 168
 - threat from lack of, 62
 - tokens, advantages over passwords, 302
- multitenancy (cloud services), 18, 267
- multitier architecture, 220-222
 - n-tier design, 220
- mutual TLS (mTLS), 304

N

- n-tier application design, 200, 220
 - layers in, emphasizing isolation to enhance security, 221
- namespaces, using with Kubernetes deployments, 300
- NAND (NOT AND) flash, 30
- Napkin.ai, 43
- NAT (Network Address Translation), 127
- nation-state actors, 232
- National Institute of Standards and Technology (see NIST)
- National Security Agency (NSA), 232
- native (or bare-metal) hypervisors, 34
- Network Address Translation (NAT), 127
- Network File System (NFS), 123
- network layer (OSI model), 23
- network masks, 27
- network protocols, cloud making use of, 18
- network security, 76-79

- data protection, 79
- defense in depth and other strategies, 78
- firewalls and network security groups, 76
- traffic inspection, 79
- virtual private networks, 77
- network security groups (NSGs), 77
- networking
 - in cloud PaaS, 42
 - in cloud Shared Responsibility model, 49
 - in the cloud, 23-29
 - network segmentation, 26
 - Open Systems Interconnection, 23
 - TCP/IP, 24
 - network monitoring and defense, 92
 - network threats to cloud storage, 126
- networks
 - access control lists, 155
 - access to cloud virtual machines, 40
 - boundaries and segmentation, 152
 - broad network access in cloud computing, 19
 - infrastructure management, 92
 - microsegmentation in zero trust implementations, 82
 - on-premises, connecting to internet, 16
 - private and public addresses for, 27
 - redundancy at data centers, 163
 - security in the cloud, 170-172
 - security network configurations and relevant controls, 9
 - segmentation of, 26, 78, 183
 - sharing network capacity in the cloud, 20
 - traffic in virtualized cloud environment, 172
 - virtual network security, 173
 - zero trust access in the cloud, 187
- New Technology File System (NTFS), 32
- New York SHIELD (Stop Hacks and Improve Electronic Data Security) Act, 284
- NIST (National Institute of Standards and Technology)
 - Cloud Computing Security Reference Architecture, 151
 - Cybersecurity Framework, 230, 237-242
 - essential functions, 238
 - mapping controls for attack lifecycle to, 239-241
 - definition of cloud computing, 17
 - destroying data through disk overwrites, 110
 - guidance on password management, 75
 - and ISO, 265-267
 - NIST CSF, 265
 - Risk Management Framework, 257-259
 - process or steps in, 257
 - threats, definition of, 61
- NIST 800-53, 265
- Node Package Manager (NPM), compromised
 - packages available from, 219
- Non-Volatile Memory Express (NVMe) devices, 31
- nonfunctional requirements, 87
- nonhuman identities forcing evolution of IAM practices, 303
- nonvolatile memory, 30
- North Korea, use of cybercrime, 232
- NoSQL databases, 115, 226
- NSA (National Security Agency), 232
- NSGs (network security groups), 77, 156
- NTFS (New Technology File System), 32

0

- OAuth, 193
- OAuth tokens, 224
- object storage, 122
- on demand, self-service (cloud computing), 18
- OneDrive, 45
- Open Systems Interconnection (see OSI model)
- Open Worldwide Application Security Project (OWASP) common vulnerabilities list, 8, 194
- OpenStack, 51
- operating systems
 - baseline for deployments, security hygiene practices, 81
 - in cloud platform as a service, 41
 - hardening, CIS controls for, 90
 - memory virtualization and, 34
 - virtualization and hypervisors, 34
 - virtualization of, 224
- operational excellence (AWS Well-Architected Framework), 89
- operational security at data centers, 161
- operational threats to cloud storage, 128
- operations, 205
 - (see also DevOps and DevSecOps)
- orchestrators (container), 225
- organization of data, 107
- organized crime, 231

- OSI (Open Systems Interconnection) model, 23
 - and Internet Protocol Suite, 24
 - layers in, 23
- outsourcing applications, 192-194
- outsourcing computing resources versus cloud computing, 16
- oversubscription to resources, 173
- overwriting data on disks, 110
- OWASP (Open Worldwide Application Security Project), common vulnerabilities list, 8, 194

P

- PaaS (platform as a service), 41
 - responsibilities in, 48
- packet captures, 79
- PAM (privileged access management), 74
- passwords
 - attacks against, 178
 - modern, emerging trends in, 301
 - NIST guidelines on password management, 75
 - password spraying attacks, 62
 - risk avoidance versus risk removal, 262
 - self-service password management in IAM, 75
 - threats from use of, 62
 - vulnerabilities of, 179
- PASTA (Process for Attack Simulation and Threat Analysis), 208
- patching
 - AWS patching policy, 270
 - ensuring you have the latest software, 185
 - in vulnerability management, 81
- Payment Card Industry (PCI), Data Security Standard (DSS) (see PCI DSS)
- payment card information (PCI), 80
- PCI DSS, 97, 264
 - evaluating cloud providers for compliance with, 98
 - groups of requirements for payment card processors, 97
 - requirements to have been implemented by processors, 97
- PCI Express bus, 31
- PDP (policy decision point), 306
- PDU (protocol data units), 23
- penetration testing, 92
- performance
 - in AWS Well-Architected Framework, 89
 - monitoring in Site Reliability Engineering, 216
- perimeter design and access control (data centers), 158
- permissions, 169
 - ensuring right level for users, 179
 - in role-based access control, 144
 - time-bound, assigning, 144
- personal health information (PHI), 80
- personal information (PI), 285
- Personal Information Protection and Electronic Documents Act (PIPEDA), Canada, 285
- Personal Information Protection Law (PIPL), China, 285
- personally identifiable information (PII), 80, 186
 - using data anonymization with, 140
- phased releases, 212
- physical destruction of data, 111
- physical layer (OSI model), 23
- physical security controls, 157
 - environmental monitoring at data centers, 159
 - operational security at data centers, 161
 - perimeter design and access controls at data centers, 158
 - regular maintenance on, 162
 - security cameras at data centers, 159
 - security guards at data centers, 160
- PIM (privileged identity management), 74
- PIP (policy information point), 306
- Plan-Do-Check-Act for implementation of an ISMS and controls, 259
- planning phase (software development), 217
- platform and infrastructure security (cloud), 149-176
- platform as a service (PaaS), 41
 - responsibilities in, 48
- Pods (container), 225, 301
- Point-to-Point Tunneling Protocol (PPTP), 78
- policies, 254, 271-274
 - Azure Policy, 270
 - for regulation and framework compliance, 273
 - regulations and frameworks, 273
 - relation to standards and procedures, 274
 - sections in, 272
- policy decision point (PDP), 306

- policy engines, 306
- policy information point (PIP), 306
- POST requests, 223
- PowerShell, 213
- Preboot eXecution Environment (PXE), 206
- precomputed hashes, 179
- presentation layer, 220
- presentation layer (OSI model), 24
- principle of least privilege, 91, 131, 168, 300
- prioritization of requirements, 87
- privacy considerations, 10, 129
- privacy regulations on data, 49, 186, 280-286
 - California Consumer Privacy Act, 283
 - compliance set out in contracts, 286
 - data location and, 118
 - General Data Protection Regulation, 281-282
 - other privacy laws, 284
- private and public network addresses, 27
- private clouds, 49
 - hybrid implementation with public cloud, 52
- privileged access, 131, 167
 - account control management, 91
 - misuse of privileged credentials, 179
 - monitoring users and their roles, 169
 - privileged access management, 74
 - privileged identity management, 74
- procedures, 274
 - relation to policies and standards, 274
- procedures (adversarial), 182
- process
 - in Agile development, 203
 - using Agile principles as excuse to dispose of, 204
- Process for Attack Simulation and Threat Analysis (PASTA), 208
- processing/organization in data lifecycle, 107
- processor utilization (CPU), 19
- production data, handling, 139
 - storing production data on nonproduction systems, avoiding, 140
- programming languages, 298
 - imperative IaC and, 36
 - supported by Azure PaaS, 41
- protocol 802.1q, 173
- protocol data units (PDUs), 23
- protocols, communications (see OSI model)
- providers, 199
 - public access to cloud storage, 180
- public cloud
 - geographical distribution of, 49
 - hybrid approach to, 52
 - providers, 49
- public data, 141
 - avoiding storing on same system as sensitive data, 183
- public/private encryption keys, 66
 - in Elliptic Curve Cryptography, 136
 - in RSA algorithm, 135
 - use in TLS, 69
- Puppet, 37, 213
- PUT requests, 223
- PXE (Preboot eXecution Environment), 206
- Python, 214
- Python Package Index (PyPI), packages known to be compromised, 219

R

- rainbow tables, 179
- RAM, 33
- ransomware attacks, 126, 232
 - treatments for, 257
- Rapid Application Development (RAD), 202
- rapid elasticity (cloud resources), 21
- RBAC (see role-based access control)
- recipes as semi-structured data, 116
- recovery, 8
 - (see also business continuity and disaster recovery plans)
 - data recovery, 91
- recovery point objective (RPO), 84, 132
- recovery stage (security operations), 245
- recovery time objective (RTO), 84, 132
- redundancy at data centers, 162-165
- reference architectures for cloud infrastructure security, 151
- regions (cloud providers), 118
- regulations, about, 264
- regulatory bodies, roles and responsibilities of, 54
- regulatory compliance, 129, 254
 - considerations for outsourced applications, 194
 - data location and, 118
 - evaluating cloud providers for, 97
 - for health care organization, 186
 - Microsoft tools for, 270

- threats from, 129
- regulatory considerations, 279
- relationships
 - among CCPA entities, 283
 - in GDPR, 281
- reliability, 214
 - (see also Site Reliability Engineering)
 - advantages of cloud adoption, 55
 - in AWS Well-Architected Framework, 89
 - ensuring at data centers, 162, 165
- Remote Desktop Protocol (RDP), using for
 - direct access to cloud systems, 126
- removal of cloud service customer assets, 99
- replication of data, 112
- repositories (see code repositories)
- reproducibility of vulnerabilities (DREAD), 209
- repudiation, 208
- requirements
 - gathering functional requirements, 87
 - prioritizing to iron out conflicts in, 87
- requirements stage, 201
- resources
 - access control and limited capabilities for, 174
 - oversubscription to, 173
 - resource pooling, 19
- responsibilities when using cloud services, 6, 16, 53
 - (see also roles and responsibilities; Shared Responsibility Model)
 - for applications, 178
- REST (Representational State Transfer), 196
- RESTful applications, 196
- restricted data, 141
- retention of data, 109
- risk management, 254-264
 - calculating risk value, 255
 - on CCSP exam, 8
 - FAIR, 262
 - ISO risk management process, 259-262
 - liability and risk allocation, in contracts, 287
 - likelihood versus risk, 254
 - NIST Risk Management Framework, 257-259
 - risk register sample, 256
 - risk, defining, 254
- risks, 10
 - information assets incurring, 253
 - risk and impact analysis in PASTA threat modeling, 209
- Rivest-Shamir-Adleman (RSA) algorithm, 135
- role-based access control (RBAC), 74, 144, 169
 - in zero trust cloud architecture, 306
- roles, 168
 - in GDPR, 281
- roles and responsibilities, 53
 - cloud provider, 53
- rotation ciphers, 65
- routers
 - network ACL filtering traffic between router and subnets, 155
- RPO (recovery point objective), 84, 132
- RSA (Rivest-Shamir-Adleman) algorithm, 135
- RTO (recovery time objective), 84, 132
- runtime protection, 299

S

- SaaS (software as a service), 43, 199
 - responsibilities in, 48
- Salt, 213
- SAML (Security Assertion Markup Language), 192, 224
- SANS, list of critical security controls, 90
- Sarbanes-Oxley Act (SOX), 268
- SAs (Supervisory Authorities), 282
- SASE (Secure Access Service Edge), 190-191
- SASE solutions, 191
- SAST (static application security testing), 211
- SATA (Serial AT Attachment) device, 31
- SBOM (software bill of materials), 218
- scalability of cloud solutions, 36, 54
- scaling
 - measured services in cloud, 22
 - rapid elasticity in the cloud, 21
- scanners for vulnerabilities, 81
- Scrum, 204
- Scrumban, 204
- SD-WAN (software-defined wide area network), 191
- SDLC (see software development lifecycle)
- SDN (software-defined network), 29, 154
- secrets management, 137, 196
 - hashing of secrets, 179
- Secure Access Service Edge (SASE), 190-191
- secure computing (seccomp) profiles for containers, 174
- Secure Hashing Algorithms (SHA), 138

- Secure Production Identity Framework for Everyone (SPIFFE), 304
- Secure Sockets Layer (SSL), 69
- Secure Web Gateway (SWG), 189
- security
 - advantages of cloud adoption for, 55
 - awareness training in, 291
 - in AWS Well-Architected Framework, 89
 - basic security concepts and implications for cloud computing, 7
 - cloud provider security, evaluation of, 97
 - cloud security emerging trends, 297-310
 - in DevSecOps, 207
 - domains in CSA Enterprise Architecture, 93
 - introducing in cloud development, 217-220
 - phases in software development, 217
 - shifting left, 219
 - in multitier architecture, 220
 - need for information security with cloud platforms, 4
 - in software or systems development, 199
- Security Assertion Markup Language (SAML), 192, 224
- security awareness and skills training, 92
- security breaches (see breaches)
- security cameras, 159
- security concepts, 60-83
 - confidentiality, integrity, and availability, 60
 - cryptography, 65-72
 - hygiene practices, 80-82
 - Identity and Access Management program, 72-76
 - network security, 76-79
 - threats, 61-65
 - zero trust in cloud environments, 82
- security control mechanisms (cloud), 185-191
 - cloud access security broker, 186-187
 - Secure Access Service Edge, 190-191
 - Security Service Edge, 188
 - zero trust network access, 187
- security controls
 - available from cloud service providers, 6
 - coverage in contracts, 286
 - critical, 90
 - having different controls at different layers, 156
 - planning and implementation of, 8
- security engineering, 246-251
 - logging, 247
 - monitoring, 248
 - security information and event management, 249-251
 - tools, 246
- security governance and risk management (cloud), 253-277
 - business continuity and disaster recovery, 275
 - compliance, 264-271
 - policies, standards, and procedures, 271-274
 - risk management, 254-264
- security groups, 155, 156
 - (see also network security groups)
 - misconfigured, 185
 - network security groups, 76, 156
- security guards at data centers, 160
- security information and event management (SIEM) systems, 172, 181, 216, 249-251
 - process of, 249
 - support for automated actions, 250
- security monitoring for data centers, 159
- security operations (cloud), 229-252
 - about, 229
 - adversaries, types of, 230-232
 - frameworks for, 233-242
 - security operations process, 242-246
- Security Orchestration, Automation, and Response (SOAR), 250
- security professionals
 - applying information security fundamentals to cloud platforms, 4
 - ethical precepts, agreement to, 4
- security requirements, 217
- Security Service Edge (SSE), 188
- security testing in CI/CD pipelines, 211
- Security, Trust, Assurance, and Risk (STAR) program (CSA), 268
- segmentation, 152
 - each host within virtual machine on its own network segment, 173
 - effective network segmentation, 183
 - firewalls in network segments, 171
 - network segmentation, 26
 - poor segmentation affecting cloud application security, 183
 - zones, 195
- segregation of assets in virtual computing environments, 99
- self-service in IAM, 75

- SELinux, 174, 179, 299
- semi-structured data
 - emails, 116
 - log data, 118
 - NoSQL databases, JSON, and XML, 115
 - recipes as, 116
- sensitive data
 - network segmentation and, 183
 - retention requirements for, 109
 - tokenizing, 131
- sensitive data exposure, 62, 80
 - access to Amazon S3 buckets and, 125
- sensitive information, access by security professionals, 4
- Serial AT Attachment (SATA) devices, 31
- Server Message Block (SMB), 123
- serverless designs, segmentation and, 183
- serverless functions, 226
 - cloud native applications using, 299
- Service Level Agreements (SLAs), 215, 288
 - contracts specifying, 288
- Service Level Indicators (SLIs), 214
- Service Level Objectives (SLOs), 214
- service mesh identity, 304
- service principals
 - authentication of, 303
 - JWTs, use for authentication, 304
 - using certificate or client secret to authenticate, 302
- service provider management, 92
- session layer (OSI model), 24
- severities (syslog messages), 38
- SHA (Secure Hashing Algorithms), 138
- shadow IT problem, 186, 186
- Shared Responsibility Model, 47, 82, 268
 - vulnerability management, 180
- shared roles and responsibilities, cloud provider evaluation for, 99
- sharing and transferring (risks), 262
- SHIELD (Stop Hacks and Improve Electronic Data Security) Act. New York, 284
- shifting left, 219
- SIEM (see security information and event management systems)
- Single Loss Expectancy (SLE), 255
- Site Reliability Engineering (SRE), 214-216
 - availability, 215
 - foundational approach, 214
 - performance monitoring, 216
- SLOs and SLIs, 214
- 64-bit blocks (memory addresses), 33
- skills training for security in cloud environments, 92
- SLAs (Service Level Agreements), 215, 288
- SLIs (Service Level Indicators), 214
- SLOs (Service Level Objectives), 214
- SMB (Server Message Block), 123
- SOA (Statement of Applicability), 265
- SOAR (Security Orchestration, Automation, and Response), 250
- SOC 2 (System and Organization Controls), 268
- social engineering, 78
- software
 - application software security in the cloud, 92
 - secure configuration of, 91
- software as a service (SaaS), 43, 199
 - solutions hosting code repositories, 217
- software assets, inventory and control of, 90
- software bill of materials (SBOM), 218
- software development lifecycle (SDLC), 200-205
 - changes in software development over decades, 200
 - methodologies, 200-205
 - Agile development, 202
 - waterfall development, 201
- software vendors, notifications of vulnerabilities from, 81
- software-defined network (SDN), 29, 154
- software-defined wide area network (SD-WAN), 191
- solid state drives (SSDs), 30
 - data destruction and, 110
- SOX (Sarbanes-Oxley Act), 268
- speed and agility, advantages of cloud adoption, 54
- SPIFFE (Secure Production Identity Framework for Everyone), 304
- SPIFFE runtime environment (SPIRE), 304
- SPIFFE verifiable identity document (SVID), 304
- spoofing, 208
- spreadsheets as structured data, 114
- sprints, 203
- SQL databases
 - cloud native design moving away from, 226

- as structured data, 114
- SRE (see Site Reliability Engineering)
- SSDs (solid state drives), 30
 - data destruction and, 110
- SSE (Security Service Edge), 188
- SSH, using for direct access to remote cloud systems, 126
- SSL (Secure Sockets Layer), 69
- staging, 140
- stakeholders, 9
 - in CSA Enterprise Architecture, 93
 - identifying in gathering functional requirements, 87
- standards, 254, 274
 - relation to policies and procedures, 274
- STAR (Security, Trust, Assurance, and Risk) program (CSA), 268
- state information, transferring between client and server, 196
- Statement of Applicability (SOA), 265
- static application security testing (SAST), 211
- storage, 29-33
 - cloud data lifecycle stage, 106
 - cloud data storage architectures, 120-124
 - storage types, 120-124
 - threats to cloud storage, 124
 - cloud storage as a service, 44
 - destroying stored data at data centers, 161
 - filesystem, 31
 - financial considerations in data retention, 109
 - hardware, 29
 - legal's awareness of cloud provider's practices, 292
 - memory, 33
 - public access to cloud storage, 180
 - regions available in Google Cloud, 118
 - sensitive data exposure from cloud storage, 62
 - sharing capacity in the cloud, 20
 - threats to cloud storage, 124
- stream encryption, 136
- STRIDE framework for threat modeling, 207
- strong passwords, 179
- structured data, 114
 - data that is considered as, 115
 - spreadsheets as, 114
 - SQL databases, 114
- subnet masks, 27
- subnets, 27
 - accessibility in the cloud, 78
 - filtering traffic with network ACL, 155
 - leaving unprotected, 65
- Supervisory Authorities (SAs), 282
- supply chain weaknesses, 64
- sustainability
 - in AWS Well-Architected Framework, 90
 - fully sustainable applications, 84
- SVID (SPIFFE verifiable identity document), 304
- SWG (Secure Web Gateway), 189
- symmetric encryption, 68, 136
 - challenge of ever-changing keys, 137
- SYN, SYN/ACK, ACK pattern in TCP handshake, 76
- syslog, 37, 247
 - facilities in log messages, 37
 - severities in log messages, 38
- System and Organization Controls (SOC) 2, 268
- system development, 212
- system image creation automation, 205
- systems, 207
 - automation of creation and management, 207

T

- tactics (adversarial), 182
- Tactics, Techniques and Procedures (TTPs), 237
- tailgating (in physical access), 159
- tampering, 208
- TCP/IP, 24
 - three-way handshake in TCP, 76
- TCP/IP networks, HTTP/HTTPS running on, 19
- technical innovation, advantages of cloud adoption, 55
- techniques (adversarial), 182
- templates
 - implementing baselines for operating system deployments, 81
 - use in automation in cloud computing, 36
- termination and transition (contracts), 287, 290
- Terraform, 36, 212
- testing, 140
 - in CI/CD pipelines, 211

- disaster recovery and business continuity
 - testing at data centers, 166
 - testing phase in software development, 218
 - testing stage in development, 202
- TFTP (Trivial File Transfer Protocol), 206
- threat modeling, 8, 207-210, 218, 219
 - DREAD framework, 209
 - PASTA approach to, 208
 - STRIDE categories of threats, 207
- threat vector, 61
- threats, 61-65
 - application security threats in the cloud, 178-185
 - assessing for data center disaster recovery plan, 165
 - cloud data storage threats, 124-129
 - access threats, 124
 - data protection threats, 125
 - network threats, 126
 - operational and compliance threats, 128
 - common threats related to deployments of cloud computing, 61
 - defined, 207
 - high-level threats in the cloud and on-premises, 59
 - versus vulnerabilities, 209
- TLBs (translation lookaside buffers), 34
- TLS (Transport Layer Security), 68, 170
 - hybrid approach to encryption, 69
 - mutual TLS (mTLS), 304
- tokenizing data, 131, 140
- tokens, 167, 193
 - advantages of authentication tokens over passwords, 302
 - JWT and OAuth, 224
- traceability, 145
- traffic inspection, 79
- training and awareness
 - for application security, 8
 - for legal compliance and best practices, 291
 - security awareness and skills training, 92
 - training offered by ISC2, 4
- transformations of data
 - documenting in data flow diagrams, 113, 143
- transition to another service provider, 287
- translation lookaside buffers (TLBs), 34
- transport layer (OSI model), 24
- Transport Layer Security (see TLS)

- Trivial File Transfer Protocol (TFTP), 206
- trust
 - boundaries and zones, 152
 - between multiple sources of identities, 170
 - trust boundaries in DFDs, 113
 - zero trust network access, 187
- TTPs (Tactics, Techniques and Procedures), 237
- typosquatting attacks, 219

U

- updating in vulnerability management, 81
 - (see also patching)
- US Department of Defense manual 8140.03, 5
- US National Institute of Standards and Technology (see NIST)
- US, government-sponsored adversaries, 232
- usage/analytics stage in data lifecycle, 107
- USB devices, use as authentication tokens, 302
- usernames, attacks against, 178
- users
 - access threats to cloud data storage from, 124
 - authentication and identity management in zero trust, 82
 - deprovisioning, 169
 - functional requirements focusing on, 87
 - identity and access management, 72
 - identity and access management for, 167
 - managing throughout active lifetime, 169
 - verifying identity of, 167

V

- VDI (virtual desktop environment), 247
- VDI (virtual desktop infrastructure), 91
- vendor lock-in, cloud adoption and, 56
- vendor management, 92, 288-290
 - coverage in contracts, 287
 - good practices in, 194
 - lifecycle of, 288
- vendors, 199
 - access to data centers, 161
 - assessments under China's PIPL, 285
 - contracts with, 280
 - training and awareness for legal compliance, 291
- versioning data, 122, 132, 142
 - benefits of, 126

- virtual computing environments, segregation in, 99
- virtual desktop environment (VDI), 247
- virtual desktop infrastructure (VDI), 91
- virtual LANs (VLANs), 26, 153
 - lacking security controls, 154
 - simple VLAN, diagram of, 154
 - tagging network traffic on, 173
- virtual machines (VMs), 40, 172
 - fully isolating from each other, 172
 - hardening of, evaluating cloud providers for, 99
 - network access controls in Azure, 126
 - using SDN with, 154
- virtual private clouds (VPCs), 27, 78, 155
 - building block for network security in cloud environments, 170
 - restricting access to services within, 126
- virtual private networks (VPNs), 77
 - access to cloud services and, 126
 - TLS encrypting traffic between sites, 68
- virtualization, 33, 224
 - memory, 33
 - security for, 172-174
 - container security, 173-174
 - problems from virtualization, 172
 - virtual network security, 173
 - virtualized systems and automation, 36
- visibility, 145
 - CASB providing additional visibility, 187
 - complete, collecting enough logs for, 181
 - essential to security operations, 247
 - reasons for needing, 145
- visitors to data centers, 161
- visualization, 3
- volatile memory, 30
- VPCs (see virtual private clouds)
- VPNs (see virtual private networks)
- vulnerabilities, 5
 - in cloud native application deployments, 299
 - container, 174
 - continuous vulnerability management, 91
 - identifying in PASTA threat modeling, 209
 - management of on CCSP exam, 8
 - originating from dependencies, reducing, 218
 - OWASP, web application firewall checking for, 194

- poor vulnerability management affecting
 - cloud application security, 180
- remediating vulnerabilities identified by OWASP, 8
- versus threats, 209
- vulnerability management, 80, 156

W

- WAF (web application firewall), 156, 170, 194
- WANs (wide area networks), SD-WAN, 191
- waterfall development, 201
 - problems with, 202
 - stages in, 201
- weak passwords, 178
- web application firewall (WAF), 156, 170, 194
- web applications
 - application security, 194-196
 - layers of, 194
 - cloud deployments' focus on, 94
 - data flow diagram for application with web and mobile interfaces, 112
 - security testing in CI/CD pipelines, 211
 - using APIs, 196-197
- web browsers, 40, 45, 222
 - email and web browser protections, 91
 - TLS use with, 68
- web servers, 195
 - denial-of-service attacks on, 64
- web technologies, applications using, 212
 - APIs, 222
- web-based protocols, use in cloud, 18
- Well-Architected Framework (AWS), 88, 151
- Windows
 - Event logs, 247
 - filesystems, 32
 - logging and creation of data, 106
 - logging in, 38
- work units (Agile), 203

X

- XML, 115, 197
- XP (Extreme Programming), 202

Y

- YAML, 213

Z

- Zed Attack Proxy (ZAP), 211

- zero trust, 82
 - microsegmentation in zero trust implemen-
tations, 154
 - network access in the cloud, 187
 - zero trust network access, 189
- zero trust architecture, 298
- zero trust architecture (ZTA), 305-307
 - assumption that any component is compro-
mised, 305
 - design philosophy, not a product to buy, 307
 - elements used in zero trust cloud applica-
tions, 306
- zones, 152, 195

About the Author

Ric Messier has been poking at computers and networks since the early 1980s, back when “hacking” meant finding creative ways to make things work rather than breaking them. These days, he’s turned that curiosity into a thriving career as a cybersecurity expert, author, and educator who helps organizations stay one step ahead of the bad guys.

When he’s not writing books, Ric works at Apple as a security engineer. He’s worn more tech hats than a haberdashery: programmer, system administrator, network engineer, security manager, VoIP engineer, consultant, and professor (including a stint at Harvard, which still amazes his younger self who was more interested in command lines than college lectures).

A firm believer that knowledge should be shared, not hoarded, Ric has dedicated much of his career to teaching others. He’s developed master’s degree programs in cybersecurity, taught countless students, and written books on everything from ethical hacking to Rust programming. His collection of certifications (CISSP, CCSP, AWS CCP, GCP ACE, and more) might be longer than some people’s grocery lists, but he maintains that his best qualification is an insatiable curiosity about how things work—and how they can be made to work better.

Whether he’s conducting penetration tests, architecting cloud security solutions, or explaining complex security concepts in ways that actually make sense, Ric brings the same blend of expertise, creativity, and pragmatism to everything he does. Just don’t get him started on the importance of proper security controls unless you have a plate of spicy Thai food and a cold Coke Zero handy—you might be there a while.

Colophon

The animal on the cover of *Learning Cloud Security* is an Eyra cat. More commonly known as the jaguarundi (*Herpailurus yagouaroundi*), this wild cat is native to the Americas and covers a vast range, from southern Texas and Mexico to central Argentina and South America, east of the Andes.

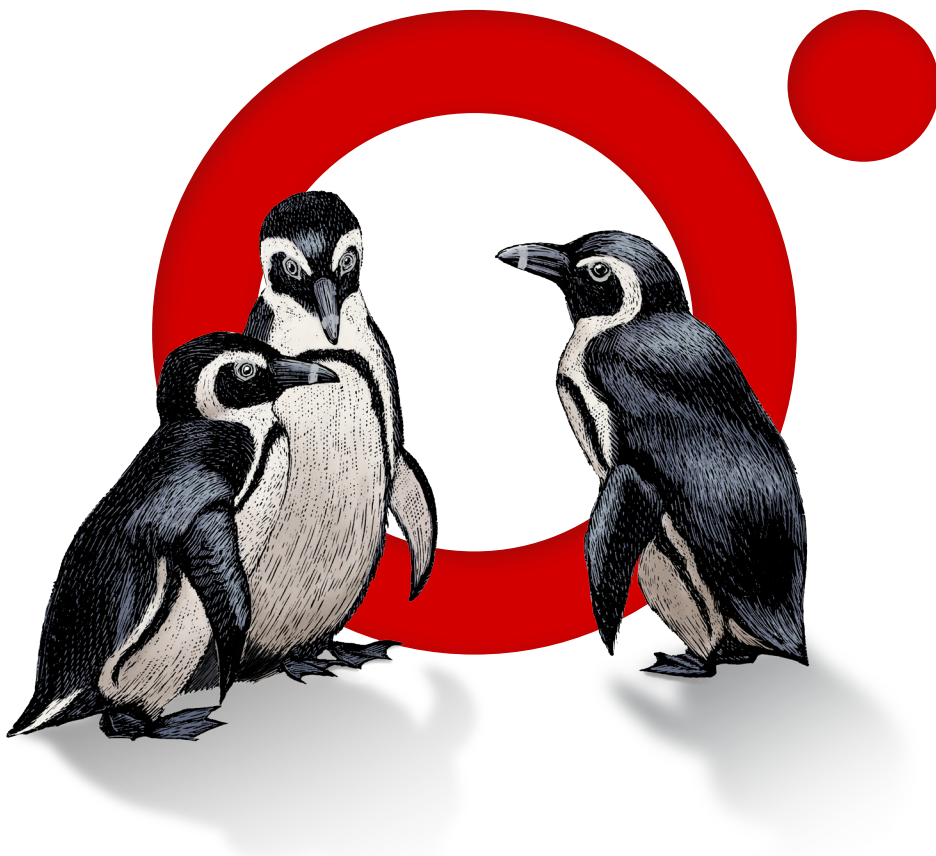
The Eyra cat is often described as “weasel-like” due to its elongated body, short legs, small, narrow head with rounded ears, and short snout. Its long, thick tail resembles that of a weasel or an otter. On average, an adult Eyra cat measures between 21 and 30 inches from its head to its rear; its tail alone can range from 12 to 20 inches long. On average, they weigh between 8 and 15 pounds, but larger adults weighing close to 20 pounds have been reported, with males being larger than females. Their sleek, uniform coats have two color variations: gray and reddish-brown. Both serve as excellent camouflage.

Eyra cats are solitary and shy creatures by nature; they are most active during the day and can be found hunting in tropical rainforests, deciduous forests, deserts, and shrub lands. Although Eyra cats are exceptional climbers, they prefer to hunt on ground and are known to leap up to six feet into the air to catch birds. They feed on other types of prey as well, including reptiles, small mammals, and rodents.

Currently, the Eyra cat is listed as Least Concern on the IUCN Red List. Although not endangered, their population has been steadily decreasing due to human conflict and habitat loss caused by large-scale agriculture.

Many of the animals on O'Reilly covers are endangered; all of them are important to the world.

The cover illustration is by José Marzan Jr., based on an antique line engraving from *Natural History of Animals*. The series design is by Edie Freedman, Ellie Volckhausen, and Karen Montgomery. The cover fonts are Gilroy Semibold and Guardian Sans. The text font is Adobe Minion Pro; the heading font is Adobe Myriad Condensed; and the code font is Dalton Maag's Ubuntu Mono.



O'REILLY®

**Learn from experts.
Become one yourself.**

60,000+ titles | Live events with experts | Role-based courses
Interactive learning | Certification preparation | Verifiable skills

Try the O'Reilly learning platform free for 10 days.

